Readiness of Cybersecurity in the USA Energy Industry

by

Aaron Cavanaugh

A dissertation submitted in partial fulfillment of the
requirements for the degree of

Doctor of Philosophy
in
Technology Management

Dissertation Committee:
Tugrul Daim, Chair
Birol A. Yesilada
Shawn Smallman
John M. Acken

Portland State University

2024

© 2024 Aaron Cavanaugh

ABSTRACT

Cybersecurity Readiness shows an organizations ability of applicant and application to be able to fully utilize computing resources through behaviors (e.g., training employees), practices, and processes, while managing risk through efficient controls in order to prevent, detect, and respond to outage scenarios using audit and assessment techniques. An evaluation of cybersecurity readiness for the USA energy industry assists industry decision makers to comprehensively assess readiness gaps for prioritizing a risk-based cybersecurity implementation plan. There is a current a lack of a Multi-Criteria Decision Model (MCDM) to assist decision makers to comprehensively assess Readiness of Cybersecurity in the USA Energy Industry.

A hierarchy links records together. The Hierarchical Decision Model (HDM) was created using a multidisciplinary research approach, studying academic principles and security expert approaches including frameworks, models, and theories [1]. Research was then conducted through expert participants qualitative evaluations and quantitative scoring. The HDM model identifies common factors that have major impact, assesses readiness, and points out where corrective actions are needed [2] through case studies and scenarios. The model prepares an organization to implement cybersecurity criteria with the goal of reducing the time to recover the electric grid in order to provide stability, if and when, an incident happens. This dissertation verifies and validates the previous literature reviews and interviews.

The findings and output of the dissertation has created artifacts designed to meet energy sector specific readiness and thus resilience needs. An organization must be able

to resume operations, from attacks and outages, in order to be considered resilient. Readiness is also important because remediation will lead to reliable operations which contributes to higher financial returns overall.

DEDICATION

Thanks be to God/Holy Spirit/Jesus for carrying me to and through this work.

To my Parents. My mother and father whose prayers and encouragement supported me. Without them, I would not be where I'm in my life.

To my wife, whose love and support is endless. She stood by my side for bad and for good and supported me.

To my parents-in-law for their tireless help in supporting our family.

To my aunt who has been a rock supporting me throughout.

To my brother who encouraged me.

To my daughter, who constantly brings joy and happiness to my heart and soul. I pray that you are the most awesome and amazing person possible.

To my coworkers for supporting me in this work.

To my Family and Friends, Thank you all.

ACKNOWLEDGEMENT

All glory honor and praise are due to God/Holy Spirit/Jesus for giving me the strength and capacity to complete this ultimate achievement.

I want to express my gratefulness to my country the United States of America for the financial support throughout the PhD studies.

I cannot begin to express my appreciation and gratitude for the many individuals who provided me with the motivation, encouragement, and guidance throughout my PhD journey. I am eternally grateful to all of them.

I would like, first, to give my gratitude and appreciation to my mentor, adviser, and dissertation committee chair, Professor Tugrul Daim, for his wisdom, guidance, and unlimited support that made this research work a rewarding journey. His willingness to share his valuable knowledge, time, and experience has been deeply appreciated and I am privileged to be one of his students. Thank you Dr. Daim.

I would like to express my deep appreciation to my dissertation committee members, Dr. Birol A. Yesilada, Dr. Shawn Smallman, Dr. John M. Acken for their constructive feedback and continuous support throughout this journey. I would also like to acknowledge the support of Dr. Judith Estep, and Dr. Barbara Endicott-Popovsky who has helped me in the early stages of this research and through the comprehensive exam.

I would like to thank all the 54 experts who participated in my research for their patient, time, and useful feedback. I would also like to thank those who took time for interviews and those whose data ultimately did not make it into the model because of verification and validation.

I am particularly thankful to my mentor Albert Roybal for all the support, encouragement, and advices he has offered me with in the past few years and for listening to me in difficult times. Also, I'm so grateful to my classmates Chip Corbett and Aynur Kirbac, for his engagement on topics of the USA Energy Industry and Cybersecurity. Thanks to those who are, and were, a part of the Mark O. Hatfield Cybersecurity & Cyber Defense Policy Center. Many thanks to Dr. Acken's PhD research group in Electrical and Computer Engineering at Portland State University who spent many hours reviewing my presentations. I'm as well thankful to all my friends who have been there for me when I needed them.

I would like to thank all faculty members, staff, and friends in the ETM department whom I have spent many years with here at Portland State University.

The support I have received from so many people has been tremendous, so please accept my apologies if I failed to mention your name.

Finally, words are not enough to express my gratitude and appreciation for the role and help of my family during my study. I am grateful and indebted to my wife, for being extremely understanding and supportive. Her unconditional support and love have been a driving force to my success. I would also like to express my sincere appreciation to my mother-in-law and father-in-law for their unconditional support and encouragement during my graduate studies. Thank you to Deanna for your support of our family. My daughter I pray that this achievement is my a gift to you and that you ultimately honor God in all you do.

TABLE OF CONTENTS

ABSTRACT ii
DEDICATION iv
ACKNOWLEDGEMENT v
TABLE OF CONTENTS vii
LIST OF FIGURES x
LIST OF TABLES xiii
CHAPTER 1: INTRODUCTION 1
1.1 Cybersecurity Readiness in the Energy Industry 5
1.1.1 Resiliency 7
1.1.2 NERC 10
1.2 Background 12
1.3 Research Motivation 14
1.3.1 Outage Causes 20
1.3.2 Attack 22
1.3.3 Ukraine 27
1.4 Problem Statement 29
CHAPTER 2: LITERATURE REVIEW 31
2.1 Critical Infrastructure and Key Resources (CIKR) 32
2.2 Industrial Control Systems (ICS) 36
2.3 Stakeholders 38
2.4 Existing Quantitative Models 40
2.4.1 Structural Equation Models (SEM) 40
2.4.1.1 Organization Benefit as an Outcome of Organizational Security Adoption: The Role of Cyber Security Readiness and Technology Readiness 40
2.4.1.2 Evaluating The Cyber Security Readiness Of Organizations And Its Influence On Performance 41
2.4.2 Factors Affecting Perceptions of Cybersecurity Readiness Among Workgroup IT Managers 43
2.5 Existing Qualitative Models 45
2.5.1 A Cyber-Security Culture Framework for Assessing Organization Readiness 45
2.5.2 A Conceptual Model For Digital Forensic Readiness 46
2.5.3 A Generic Digital Forensic Readiness Model For BYOD Using Honeypot Technology 48
2.5.4 A Socio-Technical Analysis Of China's Cybersecurity Policy: Towards Delivering Trusted E-Government Services 48
2.5.5 Adoption Of Cybersecurity Capability Maturity Models In Municipal Governments 50
2.5.6 ICS Testbed Tetris: Practical Building Blocks Towards a Cyber Security Resource 50
2.5.7 Internet of Things & Cybersecurity Readiness in Smart-government and Organizations 51
2.5.8 Mobile Cloud Forensic Readiness Process Model for Cloud-Based Mobile Applications 53
2.5.9 Towards verifiable evidence generation in forensic-ready systems 53
2.5.10 Towards a Systemic Framework for Digital Forensic Readiness 54
2.6 DOE's Use of the Term Readiness 55
2.7 Analysis 61
CHAPTER 3: GAPS ANALYSIS 74
3.1 Research Questions 74

3.1.1 Question 1 - What strategies might be proposed to improve organizational readiness and mitigation of threats? 75
3.1.2 Question 2 - What percentages should be assigned to actionable goals for Industrial Control Systems (ICS). 75
3.1.3 Question 3 - How can the HDM Model inform a roadmap for Cybersecurity Readiness? 76
3.2 Gap 1 - Standards and controls for application to Cybersecurity Readiness for the Energy Industry is complex thus creating gaps in implementation 77
3.3 Gap 2 – Cybersecurity readiness literature review results and scope of research for organizational and cultural approaches is limited 79
3.4 Gap 3 – Limited quantitative research and no research that has used Multi-Criteria Decision Modeling (MCDM) Methodology for Cybersecurity Readiness in the USA Energy Industry 80
3.5 Research Goal 82
CHAPTER 4: RESEARCH METHODOLOGY AND APPROACH 84
4.1 Multi Criteria Decision Analysis (MCDA) 84
CHAPTER 5: HDM METHODOLOGY 86
5.1 Justification 91
5.2 Disagreement 92
5.3 Desirability 93
5.4 Inconsistency 95
5.5 Sensitivity 98
CHAPTER 6: RESEARCH PLAN AND DATA COLLECTION 100
6.1 Expert Panels 101
CHAPTER 7: RESEARCH APPLICATION 103
7.1 Construct Validity 103
7.2 Content Validity 103
7.3 Criterion Validity 104
7.4 Validation 104
7.4.1 Interview: Pacific Northwest National Laboratory (PNNL) 105
7.4.1.1 How do you see this resilience taxonomy tying into the readiness model which I previously talked about in the comprehensive proposal? 105
7.4.1.2 Is there a cause-and-effect aspect of resiliency, and/or findings of resiliency that needs to be considered? 105
7.4.1.3 What other ways of working with resilience are you familiar with or have you used? 106
7.4.2 Interview: Bonneville Power Administration (BPA) 106
7.4.2.1 How do you see this resilience taxonomy tying into the readiness model which I previously talked about in the comprehensive proposal? 107
7.4.2.2 Is there a cause-and-effect aspect of resiliency, and/or findings of resiliency that needs to be considered? 107
7.4.2.3 What other ways of working with resilience are you familiar with or have you used? 107
7.5 Perspectives 108
7.6 Leadership Criteria 114
7.7 Information Management Criteria 117
7.8 Systems Management Criteria 119
7.9 Organizational Criteria 123
7.10 Professional Criteria 126
7.11 Model Generalization 129
CHAPTER 8: CASE ANALYSIS 130
8.1 Research Application 130
8.1.1 Data Collection 135

8.1.2 Panels 135
8.1.2.1 Validation Questionnaire Results 136
8.1.2.2 HDM Results 142
8.1.2.3 Final Model 154
8.1.2.4 Desirability Results 158
8.1.3 Analysis of Cases 186
8.1.3.1 Agencies of Government and Private Entities Readiness 187
8.1.4 Improvement Simulations 205
8.1.4.1 Implications of Agencies of Government Improvement Simulation Scenario 208
8.1.4.2 Implications of Private Entity Improvement Simulation Scenario 213
8.2 Scenarios 215
8.2.1 Sensitivity Analysis 215
8.2.1.1 Organizational Emphasis 217
8.2.1.2 Information Management Emphasis 220
8.2.1.3 Systems Management Emphasis 223
8.2.1.4 Professional Emphasis 226
8.2.1.5 Leadership Emphasis 228
8.2.1.6 Emphasis Summary 231
CHAPTER 9: CONCLUSIONS AND CONTRIBUTIONS 233
9.1 Conclusion 233
9.2 Contribution 235
CHAPTER 10: LIMITATIONS AND FUTURE WORK 239
10.1 Limitations 239
10.2 Future Work 241
REFERENCES 245
APPENDICES 262
Appendix A – Model Taxonomy 262
Appendix B – Selected Terms and Definitions 266
Appendix C – Attack Mapping to HDM 267
Appendix D – References for HDM Model 271
Appendix E – Desirability Questions 282
Appendix F – Closely Related Definitions of Readiness 287
Appendix G – Letters to Participants 289
Appendix H – Original 52 literature gaps combined to 29 for the HDM model 312
Appendix I – Energy and Electricity Definitions 314
Appendix J - Control Schemes 315
Appendix K – HDM to NIST Crosswalk (Based on a FedRamp Low with 48 NIST 800-53 Controls) 322
Appendix L – HDM RSV Table for Inconsistency 325
Appendix M – Case Desirability Calculations 327

LIST OF FIGURES

Figure 1 – The 11 Security Automation Domains from NIST 800-137 ISCM 4
Figure 2 – Cybersecurity Readiness Definition 5
Figure 3 – Culturally Significant Controls in the HDM Model 6
Figure 4 – Intensity of Dynamic Judgements 9
Figure 5 – PhD Research Process 12
Figure 6 – Research Framework 14
Figure 7 – The Cybersecurity Importance of Energy sector in relation to other Critical Infrastructure sectors 35
Figure 8 – Structural Equation Model (SEM) Research Model 41
Figure 9 – Cybersecurity Readiness Model Based on Hypothesis 42
Figure 10 – Chapmans PACRM Detect, Prevent, Recover Model and each Proposition/Hypothesis Link/Path 44
Figure 11 – Cyber-Security Culture Model 46
Figure 12 – China e-government conceptual model 49
Figure 13 – Readiness in Smart-government and Organizations 52
Figure 14 – Organizational Forensic Readiness Model for Digital Evidence 54
Figure 15 – Department of Energy (DOE) Technology Readiness Assessment (TRA) with TRL 57
Figure 16 – Research Gaps Goals and Questions 74
Figure 17 – HDM Normalization 86
Figure 18 – HDM Hierarchical Structure 89
Figure 19 – Desirability Calculation 94
Figure 20 – Original HDM Consistency Example with Four Criteria 96
Figure 21 – Root Sum Variance Consistency Example with Four Criteria 96
Figure 22 – HDM Inconsistency Thresholds Visualizations of Lookup Table 97
Figure 23 – NIST NICE Operational Framework 108
Figure 24 – The HDM Model with Criteria and Reference Numbers 128
Figure 25 - Most Contentious Validation Criteria 135
Figure 26 - Cronbach's Alpha Rule of Thumb 142
Figure 27 - Perspectives of Readiness Importance Government vs Industry 144
Figure 28 - Where Readiness Assessments Fit into the Process of an Organizational Lifecycle 147
Figure 29 - Final Model Weights 156
Figure 30 - Desirability Metrics Quantification Outcomes for To what degree are computer user's settings and permissions known by management? 159
Figure 31 - Desirability Metrics Quantification Outcomes for What is the expected level of Cybersecurity Readiness Assessments in the organization? 159
Figure 32 - Desirability Metrics Quantification Outcomes for What is the level that documents are marked and protected? 160
Figure 33 - Desirability Metrics Quantification Outcomes for What is the degree of implementation oversight? 161
Figure 34 - Desirability Metrics Quantification Outcomes for What is the degree of legal understanding? 162
Figure 35 - Desirability Metrics Quantification Outcomes for What is the extent to which social impact of breaches are talked about? 163
Figure 36 - Desirability Metrics Quantification Outcomes for What is the expected level of Cybersecurity vocabulary awareness? 164

Figure 37 - Desirability Metrics Quantification Outcomes for What is amount of communication sharing with Internet Service Provider? 166
Figure 38 - Desirability Metrics Quantification Outcomes for Logging required is sufficient for Security and Forensics? 167
Figure 39 - Desirability Metrics Quantification Outcomes for What is the extent that Network and System Administration procedures are documented? 167
Figure 40 - Desirability Metrics Quantification Outcomes for What is the degree of retention periods in place for data and information? 168
Figure 41 - Desirability Metrics Quantification Outcomes for What is the expected level that standards are understood? 169
Figure 42 - Desirability Metrics Quantification Outcomes for What is the complexity of Data Loss Prevention (DLP) systems that are in place? 171
Figure 43 - Desirability Metrics Quantification Outcomes for To what degree are Energy System outages planned to? 171
Figure 44 - Desirability Metrics Quantification Outcomes for What is the degree that machine limitations are recorded? 172
Figure 45 - Desirability Metrics Quantification Outcomes for What is the degree of network modeling for ICS/IoT/Nuclear done? 173
Figure 46 - Desirability Metrics Quantification Outcomes for What is the expected level of outages required for applying security updates? 173
Figure 47 - Desirability Metrics Quantification Outcomes for What is the degree of planning done for forensic evidence collection? 174
Figure 48 - Desirability Metrics Quantification Outcomes for To what extent is cybersecurity awareness of behavior of staff checked? 176
Figure 49 - Desirability Metrics Quantification Outcomes for What is the required amount of external reporting? 176
Figure 50 - Desirability Metrics Quantification Outcomes for What is the degree of vendor and supply alignment on security? 177
Figure 51 - Desirability Metrics Quantification Outcomes for What is the expected level that threats to the organization are modeled? 178
Figure 52 - Desirability Metrics Quantification Outcomes for What is the expected level that change management will be considered? 179
Figure 53 - Desirability Metrics Quantification Outcomes for Are Cybersecurity goals identified in the organization? 181
Figure 54 - Desirability Metrics Quantification Outcomes for What is the amount of Cybersecurity learning sources available? 182
Figure 55 - Desirability Metrics Quantification Outcomes for Cybersecurity Risk is a required topic by C-Suite? 182
Figure 56 - Desirability Metrics Quantification Outcomes for What is the expected level of policy updating? 183
Figure 57 - Desirability Metrics Quantification Outcomes for What is the required level of certification in operations roles? 184
Figure 58 - Desirability Metrics Quantification Outcomes for Are complex Cyber supply chain risks considered in procurement? 185
Figure 59 - HDM model with Strengths (Green) and Weaknesses (Red) for both Entity Types Highlighted 203
Figure 60– Agencies of Government My Proposal 1 208

Figure 61 – Agencies of Government My Proposal 2 209
Figure 62 – Agencies of Government My Proposal 3 210
Figure 63 – Private Entities My Proposal 1 213
Figure 64 – Private Entities My Proposal 2 214
Figure 65 – Private Entities My Proposal 3 215

LIST OF TABLES

Table 1 – Major Breaches and Known Attacks Closely Related to the Energy Sector 16
Table 2 – Core Articles by Methodology on Current State of Cybersecurity Readiness 31
Table 3 – Existing Quantitative Approaches 61
Table 4 – Previous Energy Industry Standards that Have Focused on the Electric Power Industry 78
Table 5 – HDM Modeling Basis 88
Table 6 – Benefits of HDM 89
Table 7 – Steps in Calculating HDM for One Experts Matrix 91
Table 8 – Calculating Composite Score Requirements 95
Table 9 – Composite Score Mathematical Notation 95
Table 10 – Personal Knowledge Cybersecurity Experts Previously Consulted by Author 100
Table 11 – Count of Positions and Organizations of Experts 101
Table 12 – Panels Proposed 102
Table 13 - Screening Questions Considered 102
Table 14 – A Construct Validity Python Script 103
Table 15 – NIST NICE 8355 Draft Competency Categories 109
Table 16 – NIST 800-137 Continuous Monitoring Mapped to NIST NICE Draft 8355 Technical Competency 111
Table 17 – NIST NICE Competencies Mapped to HDM Management Perspectives Summary 113
Table 18 – Perspectives 113
Table 19 – Leadership Criteria 114
Table 20 – Information Management Criteria 117
Table 21 – Systems Management Criteria 120
Table 22 – Organizational Criteria 123
Table 23 – Professional Criteria 126
Table 24 – Pairwise Comparison Formula and Count 131
Table 25 – Experts Roles and Questionnaire Participation 132
Table 26 - Expert Panel 1, Perspectives Level Validation 137
Table 27 - Expert Panel 2, Organizational Level Validation 138
Table 28 - Expert Panel 3, Information Management Level Validation 139
Table 29 - Expert Panel 4, Systems Management Level Validation 140
Table 30 - Expert Panel 5, Professional Level Validation 141
Table 31 - Expert Panel 6, Leadership Level Validation 141
Table 32 - Analysis of Expert Panel Results, Assessment Perspectives with Respect to the Mission 143
Table 33 - Data Table for Perspectives Radar Chart Figure 144
Table 34 - Analysis of Expert Results, Organizational Readiness Perspective 145
Table 35 - Analysis of Expert Results, Information Management Readiness Perspective 147
Table 36 - Analysis of Expert Results, Systems Management Readiness Perspective 149
Table 37 - Analysis of Expert Results, Professional Readiness Perspective 151
Table 38 - Analysis of Expert Results, Leadership Readiness Perspective 152
Table 39 - Result of Experts Judgment Quantification 155
Table 40 - Desirability Experts and Questions for Organizational Perspective 158
Table 41 - Desirability Metrics for To what degree are computer user's settings and permissions known by management? 159
Table 42 - Desirability Metrics for What is the expected level of Cybersecurity Readiness Assessments in the organization? 160

Table 43 - Desirability Metrics for What is the level that documents are marked and protected? 161
Table 44 - Desirability Metrics for What is the degree of implementation oversight?.....162
Table 45 - Desirability Metrics for What is the degree of legal understanding? 163
Table 46 - Desirability Metrics for What is the extent to which social impact of breaches are talked about? 164
Table 47 - Desirability Metrics for What is the expected level of Cybersecurity vocabulary awareness? ..165
Table 48 - Desirability Experts and Questions for Information Management Perspective 165
Table 49 - Desirability Metrics for What is amount of communication sharing with Internet Service Provider?.....166
Table 50 - Desirability Metrics for Logging required is sufficient for Security and Forensics? 167
Table 51 - Desirability Metrics for What is the extent that Network and System Administration procedures are documented?.....168
Table 52 - Desirability Metrics for What is the degree of retention periods in place for data and information? 169
Table 53 - Desirability Metrics for What is the expected level that standards are understood?.....170
Table 54 - Desirability Experts and Questions for Systems Management Perspective 170
Table 55 - Desirability Metrics for What is the complexity of Data Loss Prevention (DLP) systems that are in place?.....171
Table 56 - Desirability Metrics for To what degree are Energy System outages planned to?.....172
Table 57 - Desirability Metrics for What is the degree that machine limitations are recorded? 173
Table 58 - Desirability Metrics for What is the degree of network modeling for ICS/IoT/Nuclear done? .173
Table 59 - Desirability Metrics for What is the expected level of outages required for applying security updates? 174
Table 60 - Desirability Metrics for What is the degree of planning done for forensic evidence collection? 175
Table 61 - Desirability Experts and Questions for Professional Perspective 175
Table 62 - Desirability Metrics for To what extent is cybersecurity awareness of behavior of staff checked? 176
Table 63 - Desirability Metrics for What is the required amount of external reporting? 177
Table 64 - Desirability Metrics for What is the degree of vendor and supply alignment on security?.....178
Table 65 - Desirability Metrics for What is the expected level that threats to the organization are modeled? 179
Table 66 - Desirability Metrics for What is the expected level that change management will be considered? 180
Table 67 – Desirability Experts and Questions for Leadership Perspective.....180
Table 68 - Desirability Metrics for Are Cybersecurity goals identified in the organization?.....181
Table 69 - Desirability Metrics for What is the amount of Cybersecurity learning sources available? 182
Table 70 - Desirability Metrics for Cybersecurity Risk is a required topic by C-Suite?.....183
Table 71 - Desirability Metrics for What is the expected level of policy updating? 184
Table 72 - Desirability Metrics for What is the required level of certification in operations roles? 185
Table 73 - Desirability Metrics for Are complex Cyber supply chain risks considered in procurement? ...186
Table 74 – Experts for Agencies of Government Case 189
Table 75 - Agencies of Government Assessment Score.....190
Table 76 - The Strengths and Weaknesses of Agencies or Government.....191
Table 77 - Experts for the Private Entity Case 193
Table 78 – Private Entity Assessment Score.....194
Table 79 – The Strengths and Weaknesses of Private Entities.....196

Table 80 - Case Analysis and Readiness Score 197
Table 81 - The Strengths and Weaknesses of Both Cases 197
Table 82 - Improvement Simulation – Case of Agencies of Government 205
Table 83 - Improvement Simulation – Case of Private Entities 210
Table 84 - Future Scenarios 216
Table 85 - Organizational Emphasis 217
Table 86 - Organization Score and Rank Change 219
Table 87 - Information Management Emphasis 220
Table 88 - Information Management Score and Rank Change 222
Table 89 - Systems Management Emphasis 223
Table 90 - Systems Management Score and Rank Change 225
Table 91 - Professional Emphasis 226
Table 92 - Professional Score and Rank Change 228
Table 93 - Leadership Emphasis 229
Table 94 - Leadership Score and Rank Change 231
Table 95 - Summary of Scenario Score and Rank Changes 231
Table 96 - How the Research Addressed the Gaps, Goal, and Questions 237
Table 97 – Types of Questionnaire Research Bias 239
Table 98 – Factorials 4 to 10 240

CHAPTER 1: INTRODUCTION

This research contributes to the emerging field of cyber readiness in the energy industry. The contributions can be used by (including, but not limited to): Policy Makers ([via] mandatory management directives [3]): for National priorities, Technology Suppliers: identifying development areas, Energy Utilities: for large scale deployments, and Universities/Research: for research focus. There is a lack of research on quantitatively evaluating cybersecurity criteria for the energy industry [4].

There is a long history of trying to secure cyberspace. The very first computer controls were created by RAND corporation in 1969 [5]. The roots of cybersecurity standards can be traced back to the National Institute of Standards and Technology (NIST) Rainbow Series documents in the 1970s and 1980s [6]. Additionally, the USA National Computer Security Center (NCSC) consistently put out cybersecurity guidance and assessment tools in the late 1980s and in the 1990s [7-18].

First we must define what we mean by security. The Oxford dictionary defines security as “the state of being free from danger or theat. [19]” An electric grid resilience oriented definition is: “in electricity networks security is defined as the ability of the system to recover from a disturbance and continue delivery of power. [20]” Thus security is a state of being free from threats while being able to have continuity and recoverability. Data Security is a means to protect data and assets from unacceptable consequences [21]. Data Security is the operational work of guarding of your data and assets.

Federal Information Security Management Act (FISMA) law defines information security from the USA government perspective:

> The term ‘information security’ means protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide—‘‘(A) integrity, which means guarding against improper information modification or destruction, and includes ensuring information nonrepudiation and authenticity;‘‘(B) confidentiality, which means preserving authorized restrictions on access and disclosure, including means for protecting personal privacy and proprietary information; and‘‘(C) availability, which means ensuring timely and reliable access to and use of information [22].

Cybersecurity is also known as Information Security (IS) [or logical security [23]] and is a subset of Information Technology (IT) [24]. Cybersecurity involves “the collective application of strategies, security measures, threats, administration tactics, training, paramount practices, assurance and expertise that can be used to guard the information system, organization and all related assets” [25]. Cybersecurity is implemented through a lifecycle of monitoring, testing (including exercises), and dashboards [26]. Cybersecurity readiness shows an organizations behaviors, practices, and processes towards managing risk, having efficient controls, training employees on cyber risks and detecting and responding to threats specifically related to outages using audit and assessment techniques. In “The Need for Integrated Cybersecurity and Safety Training” Gupta states that cybersecurity failures should be assumed. [27]. The Readiness [lifecycle] includes identification of requirements, action plan creation, and going live [28].

From a practical perspective “cybersecurity aims to reduce the likelihood that attackers can access systems, and to limit the damage if they do” [29]. Cybersecurity needs to be a key component of the risk management program [30]. There are multiple ways this is address cybersecurity in practice. Federal Information Processing Standards (FIPS) 199 topics of Confidentiality, Integrity, and Authentication (CIA “aka CIA triad”) [31] are the three pillars (aka perspectives) in most cybersecurity discussions. Identity, Authentication, Authorization, and Accountability (IAAA) [sometimes audit is a fourth A added as in CISSP exam] is an alternative Security Principle [32] (aka Identity and Access Management “IAM” principle). Audits make sure systems are doing what they are supposed to be doing. Principles are similar to pillars. System and Organization Controls for Service Organizations (SOC2) by American Institute of Certified Public Accountants (AICPA) [33] adds privacy, and security, as a pillar to the CIA triad to create a total of five categories. An alternative model is the Parkerian Hexad which is made up of six total attributes (aka perspectives, including the CIA’s three attributes) [34]. A model is a “skeleton” one can use if one decides to use a specified process for perspective analysis.

My tailored HDM model has five perspectives that are drawn from National Institute of Standards and Technology (NIST) National Initiative for Cybersecurity Education (NICE) 8355 draft for comments, and NIST 800-137 (Information Security Continuous Monitoring) ISCM. The Hierarchical Decision Model (HDM) model is a decision-making tool using Multi-Criteria Decision Analysis (MCDA) [35]. My HDM model is specifically tailored for the readiness in the energy industry for the USA.

Figure 1 – The 11 Security Automation Domains from NIST 800-137 ISCM



Note: Taken from National Institute of Standards and Technology (NIST), "NIST 800-137: Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations," September ed. Gaithersburg, MD: U.S. Department of Commerce, 2011.

The HDM selection of criteria were designed from 421 articles 74 overall findings (data points), 37 of the 74 were in the technical perspective, 52 were identified as unique gaps, which were ultimately combined to 29 final gaps. Articles reviewed for this proposal included journals such as: Journal Of Computer Information Systems, International Journal Of Critical Infrastructure Protection, IEEE Transactions On Power Delivery, and Computers & Security. Standards in the industry were reviewed for applicability. Experts were interviewed for comment.

1.1 Cybersecurity Readiness in the Energy Industry

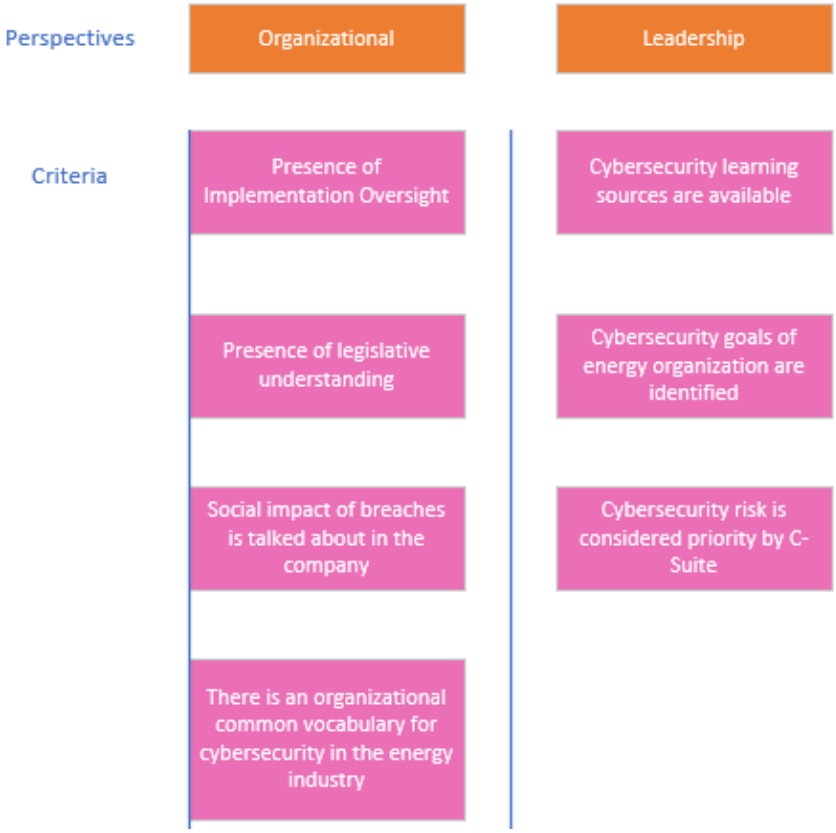
Readiness informs a risk decision. N. N. Muraguri, T. Mwalili, and T. Mose defined cybersecurity readiness as: “Cybersecurity readiness shows an organization’s behaviors, practices, and processes towards managing risk, having efficient controls, training employees on cyber risks and detecting and responding to threats” [25]. This research expands the concept of threats to include any outage situation. Outages were caused by Enron who throttled power in California causing outages to raise their share price [36]. Outages were also caused in the Northeast USA in the Northeast blackouts because of improper load balancing when a tree caused tripping which cascaded [37]. Based on Department of Energy (DOE) current usage of the term readiness it is specifically related to using audit and assessment techniques. The National Energy Research Scientific Computing Center (NERSC) defines readiness in terms of “ability of applications and applicant to fully utilize computing resources” [38]. The definition for cybersecurity readiness is below.

Figure 2 – Cybersecurity Readiness Definition

Cybersecurity Readiness shows an organizations ability of applicant and application to be able to fully utilize computing resources through behaviors (e.g., training employees), practices, and processes, while managing risk through efficient controls in order to prevent, detect, and respond to outage scenarios using audit and assessment techniques

This HDM model is half administrative based and half technical controls, with the addition of culturally based controls in the Organizational and Leadership perspectives, yet this is not a complete controls solution for compliance. “Cyber security requires the participation of people, processes, and technology… to protect the organization, people, and IT infrastructure” [39]. This solution is best implemented using audit type checklists.

Figure 3 – Culturally Significant Controls in the HDM Model



Note: Based on authors determination

Further elaborating on Readiness, Muraguri [40] quoting the International Communication Union, stated that "cybersecurity is the collective application of strategies, security measures, threats, administration tactics, training, paramount practices, assurance and expertise that can be used to guard the information system, organization and all related assets". The Research and Development (RAND) Corporation states that cybersecurity is a blue team "reactive/response" exercise with static countermeasures based on known best practices [41]. This reactive response is due to varying ways to evaluate cybersecurity preparedness including readiness.

In practice once a readiness assessment is completed a risk assessment is done usually at the executive level. The executive function is iterative. It is a discipline of grouping sub systems, labeling interfaces (aka roles). Executives operate at the interdependency level. A risk assessment is a control that addresses a scenario with metrics as an output.

Metrics should make the case: Why the organization is compliant. The HDM model data could be used to provide inputs for metrics. A test to achieve readiness needs to include technical experts, risk acceptors, executives, and business operations (the customer or consumer). The readiness model, in organizational practice, will allow adjudication with a common set of criteria so as not to unfairly stack the results based on one group criterion. Qualitative results can be used for metrics creation.

Research showed that: Readiness [planning results in] correct alignment of Cybersecurity activities of business, creates a posture awareness about organization needs and abilities [28]. A quantitative assessment for "reasonable assurance" of Cybersecurity controls is gained through periodic re-evaluation [using modeling and/or surveys]" [42]. Quantitative assessment of what aspects of security are important is needed so that the organization can have reasonable assurance of taking appropriate actions [26]. Reasonable assurance means that the level of detail, depth, time, and resources are sufficient to provide security for the environment (riskiness and comforts).

1.1.1 Resiliency

Resilience (which is related to readiness but is more broad) is normally aimed at mitigating catastrophic change [43]. "Electric grids are typically operated according to

the N-1 security criterion, which requires the network to remain secure and maintain supply following a single disturbance“ [20]. Resiliency can be thought of as “flexibility to overcome consequences of disruptive events rapidly and economically” [44]. A resilient system is able to recover a minimum level of functionality [43].

Definitions of resilience are: “having the ability to respond properly by adapting to changing conditions, to recover from an incident, and resume close-to-normal operations within acceptable time and cost” [45]. Another is “ability to maintain continuity during and after an incident” [45]. A more cyber related resilience definition is “ability to anticipate, withstand, recover from, and adapt to adverse conditions, stress, attacks or compromises on cyber resources” [45].

[The] resilience definition from Computer Emergency Readiness Team (CERT) Resiliency Management Model (RMM)… and [46] [47] and [48]… is “a flexible continuity during and after a cybersecurity event to withstand and recover operational capacity within a specified period of time” [43]. The ultimate goal of these definitions can be summarized as “continuity during and after a cybersecurity event” [45]. There are 15 domains for resilience maturity per the CERT RMM. Each domain in the CERT RMM document has information for checklists.

Saaty [49] discusses intense dynamic judgements which are needed in disruptive events, which resiliency topics cover. The figure below shows that most events can be mathematically calculated except for catastrophic change. This figure lends support to the justification why we need a readiness model, to prepare and quantitatively measure, prior to catastrophic events.

Figure 4 – Intensity of Dynamic Judgements

Time-dependent importance intensity	Description	Explanation
α	Constant for all t, $1 \leqslant \alpha \leqslant 9$ an integer	No change in relative standing
$a_1 t + a_2$	Linear relation in t, increasing or decreasing to a point and then a constant value thereafter. Note that reciprocal is a hyperbola	Steady increase in value of one activity over another
$b_1 \log (t+1) + b_2$	Logarithmic growth up to a certain point and constant thereafter	Rapid increase (decrease) followed by slow increase (decrease)
$c_1 e^{c_2 t} + c_3$	Exponential growth (or decay if c_2 is negative) to a certain point and constant thereafter (note reciprocal of case c_2 is negative is the the logistic S-curve)	Slow increase (decrease) followed by rapid increase (decrease)
$d_1 t^2 + d_2 t + d_3$	A parabola giving a maximum or minimum (depending on d_1 being negative or positive) with a constant value thereafter. (May be modified for skewness to the right or left)	Increase (decrease) to maximum (minimum) and then decrease (increase)
$e_1 t^n \sin (t + e_2) + e_3$	Oscillatory	Oscillates depending on $n > 0$ ($n \leqslant 0$) with decreasing (increasing) amplitude
Catastrophies	Discontinuities indicated	Violent change in intensity

Note: Taken from T. L. Saaty, The Analytic Hierarchy Process: Planning, Priority Setting, Resource Allocation. New York, NY: McGraw-Hill, 1980 [49].

Resiliency includes having response plans for high risk rated hazards [46]. North American Electric Reliability Corporation (NERC) has defined the adequate level of reliability (ALR) to include resilience as a time-based component of reliability" [48]. NERC defines Bulk Electric System (BES) reliability as SRI*bps* = [(RPL) × wL × (MWL) + wT × (NT) + wG × (NG)] X 1000 [50]. The Bulk Power System Severity Risk Index (SRI) is a daily metric where transmission loss (T), generation loss (G), and load loss events (Megawatt Loss) aggregate into a single value, using a weight (w) and restoration time (R) that indicates performance. To be resilient and ready [an

organization] needs control of technical and procedural [aspects] [43] of the organization. For routine resumption [from an outage]… no spur of the moment additional Readiness Review (RR) is [likely] required [28].

Overcoming adverse consequences [timely] resilience is dependent on good security [posture]. Resilience models are [needed and used] for critical infrastructure [which includes energy] and military defense [43]. Resilience models, like CERT RMM can be drawn upon for policy tailoring. A consolidated organizational approach for cyber practice (strategy and controls) eases tension between policy experts (those that know government workings) and technical experts (those that know engineering).

1.1.2 NERC

NERC operates the Electricity Information Sharing and Analysis Center (ES-ISAC or E-ISAC) https://www.eisac.com/, which works with the Department of Homeland Security (DHS), the Department of Energy (DOE), and other agencies to help protect the North American Bulk Electric System (BES), defined as operating at voltages of 100 kV or higher, from cyber and physical attacks. Energy ISAC (E-ISAC) posts advisories, alerts, warnings, and the current threat alert levels for the Homeland Security Advisory System, the Department of Energy, and the electricity sector [51].

The E-ISAC offers membership to North American electric and natural gas industry asset owners and operators.

E-ISAC members receive: private-level situational awareness on security threats, including alerts; physical security and cyber security bulletins; remediation; task

> force reviews; events calendars; and other security specific resources. Members are encouraged to use the E-ISAC's trusted forums to network and share candidly, directly with peers [52].

Thus, incident response and reporting are already a going concern for grid operators.

It is NERC's responsibility to gather, disseminate, and interpret security related information. NERC operates, as a non-profit, between industry and the government and among all the energy industry sector entities [53]. “Technological improvements have caused the U.S. bulk electric system to be increasingly vulnerable to intrusions from cyberspace” [54]. ICS systems are increasingly being connected to the internet for remote control and maintenance.

Federal law requires that U.S. federal government entities must use NIST-approved or allowed algorithms. FIPS 140-2 standardizes cryptography. This standard is mandatory to all Federal agencies that use cryptographic based security systems to protect sensitive information in computer and telecommunication systems (including voice systems) as defined in Section 5131 of the Information Technology Management Reform Act of 1996, Public Law 104-106 [53].

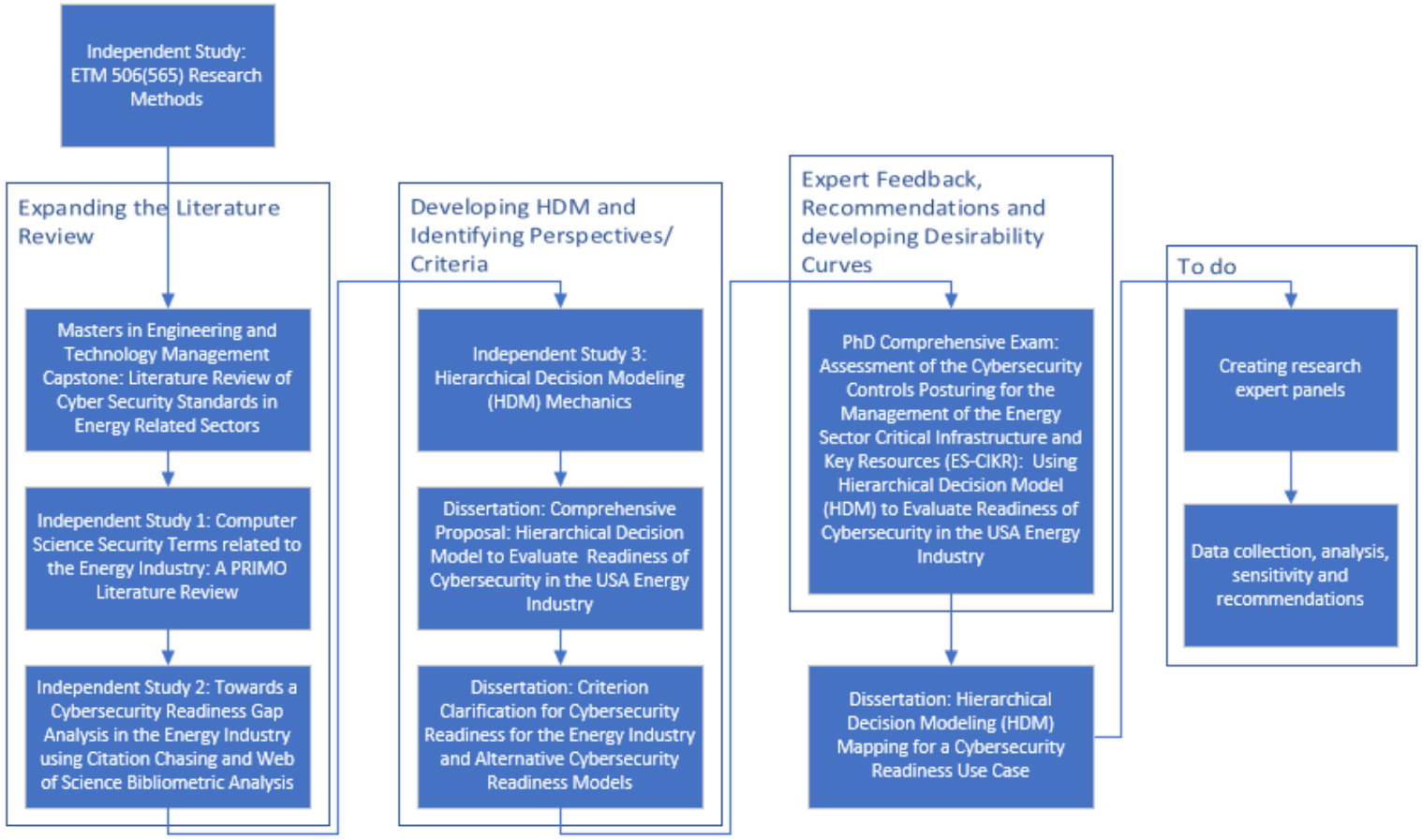
The Federal Information Processing Standards (FIPS) documents were created because of FISMA which is legislation for cybersecurity of USA Federal government agencies. NIST Federal Information Processing Standards (FIPS) document 199 provides a framework of impact levels low, medium, and high (used in NERC Critical Infrastructure Protection (CIP)). NIST FIPS 200 specifies minimum security

requirements for Federal information and information systems [28]. The publication is a mandatory federal standard developed by NIST in response to FISMA legislation. To comply organizations first determine the security category of their information system in accordance with FIPS Publication 199, Standards for Security Categorization of Federal Information and Information Systems. Then they derive the information system impact level from the security category in accordance with FIPS 200. Then they apply the appropriately tailored set of baseline security controls in NIST Special Publication 800-53 [53].

1.2 Background

The research process involved three major phases shown in the figure below. First was the literature review, then developing the model, then getting expert feedback. The next step is to do the analysis and report.

Figure 5 – PhD Research Process


Independent Study: ETM 506(565) Research Methods
Expanding the Literature Review
Masters in Engineering and Technology Management Capstone: Literature Review of Cyber Security Standards in Energy Related Sectors
Independent Study 1: Computer Science Security Terms related to the Energy Industry: A PRIMO Literature Review
Independent Study 2: Towards a Cybersecurity Readiness Gap Analysis in the Energy Industry using Citation Chasing and Web of Science Bibliometric Analysis
Developing HDM and Identifying Perspectives/ Criteria
Independent Study 3: Hierarchical Decision Modeling (HDM) Mechanics
Dissertation: Comprehensive Proposal: Hierarchical Decision Model to Evaluate Readiness of Cybersecurity in the USA Energy Industry
Dissertation: Criterion Clarification for Cybersecurity Readiness for the Energy Industry and Alternative Cybersecurity Readiness Models
Expert Feedback, Recommendations and developing Desirability Curves
PhD Comprehensive Exam: Assessment of the Cybersecurity Controls Posturing for the Management of the Energy Sector Critical Infrastructure and Key Resources (ES-CIKR): Using Hierarchical Decision Model (HDM) to Evaluate Readiness of Cybersecurity in the USA Energy Industry
Dissertation: Hierarchical Decision Modeling (HDM) Mapping for a Cybersecurity Readiness Use Case
To do
Creating research expert panels
Data collection, analysis, sensitivity and recommendations

The proposal is organized as follows: First, the report provides an overview of the literature related to Cybersecurity and Readiness in the Energy Industry. This highlights the gap analysis inclusive of goals and objectives. The next section discusses the HDM Model and comparison vis-à-vis other methodologies. Then the research plan and validation process are presented. The last section is the implications and Improvements of leading this research (aka benefits and value).

Figure 6 – Research Framework



1.3 Research Motivation

"The contemporary power grid is vulnerable to various sabotages, cyber-attacks, vandalism activities, terrorist attacks, and other emerging threats" [55]. From the research it can be concluded that if there is a computer connection there is a way to penetrate the "system" whether code, network, electromagnetic etc. Mike McConnell, Booz Allen Hamilton Vice Chairman and former U.S. Director of National Intelligence observed that "there isn't a corporation in the nation today that can't be penetrated, not one" [56]. With highly interconnected systems there exists the potential for malware to move laterally through the network from one asset to another [57]. Lateral movement is how pentesters are ultimately able to compromise a system.

Most Information Technology (IT) systems are hardened sufficiently to thwart known attacks, such as scripts available in Metasploit. Trust relationships from computer services to computer services are usually how pentesters (or adversaries) can manipulate

another machine to sending information that ultimately enables a network privilege to be provided and that privilege to be reassigned from the service to the attacker. Smaller companies don't necessarily have cyber security expertise or bandwidth to handle the complexity in computers beyond purchasing and end use. This was evidenced in the Target Corporation breach where the Heating Ventilation Air Conditioning (HVAC) vendor was compromised [58] which had privileges to talk to Target machines. The attackers reassigned privileges and stole credit card information.

The use of cyber-attacks in Industrial Control Systems (ICS) and Internet of Things (IoT) mean that we need a tool to adopters to assess, plan, and prepare for readiness work (including restart implementations) [43]. It is cautioned that cybersecurity if implemented improperly can open up doors to attackers. "Damage caused by cyberattacks can… directly impact people's lives" [59]. This has evidenced in power outages, and government incapacitations as shown in this dissertation.

"The need to address potential vulnerabilities has been acknowledged across the Federal government, including the National Institute of Standards and Technology (NIST), the Department of Homeland Security (DHS), the Department of Energy (DOE), and the Federal Energy Regulatory Commission (FERC)" [60]. The Cybersecurity Maturity Model Certification by the Department of Defense specifically calls out Advanced Persistent Threats (APT) which are when "an adversary that possesses sophisticated levels of expertise and significant resources which allow it to create opportunities to achieve its objectives by using multiple vectors (e.g. cyber, physical, and deception)" [61].

Operational gaps are usually found over time and result in a more mature organization. Maturity is the "extent to which vulnerabilities [or gaps] are identified and documented in a systematic and procedural way" [3]. Maturity models have their own ISO standard 15504. COBITs Capability Maturity Model Integration (CMMI), DOE's Cybersecurity Capability Maturity Model (C2M2), and DOD's Cybersecurity Maturity Model Certification (CMMC) are examples of maturity specific models [62]. By filling gaps, one can raise maturity level in an organization. Focusing operational requirements based on facts not assumptions should alleviate miscommunication based on opinions.

The first ICS attack on safety specific instruments was in 2017 [63] while there have been other significant ICS attacks [64]. Many attacks are against municipalities and smaller entities [65]. In the case of cybersecurity in the Energy Industry, an attack or failure of security, ultimately has a physical (i.e. energy load) effect [43]. The table below shows a sample of closely related attacks to the energy industry.

Table 1 – Major Breaches and Known Attacks Closely Related to the Energy Sector

2010 to 2013	Energy	Nuclear Regulatory Commission (NRC)
2023	Energy	South African power company
2022	Energy	Ukrainian state nuclear operator Energoatom
2021	Wind Manufacturer	Vestas
2020	Government	Tillamook County
2019	Government	City of Sammamish
2019	Energy	Kudankulam Nuclear Power Plant
2018	Government	City of Atlanta
2018	Government	Alaska Dept. of Health and Social Services
2017	Energy	Saudi Petrochemical Plant
2017	ICS	Honeywell Controller
2017	Government	Bingham County Server Ransom
2016	Energy	Gundremmingen nuclear power plant
2015	Energy	Duqu
2015	Energy	Ukraine Power Grid
2015	Energy	Regin

2015	Government	OMB
2014	Energy	Black Energy
2014	Energy	German Steelmill
2014	Energy	KHNP
2014	Energy	South Korea’s nuclear operator
2013	Energy	DOE
2013	Energy	Brazilian control system network infections
2013	Energy	Bowman Dam
2012	Energy	Flame
2012	Energy	Aramco oil Saudi Arabia
2011	Utility	Water utility in a rural community west of the state capital Springfield
2011	Government	RSA Tokens
2010	Energy	Stuxnet
2006	Energy	Chubu Electric Power
2005	Government	DOE NNSA
2001	Utility	Maroochy Shire, Queensland sewage

Note: Taken from authors research

Electricity [and other forms of energy] has played a critical role in human development. It enhances quality of life: safely and reliably provides power for consumers and manufacturers and other users, so they can use for purposes of creation and application in many products and services areas. Electricity has provided value for consumers and financial markets by enabling us to harness power from big generators (turbines and solar farms, etc.) and send that energy to city centers, manufacturing plants, and other users and places [53].

The scope of the protection is widening:

According to the Smart Grid Interoperability Panel Cyber Security Working Group (SGIP) “Cyber security must address not only deliberate attacks launched by disgruntled employees, agents of industrial espionage, and terrorists, but also

inadvertent compromises of the information infrastructure due to user errors, equipment failures, and natural disasters [53].

The threat landscape has grown to include ransomware. Ransomware is an ongoing concern in critical infrastructure industries [66]. Common computing technologies (Public Key Infrastructure (PKI), phones, routers etc.) with known vulnerabilities are prone to attacks (including ransomware) as is evidenced from the proliferation of: Endpoint Detection and Response (EDR) software from companies like VMware Carbon Black, SolarWinds, CrowdStrike, Cylance, etc.; Scanners: Qualys Nexpose, Tenable Nessus, Rapid 7 Metasploit, etc.; Web App Dashboards: Acunetix, Netsparker/Ivanti, Brinqa, etc. and Governance Risk and Compliance (GRC) tools: Caveonix, RSA Archer (rsa.com and archerirm.com) [not to be confused with Archer Energy Solutions Critical Infrastructure Protection Consultants (archerint.com)], etc. The Cyber Security Evaluation Tool (CSET) Tool even has a ransomware module that is also referred to as a readiness assessment tool [67]. This proliferation of tools shows how the threat footprint is growing.

In USA Cybersecurity Standardization efforts, the term readiness has not been applied to cybersecurity. There is not a single definition of cybersecurity readiness for the energy industry which leads to confusion [28] in applying the model. Readiness has been described as investigating relationships between factors [68], visualizing relationships [69], figuring a degree of preparedness [45], and being prepared to deal with threats [70]. The MITRE Threat Assessment & Remediation Analysis (TARA) model was an early attempt at combining similar variables into a quantitative assessment tool [71] but it was

specifically focused on threats and was complex. The reason for multiple definitions may be related to the industry bifurcation of network vs security monitoring concerns [72]. Or owners/operators may simply think of Readiness in terms of incident reporting in line with the DHS United States Computer Emergency Readiness Team (US-CERT) [73] usage of the term.

> A readiness test [which is essentially a quality and safety test] is a missing component in the Cybersecurity controls culture. Although a performance test is sometimes done, performance is closely aligned with maturity and capability rather than any point in recovery [or mitigation] time from [or during] an outage [26].

A big risk in the energy industry is the cascading risk of the energy grid, though it is a non-trivial task to lead to this type of cyber event for a would be attacker [74]. All parts of the grid operate together at 60Hz (a Hertz is a cycle of energy). If some parts of the grid go too far out of control then equipment may be damaged locally with the possibility to affect other [systems that are tangentially connected] [26]. [As for] energy usage itself all of modern society depends on the [product] for basic life functions [26]. In the USA there are nearly 2300 Hydro power [75] producing dams and upwards of 50 Nuclear plants [76] in the USA which provide 40% of the power mix [77] for consumers. If one or more of these powerhouses goes down there could be a cascading effect on the national grid.

"Checklists with an overwhelming number of items is counterproductive to the successful application of controls" [78]. Cyber readiness checklists could be used after an

outage (as an added requirement [above and beyond a Multi-Criteria Decision Model (MCDM)] of incident response) [26] such as in a walkdown situation. “Cursory reviews would raise safety issues while open-ended, extensive reviews could continue indefinitely introducing significant delay and expense to DOE programs” [79]. A Readiness Review (RR) report, a corrective action plan to address the findings, and certification that all… findings are resolved. With that documentation submitted and accepted, the contractor… can authorize… operations [79]. The HDM model helps an organization assign follow-up assessments work based on the model survey results (HDM should be seen as facts rather opinion because of rigor) which builds organizational trust.

1.3.1 Outage Causes

There are failures and there are attacks [43] either can cause an outage. Events that might cause disruption are climate change, natural disasters, physical attacks, and terrorism” [44]. An unscheduled outage in the power system is [usually] an unacceptable mission impact [26] and requires a corrective action plan. Degradation [is another term for] outage [26], sources of misuse [that cause outage] can be accidental, involuntary, an environmental hazard, not being hardened/prepared for, or via abuse as is an intentional act of maliciousness. Hardening is a procedure to make sure that all controls related to a system or information have been implemented.

> Outages can happen for a variety of reasons: storms [and even space weather [80] and Electromagnetic Pulse (EMP)], network issues, host issues, malware, cybercrime, or sensitive data loss/leaks. A periodic review or a change request for significant security changes are things that could be considered as planned outage.

> An unplanned outage would be… a threat that is unscheduled. Some causes for outages are: Advanced Persistent Threats (APT's) such as government's cyber warfare and criminal terrorists, natural hazards such as electro mechanical systems getting bits and bytes mixed up, accidental well-meaning exchanges of Personally Identifiable Information (PII), or accidents that take down machines [26].

Disruptions in Energy supply chains happen when significant risks such as: natural hazards, diseases, major accidents, and societal risks are realized [81]. A merger or acquisition scenario also may result in likely planned (also known as a Designated System Time [DST] window) and unplanned outages. There is risk [82] at all levels of the workforce from Executive to Acquisition and the HDM model can reduce some of biased stressful decision making. Additional security risks in organizations customized applications or environment (culture and/or operations risk), and HR (such as insider threat from disgruntled employees during the reorganization) [26].

An outage/restart situation (that is situational awareness) is not normally covered in a NIST 800-53 cyber controls assessment, regardless of whether the situation is a Blackstart (localized power source) or non-Blackstart (transmission line-based power) restart speed of recovery is a hot topic [83]. To go live an acceptance of risk for the system must be made by management. Many of the issues for outage and restarts are captured in a business impact analysis (BIA) which can also include a contingency plan. A recovery plan (part of a vulnerability response) should be able to identify which parts of the system that would need to be reconfigured to prevent recurrence [84].

So, how can an organization justify to an oversight agency that they should have the Authority to Operate (ATO) back onto the interconnected grid after an outage (or an incident)? To provide confidence an organization can do a readiness assessment. A readiness assessment is essentially a gap analysis in order to provide confidence to put a system or application into production. The readiness assessment shows where you are and you can compare that to where you need to be for the next step [85] to restart operations. An author stated in relation to Cybersecurity that that readiness is being "prepared to deal with threats" [45]. Thus, readiness includes two mutually concerns: gaps and threats.

1.3.2 Attack

A cyber-attack is the manifestation of electronic or digital threats [86]. "Before an organization can have cyber security in place, it must be aware of the possibility of cyber-attacks and commit to preventing, detecting, and combatting such attacks" [87]. The use of cyber-attacks in ICS and IoT (National Grid systems also have IoT devices because embedded systems "aka IoT" are used throughout the grid to support monitoring and controlling functions [88]) mean that we need a tool for adopters to assess, plan, and prepare for the readiness work [in the organization].

Readiness must be defined and measured. "Readiness is essential to move forward and ensure a baseline on which IoT… can be built" [89] into the organization. IoT devices can be used to monitor grid connected devices. Data, connectivity, and power surges are areas for attack with IoT networked devices. "Cyber security must address not only deliberate attacks launched by disgruntled employees, agents of industrial

espionage, and terrorists, but also inadvertent compromises of the information infrastructure due to user errors, equipment failures, and natural disasters" [60].

A [Readiness] methodology requires the use of multiple tools [3]. Vulnerability methods run in parallel to readiness, and are parent to control frameworks in that they are inclusive of control frameworks (including threat modeling). Vulnerability methods are also inclusive of pentesting. A resilience method requires multiple sub-methods: readiness, reliability, and vulnerability. Vulnerability assessments include qualitative (and possibly quantitative) assessment based on security environment (risk, confidence, maturity, and capability) and can include threat modeling, and scanning and red team work (aka a penetration test) [3]. Scanning not only checks for open ports and services (some likely due to misconfiguration), scanning also checks for patching and upgrading [3].

The characteristics of vulnerabilities, threats and assets should be quantitatively summarized with tiers that could be included as an input to a threat value model [90]. Abuse types at a technical level can be categorized as: hardware, software, data, and services [91]. "The foundation document for NIST Cybersecurity Framework (CSF)" was developed in response to the abuses and corresponding threats [91]. Homeland Security Systems Engineering and Development Institute (HSSEDI), run by MITRE, provides a good overview of threat readiness assessments [92]. Threats can be documented as hazards [93] or through a traditional cybersecurity threat model.

MITRE which stands for Adversarial Tactics, Techniques, and Common Knowledge (MITRE ATT&CK model), both the enterprise and the ICS versions, and

MITRE's other tools (Common Vulnerability Enumeration "CVE", Common Attack Pattern and Enumeration Classification "CAPEC" etc.) should be used for readiness risk input aids in order to understand what adversaries do. MITRE tools are a starting point (aka a knowledge base) for adversary tactics and techniques understanding and enumeration based from real-world observations. Att&ck descriptions are lessons learned and the researcher can use CAPEC enumerate and classify. Classification/risk prioritization must be done with CVE or other code of accounts (aka numbering systems). MITRE Att&ck mitigations are a high-level idea of what you put into an incident response plan. The technical procedures to implement the mitigations can be based on CIS benchmarks technical hardening documents.

Assets for Industrial Control Systems can be self-assessed with the Cyber Security Evaluation Tool (CSET), formerly Control System Cyber Security Self-Assessment Tool (CS2SAT) + Industrial Control System computer emergency response team (ICS-CERT) Cybersecurity Service Provider (CSSP) vulnerability assessment tool, free software. DISA STIG Viewer freely available from the USA Department of Defense is another tool for assurance of Cybersecurity software. One tool for external validation is the Command Line Interface (CLI) tool for Shodan which is a search tool to show Internet of Things (IoT) Devices on the internet that are vulnerable.

Vulnerability scores have to be reassessed periodically as systems are hardened. MITRE has a baseline list of vulnerabilities they call the Common Weakness Enumeration (CWE)/ Common Vulnerabilities and Exposures (CVE)/Common Weakness Scoring System (CWSS), National Institute of Standards and Technology

(NIST) has NIST Interagency Report (NISTIR) 7628 Vol.3 Ch.6, and the organization Open Web Application Security Project (OWASP) has a Top 10 web application security list. Basic mitigations are provided by DHS for vendors and asset owners in table EX-2, and Tables 1, 2, 4 and 6, of their report "Common Cybersecurity Vulnerabilities in Industrial Control Systems" [94]. Cyber threat vectors have been categorized by the most common cyber-attack types small businesses experience: hacking (e.g., stolen credentials), malware (e.g., ransomware), social engineering (e.g., spear phishing, and physical character attacks – note people are often referred to as the weakest links [56]), misuse (e.g., malicious insider), and web-based attacks [45].

The MITRE (not an acronym) corporation has a set of resiliency metrics [95]. MITRE Att&ck framework can be described as a way to think about everything you come across on your system, or that is bad that can happen on your system [96]. The approach to a cyber stable and "connected" energy system problem is multifaceted because there are so many attack vectors [53].

The MITRE ATT&CK Navigator on GitHub https://github.com/mitre-attack/attack-navigator is a good tool. The tool is used for keeping track of what has been mitigated based on broad cybersecurity categories. This tool can be downloaded for free and saved locally. It's based on known attacks and Advanced Persistent Threats (APT's) which are often state sponsored organizations who attempt cyber-attacks (including espionage).

If one can determine the most likely attacks one can cover those concerns and create a break (in the chain (aka the kill chain)). That means that through "layers of defense" the attack fails. Some cybersecurity categories are mandatory and some optional, based on industry and size of organization. No company can implement all cybersecurity controls perfectly. APT's are also referenced in the Cybersecurity Maturity Model Certification (CMMC), and the DoD Office for Acquisition and Sustainment Model for risk reduction and preparedness [61].

Size impacts threat value from an attacker perspective. Governance and management objectives [97] are needed to manage the organization's response. "Governance is a process not a technical solution" [98]. Some small businesses work with government as contractors. Small organizations have limited resources and thus need a simpler threat value model. Value can be defines as realizing benefits of optimal resource cost while optimizing risk [99].

Large organizations can do diverse testing including: endpoint visibility, user anonymization, analytics, and expert insider information [100]. Large organizations have resources and thus: “recommendations include preparing the organization's response (likely with a cyber security incident response team (CSIRT)) to the attack, and by supporting and promoting a culture of security awareness”[100]. The PhD readiness model can reduce barriers for small businesses in the energy industry who don’t have a lot of resources to put into high-cost compliance models. The model is still adaptable to larger organizations however because of the in-depth research provided.

The attack reaction decisions are very complex and are beyond the scope of the model. The Risk and Vulnerability Assessment (RVA) [101] and Cyber Performance Goals (CPG) [102] can be used together to implement an attack response to Readiness. Committee on National Security Systems Instruction (CNSSI) 1253 also includes a mapping to MITRE Att&ck concepts, and NIST 800-53 controls [26].

1.3.3 Ukraine

The 2015 and 2016 attacks on Ukraine showed evidence that a nation state is developing offensive capabilities aimed at the energy industries technologies. Russian actors discovered how to create outages remotely. Paul Stockton, former Assistant Secretary of Defense for Homeland Defense from 2009 to 2013 wrote: “the Bulk Power System (BPS) faces increasingly severe threats from China, Russia and others… Executive Order (EO) 13920 discusses these threats and the danger off cutting of services to Defense and critical facilities” [103].

On December 23, 2015 blackouts in several regions (a total of six companies “180 systems” were attacked, but some did not lose power) in Ukraine. The actual power outages affected 230 thousand people [104] “approximately half of the homes in the Ivano-Frankivsk region” [105]. One power distribution provider, in Ukraine called Oblenegro, “Kyivoblenergo provided public updates to customers indicating there was an unauthorized intrusion (from 15:30 - 16:30) that disconnected 7 substations (110 kV) and 23 (35 kV) substations leading to an outage for 80,000 customers” [106]. The cyber-attacks were a result of Russian geographically located groups. These attacks were the first known attacks resulting in electrical power outage.

The attackers used stolen credentials, and delayed incident recovery with planted malware. Backdoors such as DropBear and Kryptik [107] were installed, and Remote Access Trojan (RAT) which could corrupt downloads (among other things). The foothold was gained through spear phishing via Microsoft Office attachments [107] “such as Cross site scripting (XSS) or Command Line Interface (CLI) shells.” Although the Ukraine Oblenegros passwords were complex and could not be cracked with tools like John the Ripper, or brute forced with Hydra on Kali Linux, Multi-Factor Authentication (MFA) was not being used so intercepted TCP traffic passwords were reused [108].

Remote Desktop Protocol (RDP) access was gained so that the Graphical User Interface (GUI) of the machines could be used. VPNs were rerouted. The assets (aka machines) shutdowns were remotely scheduled. Denial of Service was an attack vector used on the call centers who supported incident response teams. Firmware overwrites were used to destroy some hardware usage in Oblenegros routers. Manual control of the

power system was the first incident response because attackers had wiped the systems master boot record (KillDisk was used [109]).

The Ukraine attacks have been extensively discussed. The attacks have been identified with different names. Dragos calls the Ukraine attack CrashOverride and has two writeups [110, 111]. While, ESET, an antivirus company, calls the Ukraine attacks Industroyer. ESET is a software company specializing in cybersecurity from Slovakia [112] with North American offices in San Diego. “FireEye calls the Russia-linked hacking group that has been targeting the US grid "TEMP.Isotope." It's also known as Dragonfly 2.0, or Energetic Bear [113].” Alert (AA22-110A) provides more details and precautions [114]. BlackEnergy is the backdoor that was used and is still thought to be in a lot of Ukraine enterprises infrastructure. The attack can now be flagged with an intrusion Yet Another Ridiculous Acronym (YARA) rule.

1.4 Problem Statement

The cost of [Cybersecurity] incidents varies, according to the size of the organization… An organization of more than 75,000 employees [large organizations], spend an average of $7.8 million to resolve a major incident. Organizations with 1,000 to 5,000 employees [small businesses], spend an average of $2 million [28]. Ultimately “insecure systems lead to financial loss” [89]. Procurement and cost principles are covered in guidelines NIST 800-35 [115] and NIST 800-65 [116] respectively. For the government the cost of major acquisition, of tooling, is governed by Federal Information Technology Acquisition Reform Act (FITARA) and the guidance document OMB M-15-14 [117]. Thus, the costs are high to keep up with compliance and lawmaking. There is

also escalating costs and need for implementation of new resources and tools to be compliant. FireEye who is an enterprise security vendor (later part of Mandiant, and Mandiant was later acquired by Google) states that their tools can provide over $1 million in benefit to Return on Investment (ROI) for a three year period in an example enterprise use case [118]. However, the cost to acquire such industrial cyber tools is not trivial.

Cybersecurity, as a hot industry, exists because of misuse and abuse. Abuse can be categorized (by Operators) as: hardware, software, data, and services [91]. “The foundation document for NIST CSF” was developed in response to the [escalating] abuses and corresponding threats [91].

Threats are the output of abuse. A threat vector (also called an attack vector) refers to the means by which an attack action may occur, such as the tool, technique, or path via which an unauthorized actor gains access [45]. A threat results in an event that requires a change at the organization (such as a remediation). When the components are compromised this is called an incident (this would require mitigation) [62]. Incidents are threats that are being actively managed. To actively manage you need to get the right information at the right time. Communication of organizational priorities is at the heart of the HDM readiness model. The characteristics of vulnerabilities, threats and assets should be quantitatively summarized with tiers that can be included as an input to a threat model [90].

CHAPTER 2: LITERATURE REVIEW

The literature review examined the applicable literature, with a focus on journals, to garner understanding of best practices and efforts in Cybersecurity Readiness and how the information could be used for decision making. More attention has been paid on peer-reviewed journals as they "serve as the major base of literature review as it provide sufficient theoretical background as well as leads for additional references on the specific subject matter [119]"

Table 2 – Core Articles by Methodology on Current State of Cybersecurity Readiness

Methodologies Used	**#**
Instructive Material	**9**
Cyber Security Basic Defenses and Attack Trends	1
Cybersecurity for Financial Institutions: The Integral Role of Information Sharing in Cyber Attack Mitigation	1
Cyber-Terrorism: Nigeria's Payment System Infrastructural Readiness	1
Forensic Readiness of Smart Buildings: Preconditions for Cybersecurity Tests	1
Graded security forensics readiness of SCADA systems	1
Information Security Standards	1
Managing Cyberthreat	1
The Current State of Insider Threat Awareness and Readiness in Corporate Cyber Security - An Analysis of Definitions, Preventions, Detection, and Mitigation	1
The Need for Integrated Cybersecurity and Safety Training	1
Interview	**1**
New tool assesses banks' cybersecurity readiness	1
Literature Review	**2**
Indicators for maturity and readiness for digital forensic investigation in era of industrial revolution 4.0	1
Technology Readiness and the Smart Grid	1
Model	**6**
A conceptual model for digital forensic readiness	1
A Generic Digital Forensic Readiness Model for BYOD using Honeypot Technology	1
ICS Testbed Tetris: Practical Building Blocks Towards a Cyber Security Resource	1
Mobile Cloud Forensic Readiness Process Model for Cloud-Based Mobile Applications	1
Towards a Systemic Framework for Digital Forensic Readiness	1

Towards verifiable evidence generation in forensic-ready systems	1
Model, Literature Review	**1**
A socio-technical analysis of China's cybersecurity policy: Towards delivering trusted e-Government services	1
Model, Statistics	**1**
Factors Affecting Perceptions of Cybersecurity Readiness Among Workgroup IT Managers	1
Model, Structural Equation Modeling	**1**
Evaluating the cyber security readiness of organizations and its influence on performance	1
Model, Survey	**1**
Internet of Things & Cybersecurity Readiness in Smart-government and Organizations	1
Poster One-Pager	**1**
Verification of Forensic Readiness in Software Development: A Roadmap	1
Prototype	**1**
Secure Logging in Operational Instrumentation and Control Systems	1
Semi-structured interviews	**2**
Cybersecurity incident response capabilities in the Ecuadorian financial sector	1
Cybersecurity Readiness of E-tail Organizations: A Technical Perspective	1
Statistics	**1**
Information Security: Cybersecurity Standards Adoption Among Malaysian Public Listed Companies	1
Survey	**4**
Cyber security readiness in the South Australian Government	1
Cybersecurity Readiness as a Business Value	1
Cybersecurity Readiness: An Empirical Study of Effective Cybersecurity Practices for Industrial Control Systems	1
Experts' reviews of a could forensic readiness framework for organizations	1
Survey, Model	**1**
Adoption of Cybersecurity Capability Maturity Models in Municipal Governments	1
Survey, Statistics	**4**
An Empirical Assessment of Cybersecurity Readiness and Resilience in Small Businesses	1
CISTAR Cybersecurity Scorecard	1
Cyber Security Readiness Assessment Model in Kenya's' Higher Learning Institutions: A Case of University of Nairobi	1
Factors Influencing Cybersecurity Readiness in Deposit Taking Savings and Credit Cooperatives: A Case Study of Nairobi County	1
Grand Total	**36**

Note: This includes Web of Science and Computer Science Literature Reviews

2.1 Critical Infrastructure and Key Resources (CIKR)

There are 16 critical infrastructure sectors in the USA. Critical Infrastructure (CI) is defined in the US Patriot Act of 2001 as: "Systems and assets, physical or virtual, so

vital to the United States that the incapacity or destruction of such systems and assets would have a debilitating impact on security, national economic security, national public health or safety, or any combination of those matters" [120]. In 2003, Homeland Security Presidential Directive (HSPD) 7 established the national policy requiring federal departments and agencies to identify and prioritize United States Critical Infrastructure and Key Resources (CIKR) and to protect them from terrorist attacks.

The USA government has given itself responsibility over Critical Infrastructure with Executive Order No. 13800 [121] which states that The Federal Executive Branch operates information technology (IT) on behalf of the American people, and the owners and operators of the Nation's critical infrastructure. As a part of this Critical Infrastructure, DOE has 17 official National Laboratories of the U.S. Department of Energy across the country (aka The Department of Energy's National Laboratory Complex) including the National Renewable Energy Laboratory (NREL) in Golden Colorado and Sandia Laboratory in New Mexico. The laboratories in part study integration projects such as wind power integration Western Wind and Solar Integration [122].

Critical Infrastructure according to Cybersecurity and Infrastructure Security Agency (CISA) is a designation of an industry sector "whose assets, systems, and networks, whether physical or virtual, are considered so vital to the United States that their incapacitation or destruction would have a debilitating effect on security, national economic security, national public health or safety, or any combination thereof (CISA,

2016). The Energy sector is defined as one of these critical sectors [53]. Cybersecurity is one significant overarching concern that connects all critical infrastructures.

The energy industry scope for this research includes: the Bulk Energy Systems (BES) that provide power to the grid; and Organizations, Entities, and Facilities that do production, generation, transmission, distribution, and assessment of energy resource. The energy sector consists of thousands of electricity, oil, and natural gas assets that are geographically dispersed and connected by systems and networks [123]. The research did not include: Exploration (such as for oil), Energy efficiency, Heating Ventilation Air Conditioning (HVAC), Smart Grids, Nuclear Safety Concerns such as National Security Systems.

The Government Accountability Office (GAO) stated that the federal government has several options… [to] improve the cybersecurity posture of critical infrastructure sectors [53] such as defense in depth [which] uses "a layered approach… (sometimes referred to as the castle model)" [124]. How readiness is related to defense in depth is that if one can determine the most likely attacks one can cover those concerns and create a break (in the chain (aka the kill chain)). That means that through "layers of defense" [aka multiple countermeasures] the attack will fail [28].

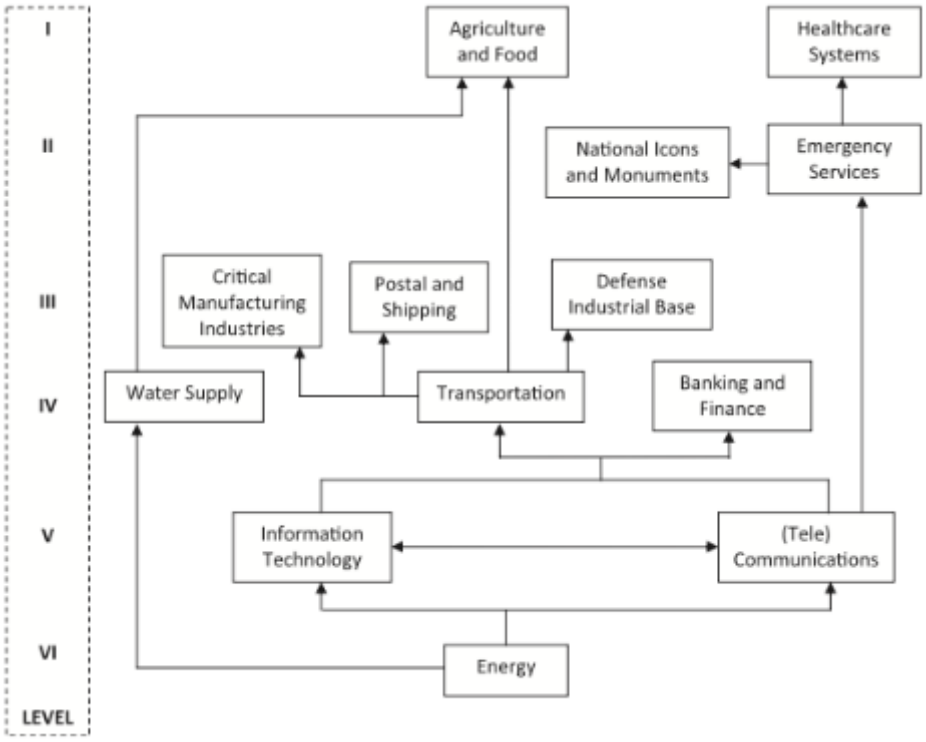
Electric Grid Cybersecurity, published in 2018, [125] is a United States congressional government report that explores readiness and gaps in the government's ability to react to cybersecurity events. The article explains the grid in terminology that is easily readable, in order to give the reader a general, but comprehensive overview of the

landscape. As the grid is a threat landscape new models are being created to address the cybersecurity [126].

Key resources are defined by Congress in Homeland Security Act of 2002 Section 2(9) as “essential to operations of economy and government” [127]. The biennial report on Critical Energy Infrastructure and Key Resources from Washington State inferred that Key Resources are local jurisdictional (not state or Federal) [128]. Defined roles and responsibilities for the Department of Homeland Security and sector-specific agencies to work with sectors to coordinate CIP activities. “Policy action Homeland Security Presidential Directive 7, Dec. 2003, Superseded PDD 63” [51]. The Department of Energy (DOE) was designated as the Sector Specific Agency (SSA) for the energy sector.

Critical Infrastructure risks are different than normal risks. Critical Infrastructure risks have risk to entity and risk to the nation [129] and, therefore, a threat to national security. Critical Infrastructure also can also result in supply shortages, safety concerns, and other consequences [130]. Critical Infrastructure Information (CII) is defined in regulation as “information not customarily in the public domain and related to the security of critical infrastructure or protected systems” [131].

Figure 7 – The Cybersecurity Importance of Energy sector in relation to other Critical Infrastructure sectors



Taken from: W. Miron, "Adoption of Cybersecurity Capability Maturity Models in Municipal Governments," Master of Applied Science, Technology Innovation Management, Carleton University, Ottawa, Canada, 2015.

2.2 Industrial Control Systems (ICS)

ICS systems are sensing and management devices for flow and pressure made up of pumps, valves, and switches. “ICS includes supervisory control and data acquisition (SCADA) and Inter-control Center Communications Protocol (ICCP)” [53] along with other protocols such as Modbus, and DNP3. A protocol is a set of rules and communication bases for conducting transactions. The energy industry is structured with a common framework with other Industrial Control Systems (ICS) and the interconnected national grid.

> Industrial Control Systems (ICS)/ Supervisory control and data acquisition (SCADA) and their components (proprietary protocols) and the Industrial energy machines (including routers and switches) that use them called Programmable Logic Controls (PLC). Closely related industries that use SCADA/PCS/ Distributed Control Systems (DCS) are: telecommunications (including internet), and water (including sewage). Although differences in these systems do exist, their similarities enable a common framework [94].

Three sectors of the Energy Industry: Industrial Control Systems (ICS), Internet of Things (IoT), and Nuclear [28] are prominent. Bulk Energy Systems (aka the national grid), which is an ICS system, are comprised of three more systems: generation, transmission, and distribution. There are many private contractors that provide ICS services in the interconnected USA national grid [28]. “A Survey of Cyber Security Management in Industrial Control Systems (ICS)” [132] advocates for cyber security in the Energy Industry.

> Cybersecurity became a major issue for the energy industry in the last few years because it is a high value industry [target by attackers [133] because of the industry’s] deep pockets. Energy is [also] targeted by hostile parties because modern society requires it and opposition parties want to destroy their enemies. Through the internet and other interconnected technology [the] means [for] attacks can be done remotely [28].

As discussed and shown previously the attacks on energy related organizations continues yearly.

2.3 Stakeholders

There many stakeholders for Critical Infrastructure (CI). The U.S. Department of Homeland [Security] has several projects and programs related to energy cybersecurity and standardization [53]. The Interagency Security Committee (ISC) is a DHS-chaired organization comprised of 54 member agencies that is housed within the Office of Infrastructure Protection (IP) and is responsible for establishing policies for security in, and protection of, buildings and facilities in the United States occupied by federal employees for nonmilitary activities [134]. NIST is part of the US Department of Commerce. NIST is one the most prolific standards entities and is well known for Special Publications (SP) series: 500, 800, 1800, and Interagency Reports (IR's). NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems [135]. Standards are a published set of rules or behaviors that everyone can use to get to a base level of security. These guidelines, standards, methods, and technology to address cybersecurity concerns receive constant attention [136].

A lack of interagency communication creates a trust and awareness gap. Thus, there are two criteria in the HDM model that check for communications (external reporting and vendor/supply coordination). European Union (EU) member's (similar to USA states) communication is legislated in the Network and Information Security (NIS) 2 Directive [137] which is the corollary to USA FISMA legislation. The Directive directs

EU member states to work together. In USA government communications are driven by Computer Security Incident Response Team (CSIRT) and Computer Emergency Response (or Readiness) Team (CERT) Security Operations Center (SOC) Information Sharing and Analysis Center (ISAC) requirements and agreements. If there is a lack of communication it is likely that there is no requirement or agreement in place, or enforced, that ensures safety and security of participants.

> The industry relies on Incident Response Plans [IRP] for outages. IRP's address people, process, and operations procedures (but not necessarily with security in mind of restarting operations). Technical aspects are left to the experts, in the moment, to decide what's most important based on any scenario [26].

In the USA military:

> In 2010 the United States established a dedicated military unit—the United States Cyber Command—to defend against cyber threats to military infrastructure. Its mission was expanded in 2015 when the Department of Defense's (DoD) Published its second Cyber Strategy to guide the development of DoD cyber forces [138].

Another stakeholder, the IEEE Computer Society Technical Committee (TCSP) on Security and Privacy's goal is to foster excellence in computer security and privacy research. They coordinate five industry conferences annually [53]. The United States Senate Committee on Armed Services Subcommittee on Cybersecurity also addresses the Energy sector and its related industries [139]. In addition states have committees [140]

and task forces [141]. Beyond Oregon and California: Colorado, Maryland, Michigan, Virginia and Illinois are additional leaders in State cybersecurity [53].

Readiness (aka pre-planning prevention) and communication can decrease the cost to the organization while minimizing disruption and increasing usefulness [28] of the response. Communication also creates trust between partners. “Incident response plans are not enough to be fully comprehensive [in a cybersecurity] posture towards resiliency” [142]. Thus, other criteria must be considered for a readiness application.

2.4 Existing Quantitative Models

2.4.1 Structural Equation Models (SEM)

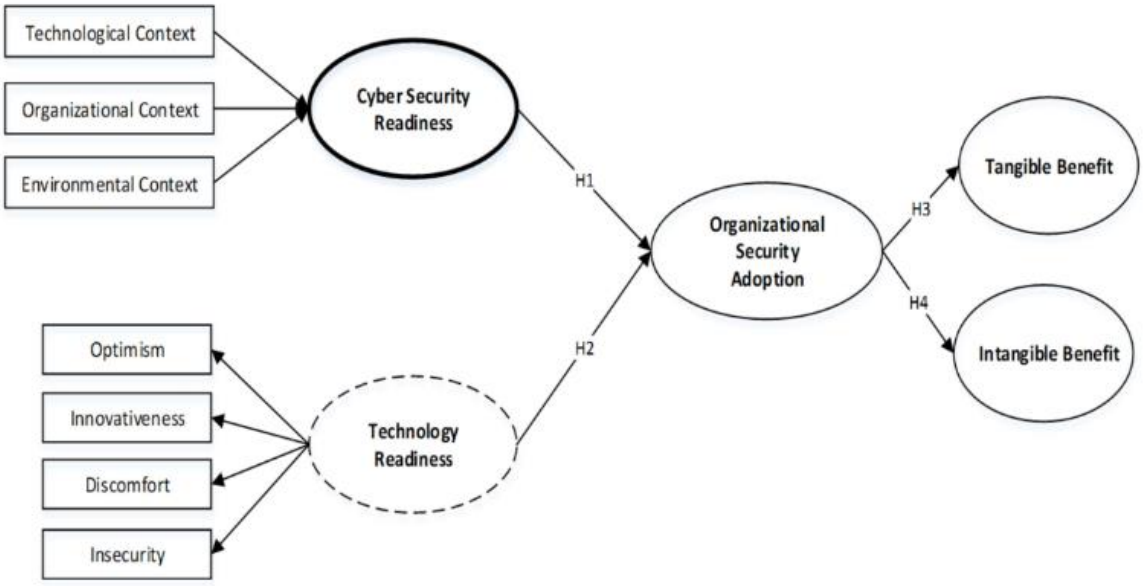
The articles: “Organization Benefit as an Outcome of Organizational Security Adoption: The Role of Cyber Security Readiness and Technology Readiness” [39] and “Evaluating the cyber security readiness of organizations and its influence on performance” [87] are Structural Equation Models that have been built for Readiness for Cybersecurity in the Energy Industry. These models are discussed below.

2.4.1.1 Organization Benefit as an Outcome of Organizational Security Adoption: The Role of Cyber Security Readiness and Technology Readiness

The model breaks Readiness into two perspectives Cybersecurity and Technology and cybersecurity specifically into three variables technology, organizations, and environment [39]. The model attempts to quantify performance based on readiness at a high level to understand the factors that affect readiness. The model does not elaborate downward to the criteria level. The authors state that that takeaway is “readiness and

technology have a positive impact on organizational security performance which in turn has tangible and intangible benefits" [39].

Figure 8 – Structural Equation Model (SEM) Research Model



Note: Taken from Berlilana, T. Noparumpa, A. Ruangkanjanases, T. Hariguna, and Sarmini, "Organization Benefit as an Outcome of Organizational Security Adoption: The Role of Cyber Security Readiness and Technology Readiness," Sustainability, Dec 13 2021.

2.4.1.2 Evaluating The Cyber Security Readiness Of Organizations And Its Influence On Performance

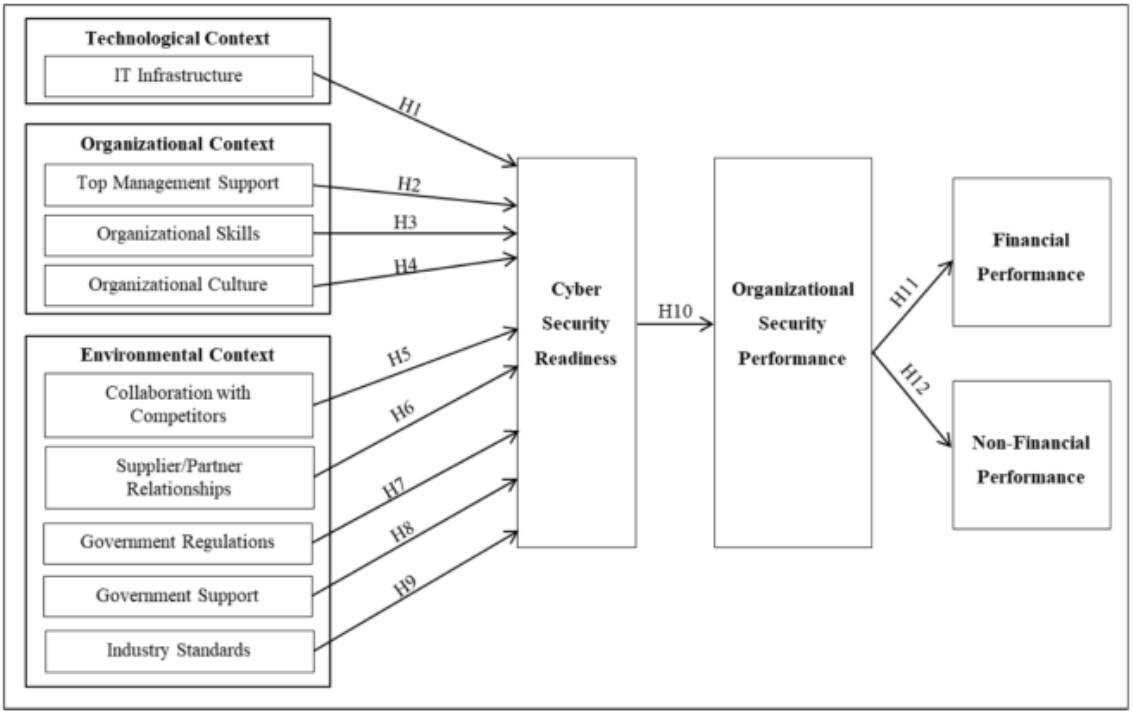
This article in the Journal of Information Security and Applications is an Australian and Malaysian authored paper [87]. This article uses a Technology and Organization and Environment (TOE) framework. People, processes, and technology are considered the core elements of Cybersecurity by the authors based on their research. Takeaways comes from a literature review factor and theory categorization table. The

authors note that Cybersecurity's impact on performance (decreasing breaches, reputation concerns, processes, capabilities, and capacities) has not been empirically tested. A holistic theory of Cybersecurity on organizations has not been realized.

16 papers theories were identified as the most critical to the TOE framework. Institutional Theory; Game Theory; Deterrence Theory (GDT) abuse, passive and active restrictions and punishment; and other theories including Balanced Scorecard are discussed. Based on the 16 theories nine factors were identified and incorporated into the aforementioned TOE inspired categorization table. Next a visual model was created based on, if greater than or if the existence of, a control then the overall model/hypothesis calculation for readiness is higher.

A discussion for each hypothesis is included. A Kingdom of Bahrain survey validated the model by experts, and a statistical analysis reviewed the arrowed relationships. The study found that management, standards, and partner relationships are the most important factors to readiness in Cybersecurity.

Figure 9 – Cybersecurity Readiness Model Based on Hypothesis



Note: Taken from S. Hasan, M. Ali, S. Kurnia, and R. Thurasamy, "Evaluating the cyber security readiness of organizations and its influence on performance," Journal of Information Security and Applications, vol. 58, p. 102726, Feb. 4 2021.

2.4.2 Factors Affecting Perceptions of Cybersecurity Readiness Among Workgroup IT Managers

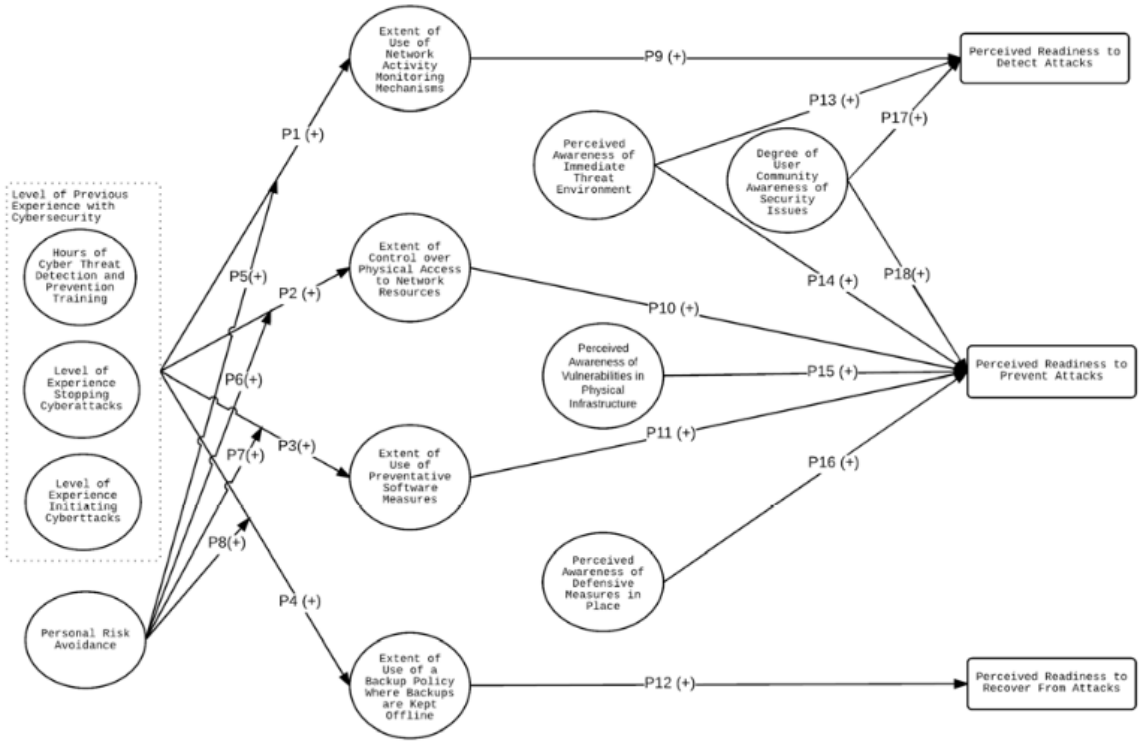
This PhD Dissertation, at the University of Mississippi in the USA, studied managers factors of: experience, best practice, network infrastructure, and education of their user community (which was added as an additional factor to the model during implementation based on manager concerns of lack of control) [91]. The author notes that research on universities vis-à-vis their own cybersecurity internal practices is limited. A survey was conducted to these managers at universities and statistical analysis was done to validate the authors Practice and Awareness Cybersecurity Readiness Model (PACRM). The reliability of the sample was verified with Cronbach's Alpha (which is

a .70, aka 70%, threshold for raters for the measure reliability and is thus considered a good/valid question model). The model drew on previous Information Systems models such as Goodhue's and Straub's research on centralized/top management managerial concerns.

PACRM is a statistics model. Theory of Planned Behavior (TPB) about types of beliefs (such as belief in compliance or not) is implemented into the author's model, and references Self-Efficacy Theory (SET). Viruses and Defense-in-Depth are discussed as concerns for IT managers. The PACRM is correlated to the Center for Internet Security (CIS) controls. Metrics/Measurements for each factor in the model are provided by Chapman. This was an exploratory study with limited observations (135 IT Managers), so it is not a full structural equation model. Path analysis was used instead, averaging out paths, but only a handful of the paths shown (regression) in the model were supported. Meanwhile 11 of the 21 hypotheses were supported (some not shown in the model paths) according to the author.

Overall, the survey asked managers if they were experts, which is a self-efficacy theory idea, and then tried to correlate findings. PACRM is processed in Statistical Package for the Social Sciences (SPSS). R-squared and chi-squared are used for Confirmatory Factor Analysis (CFA), and model validity.

Figure 10 – Chapmans PACRM Detect, Prevent, Recover Model and each Proposition/Hypothesis Link/Path



Note: Taken from T. A. Chapman, "Factors Affecting Perceptions of Cybersecurity Readiness Among Workgroup IT Managers," Doctor of Philosophy in Business Administration, Management Information Systems, University of Mississippi, 2018.

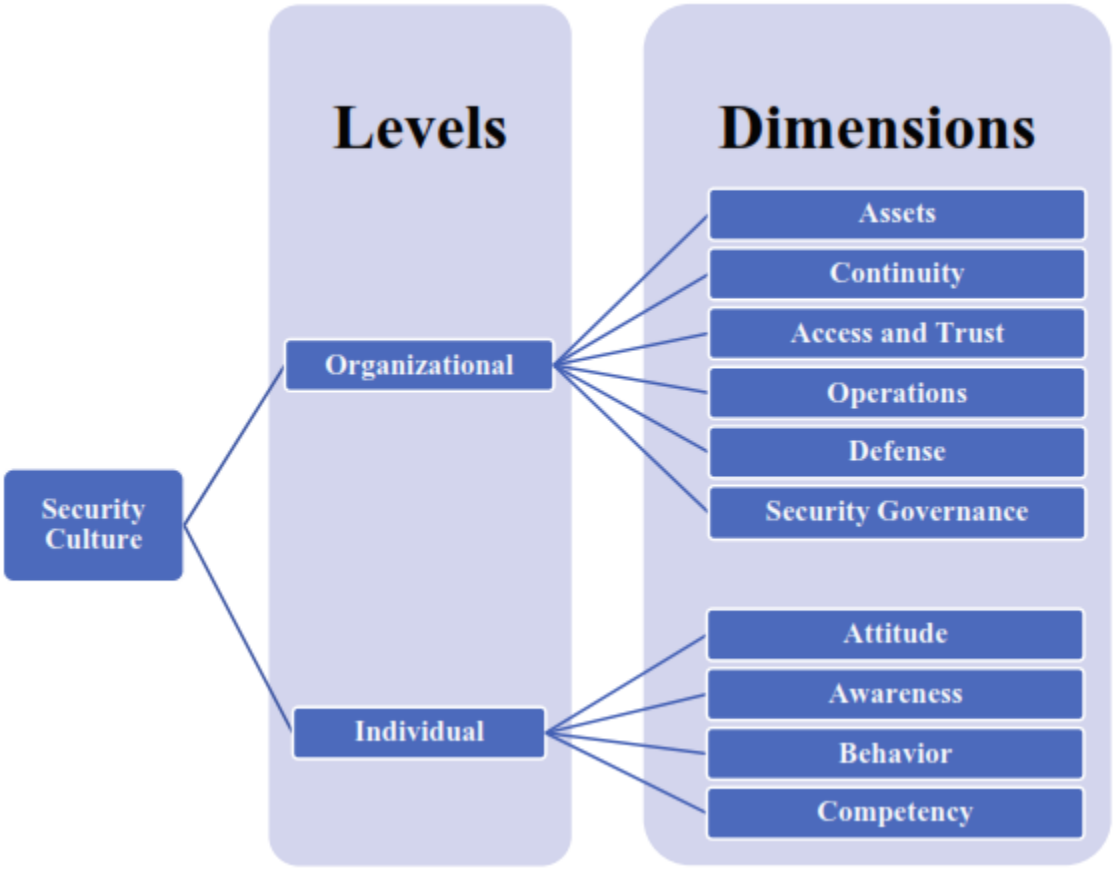
2.5 Existing Qualitative Models

2.5.1 A Cyber-Security Culture Framework for Assessing Organization Readiness

The model is focused on readiness of workforce (i.e., human related) from a cultural perspective of an organization [1]. The culture is analyzed in the model from an individual's perspective and from an organizational perspective. Unfortunately, the model fails to identify how quantification might be handled by saying: "Individuals are

invited to participate in different campaigns by fulfilling questionnaires, running simulations and serious gaming."

Figure 11 – Cyber-Security Culture Model



Note: Taken from A. Georgiadou, S. Mouzakitis, K. Bounas, and D. Askounis, "A Cyber-Security Culture Framework for Assessing Organization Readiness," Journal of Computer Information Systems, vol. 62, pp. 452-462, 2020.

2.5.2 A Conceptual Model For Digital Forensic Readiness

In this University of South Africa conference paper, a literature review was conducted to create a forensic readiness model though identifying gaps [143]. The paper studied the impact of fraud/white collar crime on organizations. As forensics exist across

networks this paper tries to bring previous forensic research into one conceptual model. The authors created data tables to present the information found from seven university databases from articles written after 2002 when the SA cybersecurity law was put into place.

The authors used interrater reliability (Cohens Kappa) which counts a record when two or more people independently observe the same behavior. Creating a dump/bitstream of an image (which is hashed) is one method used. Live/fast forensics are time based in the first few hours of when an investigation begins (usually on-site). Dead analysis is used with only the software that was originally on the machine when the event occurred. A boot disk can be used but makes changes to the running system (memory and disk). A running system snapshot is called blurry because it is making changes while the image is being created (so is less permissible in court).

The model is a quad chart which puts: people, process, policy, and technology into quadrants as the overarching perspectives with proactive and reactive activities assigned to each quadrant. In addition, the paper lists steps that are appropriate for incidents. For example, an Incident Response Plan (IRP), an Incident Response Team, a forensic methodology, policy plans, appropriate technology appropriate resources/standards for awareness and hardening. Technology includes Intrusion Detection Systems (IDS) which detect and alert, and Intrusion Prevention Systems (IPS) which detect, prevent, and correct.

2.5.3 A Generic Digital Forensic Readiness Model For BYOD Using Honeypot Technology

This African conference paper proposes honeypots to attract, harvest, and encrypt evidence for legal proceedings of a security incident. Bring Your Own Device (BYOD) decreases end user computing distributed costs. The increased interconnectivity has made organizations accept BYOD as an alternative to providing work machines.

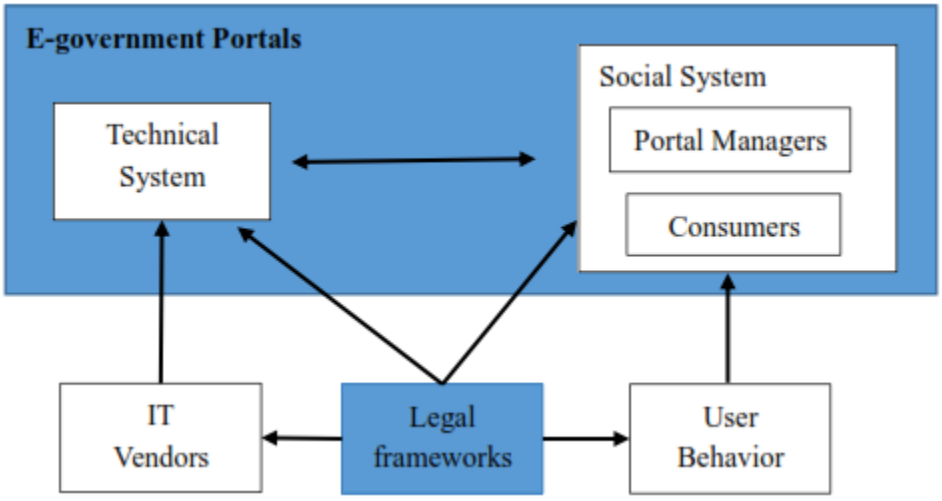
International Organization for Standardization (ISO) 27043 “classes of evidence” are referenced. Protecting and investigating data are discussed. A honeypot is a decoy machine that if hit sends an alert, and/or collect information, to be sent to the computer administrator. The model creates an Object-Oriented generic proactive approach/model to manage users in the environment. Pre-incident planning is discussed to reduce cost. Internet Protocol (IP) packet logging for preservation is proposed. A sequence of execution of deploying, gathering, and hashing is proposed to enhance investigations, and environments using BYOD.

2.5.4 A Socio-Technical Analysis Of China's Cybersecurity Policy: Towards Delivering Trusted E-Government Services

A paper presented at the Research Conference on Communications, Information, and Policy (TPRC) discusses, and outlines the provision’s China’s 2016 Cybersecurity Law [144]. The paper investigates e-government (considered critical information infrastructure (CII) by the authors based on the Cyberspace Administration of China (CAC) definition) service’s usage and impact on users based on a social technical systems (STS) theory. Legal, technical, managerial, and human elements are analyzed with a focus on comparing social vis-à-vis technical and show that legal concern is most

important factor to both in e-government China. Expert (10+ years in government) semi-structured interviews were done to identify these impacts and make the model.

Figure 12 – China e-government conceptual model



Note: Take from H. Zhang, Z. Tang, and K. Jayakar, "A socio-technical analysis of China's cybersecurity policy: Towards delivering trusted e-Government services," in TPRC, 2017.

The Technology Acceptance Model (TAM) is referenced as a source to gauge whether users will actually use the product. Overall, expectations of users were reviewed from prior literature. The literature review findings were categorized into a table with each domain: technical, perception of government, trust, and safety further broken down into further dimensions associated with each such as risk, usefulness, etc. Although the law is in place there is no money for actual oversight in local jurisdictions in China.

2.5.5 Adoption Of Cybersecurity Capability Maturity Models In Municipal Governments

This Master's thesis was written for a Canadian university [145]. Data about Cybersecurity practices from Canadian municipalities (including but not limited to energy) is gathered using surveys. The surveys were validated with expert advice. Capability Maturity Models (CMM) were reviewed but were noted as not pertaining to municipalities' critical infrastructure. Rogers Diffusion of Innovation, and its references to consequences, good and bad, on parties involved was used as a baseline format to build a Cybersecurity Capability Maturity Model (CCMM), based on International Organization for Standardization (ISO) 27000 domains. The hope of the paper is to increase diffusion of the CCMM into local governments.

CMM's measure progress, usually through self-assessments, towards a target state. Resiliency and Security CMM's that currently exist are listed. International Organization for Standardization (ISO's) provide prescriptive standards whereas a CMM would not. CMM can be used to implement/mitigate controls. CMM's however lack specificity needed for action. After the surveys were conducted Analysis of Variance (ANOVA) and chi-squared cluster (good fit - that is, a valid variable for any data statistic) analysis tables were calculated to show improvement possibilities by using a CMM. The author also tested if CMM's are deemed beneficial and the answer was yes.

2.5.6 ICS Testbed Tetris: Practical Building Blocks Towards a Cyber Security Resource

This paper proposes a high-level model/reference architecture for Industrial Controls Systems (ICS) testing environment [70]. The testing environment could be

virtual or physical. A survey was conducted to provide and create the reference model. ICS models at the device level are prescriptive and not generalizable thus the model only creates oversight layers (for engaging a testing strategy). A discussion of devices categories and concerns is provided.

The Purdue model is used as a comparative model to the ICS Testbed model. Like the Purdue model not every level is needed in every environment. A testbed is protected from unauthorized disruption. Layers (e.g., environment, experimental, user) and bridges are the terms used for the model. Safety and security are considered in all parts of the model. In a testbed a single tunnel or access point is recommended for each internet connectivity level.

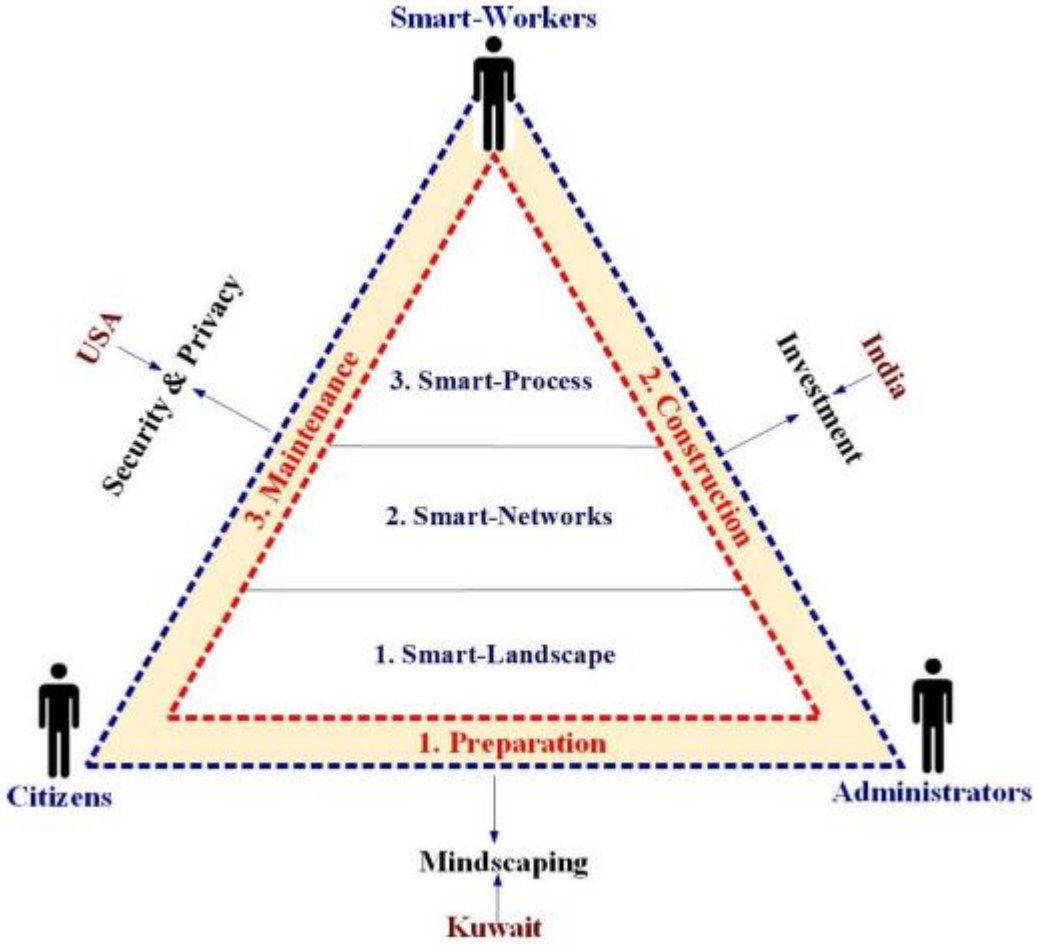
2.5.7 Internet of Things & Cybersecurity Readiness in Smart-government and Organizations

This Kuwait Master's thesis discusses IoT in cities [89]. Measurement is done through a survey, in India, USA, and Kuwait, of IoT usage and performance. The author states that Closed Circuit Television (CCTV) is a staple for any city to be smart. Economy, mobility, and governance are common categories for smart city measurements. The smart government philosophy is related to open sharing of information and e-data processing.

This paper's model recognizes phases: preparation, construction, and maintenance. The challenge, the author states, is infrastructure investment in these phases. Embedded systems/IoT are terms created by Massachusetts Institute of

Technology (MIT) and Cisco Systems over the years of computer history. IoT is still considered a new technology.

Figure 13 – Readiness in Smart-government and Organizations



Note: Taken from A. AlEnezi, "Internet of Things & Cybersecurity Readiness in Smart-government and Organizations," Master's Degree in Information Technology, Information Technology, Kuwait University, 2020.

Additionally, statistical analysis, that is social science (a small sample dataset structural equation model) was conducted. Conducted from the survey in order to look at relationships between the answers based on Likert scale readiness answers (looking for

statistical significance). Investment, compliance, and risk were found correlated to cybersecurity readiness.

2.5.8 Mobile Cloud Forensic Readiness Process Model for Cloud-Based Mobile Applications

This article from India discusses the peculiarities for mobile and cloud [146]. Cloud severs and systems allows global mobile demands to scale easily. The forensic process takes place after an incident has taken place. Digital, smartphone, mobile, and cloud models, and conceptual frameworks already have existed. Because forensics it is a costly and time-consuming process readiness work is justified.

The author's model/framework is based on business goals and objectives which are a little different than, but relies heavily on, the legal only goals of other model and frameworks. Integrity, reliability, completeness, and admissibility are important concerns of forensics readiness. The device and the cloud system/database (i.e., the Cloud Service Provider "CSP") have to be correlated (often a keeping the correct time/date stamp concern) to provide the complete infrastructure-based evidence if needed for the investigation. The contract (aka Service Level Agreement "SLA") is important to obtaining the CSP concurrence. The CSP also has to be willing to work with the investigator. The author's output was a sequence diagram (aka a workflow) for the investigation process.

2.5.9 Towards verifiable evidence generation in forensic-ready systems

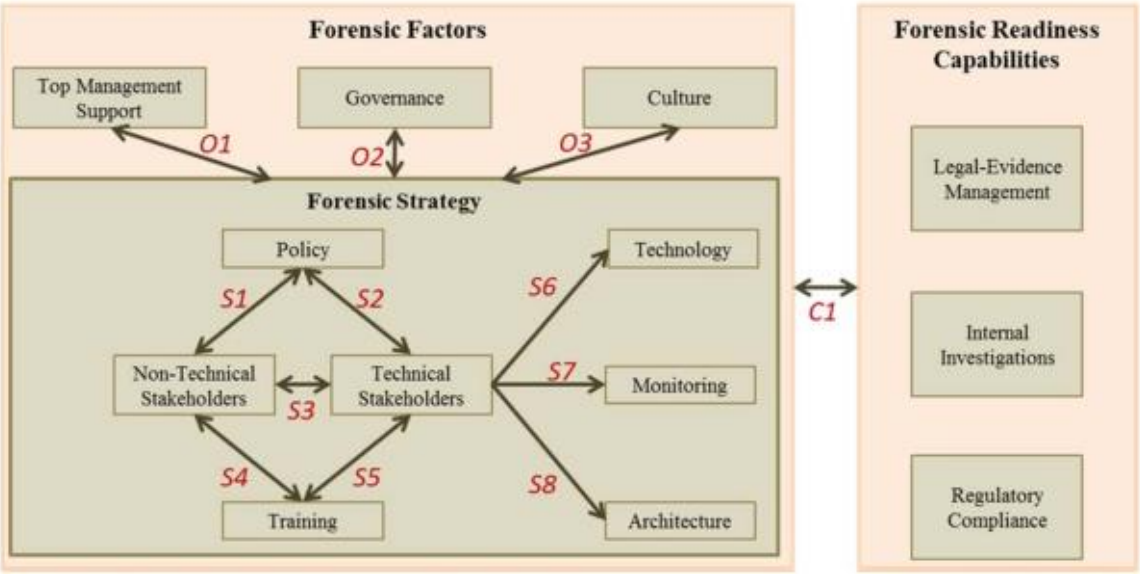
This IEEE conference paper proposes a workflow process, based on a roadmap, for digital evidence from software systems [147]. Syntax, Semantic (knowledge if A

affects or answers B), quality (timestamps, chain of custody, etc.) being followed, and handling data so it's "not dirty." The model can be used for attacks and/or failures of systems and software. Trusted evidence like an airplanes black box except for an organization is the goal of this paper thesis.

2.5.10 Towards a Systemic Framework for Digital Forensic Readiness

This journal article by University of Melbourne Australia authors write about organizational forensic readiness [148]. The framework is based on a Literature Review. Each factor (including those in strategy) is explained in detail. The pre-published version referenced is theoretical and was not empirically tested.

Figure 14 – Organizational Forensic Readiness Model for Digital Evidence



Note: Taken from M. Elyas, S. B. Maynard, A. Ahmad, and A. Lonie, "Towards a Systemic Framework for Digital Forensic Readiness," Journal of Computer Information Systems, vol. 54, pp. 97-105, January 2014.

2.6 DOE's Use of the Term Readiness

Readiness is defined differently throughout literature. Readiness can be a threat level, sometimes it is a technology level, sometimes it's an implementation ability, sometimes it's a maturity of an organization. The science and technology, program management, and systems engineering communities each view technology readiness through their own lenses [149].

Readiness activities impact areas of personnel (e.g. training, proficiency, numbers), equipment (safety and process systems), and safety management programs (e.g. safety basis implementation, operational formality, maintenance, Integrated Safety Management (ISM), quality) [28]. Implementing readiness activities can guide organizational improvements by being prepared.

Readiness reviews are required by DOE Order 425.1D and are grouped into two types: Operational Readiness Reviews (ORR) and Readiness Assessments (RAs). The DOE Handbook 3012 is a detailed listing of work schedules, duties, and meeting that are part of a readiness review. Both ORR and RA have their own needs. For example, ORR requires assessments, training, interviewing, verification, and integration. Readiness reviews require assistance, contractor reviews, and interfaces with different governmental groups [150]. The main difference between an ORR and an RA involves the scope of the review [79]. A Readiness Assessment (RA) is a review that all requirements were met. Each RA report must contain a lessons-learned section, as required by DOE Order 425.1D. It may also contain a systems assessment and critical infrastructure information as detailed in NNSA SD 205.1 Baseline Cybersecurity Program [151].

Readiness is a facilitated process which aims to remove severe consequences proactively [26]. The Department of Energy (DOE) states that readiness is not needed if technology is already demonstrated or if project is purely for science (scientific principles) with no application to implementation/production [152]. Readiness has a goal to decrease the cost while minimizing disruption [153] and increasing usefulness [153]. Other words for readiness are: posture, preparedness, adoption. The relationship between risk and cybersecurity activities refers to the level of preparedness [45]. Preparedness becomes posture which is then measured in a maturity model/assessment [28]. Posture is the security status based on information assurance resources and capabilities to manage defense and to react to changes [154]. The Readiness lifecycle touches on all areas of organization and operation, preparedness and posture.

Readiness applies to the areas of personnel (e.g. training, proficiency, numbers), equipment (safety and process systems), and safety management programs (e.g. safety basis implementation, operational formality, maintenance, Integrated Safety Management (ISM), quality) [79]. The need for safety while meeting system operational requirements drove these early readiness reviews.

DOE standard 1189, integration of safety into the design process, has been influential in providing readiness language. Definitions of risks and opportunities become an input to readiness model building. The US Department of Energy has adopted the National Aeronautics and Space Administration (NASA) (and also used by Department of Defense “DoD”) Technology Readiness Assessment. The DoD also uses the term readiness in relation to inspections and testing [155]. Technology Readiness Levels

(TRL) was originated by NASA to monitor the development of systems being readied for space…; now TRL is being applied to the smart grid [156]. “The TRL scale ranges from 1 (basic principles observed - theoretical) through 9 (total system used successfully in project operations - operational)” [152]. Levels 1 to 4 are for basic development and levels 5 to 9 are for demonstration and deployment phases.

Figure 15 – Department of Energy (DOE) Technology Readiness Assessment (TRA) with TRL

Relative Level of Technology Development	Technology Readiness Level	TRL Definition	Description
System Operations	**TRL 9**	Actual system operated over the full range of expected mission conditions.	The technology is in its final form and operated under the full range of operating mission conditions. Examples include using the actual system with the full range of wastes in hot operations.
System Commissioning	**TRL 8**	Actual system completed and qualified through test and demonstration.	The technology has been proven to work in its final form and under expected conditions. In almost all cases, this TRL represents the end of true system development. Examples include developmental testing and evaluation of the system with actual waste in hot commissioning. Supporting information includes operational procedures that are virtually complete. An Operational Readiness Review (ORR) has been successfully completed prior to the start of hot testing.
	TRL 7	Full-scale, similar (prototypical) system demonstrated in relevant environment	This represents a major step up from TRL 6, requiring demonstration of an actual system prototype in a relevant environment. Examples include testing full-scale prototype in the field with a range of simulants in cold commissioning[1]. Supporting information includes results from the full-scale testing and analysis of the differences between the test environment, and analysis of what the experimental results mean for the eventual operating system/environment. Final design is virtually complete.
Technology Demonstration	**TRL 6**	Engineering/pilot-scale, similar (prototypical) system validation in relevant environment	Engineering-scale models or prototypes are tested in a relevant environment. This represents a major step up in a technology's demonstrated readiness. Examples include testing an engineering scale prototypical system with a range of simulants.[1] Supporting information includes results from the engineering scale testing and analysis of the differences between the engineering scale, prototypical system/environment, and analysis of what the experimental results mean for the eventual operating system/environment. TRL 6 begins true engineering development of the technology as an operational system. The major difference between TRL 5 and 6 is the step up from laboratory scale to engineering scale and the determination of scaling factors that will enable design of the operating system. The prototype should be capable of performing all the functions that will be required of the operational system. The operating environment for the testing should closely represent the actual operating environment.
Technology Development	**TRL 5**	Laboratory scale, similar system validation in relevant environment	The basic technological components are integrated so that the system configuration is similar to (matches) the final application in almost all respects. Examples include testing a high-fidelity, laboratory scale system in a simulated environment with a range of simulants[1] and actual waste[2]. Supporting information includes results from the laboratory scale testing, analysis of the differences between the laboratory and eventual operating system/environment, and analysis of what the experimental results mean for the eventual operating system/environment. The major difference between TRL 4 and 5 is the increase in the fidelity of the system and environment to the actual application. The system tested is almost prototypical.

Technology Development	**TRL 4**	Component and/or system validation in laboratory environment	The basic technological components are integrated to establish that the pieces will work together. This is relatively "low fidelity" compared with the eventual system. Examples include integration of ad hoc hardware in a laboratory and testing with a range of simulants and small scale tests on actual waste[2]. Supporting information includes the results of the integrated experiments and estimates of how the experimental components and experimental test results differ from the expected system performance goals. TRL 4-6 represent the bridge from scientific research to engineering. TRL 4 is the first step in determining whether the individual components will work together as a system. The laboratory system will probably be a mix of on hand equipment and a few special purpose components that may require special handling, calibration, or alignment to get them to function.
Research to Prove Feasibility	**TRL 3**	Analytical and experimental critical function and/or characteristic proof of concept	Active research and development (R&D) is initiated. This includes analytical studies and laboratory-scale studies to physically validate the analytical predictions of separate elements of the technology. Examples include components that are not yet integrated or representative tested with simulants.[1] Supporting information includes results of laboratory tests performed to measure parameters of interest and comparison to analytical predictions for critical subsystems. At TRL 3 the work has moved beyond the paper phase to experimental work that verifies that the concept works as expected on simulants. Components of the technology are validated, but there is no attempt to integrate the components into a complete system. Modeling and simulation may be used to complement physical experiments.
Basic Technology Research	**TRL 2**	Technology concept and/or application formulated	Once basic principles are observed, practical applications can be invented. Applications are speculative, and there may be no proof or detailed analysis to support the assumptions. Examples are still limited to analytic studies. Supporting information includes publications or other references that outline the application being considered and that provide analysis to support the concept. The step up from TRL 1 to TRL 2 moves the ideas from pure to applied research. Most of the work is analytical or paper studies with the emphasis on understanding the science better. Experimental work is designed to corroborate the basic scientific observations made during TRL 1 work.
	TRL 1	Basic principles observed and reported	This is the lowest level of technology readiness. Scientific research begins to be translated into applied R&D. Examples might include paper studies of a technology's basic properties or experimental work that consists mainly of observations of the physical world. Supporting Information includes published research or other references that identify the principles that underlie the technology.

Note: Taken from Department of Energy, "Technology Readiness Assessment Guide," Office of Management, Ed., ed. Washington, DC: US Department of Energy (DOE), 2011.

Note 2: Highlights are the authors.

DOE technology or engineering uses a “graded approach” which means the process used depends on the level of analysis, document, and actions necessary to complete the project requirements. Or to say it in cyber language a graded/risk approach means that we defend each level with the best defenses we can. Technology Readiness Level (TRL) is used for planning future program requirements [157], from research beginning through to successful operation. This tailored example used the term Data Readiness Levels (DRL) are “seven graded definitions (0-6) of data quality and data maturity. Unlike Technology Readiness Levels (TRL), DRL’s are augmented with metadata qualifiers that enable further assessment, reproduction, or use of the data by others” [158]. Tailoring is useful thinking for HDM model building.

In engineering projects, Technology Readiness Assessments (TRA) readiness is about technical strengths and weaknesses. TRA’s are used to evaluate and monitor the maturity of critical technologies [149]. A TRA assessment measures how far the technology development has proceed based upon documented evidence [152]. The Department of Energy (DOE), Office of Environmental Management, requires that TRA’s and technology maturation plans (TMP) be conducted for major capital projects where new critical technologies are being developed prior to Critical Decision 2 (the third governmental stage gate where 90% of planning has been done) [152]. The TMP is where a gap is identified usually after stage gate 2 (aka Critical Decision 2).

2.7 Analysis

Overall, the current modeling literature theme is that of identifying findings and then creating workflow models in order to identify a pathway in order to prevent an attack. In addition, sometimes statistical methods are being used based on historical attack patterns. Another approach is to identify high level areas to address. The weaknesses of these model are that they are using historical data that is not tailored to the energy industry.

During the literature review 13 previous model papers were found (ten qualitative and three quantitative with two of the quantitative Structural Equation Models (SEM). The SEM models with quantitative variables were discussed above. Unfortunately, the non-MCDMA readiness models (also described above) do not capture a systems recovery aspect, which is a focus of readiness due to readiness's child relationship to resiliency. The quantitative approaches are referenced below.

Table 3 – Existing Quantitative Approaches

Statistical Structural Equation Models (SEM) • Berlilana, T. Noparumpa, A. Ruangkanjanases, T. Hariguna, and Sarmini, "Organization Benefit as an Outcome of Organizational Security Adoption: The Role of Cyber Security Readiness and Technology Readiness," Sustainability, Dec 13 2021. • S. Hasan, M. Ali, S. Kurnia, and R. Thurasamy, "Evaluating the cyber security readiness of organizations and its influence on performance," Journal of Information Security and Applications, vol. 58, p. 102726, Feb. 4 2021.
Covariance Approach using Cronbach's Alpha • T. A. Chapman, "Factors Affecting Perceptions of Cybersecurity Readiness Among Workgroup IT Managers," Doctor of Philosophy in Business Administration, Management Information Systems, University of Mississippi, 2018. • A. Terminato, A. N. Hidayanto, and W. Nugroho, "Measurement of Readiness Levels for Adoption of Enterprise Resource Planning Clouds in Small Medium Enterprise with Net Ready Model," Journal of Computational and Theoretical Nanoscience, vol. 16, pp. 5396-5407, 2019.

Note: The "Measurement of Readiness Levels for Adoption of Enterprise Resource Planning Clouds in Small Medium Enterprise with Net Ready Model" is an

approach not included in the initial Literature Reviews. This model addresses security aspects of cloud models.

The overall Cybersecurity Readiness in the Energy Industry literature research revealed areas where there are gaps and concerns. These findings discussion identifies areas where areas of high risk can be focused. Most of these cybersecurity criteria have cross-cutting (aka overlap) with other criteria.

There is a concern with change management is that it is not considered. That is, there is no monitoring for changes to the network [159]. A change must be authorized. Change management and configuration management are mostly the same type of work covered by the same resources. A configuration management plan defines: naming conventions, version control system, and document storage and retrieval system. Scope changes need to have a constraint/impact assessment against: quality, risk, schedule, cost, resources, and customer satisfaction. When changes are not logged using a configuration management system then the project or program becomes out of control. Thus, there is a security gap as no one is aware of the current state of vulnerability. Changes that can lead up to vulnerabilities include but are not limited to: Baseline incorrect, Baseline update exceeding 30 days, missing security controls testing evidence, monitoring exceeds a 35-day requirement, pre/post Implementation results not captured, and unauthorized changes taking place [160]. Test plans should be used to verify the baselines.

Settings and permissions are part of a defense in depth strategy. Line managers exercise due care to be in compliance with controls. If line management does not understand what each staff person needs to know (their profiles) [91] then overprivileged

settings may occur which can lead to breaches of data either from insiders or outsiders. A rudimentary Access Control Matrix (ACM) can be used. Line managers are verifying information access formally and informally during normal business conversations. The manager should be able to identify when a privilege, at a high level, is likely necessary or unnecessary. Data owners validate who is on the access list, whereas a system administrator would do the technical work of entering the permissions on the server. One way to harden systems is to make sure that usernames are non-descriptive such that admin usernames are renamed to something else so as to make attackers jobs harder in identification of privileged accounts. In order to mitigate this threat, the organization and management must develop and review security requirements on a regular basis [89]. User settings and permissions are at the crux of cybersecurity practices, and need to be tested [87]. Having the correct permissions set ensures organizational performance.

If staff doesn't thoroughly understand the difference between good and bad cyber behavior there may be rogue access points for Wi-Fi or clicking on malicious links that steal cookies that create a man in the middle browser attack. Not checking cyber awareness with staff leads to vulnerable employees, which leads to a vulnerable organizations computer systems and data. You understand the difference between good your team should understand bad cyber behavior [100].

Organizational goals must be updated to ensure that the strategy is met. With updated controls in place [145] you ensure continued viability. When new technology complexities arise training [87] and requirements need to be updated. A dashboard for

security status (e.g., people, processes, and technology) [62] is a great way to keep on top of goals of the organization's security because it keeps security top of mind.

Advanced Persistent Threat (APT) of nation state actors and/or organized crime is a concern that users should be aware of so that they understand the risk. Terror is also an important risk to consider [161]. Often, smaller organizations are breached in order to get "keys" to larger organizations. Security resources should be made available to staff [162]. During and after training security awareness improvements should be documented [62]. When staff doesn't understand policies and practices [25] they are unprepared to take action when an incident occurs. Periodic training on new issues must be done. [87]

CISA has Executive Skilling and Cyber Essentials classes for workforce training of Cybersecurity Readiness [163]. The Naval Research and Development Establishment (NR&DE) has a Cybersecurity Readiness Facility (CREF) at the Naval Information Warfare Center (NIWC) where they utilize SME's to train the trainer on information warfare [164]. The US Army also has a Combat Readiness Center. These are practical readiness examples demonstrated.

In order to minimize disruption [45] to the organization and increase usefulness [153] of organizational assets: behaviors, practices, processes, controls, trainings, detections, and responses must be assessed [25]. If no quantitative rating through assessments, such as a survey and checklist [89], then the organization is likely missing controls and no integration of cybersecurity with the rest of operations. In the assessment the organization needs to incorporate both assets and data [165]. A simple checklist for sufficiency can ask: have you analyzed if audits are done are effectively [56], and do you

rate your cyber assessment methods annually [166]? The Institute for Internal Auditors (IIA) third line activities include “Evaluate IT assets of users with privileged access for standard security configurations, problematic websites, malicious software, and data exfiltration” [154].

Data Loss Prevention (DLP) systems [25] are inherently complex. DLP is a text matching search engine that looks for string and filetypes in egress/outbound information on the network and on disk. A DLP would block or alert if sensitive data is disclosed through unauthorized means. DLP is useful if you have critical information such as the energy industry (if not it is burdensome to maintain for small organizations without time and money). DLP systems are big in scope: logging, malfunctioning, forensics, threats, retention, reporting, and cloud are all included. Evidence retention is important after an event in order to prosecute and attribute for renumeration. Information Security Management System (ISMS) [165] can take the place of a DLP system. Prevention and detection, if included in a DLP means that the organization has a system for threat management [167]. If your organization already prevent, detect, and combat attacks [87] then a DLP is likely in place or you have a kind of DLP system. Post-incident procedures [62] (aka response and recovery) are procedures for reporting and escalation [56] for incidents and should be written down.

Cloud information should be able to be isolated [146] based on segmentation. A cloud implementation is a way to limit scope of cyber compliance requirements; but visibility of all the infrastructure is limited as a cloud subscriber so use and observation of data are hard to monitor for with attacks like Cross Site Scripting (XXS), which is

often stealing cookies, and persistence attacks that enable shell and/or remote access [26]. These attack techniques, XSS and shells, were used in the Ukraine power industry attacks [26]. Cloud Security Posture Management (CSPM) takes into consideration the shared model of Cybersecurity controls [168] between vendor and purchaser.

Energy providers have sensitive documents that should be marked and protected. Attachments that have classified information should be stored separately on differently protected systems [161]. A contingency plan should be in place for energy system outages if the organization is without power for a prolonged period of time [56].

External reporting [165, 169] brings awareness, usually anonymously, through organizations like Electricity Information Sharing and Analysis Center (E-ISAC), which can then be escalated to organizations through Computer Security Incident Response Teams (CSIRT's). It is likely others will be attacked with the same measures. Sharing information on cybersecurity with your partners [161] is a way to keep a step ahead of criminals. An association to supervise cybersecurity [30] is another approach. Organizations need to consider leveraging external guidance obtained from Federal government departments and agencies, Information Sharing and Analysis Centers (ISACs), Information Sharing and Analysis Organizations (ISAOs), existing maturity models, or other sources to assist in determining their desired tier of compliance and responsibility [120]. From an ICS perspective the National Cybersecurity and Communications Integration Center (NCCIC) and the Industrial Control Systems Cyber Emergency Response Team's (ICS-CERT) jointly put out reports [170]. In 2013 ICS-CERT reported that 53% of incident response teams send out were to the energy sector

[171] which is remarkable since most of the 16 critical infrastructure sectors use Industrial Control Systems (ICS). Joining FBI's InfraGard is another way for private organizations and government agencies staff to get up to the moment information.

Finding a weak or complicit link in a supply chain vendor is an easy way to target a power system. Coordination of security information with other organizations [145] is thus important. The organization should be getting cybersecurity information updates [161] from the supply chain vendors. An Internet Service Provider (ISP) is a type of supply chain for internet. There should be communication about security between Chief Information Officer (CIO)/or delegate and the ISP. If the Information Officer and or IT department doesn't communicate, talk to, or in contact with Internet Service Provider [91] then the organization is at risk.

Logging insufficiency is the most limiting factor in cyber investigations [147]. Information must be retrievable and understandable by design [100]. Based on network size and scope you scoped your organization can determine what it is able to collect [62]. Logging is at the foundation of response and is a key question to ascertain if a cyber data loss prevention system exists. Check that the log time is protected (that is accurate time being logged in logs [172]), to correctly attribute egregious actions. Any valid testing platform would need to have "system clocks on all hosts synchronized" [173] for quality management. Timestamps of events must be recorded with certainty that the timestamp has not been tampered with [153]. Storage devices must also be protected [143] Logging can be rolled up into a larger DLP system.

Old ICS ladder logic software that is compatible only with older versions of Windows, or variants of Linux which have known unpatched vulnerabilities increase the Cyber risk to the energy industry. Limitations (network and system admin) on systems (hardware, software, IoT/embedded) must be formally documented [62] and vetted for best possible protection. Interconnected assets with information are shared across networks and systems [174]. This can lead to data leakage.

Subnetting is one way to isolate networked components which make it difficult to do many attacks on machines. When subnets are created then attackers must resort to trying to get credentials in other parts of the system in order to break through to that subnetwork in order to have access to the next group of machines. Critical infrastructure such as energy systems requires the highest security possible. Protocol traffic capture tools (aka sniffers) can capture and flag unknown traffic as potentially malicious. A baseline known good snapshot should be taken before putting machines into production. Center for Internet Security (CIS) Controls Benchmarks, DoD Security Technical Implementation Guides (STIGs) [,and the more limited NIST Common Configuration Enumeration (CCE)] are hardening guides which includes changing all default from factory settings [26].

All open source and/or propriety software should be documented with all the security limitations of those [62]. The IT interdependence between energy to power up/on the systems, physical access safety aspects, computer protocols and services, and emitters (aka radio frequencies and functional chemical makeup of hardware) creates several vectors of attack in a power system scenario [26]. Network interfaces should be hardened

[153] and configured for only serving on common ports and normal protocols unless an exceptional circumstance is documented. Any device or interface that is interconnected should be considered above a low risk by default [174]. Cybersecurity controls should be externally vetted and should be verified and validated [25].

IoT networks are often remote, physical systems that may operate on different vulnerable protocols like ZigBee. Non-Transmission Control Protocol/Internet Protocol (TCP/IP) networks need their own security model [175]. Mitigating access control varies depending on protocol and the embedded devices used. IoT logs should be backed up [62] just as any network connected computer. Visibility and control of cloud assets [62] is always a question that comes down to contracting quality. Evidence collection must be planned for separately for cloud providers as it may or may not be possible to gather evidence from a provider without cloud providers help [176]. Thus, cloud forensic inability is a concern and needs to be planned for.

Amazon Web Services (AWS) policies are one tool [177] to harden in the cloud. Also helpful is knowledge of practical understanding of basic encryption (xor) and Linux tools like (base64 and xxd), traffic viewing tools like tcpflow for .pcap files, and Strings command for .exe files or other operating system files.

Security updates should be able to be installed without taking a machine down [174]. Putting patches onto a system likely requires a restart that can take out critical Operational Technology (OT) systems. If work stoppage outages are needed for security processes to be run then continuous operation (which is a requirement for energy systems) is impossible. Systems can be brought down but there need to be spares (aka

redundancy) to enable continuous operation of the energy interconnection. Availability is a top priority for ICS, and there is a high cost of stopping production [173].

Industry guidelines should be used for digital evidence collection [148]. A key concept of forensics is the chain of custody which is the procedure and evidence handling which needs to be written down [62] for evidentiary planning and case building. Forensic readiness has three capability types: regulatory compliance, internal investigations, and legal evidence management [148]. An organization "needs an acceptable digital forensic approach that prepares for security incidents" [178]. Evidence retention must be considered and planned for; including, but not limited to a model for cloud assets [178]. If an event occurs then retaining and discovering information is important. If there is no model for evidence retention then after an event it may be impossible to attribute, solve, or restore data. Backups include keys and certificates. Backups of Electronically Stored Information (ESI) are based on frequency of use and categorization of data. A question to ask is: do you have offline backups [62] of information and data?

Policies are the top-level strategic documents for adherence in practice. A policy would be signed off by executive management whereas a procedure can be signed off at the operational management level. Boards that accurately understand their cyber risks are better able to invest appropriately in managing those risks" [179]. Privacy legislation is one of the key drivers of data confidentiality. Policies need to be in tune at the organizational level to match the jurisdictional security and privacy requirements. Data from cyber experts (and really all data) should be anonymized [144] to inhibit full

disclosure which would be a policy level decision that could be implemented throughout the organization. Policies should be updated at regular intervals.

Polices for firewalls must be documented and vetted based on changes [25] in environment. Authentication policies should be addressed [153] because so many attacks rely on privilege escalation tactics. An organizational posture plan is formed from a risk-based approach [180]. Procedures for security must be in place [181].

Penalties for non-conformance should be known. Oversight and its validation is a key security measure for controls because when not consistently implemented [45] things fall through the cracks. Not being up on legislation can lead to lawsuits. Companies not up on legislation a misstep can be a costly monetary penalty [144]. A best practice is to have someone assigned to review the latest privacy and security legislation [174]. NERC is one corporation that is required to report to FERC for legal adherence [182].

Not hiring certified professionals can be cheaper in the short run but more costly in the long run if human or technical problems develop. Those hired should feel aware of the cybersecurity technologies [25] (both IoT/embedded, industry specific, and IT). The e-Competence framework is a good guide for human factor considerations [183].

Social engineering, aka con artistry, must be discussed. Social breach concerns that are unplanned for lead to incidents. Social engineering including effects on user [91], how it takes place, the risks it poses, and the vectors used. Insider Threats detailed in the Intelligence Community (IC) Analyst-Private Sector Partnership Program (INSA) has

been mapped to Carnegie Mellon University's (CMU) Computer Emergency Response Team (CERT).

Standards can be very complicated but need to be thoroughly understood [166]. When standards are misunderstood an auditor likely finds violations when an assessment is done. Standards a good place to start when going through a checklist or trying to create a model tailored for your organization.

A supply chain plan should cover communications and controls (such as contracts) to and with vendors. If supply chain is not addressed it leaves an attack vector open for malicious actors. Ask your organization: do you control activities of third parties in the supply chain [159]? Risk Management Frameworks (RMF's) are required to preemptively minimize adverse impact. Acquisition is part of the RMF process [184]. The DoD is well known for their RMF which is required for use by DoD contractors including those who do IT and Cybersecurity work [185]. AICPA Auditing Standards Board (ASB), assist practitioners engaged to examine and report on an entity's cybersecurity risk management program [186].

If users don't understand the cyberattack detection and prevention language, and concerns and detection and protection are not defined, then users likely are not be able to detect and prevent cyberattacks [91] or respond to incidents appropriately. Network Reliability and Interoperability Council (NRIC), a Federal Communications Commission advisory committee, has developed a number of best practices to enhance the reliability of the nation's public communications networks and service [51].

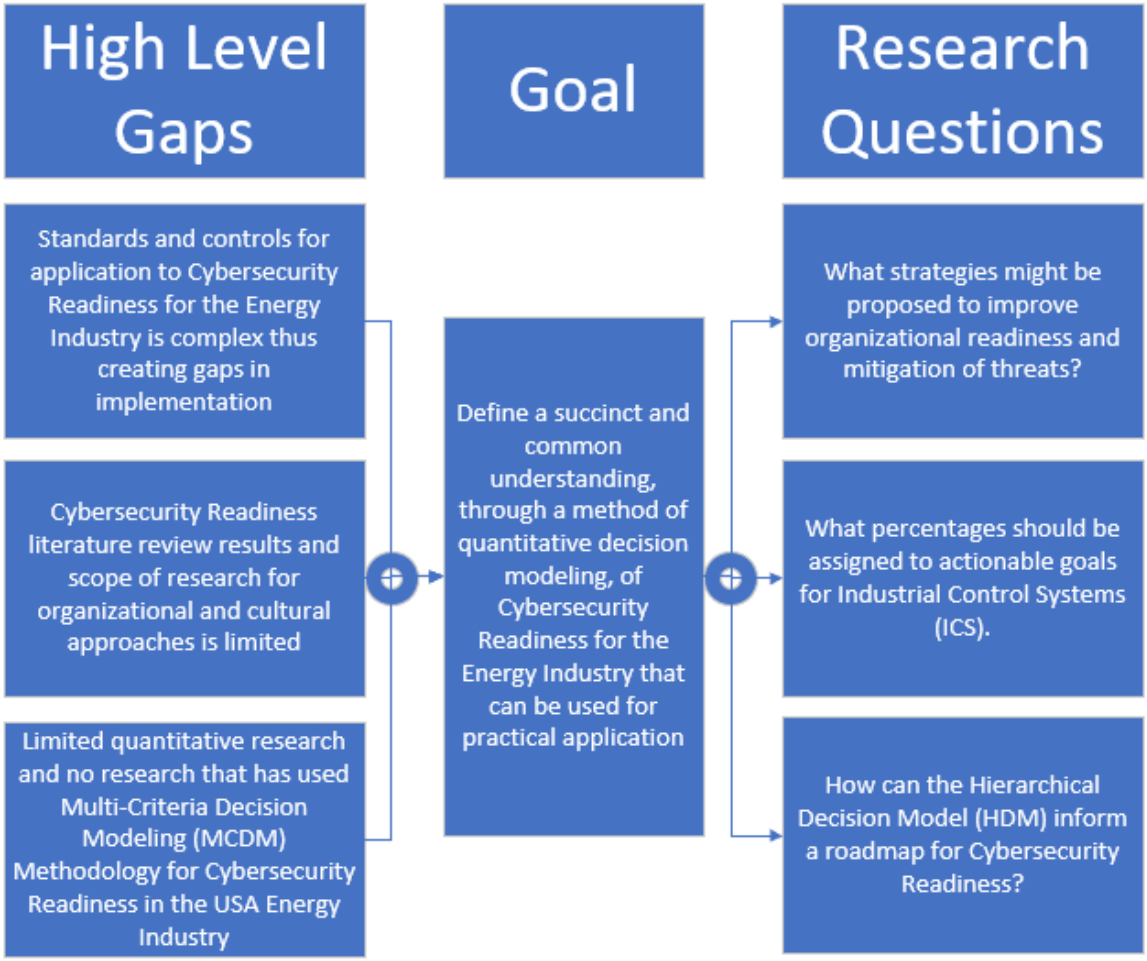
An audit is an “evaluation against standards” [3]. From an applied standpoint being readiness minded means anything that can cause an outage or lapse in visibility on security should be considered security significant issues. In this viewpoint boundary defenses [154] and heartbeat (aka Internet Control Message Protocol [ICMP) pings) checks are part cybersecurity.

Threat model should be verified and validated [162] with experts (such as those with certifications, academic degrees, and/or a lot of work experience). “Common standards and certifications can help spread best practices and build confidence that potential partners or clients will not introduce new vulnerabilities” [179]. Any news of threats and breaches should be shared often, [181] internally, and with trusted partners. Organizations that are not aware of threats and/or that don’t have a threat model that specifically pertains to the organization don’t have the awareness of security problems and attack vectors. Federal Emergency Management Agency (FEMA) has national level emergency readiness tests (aka tabletops) that have cyber components [163]. The above detailed analysis contributed to the gaps identification and model criteria creation that follows.

CHAPTER 3: GAPS ANALYSIS

The concerns found in the articles review were inputs into the Gaps, Goals, and Questions that the model and survey can help solve.

Figure 16 – Research Gaps Goals and Questions



3.1 Research Questions

This research set out to uncover the research questions to create viable recommendations to the Energy sector's critical infrastructure needs, and to gather

measurable metrics for improvement to the need of Readiness of Cybersecurity in the USA Energy Industry. Research Questions are the guides to the research in order to complete the gap analysis and to complete the goal and mission of the research.

3.1.1 Question 1 - What strategies might be proposed to improve organizational readiness and mitigation of threats?

Organizations need a strategic approach for decision making [187] for all functional areas. A functional area is one that has an operational business need. Understanding the function of readiness is crucial to achieving a higher-level strategic objective. Questions to ask are: How do we prioritize a control change for each cyber asset during an outage?

Readiness assessments should be done. Strategic thinking has been elaborated on based on the data questionnaire findings for different types of organizations. These questions were answered through desirability curves. Desirability questions are asked of a select group of experts what their organizations focus (aka strength of preferences).

3.1.2 Question 2 - What percentages should be assigned to actionable goals for Industrial Control Systems (ICS).

Impact levels are regulatory Risk Management Framework (RMF) defined in NIST FIPS 199 [31]. However, these are qualitative in nature. The data questionnaire asks surveyors to assign percentages to organizations goals in order to answer this quantitative question.

Operations are based on decisions of blending administrative needs and technical capabilities with the extra work of defining goals and other decision making. Operations

controls is a fuzzy aspect of implementation in cybersecurity. HDM modeling prioritizes and weight controls [26] which provides clarity, and provide actionable prioritization, to decisions and decision makers. Operational restrictions limit the extent to which a procedural solution can apply [188], thus the HDM model needs to change over time.

3.1.3 Question 3 - How can the HDM Model inform a roadmap for Cybersecurity Readiness?

A roadmap is a guide for a plan not finished yet. A roadmap entailing Executive (aka industry level) work getting resources and using metrics is part of question 3. A recent study on organizational Cybersecurity Readiness for Critical Infrastructure begins to lay out a roadmap for iterations, procedural next steps, questionnaires, tests, games, and checks [1]. The data from this HDM model can be used as an input to further enhance this roadmap. The data could also be used as an input to create a Markov gaming approach [55] to potential cyber-attacks.

The Homeland Security Systems Engineering and Development Institute (HSSEDI) provides a good roadmap overview of threat readiness assessments [92]. Threats can be documented as hazards [93] or in a traditional cybersecurity threat model. More sensemaking about readiness is useful because it's an understudied topic area. Organizational readiness includes the physical protection program which provides a comprehensive approach to an individual’s safety and security.

There is a cyber response/implementation gap when an incident happens between different types of workforce individuals in administration, operations, and technical. Will our current posture change our cyber reaction priorities in an incident scenario? That gap

can be mitigated through quantification of readiness using the HDM model. Posturing in the HDM model consists of scoring methods or summaries of analysis [188] to be put into action. The model ensures that the posture (aka assessment of connections [189]) within the organization is always focused on security even during a disruptive incident. Posture is a risk culture and operational reality in dealing with risks [26] and is part of the roadmap.

3.2 Gap 1 - Standards and controls for application to Cybersecurity Readiness for the Energy Industry is complex thus creating gaps in implementation

Standards are used for compliance (aka methodology requirements to be met by organization) while being safeguarded and secure. Standards are an agreement that everyone communicates in the same way. To develop a standard for practical implementation requires a decision tool to gather expert opinions. In order to implement cybersecurity readiness for the energy industry there are many factors to consider. The model has to "combine scientific results and business findings… [in order to] provide a robust security culture framework… to evaluate and meaningfully contribute to… the security reality of an organization" [1]. A. Georgiadou, S. Mouzakitis, and D. Askounis discuss cyber-security [organizational] culture frameworks which covers cultural aspect of organization but does not address technical controls required in the USA Energy System [190].

Adherence to standards frameworks is complex partly because technology is complex [87] and Data Loss Prevention (DLP) is complex [25]. NIST 800-53 is a technical approach. NIST 800-53 controls have become large (1000+) for and are thus

high cost [191] to implement needing employing specialized and highly trained personnel. NERC CIP controls [specifically for the Bulk Energy System, have prescriptive technical controls, and] specifies metrics [26]. NERC CIP is complex [and thus expensive] to interpret and to implement [192]. Because NERC CIP is prescriptive is takes a more hands on approach as a DLP program might.

Table 4 – Previous Energy Industry Standards that Have Focused on the Electric Power Industry

* ISO/IEC 27019: *Information technology — Security techniques — Information security management guidelines based on ISO/IEC 27002 for process control systems specific to the energy industry*
* NISTIR 7628: *Guidelines for Smart Grid Cyber Security*
* NERC CIP 2-9: *Critical Infrastructure Protection*
* IEC 62351 series: *Power systems management and associated information exchange – Data and communications security*

Note: Taken from: Cleveland, F. (2013). What Security Topics Should Be Covered in Standards and Specifications. Retrieved from IEC TC57 WG15 on Data and Communication Security for Power Systems

Interconnection requirements into the national electric grid require entities to meet cybersecurity standards for interoperability. Cybersecurity is now considered a topic in this conversation. The use of technology (including interconnected devices such as IoT) is being driven in part by Department of Energy's (DOE) goal is to improve energy use per square foot in this sector by 30% by 2030, relative to 2010 [193]. In 2020 Hiscox saw that "the proportion of businesses qualifying as expert [level] cyber readiness model had nearly doubled in a year – from 10% to 18%" [194] which means that the Readiness concern [and cost] is growing among the industry.

HDM provides a less laborious way to map and overlay practical organizational and technical controls that helps solve resiliency concerns. The HDM model should be

used in pre-incident planning (PIP) [195], but is nimble enough to be used by an Incident Commander during a response situation. A best practice is to engage on the front end so that one does not have problems on the back end.

3.3 Gap 2 – Cybersecurity readiness literature review results and scope of research for organizational and cultural approaches is limited

Research on industry standards for cybersecurity readiness in the energy industry are limited [196]. “Previous research has not fully understood the broad set of factors to determine impact of cyber security readiness [this is because of] limitations of researchers perspective… to individual theories” [39]. There have not been many previous studies on the effect of cyber security readiness and technology on organizational performance [39]. There are few studies that integrate factors that affect organizational cybersecurity [197].

While workforce (i.e., human related factors) have been analyzed by NIST NICE and the Australian Signals Directorate (ASD) some cultural practices have not been integrated [1]. The Australian Signals Directorate (ASD) Cyber Skills Framework version 2 published by the Commonwealth of Australia in 2020, and the e-Competence framework are good guides for human factor considerations [168]. The standard interface diagram from Digiframe – under the Plan and Build sections, is helpful for building a tailored readiness model.

The proposed HDM model is 50% culture criteria (professional, organizational, leadership) based and 50% technical (system management and information management perspectives) criteria. Using both is key to hardening an organization for mission work.

Hardening gives the organization the greatest chance of survival when under attack (or facing an outage) by taking off unnecessary components, stripping down and taking away weaknesses and building up with best security practices and tools.. “Cyber security requires the participation of people, processes, and technology… to protect the organization, people, and IT infrastructure” [39]. The technical, professional, organizational and leadership strengths and weaknesses of prioritized results are elaborated.

3.4 Gap 3 – Limited quantitative research and no research that has used Multi-Criteria Decision Modeling (MCDM) Methodology for Cybersecurity Readiness in the USA Energy Industry

There is no existing quantitative decision model appropriate for assessing Readiness of Cybersecurity in the USA Energy Industry. The PhD dissertation provides a validated quantitative model for Readiness of Cybersecurity in the USA Energy Industry. Cunningham wrote: “The characteristics of vulnerabilities, threats and assets should be quantitatively summarized with tiers that could be included as an input to a threat value model” [90]. The HDM model helps an organization focus operational requirements based on quantitative and consolidated analysis from governance (aka strategy and policy), and technical staff.

There is no quantitative CDMA (aka Multi-Criteria Decision Models “MCDM”, Multi-Attribute Decision Making “MADM”, or Multicriteria Decision Making and Analysis “MCDMA”)] for operational controls posturing [26]. Cybersecurity in the Energy industry doesn’t use Multicriteria Decision Making/Analysis (MCDM/A) quantitative controls application framework for decision making for Operations [4].

While there has been some Cybersecurity readiness modeling, i.e., Cybersecurity Readiness in Energy and closely related Industries, most models are statistical in nature rather than decision model based. Some research process models, some theoretical, and some categorizations/checklists that help in practical assessments. However, no Multicriteria Decision Model for Cybersecurity Readiness in the Energy Industry (only partial models) has yet been published [198].

The National Security Agency (NSA) published a very high-level attempt at Cybersecurity specifically for Industrial Control Systems (ICS) which is a good whitepaper for the energy grid [199] but it's not an MCDM approach. The applicability of how much effort to apply in scenarios and how sensitive models are has not been elaborated in the literature.

Nikhil [4] wrote:

> Rank–weight methods have been used in other areas, such as logistics, inventory management, and economics/cost–benefit analysis, the combination of rank–weight methods and MCDA techniques in cybersecurity vulnerability mitigation has not been explored by many researchers. In one of the recent attempts to use rank–weight methods in cybersecurity [200], the authors demonstrated a quantitative risk assessment methodology. Through their work, the authors were able to relatively estimate the risk value of various use cases based on the subjective estimates and assumptions about the cyber threats, vulnerabilities, and consequences.

> Another similar risk estimation attempt based on partial MCDA techniques was presented in [201] where the authors evaluated various smart grid systems to grade a small set of high-level vulnerabilities, likelihood of attack, and impact to qualitatively estimate relative risk value. Other risk quantification research publications and government reports that focused on likelihood, impact, and associated risk value are detailed in [29–33]. Although, those methods are efficient in performing relative risk estimation, they have certain limitations and gaps that restrict their scalability and the ability to use them towards vulnerability mitigation… [That is] all of the previously mentioned methods assumed a high-level set of organizational-level vulnerabilities and developed their formulation based on manual grading/scoring methods.

The model does not assume vulnerabilities. HDM asks the experts for criteria and strategy rankings for organizational goals so that the score is cross referenced and tailored to the organization and the organizations existing posture.

3.5 Research Goal

The research goal is to define a succinct and common understanding, through a method of quantitative decision modeling, of Cybersecurity Readiness for the Energy Industry that can be used for practical application. The use of cyber-attacks in ICS mean that we need a tool to adopters to assess, plan, and prepare for readiness work (restart implementations) [43]. HDM identifies priorities for IT assets to be put back “into control” the organization.

CHAPTER 4: RESEARCH METHODOLOGY AND APPROACH

4.1 Multi Criteria Decision Analysis (MCDA)

Using a decision tool for readiness mitigates bad decisions resulting from "incomplete or insufficient information… [and] poor collaboration" [202]. Bad decisions erode trust. "A model is a replica or representation… and is critical to understanding complex[ity]" [3]. Multi-Criteria Decision Making (MCDM) represents a problem in a hierarchical format so that the decision makers can visualize which items (criteria and sub-criteria) can affect the objective/mission [203].

All Multi-Criteria Decision Model and Analysis (MCDMA) options/tools are designed for use cases that link back to consequences of making a decision. The goal of these types of tools is to begin implementation, with rational justification, based on the highest ranked elements [49] (any aspect scored in the model). Analytical Hierarchy Process (AHP) and Decision-Making Trial and Evaluation Laboratory (DEMATEL) were considered the best alternatives for this research.

AHP is arguably the most popular MCDMA method. it is similar to HDM and has a dedicated Windows tool called SuperDecisions which can help in the analysis.). AHP calculates by multiplying and then adding (additivity): Option 1 times Option 2 + Option 2 times Option 3 + Option 3 times Option 1 . The results are then added across the row vector. Inconsistency in AHP matrix is calculated via the eigenvalues. The eigenvalue is a measure of consistency of the judgement [49]. One problem with AHP is that Saaty's original consistency index scale only allows up to 10 criteria in any one perspective, for

the consistency index calculation. If one uses MS Excel, it only gives you the approximation of eigenvalue, not the real one" [204].

Many alternate methods to calculating AHP consistency have been proposed. Harmonic Consistency Index (HCI) is proposed as an alternative [205, 206] to AHP's eigenvector inconsistency calculation. Most troubling is that AHP can result in changes of rank, which is mitigated in HDM by using the orientation matrix (aka permutations).

DEMATEL is an alternative MCDM that explores cause and effect relationships. "The main advantage of DEMATEL is its ability to uncover causal relationships and interdependencies" [81]. DEMATEL is used for cause and effect but is more useful for looking at cybersecurity attack models, and has also been used in supply chain [81], which is beyond the scope of this project. DEMATEL shows which way causes are trending through normalized scores which become weighted averages which are then put into a matrix and graphed into quadrants [81]. Barriers, drivers, and intended effects on risk can be explained by DEMATEL relationships. Relationships can also be quantitatively analyzed for coefficients [81]. DEMATEL may be useful in future work for creating critical paths for threat mitigation or scenario-based problems.

CHAPTER 5: HDM METHODOLOGY

The HDM evaluation methodology is a reliable, multi perspective decision model to address problems. HDM is a tested way to make a decision and it follows scientific process to depict multiple perspectives that can have an impact on operational results [28]. Through panels, consistency checks, desirability curves and other techniques HDM provides a comprehensive approach vis-à-vis the alternative MCDMA options [43]. Expert feedback identifies status an organization or industry has regarding governance factors [207].

The benefits of HDM are capturing data, generation of quantitative output from qualitative gap findings, detecting changes to be made and constructing rightsized plans, with output of ratings and recommendations to executives about the importance of the selections [28]. Readiness identified drives decision making.

The HDM decision model sheds light to see the big picture of applying cybersecurity in the energy industry. That is it pinpoints determinants [28] to focus on and identifies common factors that have major impact, assessing readiness, and pointing out where corrective actions are needed" [207]. HDM does this through a gathering and normalizing process to get a mean score for a criterion. Normalization is a reordering of the data so that all permutations are correctly scored.

Figure 17 – HDM Normalization

		Before normalization					Normalized			
	Orientation	A	B	C	D	Sum	A	B	C	D
1	*ABCD*	1.81	3.31	0.74	1.00	6.85	0.26	0.48	0.11	0.15
2	*ABDC*	3.61	6.62	1.00	3.11	14.35	0.25	0.46	0.07	0.22
3	*ACBD*	1.88	2.13	0.60	1.00	5.61	0.34	0.38	0.11	0.18
4	*ACDB*	1.56	1.00	0.50	0.68	3.73	0.42	0.27	0.13	0.18
5	*ADBC*	3.50	4.48	1.00	3.03	12.00	0.29	0.37	0.08	0.25
6	*ADCB*	1.02	1.00	0.28	0.88	3.19	0.32	0.31	0.09	0.28
7	*BACD*	2.30	5.65	0.74	1.00	9.69	0.24	0.58	0.08	0.10
8	*BADC*	3.60	8.84	1.00	3.11	16.56	0.22	0.53	0.06	0.19
9	*BCAD*	1.16	3.86	0.86	1.00	6.88	0.17	0.56	0.13	0.15
10	*BCDA*	1.00	6.58	1.47	1.99	11.04	0.09	0.60	0.13	0.18
11	*BDCA*	1.00	4.94	0.75	2.32	9.01	0.11	0.55	0.08	0.26
12	*BDAC*	3.11	13.17	1.00	6.19	23.47	0.13	0.56	0.04	0.26
13	*CABD*	1.16	2.13	0.87	1.00	5.16	0.23	0.41	0.17	0.19
14	*CADB*	0.78	1.00	0.58	0.68	3.04	0.26	0.33	0.19	0.22
15	*CBAD*	1.16	2.84	0.81	1.00	5.80	0.20	0.49	0.14	0.17
16	*CBDA*	1.00	4.23	1.20	1.99	8.42	0.12	0.50	0.14	0.24
17	*CDAB*	0.55	1.00	0.80	1.09	3.43	0.16	0.29	0.23	0.32
18	*CDBA*	1.00	2.46	1.23	1.66	6.34	0.16	0.39	0.19	0.26
19	*DACB*	0.88	1.00	0.28	1.76	3.92	0.23	0.25	0.07	0.45
20	*DABC*	2.44	4.48	1.00	4.86	12.78	0.19	0.35	0.08	0.38
21	*DBAC*	3.11	7.65	1.00	5.17	16.93	0.18	0.45	0.06	0.31
22	*DBCA*	1.00	3.34	0.75	2.26	7.35	0.14	0.45	0.10	0.31
23	*DCAB*	0.55	1.00	0.41	1.27	3.22	0.17	0.31	0.13	0.39
24	*DCBA*	1.00	2.46	0.70	2.17	6.32	0.16	0.39	0.11	0.34
						Mean	**0.21**	**0.43**	**0.11**	**0.25**
						σ^2	**0.00591**	**0.0106**	**0.00218**	**0.00710**

Note: Reference: M. S. Abbas, "Consistency Analysis for Judgement Quantification in Hierarchical Decision Model," PDXScholar, Portland State University, 2016.

HDM has been used historically to understand the relationship between mission, objectives, and alternatives based on expert opinion and to avoid projects that are of little value (low quality), missing the mark in requirements (objectives not clearly defined), and to prioritize the work (avoid risks and increasing returns) if it the project appears to be performing/trending correctly [188].

The approach that the HDM model takes is reflected in the hierarchical structure. HDM modeling prioritizes and weights [26]. A properly constructed hierarchy gives

results close to those of a system with feedback [49]. HDM model building involves a lifecycle of: knowledge capture -> interviews -> testing/survey -> verifying results -> and summarizing [26]. The HDM model solves business operations problems through criterion weights and is vetted by evaluators. A resultant posture is created from putting the output into action.

This HDM model also integrates business objectives with technical requirements making the output more easily understood by upper management. The HDM model allows us to look at the cybersecurity problem comprehensively (criterion based, goal based, and composite based). HDM quantitative analysis allows for benchmark reporting is on cybersecurity readiness towards threats in the Energy Sector and Critical Infrastructure [28]. The weights given are those items that are nice to have based on the intra-group decision making process [208]. Once a composite score is obtained that number can be baselined to achieve business focused results.

Table 5 – HDM Modeling Basis

Three concepts form the basis of HDM modeling: 1. Structuring the decision problem in a hierarchy consisting of [perspectives], criteria and alternatives. 2. Conducting pairwise comparisons among all variables at every hierarchy of the decision model with respect to each criterion on the prior/higher level. 3. Synthesis of priorities at all levels of the hierarchy after obtaining the relative judgment weights, and checking the consistency [209].

Note: The methodology can be used for quantifying the judgment of a single decision maker, or multiple decision makers [209].

"A [readiness] decision model should: identify common factors that have major impact, assess readiness, and point out where corrective actions are needed" [2]. HDM does this by capturing intuitive understandings of participants to create a mathematically

stable decision result [43]. This is important because “mathematics and logic proofs establish theoretical foundations” [210]. Matrix math is an array of numbers arranged in a table calculation. The matrix (aka the model’s tool) is needed to do the consistency mathematics to ensure scientific integrity of pairwise survey responses.

This HDM model allows for a comparison of tangible readiness factors with varying perspectives by way of a pairwise comparison. The pairwise comparison “indicates the degree to which factor *i* is weighted in importance to factor *j*. HDM considers all permutations for an inconsistency score. Pairwise quantification enables a reliable readiness analysis to be done in a short timeframe [26]. Multi Criteria Decision-Making Models (MCDM) including Hierarchical Decision Modeling (HDM) use matrix and multiplication division to calculate a score based on expert opinion.

Figure 18 – HDM Hierarchical Structure

Mission	Level 1	The Decision
Perspectives	Level 2	The property of application. That is how it is situated in a general context. You can think of this as a defined set of capabilities.
Criteria	Level 3	The capability (which we have criteria and sub criteria for) which is what is expected to be achieved. These are qualitative items that we are processing for qualitative results.

Note: Adapted from A. Cavanaugh, "PhD Comprehensive Exam: Assessment of the Cybersecurity Controls Posturing for the Management of the Energy Sector Critical Infrastructure and Key Resources (ES-CIKR): Using Hierarchical Decision Model (HDM) to Evaluate Readiness of Cybersecurity in the USA Energy Industry," ed. Portland, OR: Portland State University, 2022.

Table 6 – Benefits of HDM

HDM offers many benefits. Here is a review of the main benefits of HDM:

- Effective decision-support tool. HDM helps make the right decision under uncertainty, where there are multiple complex competing objectives and criteria.
- HDM is a robust method that can capture the subjective judgment of experts and convert it into quantitative numbers that in turn can be analyzed and used effectively.
- HDM Aggregates opinions of diverse experts to create a meaningful and well-represented decision.
- Under HDM, experts are not affected by the "loudest voice" in the room.
- Everybody contributes to the decision, no "silent bystanders".
- No need for physical meetings.
- Experts' judgment can be tested for inconsistency and disagreement, allowing for more trust and reliability in the generated model.
- A model generated using HDM can be tested for flexibility and sensitivity to changes.
- Models generated by HDM are intuitive and practical. Such models can be used, after being built, in real life by users who don't poses high analytical and academic knowledge.

Note: Taken from H. Barham, "Doctoral Dissertation Proposal: Project Readiness Assessment - A Hierarchical Decision Model to Evaluate Readiness for a Smart-City-Related Big Data Project," Doctor of Philosophy, Engineering and Technology Management, Portland State University, Portland, OR, USA, 2018.

The HDM model makes recommendations based on empirical knowledge by grouping data and information. HDM is good for new study topic area dataset building where regression calculations are not yet [28] available. HDM's most notable characteristics are visualization, information extraction, feature importance, interpretability, and decision making [28]. The data questionnaire was based on a cross-section of stakeholders who prioritize cybersecurity readiness, based upon their industry knowledge and experience, through literature or through industry [28]. The model includes not only business drivers, but societal drivers. HDM modeling is social based and thus considers social and environmental factors which do not translate in any reasonable way to dollars [49]. In order to rank Readiness Decision Making with the

HDM process Cybersecurity in the Energy Industry a Hierarchical Decision Model (HDM) using web-based software provided by Portland State University (PSU) was used.

Table 7 – Steps in Calculating HDM for One Experts Matrix

1. Create a list of permutations
    a. Create comparisons
2. Put expert values into matrix
3. Create columnar data
    a. Divide columnar data
4. Calculate all orientations
    a. The output is raw weights
        i. Sum the raw weights
5. Create normalized matrix
6. Reorder columnar data to align to each criterion
    a. Output is average score
        i. Calculate standard deviation of column criteria
            1. Average the column criteria for consistency score. Note: if using Root Sum of Variance (RSV) method then square the deviations and use lookup table.

5.1 Justification

"Despite the noted role of cyber security in enhancing organizational performance, its influence on organizational performance has not been empirically tested" [87]. Readiness, usually with regards to… restarting after downtime, hasn't been enumerated in cyber [28]. AlEnezi wrote in 2020 "there is still no appropriate methodology or framework for mitigating IoT cyber security challenges" [89].

Traditional Industrial Control Systems (ICS) System operators are required to operate energy assets but are not cybersecurity experts. The results from the model empower [28] operators/practitioners and those they work (such as System Owners), with rapid decision making. A type of internal roadmap is created by "the System Owner or Information Owner [that] categorizes the information system and records the results of security categorization in a system security plan [108].

The HDM model use case demonstrates security challenges based on day-to-day operations. Layers of defense tries to disrupt attacks on the grid by analyzing goals, examining the implications, and developing countermeasures [103]. The goal of [the HDM tool] is to begin implementation, with rational justification, based on the highest ranked elements [49] (any aspect scored in the model) [43]. The HDM model for this work produces a generalized model and a tailored case using insights from the above.

The HDM ranking score is calculated through the pairwise comparison weighted method to support the robustness and reliability of experts decisions. If one criterion is more important than another the result means this criterion has some incentive for the panelist to choose based on their role, function, or knowledge [43]. A lower score should be considered less important [43].

5.2 Disagreement

Disagreement can be calculated using content validity ratio [211]. Interclass correlation coefficient (ICC) [212, 213] is very similar (it's ratio creates a -1 to +1 decimal result) but uses ANOVA mean variance. If a score is less than 50% (aka less than zero) the item is a poor fit [213]. Small values indicate commonality. If closest to zero, then we can infer a reliable assessment [43]. Since no objective standard for disagreement exists, the disagreements between the judgments of the experts cannot be interpreted directly as [accuracy or] inaccuracy [214] of the model.

The disagreement score in the HDM tool deciphers whether test takers panels answers are reliable (aka random). Disagreement may happen because the expert lacks commitment, qualifications, or doesn't understand the tool. Group disagreement, in the

model, can be expressed by standard deviation [214]. If there are less than 10% disagreement deviation, as a sum of all deviation, then the participants answer, as a whole, are statistically of higher value and a good fit. “If a group disagreement index exceeds the value of 0.10, then it is concluded that there is disagreement among experts” [215].

5.3 Desirability

Kocaoglu posited that… one could use a curve (he calls responsibility curve) which is a weight additionally assigned to a participant’s score [216]. [The weight is] based on organizational strategy experts ranking. Survey questions are created for strategic decision makers, to get scores from them, and then applied to the SME criterion rankings for a comprehensive HDM decision. Changes in attribute weights have a considerable impact on the selection of the best options.

The desirability term originates from Multi-attribute Utility Theory (MAUT or MAU). Desirability is the strength of preferences from ordinal or cardinal lists which is called Utility [49]. A utility theory gives a measure of how much better a solution is than another solution [43]. Adding desirability to the HDM model can be described as “a blending of methods whereby an assessor begins with a precomputed risk metric and modifies the final output through qualitative reasoning” [3].

Desirability questions are in the Appendix E. The percentage scores in the Appendix E are for representation (aka plug numbers) only. The actual scores were gained by asked and asking experts to assign a percentage value.

"The average value of experts' judgments [i]s considered as the final value for the curves creation" [213]. When calculated for the criterion, *i* strategy expert sample data (D Score) is multiplied by *j* which is a global weight which results in weighted criterion score. This desirability score [D Score] weight is a risk appetite of the [strategic experts] [43]. Strengths (top scores) and weaknesses (lowest scores) can be separated and shown in a report.

The details of the desirability score are: Local Weight Raw divided by n perspectives which equals Global Weight (summed to 1) that is then multiplied by desirability score to get the criterion weight which equals the Criterion Score which are then summed for a composite score. Attractiveness Factor (aka the Final Score) is the success measure of the nth variable to the nth perspective. Thus, the desirability calculation is shown below.

Figure 19 – Desirability Calculation

$$\text{AF Score} = \sum_{n=1}^{N} \sum_{Jn=1}^{Jn} \left(S_{n,Jn}^{AF}\right)(D, Jn)$$

Where Attractiveness Factor (AF) = variables with possible impact on the outcome (aka how much the experts desire the factor)

(D, J_n) = desirability value of performance measures relative to J_n AF success attribute with respect to the nth perspective

$(S_n{}^{AF}, J_n)$ = the relative value of the J_n AF success measure relative to the nth variable, and in relation to factors affecting the project [217] .

Table 8 – Calculating Composite Score Requirements

1. D Score (D) = average of all d scorers 2. Local Weight Raw (LWR) = raw score from experts for each criterion 3. Perspective Weight (PW) = average score from raw model for the perspective 4. Global Weight (GW) = Perspective Weight * Local Weight Raw 5. Criterion Score (n) = D Score * Global Weight 6. Composite Score (N) = Sum of all Scores (n)

The composite score has also been written in the following format in the table below by multiple authors for impact [217] and readiness [35].

Table 9 – Composite Score Mathematical Notation

$\sum_{p=1}^{P} \sum_{c=1}^{C} P_p \, C_c^p \, d(m_{p,cp})$ Where: C: Number of criteria P: Number of perspectives P_p: The degree (weight) to which perspective p contributes towards the mission (the mission is Cybersecurity Readiness in the Energy Industry). C_c^p: The relative contribution of criterion c under perspective p toward the mission. $d(m_{p,cp})$: Desirability value of the performance metric for c^{th} criterion under p^{th} perspective.

5.4 Inconsistency

Kocaoglu states: “When the pairwise comparisons have inconsistencies, certain perturbations are introduced into the final results” [218]. Consistency is a degree of certainty in judgements [49]. HDM consistency measure is more accurate compared with AHP. Inconsistency [as defined] is a violation of proportionality [49]. In general consistency means if alternative A is preferred over B, and B is preferred over C, then A must be preferred over C. If a user chooses C as preferred over A, then ordinal consistency is violated [209]. Ordinal consistency is called transitive trust (or a cross-trust model) in security topics. Cardinal consistency requires preservation of preference proportions; for example: if A1 is preferred twice over A2, and A2 is preferred thrice

over A3, then A1 must be preferred 6 times over A3. Cardinal consistency is violated if the expert chooses A1 to be 5 times preferred over A3 [209]. If inconsistency happens then there may have been some internal conflict or preference towards another option not listed that skewed the [result] [43]. HDM inconsistency is a standard deviation (aka variance) of all permutations. This "variance in the distribution of the relative values is used as a measure of internal inconsistency" [218]. HDM's inconsistency is comprehensive of all the possible permutations.

In the below examples there are four variables. The standard deviations were calculated. In the first example the square root was taken for each variable and then summed. In the second example the standard deviations were added together and then a lookup table was used to calculate inconsistency. Both calculations show the difference in measured deviations.

Figure 20 – Original HDM Consistency Example with Four Criteria

$$Inconsistency = \frac{1}{n}\sum_{i=1}^{n}\sigma_i$$

$$Inconsistency = \frac{1}{4}\left(\sqrt{0.00591} + \sqrt{0.0106} + \sqrt{0.00218} + \sqrt{0.00710}\right)$$

$$Inconsistency = \frac{1}{4}(0.0769 + 0.1029 + 0.0467 + 0.0843)$$

$$Inconsistency = 7.77\%$$

Note: Reference: M. S. Abbas, "Consistency Analysis for Judgement Quantification in Hierarchical Decision Model," PDXScholar, Portland State University, 2016.

Figure 21 – Root Sum Variance Consistency Example with Four Criteria

$$RSV = \sqrt{\sum_1^n \sigma_n^2}$$

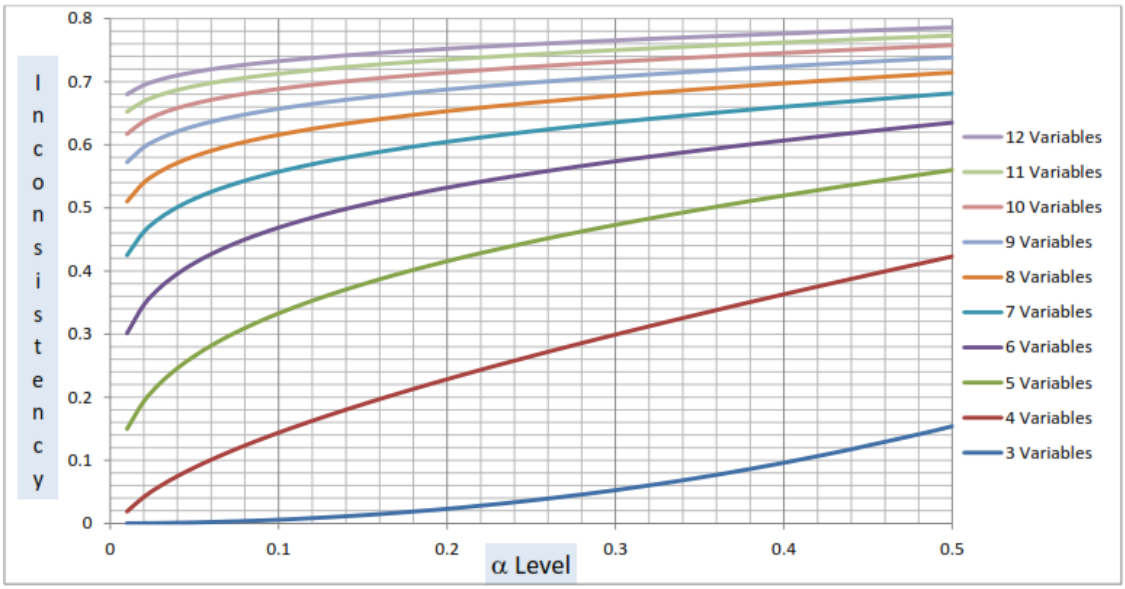
$$RSV = \sqrt{0.00591 + 0.0106 + 0.00218 + 0.00710}$$

$$RSV = 0.161$$

Note: Reference: M. S. Abbas, "Consistency Analysis for Judgement Quantification in Hierarchical Decision Model," PDXScholar, Portland State University, 2016.

Note 2: Using RSV (in the Appendix L) lookup table .161 corresponds to .12 because this RSV is based on 4 variables.

Figure 22 – HDM Inconsistency Thresholds Visualizations of Lookup Table



Note: Taken from M. S. Abbas, "Consistency Analysis for Judgement Quantification in Hierarchical Decision Model," PDXScholar, Portland State University, 2016 [209].

Visualizing the standard statistical measures can help explain how changes in the number of variables affects the threshold used in the root sum of variance inconsistency

measure. The above chart shows that between four and seven variables the standard deviation count thresholds on the x-axis are separated and show rates of inconsistency that change more often than do those models using eight or more variables. Three variables have an inverse curve to those solutions with four or more variables.

For an individual rating if the experts inconsistency exceeds the 0.10 value 1) the respondents are informed of the inconsistencies and additional measurements are required. If the value is still higher than 0.10 after the second session, the respondent who had the inconsistency were removed from the expert panel [215, 219]. It should be noted that one of Kocaoglu's earliest papers, published in 1983, recommended that inconsistency be at .04 or lower [218] based on a Master's Thesis at the University of Pittsburgh on consistency method for constant sum. This 4% could be considered a more valid stretch goal for an analysis. If inconsistency is high (aka out of bounds; out of control) for many participants an alternative to discarding information is to do a cluster analysis to group decision makers into new groups. This mitigation can be helpful in explaining out of bounds situations.

5.5 Sensitivity

A sensitivity analysis examines the impact of a change of priorities (that is uncertainty). It's a "what if" analysis. Sensitivity analysis seeks to answer the question "how changes in factor *i* result in variations to factor *j*" [81]. Sensitivity is a concept to use substitution data to make one perspective and all its sub criteria weighted higher. If no change in rank, at some criteria level in the (90% range) which is a high sigma, it can be determined that the model is (or is not) sensitivity averse. Sensitivity shows how much

the output moves from its original point… [thus] the tolerance level of the model can be assessed [217]. Sensitivity focuses on the areas in which the cumulative score changed and make recommendations for implementation.

Abotah equates sensitivity to a feasibility models allowable change (aka tolerance) or perturbations (aka coefficients) [215]. Others use the term influence as a synonym for sensitivity [81]. Sensitivity can also be measured on a normalized scale such as summing to one or summing to zero, or through measuring variations in movement of any scale which measures robustness [212]. Sensitivity involves altering specific conditions in the model to analysis that change in weight, rank, etc.

CHAPTER 6: RESEARCH PLAN AND DATA COLLECTION

Data collection involves research of practioners with the appropriate level of experience and knowledge in the Cybersecurity and in the USA Energy Industry. “An expert selection model (ESM)… is a reliable model that helps decision makers or analysts decide… based on their credentials and experience” [81]. Experts were chosen through email searches, personal knowledge, and referrals. The survey targeted experts at the following organizations (or alternatives), with a goal of including government experts who are experts into panels:

- PNNL – Pacific Northwest National Laboratory
- INL – Idaho National Laboratory
- SCL – Seattle City Light
- NERC – North American Electric Reliability Corporation
- EPRI – Electric Power Research Institute
- WECC – Western Electricity Coordinating Council
- SEI CERT @CMU – Software Engineering Institute Cyber Emergency Response Team @ Carnegie Mellon U.
- NCCOE NIST – National Cybersecurity Center of Excellence National Institute of Standards and Technology
- DHS CISA – Department of Homeland Security Cybersecurity Information Security Agency
- MITRE Corporation
- BPA – Bonneville Power Administration

Table 10 – Personal Knowledge Cybersecurity Experts Previously Consulted by Author

Title	Job Function	Company
Researcher	Cyber Security	PNNL
Researcher	Cyber Security	PNNL
Researcher	Cyber Security	PNNL
Researcher	Cyber Security	PNNL
Scientist	Smart Grid	PNNL
Product Management	Compliance	BPA

Specialist	Compliance	BPA
Specialist	Compliance	BPA

6.1 Expert Panels

Paneling creates HDM model applicability to different roles/responsibilities, units or other categories [43]. Panels show divergence and similarities between different groups thinking. With any human subject study, the results can be impacted by biases. Panels bring out bias based on grouping [43] through the narrative reporting. This method can also be used when respondents have different levels of experience and knowledge.

There were 12 expert panels with membership participation of up to 14 members. Therefore, the number of human subjects in the study was 54. That is 54 individual experts participated in a combination of model validation and quantification efforts. The advisor and dissertation committee chair reviewed the panel formation and selection process and list of experts to ensure a balanced perspective has been achieved. The experts were affiliated with prominent US energy industry organizations (private or agencies).

Table 11 – Count of Positions and Organizations of Experts

Positions	Organizations
Executive: 11 Project Manager: 7 Strategic Thinker: 12 Technical SME: 24	Agencies of Government: 13 USA National Lab: 6 Private Entity: 32 Small Business: 3
Total: 54	Total: 54

Creating expert panels to solve a decision creates suitability towards a problem [212]. Experts (aka Subject Matter Experts “SME”) provide detailed operational understanding [28]. Experts cannot be expected to perform effectively without a model or

tool to address the full spectrum of systems and sub-systems [26]. Experts verify, and validate, the decision model [85]. For pairwise research setting the expert up beforehand with what will happen and why it will happen [216] is of high importance. Experts are qualified people with significant experience who characterize, detail, and tell one what could result (and many other things), usually through interviews [26].

Table 12 – Panels Proposed

Which panel do you most align with?	**Organizational**	**Professional**	**Leadership**	**Systems Management**	**Information Management**
Industrial Control Systems (ICS)/National Grid	Panel 1	Panel 2	Panel 3	Panel 4	Panel 5

The decision model analysis was conducted through paneling expert participants using quantitative scoring to prioritize the organizational approach for cyber practice and posture. Experts for this survey were voluntary, have no-commitment, and no-cost access to the research resources (to be provided by the researcher) and can freely use the tools and techniques from the study in order to improve the organizational cybersecurity readiness going forward [28].

Table 13 - Screening Questions Considered

Do you have any role or involvement in Cybersecurity Readiness for the Energy Industry? • Yes, full involvement • Yes, partial involvement • Yes, minimal involvement • No involvement (stop)
How familiar are you with your organizations Cyber Readiness process? • Very familiar • Familiar • Somewhat familiar • No knowledge (stop)

CHAPTER 7: RESEARCH APPLICATION

7.1 Construct Validity

The construct validity of the research model was assessed through interviews conducted as a component of the comprehensive exam. The model was validated (that is sufficiently designed) using interviews during the model development phase [35]. Construct validity is a test of the appropriateness of assessment tools in collecting the desired information from a select population of respondents [220].

7.2 Content Validity

The accuracy of a model's contents is assessed using content validity, which ensures that the most critical aspects associated with the study topic are properly represented. In addition, a validation survey was used to ensure the correctness (eliminate or add variables) to model components by subject matter experts. That is, experts fine tune and finalize the model.

An equation can be used to make a ratio number appear on a scale from -1 to +1 [211]. This ratio is called a Content Validity Ratio which is written as CVR = (n_e – N/2)/(N/2) [211, 213]. n_e is number of SME's (aka sample) that indicate an item is essential. N is the total number of panelists (aka population). If 50% or more of experts agree to include a variable in the model the variable is considered construct valid. That is, a positive value indicates that at least half of the SME's rated the item as essential [213] to the model.

Table 14 – A Construct Validity Python Script

```
# input values for Yes SME agrees to include in the model (ne) and all SME's (N)
ne = float(input("Enter the value of ne: "))
```

```
N = float(input("Enter the value of N: "))

# calculate the value of Validity
CVR = (n_e - (N / 2)) / (N / 2)

# print the result
print("The value is between -1 and +1:", CVR)
```

7.3 Criterion Validity

Is the effectiveness in practical application [213]. Case studies and Use Cases are used to show the application. Graduate students at Portland State University tested the model and agreed that the model can be useful and the results generalizable. Based on the literature review and feedback from SME's and students the model is applicable, accurate, and valid.

7.4 Validation

Two interviews with senior cybersecurity researchers were conducted to talk about the overarching topic of resilience. The answers to the taxonomy validation questions are summarized below. The initial three interviews were conducted to verify a proposed resilience taxonomy to inform the readiness model. Three questions were asked of interviewees:

1. How do you see this resilience taxonomy tying into the readiness model which I previously talked about in the comprehensive proposal?
2. Is there a cause-and-effect aspect of resiliency, and/or findings of resiliency that needs to be considered?
3. What other ways of working with resilience are you familiar with or have you used?

7.4.1 Interview: Pacific Northwest National Laboratory (PNNL)

7.4.1.1 How do you see this resilience taxonomy tying into the readiness model which I previously talked about in the comprehensive proposal?

The first interviewee stated that the proposed taxonomy was "on the right track." She stated that the technical considerations are the most important for the resiliency topic. She believes that resilience is "a continuum on a timeline that represents a degraded state." She stated: "An organization must come back from the degraded state to be considered resilient." The eight domains of Certified Information Systems Security Professional (CISSP) are what she uses for controls when thinking about cybersecurity. CISSP is a resource that can be used to include in a full resilience model as future work.

The second interviewee said that to be a complete taxonomy one needs to look at the later sections of Cybersecurity Capability Maturity Model (C2M2) developed by the Department of Energy (DOE) and other maturity models to pull out resilience aspects. Thus, maturity was discussed in this proposal.

7.4.1.2 Is there a cause-and-effect aspect of resiliency, and/or findings of resiliency that needs to be considered?

The first interviewee didn't have information to share (was not informed).

The second interviewee stated that at the organizational level cost metrics and their trends can be used for tracking. He recommended an IEEE paper called "The Grid: Stronger, Bigger, Smarter?: Presenting a Conceptual Framework of Power System Resilience" that explains ideas on forming resilience metrics. He recommended using metrics such as: a percent of observations, and percent of controls for baselining cyber-

physical devices in energy systems. Further metrics in the workplace could be created from the HDM quantitative output.

7.4.1.3 What other ways of working with resilience are you familiar with or have you used?

The first interviewee mentioned Systems Engineering International Organization for Standardization (ISO) as a possible resilience resource. She also recommended looking at the European Union Agency for Cybersecurity (ENISA), Smart Electric Power Alliance (SEPA), and Utilities Technology Council (UTC) for white papers, academic papers, and tabletops resilience information. The author researched these sources and found ISO as the most relevant topics which were discussed previously.

The second interviewee referenced NIST 800-30 (for risk management) to use to standup a risk program/approach. He stated that the Common Vulnerabilities and Exposures (CVE) lists (e.g., https://nvd.nist.gov) to address specifically the cyber-Applications layer would be critical in having a defense-in-depth posture. For physical systems he recommended physics/physical electrical monitoring of the energy itself so that correlations of data (for example using a “digital twin” machine/system for fault tolerance) can be made to confirm if an attack is truly happening, that is if the incident data is correct.

7.4.2 Interview: Bonneville Power Administration (BPA)

One cyber specialist BPA employee recommended looking at NIST 800-160 for resilience in systems engineering lifecycles. He believed nothing was amiss or needed to be added. The following questions were asked:

7.4.2.1 How do you see this resilience taxonomy tying into the readiness model which I previously talked about in the comprehensive proposal?

This interviewee expressed that a scenario where no electricity is flowing through the National Grid is an area that is theoretically a challenge. This is because as a society we can't take everything down and try to bring the whole grid back up again. Even taking down a segment to test resiliency is problematic because of cascading effects.

7.4.2.2 Is there a cause-and-effect aspect of resiliency, and/or findings of resiliency that needs to be considered?

The interviewee suggested using MITRE's ATT&CK for Industrial Control Systems framework for cause-and-effect mapping. This is discussed in the Appendix C.

7.4.2.3 What other ways of working with resilience are you familiar with or have you used?

The interviewee works in Reliability which he stated is fundamentally different than resiliency. [Reliability (aka stability [221] or dependability [222]) is focused on complexity of network architecture design [221], complex implementations of cyber-physical relationships [222], and interconnections [223]]. He stated that looking at a functional approach (supporting business need) rather than a systems approach (for example, NIST functions: identify, detect, protect, respond, recover in NIST 800-53) helps to segment thought processes of what to focus on. A non-functional approach is something that is dependent on environment like uptime or robustness. The interviewee also expressed that incident response plans are not enough to be fully comprehensive posture towards resiliency.

7.5 Perspectives

Perspectives are affinity categories to which descriptive statistics with importance weights are given by expert pairwise comparison.. Each perspective has a number of items (criteria) with a minimum, maximum, mean, and std. deviation [28]. This HDM model considers the state of the cyber workforce (NIST NICE Competencies) [as Perspectives] [28]. The perspective groupings are reflective of group needs found in the literature on cybersecurity readiness in the energy industry [198]. Perspectives are affinity categories to which criteria are assigned. Perspectives from a functional perspective can be thought of as lines of business [43].

Figure 23 – NIST NICE Operational Framework



Note: Taken from P. Maxson, "NICE National Initiative for Cybersecurity Education: National Institute for Cybersecurity Studies (NICS)," csrc.nist.gov, Oct 24 2011.

A competency in NIST NICE is a mechanism for organizations to assess learners. Competencies consist of a name, description, and group of associated TKS (Task, Knowledge, Skill) statements. Technical: Competencies dealing with technology and systems, Professional: Competencies that may not be job-specific, but allow a learner to work well with others, improve performance, and provide value in a workplace. Sometimes called soft or employability skills, Organizational: Competencies that are mission and business focused, Leadership: Competencies that are especially important for learners in leadership positions. These competencies have also called readiness skills [224].

Table 15 – NIST NICE 8355 Draft Competency Categories

Leadership	Organizational	Professional	Technical
Policy Development	Asset and Inventory Management	Communication	Collection Operations
Strategic Planning	Business Acumen	Conflict Management	Computer Languages
Workforce Management	Business Continuity	Critical Thinking	Data Analysis
	Contracting and Procurement	Interpersonal Skills	Data Security
	Data Management	Problem Solving	Database Administration
	Data Privacy		Digital Forensics
	Education and Training Delivery		Encryption
	Education and Training Curriculum Development		Enterprise Architecture
	Knowledge Management		Identity Management
	Law, Policy, and Ethics		Incident Management
	Organizational Awareness		Information Systems and Network Security

Process Control
Project Management
Risk Management
Strategic Relationship Management
Supply Chain Management

Information Technology Assessment
Infrastructure Design
Intelligence Analysis
Mathematical Reasoning
Modeling and Simulation
Network Management
Operating Systems
Operations Support
Physical Device Security
Requirements Analysis
Software Development
Software Testing and Evaluation
System Administration
Systems Integration
Systems Testing and Evaluation
Target Development
Technology Fluency
Telecommunications
Threat Analysis
Vulnerabilities Assessment

There are four competency types in NIST NICE 8355 Draft: Leadership, Organizational, Professional, and Technical [85]. Professional and Leadership are personnel (people) related, Organization is process (policy, procedure, and workflow) related, and Technology (engineering) related. The most prevalent factors affecting cybersecurity are technical. Thus, the Technical category has been divided into two categories (which are now two Management perspectives) The two categories are: Information Management and Systems Management, using NIST 800-137 Internet Security Continuous Monitoring (ISCM) as a guide. Categories with less than nine variables are required in order to be used with the HDM tool. NIST 800-137 has 11 categories. Kocaoglu states: “when respondents are presented with more than 10

elements, they find it difficult to make pairwise comparisons" [225]. Elements that aligned with the Information Management category were put into one category and all other elements that aligned with other NIST 800-137 categories were grouped into a Systems Management category in the HDM model. NIST 800-137, as a tool for control, is a fraction a total of all the NIST controls so this choice is an imperfect [holistic] approach to compliance [26]. The matrix used to split the NIST NICE Draft 8355 Technical perspective into two groups is shown in the figure below.

Table 16 – NIST 800-137 Continuous Monitoring Mapped to NIST NICE Draft 8355 Technical Competency

NIST 800-137 Security Automation Domains

Systems Management											Information Mgmt
Inventory Assets	Vuln. Assess	Patching	Events	Malware	Config Mgmt	Network	Soft. Licenses / Renewals	Software	Incident Mgmt		Information Mgmt
Enterprise Architecture	Data Security	Modeling and Simulation	Intelligence Analysis	Mathematical Reasoning	Operating Systems	Encryption		Computer Languages	Collection Operations		Data Analysis
Information Technology Assessment	Vulnerabilities Assessment	System Administration	Threat Analysis	Target Development	Operations Support	Network Management		Database Administration	Digital Forensics		Identity Management
Infrastructure Design		Software Testing and Evaluation			Requirements Analysis	Systems Integration			Incident Management		Information Systems and Network Security
Physical Device Security								Software Development			Technology Fluency
								Software Testin			Telecommunications
HDM Criteria											
Machine limitations are recorded			Outages are not required for security updates	Planning for forensic evidence collection	Change Management is considered				Data loss prevention system is in place		Info Officer is in contact with Internet Service Provider
									Energy system outages are planned for		Logging is sufficient for security and forensics
											Network and System admin procedures documented
											Retention periods are in place and used for information and data
											Standards are understood

A summary table is shown below of the final output of the mapping for the two perspectives System Management and Information Management using is the HDM model.

Table 17 – NIST NICE Competencies Mapped to HDM Management Perspectives Summary

Systems Management	Systems Management (cont.)	Information Management
Collection Operations	Modeling and Simulation	Data Analysis
Computer Languages	Network Management	Identity Management
Data Security	Operating Systems	Info Systems and Network Sec
Database Administration	Operations Support	Technology Fluency
Digital Forensics	Physical Device Security	Telecommunications
Encryption	Requirements Analysis	
Enterprise Architecture	Software Development	
Incident Management	Software Testing and Evaluation	
Information Technology Assessment	System Administration	
Infrastructure Design	Systems Integration	
Intelligence Analysis	Systems Testing and Evaluation	
Mathematical Reasoning	Target Development	
	Threat Analysis	
	Vulnerabilities Assessment	

The resultant five perspectives in the HDM model are described below.

Table 18 – Perspectives

Perspectives	Description
Organizational	Competencies that are mission and business focused.
Information Management	Technical competencies dealing with technology and systems that align with NIST 800-137 Information Management.
Systems Management	Technical competencies dealing with technology and systems that align with NIST 800-137 all categories (excluding Information Management).
Professional	Competencies that may not be job-specific, but allow a learner to work well with others, improve performance, and provide value in a workplace. Sometimes called soft or employability skills.
Leadership	Competencies that are especially important for learners in leadership positions.

Note taken from: National Institute of Standards and Technology (NIST), "NICE Framework Competencies: Assessing Learners for Cybersecurity Work (2nd Draft): List

of Competencies (draft) (xls)," ed. https://csrc.nist.gov/CSRC/media/Publications/nistir/8355/draft/documents/draft_nice_competencies_mar2021.xlsx: NIST, 2022.

This HDM Cybersecurity Readiness for Energy Industry is a control framework and takes an organizational approach (which is reflected in the hierarchical structure) [26]. The criteria are essentially Lines of Inquiry (LOI's) that would be asked to gain more information in order to provide assurance and confidence that the organization is ready. For model references in the criterion charts below see Appendix D for an alphabetical listing of criterion that match to the HDM model hierarchy reference architecture.

7.6 Leadership Criteria

Leadership describes capabilities related to the process of creating, communicating, and maintaining policies and procedures within an organization, to formulating effective tactics and metrics associated with the vision, mission, goals, and objectives. Building and managing a productive workforce based on organizational goals, budget considerations, and staffing needs, and ensuring that employees are appropriately recruited, selected, appraised, and rewarded; takes action to address performance problems are included. This perspective also includes retention and career pathing strategies (including mentoring or coaching) for a variety of work situations [226].

Table 19 – Leadership Criteria

Criteria	Elements	Model Reference	Paper Reference	Gaps	Articles
Cybersecurity goals of energy organization are identified	Tools make controls and updating control viable. Dashboards keep goals top of mind. Executive priorities of the energy business not tied to cybersecurity realities can put other users (including consumers) at risk.	10, 30	[62, 145]	An organization should have visibility and control of cloud assets. Dashboard for security status setup. [62] Are newer progressive controls in place to meet cyber goals? [145]	Indicators for maturity and readiness for digital forensic investigation in era of industrial revolution 4.0 - Ariffin and Ahmad [62] Adoption of Cybersecurity Capability Maturity Models in Municipal Governments - Miron [145]
Cybersecurity learning sources are available	Resources on cybersecurity and the energy system specific topic threats. Online training on crime organizations and nations with malicious intent. Those with cybersecurity training and responsibilities should know all policies and practices. Smaller organizations don't think they are a target but they are breached in order to get credentials to larger organizations machines, by theft of more credentials or because of implicit trust.	15, 28, 30	[25, 62, 162]	Cybersecurity controls are tailored for the organization. Users should be aware of the cybersecurity. Those with cybersecurity responsibility must be aware of all the organizations policies and practices. [25] Continuous security improvement processes documented. [62] Do you have security actionable resources for people on your staff? [162]	Factors Influencing Cybersecurity Readiness in Deposit Taking Savings and Credit Cooperatives: A Case Study of Nairobi County - Muraguri, et al. [25] Indicators for maturity and readiness for digital forensic investigation in era of industrial revolution 4.0 - Ariffin and Ahmad [62] Cyber Security Basic Defenses and Attack Trends - Cardenas, et al. [162]
Cybersecurity risk is considered priority by C-Suite	The board, and or C-Suite, is not considering cyber a risk. If your assets are important the organization should be paying the same or more attention on security than on ease of use and time to market. The	20, 26, 32, 34	[30, 56, 161, 174]	Is the board of directors security minded. [56] Is terrorism secured against [161]? The Board sets the priorities	Managing Cyberthreat - Trautman [56] Cyber-Terrorism: Nigeria's Payment System Infrastructural

	Chief Information Officer (CIO) should be making strategic decisions as an equal on the board if exists for Information Technology (IT) security awareness [56] at the organizational level. There is no comprehensive plan and recognition of experts for cybersecurity at the strategic level.			and if not considering cyber a risk then it cannot be said that there is a comprehensive plan for terror activities. Paying same or more attention on security than on ease of use and time to market. [174] Cybersecurity should be a key component of the organizations risk management program. [30]	Readiness - Datong [161] Forensic Readiness of Smart Buildings: Preconditions for Cybersecurity Tests - Bajramovic, et al. [174] New tool assesses banks' cybersecurity readiness - Gott and Greenfield [30]
Policies are updated	Organizational policies should match jurisdictional security and privacy requirements. Penalties should be listed. Technical authentication policies should be reviewed and updated regularly. Without policy updates disclosure of data is possible administratively.	8, 22	[144, 153]	The author asks the reader to consider if data from cyber experts will be anonymized to inhibit full disclosure. [144] Is authentication addressed in security policies? [153]	A socio-technical analysis of China's cybersecurity policy: Towards delivering trusted e-Government services - Zhang, et al. [144] Secure Logging in Operational Instrumentation and Control Systems - Bajramovic [153]
Professionals with cyber certifications are in operations roles	Those hired should feel aware of the entire landscape from governance to theory. Security could be not fully implemented. Costly incidents can happen if a problem spins out of control.	28	[25]	Staff should have certifications or recent academic degrees. [25]	Muraguri, et al. [25]

Supply chain cyber risk is considered during procurement	Communications and controls (such as contracts) are setup with vendors and suppliers. Third parties may have vulnerabilities.	17	[159]	Having oversight to activities of third parties in supply chain is key. [159]	Cybersecurity for Financial Institutions: The Integral Role of Information Sharing in Cyber Attack Mitigation - Johnson [159]

7.7 Information Management Criteria

Information Management are one of the two Technical competencies dealing with technology and systems [226]. NIST 800-137 Continuous Monitoring states information management is important because "managing the location and transfer of information is essential to protecting the confidentiality, integrity, and availability of the data" [227]. This Competency describes a learner's capabilities related to logical techniques... to evaluate data and to support organizational work, goals, and plans. Skills needed include: Securing access privileges, broadcasting, switching, control, and operation of telecommunications [226].

Table 20 – Information Management Criteria

Criteria	Elements	Model Reference	Paper Reference	Gaps	Articles
Info Officer is in contact with Internet Service Provider	There is communication between Chief Information Office (or delegate) and the Internet Service Provider or other sites. The Internet Service Provider is part of the internet network interfaces and can add to complete cyber awareness.	25	[91]	The internet service provider (ISP) and IT manager should talk. [91]	Factors Affecting Perceptions of Cybersecurity Readiness Among Workgroup IT Managers - Chapman [91]
Logging is sufficient for security and forensics	Logs must be retrievable and understandable. Log time settings must be protected in order to correctly attribute violations. Bad logging is a limiting factor for forensic teams work so an attack may not be remediated correctly.	7, 9, 22, 27, 30, 39	[62, 100, 143, 147, 153, 172]	Backup logging should be in place. [62] Is the logging system retrievable and	Ariffin and Ahmad [62] The Current State of Insider Threat Awareness and Readiness in Corporate Cyber

				understandable? [100] Are timestamps of events providing certainty of evidence. [153] Insufficient logging was the most limiting factor in cyber investigations. [147] Storage devices should be automated and completely under control at all times. [143] Accurate system time must be kept for logs. [172]	Security - An Analysis of Definitions, Preventions, Detection, and Mitigation - Mills [100] Bajramovic [153] Towards verifiable evidence generation in forensic-ready systems - Daubner, et al. [147] A conceptual model for digital forensic readiness - Pooe and Labuschagne [143] Graded security forensics readiness of SCADA systems - Li, et al. [172]
Network and System admin procedures documented	Setup policies and procedure settings are known. Administrators are identified. Without the policies and procedures thoroughness and clarity are not complete.	6, 22, 26, 28	[25, 70, 153, 174]	Policies for firewalls must be vetted. [25] In electrical grid subnetting between zones is complex [70] Security assessments must be done (during outages if possible). Interconnected devices should be a moderate or higher risk. [174] Are your interfaces ports and protocol hardened? [153]	Muraguri, et al. [25] ICS Testbed Tetris: Practical Building Blocks Towards a Cyber Security Resource - Green, et al. [70] Bajramovic, et al. [174] Bajramovic [153]

Retention periods are in place and used for information and data	Attribution, solving data issues, restoration of data are some reasons why retention is a concern. If no offline backups, based on retention goals, then data could be lost in an attack or too much data could be exposed in an attack.	12, 30	[62, 178]	Scope of network collection should be done. Offline backups kept. [62] A forensic model in must be in place before an event occurs. [178]	Ariffin and Ahmad [62] A Generic Digital Forensic Readiness Model for BYOD using Honeypot Technology - Kebande, et al. [178]
Standards are understood	Create a model to follow tailored to your organization. When standards are misunderstood there may be violations. "Industry standards may be helpful for energy system Operators of Cybersecurity in Energy and closely related industries" [53].	36	[166]	Can the organization meet cybersecurity standards? [166]	Cybersecurity Readiness: An Empirical Study of Effective Cybersecurity Practices for Industrial Control Systems - Pereira da Silva and Bobbert [166]

7.8 Systems Management Criteria

Systems Engineering principles are key to understanding integrated solutions (i.e., both system and environment based) [43]. NIST 800-160 states that cyber resilience builds on risk models for security, cybersecurity, resilience engineering, and survivability [188]. More holistically systems engineering looks at the stages of strategy the throughout the life cycle [188]). Making systems management its own Technical perspective means that the HDM model can account for changes in system such as a change request for significant security changes that can have an outage effect [26].

> Systems Management describes a capability related to executing the collection of cybersecurity information to develop intelligence, work with computer languages and applications, systematically applying statistics while protecting data, database, and resources… [Topics include:] Data recovery, vulnerability mitigation, cryptographic transformation of data, and handling cybersecurity incidents. Understanding the architecture and predicting future behavior.

Mathematical modeling and simulation of networked systems and peripherals. Distributing new or enhanced hardware and software. Building, maintaining, and repairing infrastructure. Understanding software development and interoperability, management of accounts, firewalls, and patches and integrating components. Identification of critical operational issues, and the identification and assessment of adversaries' or foreign intelligence attack capabilities and activities and supporting law enforcement and counterintelligence investigations or activities [226].

Table 21 – Systems Management Criteria

Criteria	Elements	Model Reference	Paper Reference	Gaps	Article
Data loss prevention system is in place	Data Loss Prevention system is essential for critical information and assets. DLP systems provide: logging, malfunction information, forensics, threat information, retention, reporting, and cloud information. A forensic model is in place for when an event occurs is one aspect of DLP. No DLP means there is no large integrated system for threat management.	12, 14, 16, 23, 24, 28, 30, 32, 33	[25, 56, 62, 87, 146, 167, 176, 178, 228]	A data loss prevention (DLP) system must be in place. [25] Reporting procedures captured. [56] A chain of custody should be written down for evidence collection if needed. [62] You can ask: do you prevent, detect, and combat attacks [87]? If so they you have a kind of DLP system. A forensic model for cloud assets needs to be maintained. [178] A forensic model for cloud assets needs to be maintained. The question remains a problem: Is it	Muraguri, et al. [25] Trautman [56] Ariffin and Ahmad [62] Evaluating the cyber security readiness of organizations and its influence on performance - Hasan, et al. [87] Kebande, et al. [178] Experts reviews of a could forensic readiness framework for organizations -

				possible to gather evidence from cloud without cloud providers help? [176] Are information security management systems successfully deployed? [228] Do you have a system for threat management? [167] Cloud forensic information should be available if there is an incident. [146]	Alenezi, et al. [176] Cyber security readiness in the South Australian Government - Borgman, et al. [228] Cybersecurity Readiness of E-tail Organisations: A Technical Perspective - Shah, et al. [167] Mobile Cloud Forensic Readiness Process Model for Cloud-Based Mobile Applications - Sharma, et al. [146]
Energy system outages are planned for	There should be a plan for power loss. Unplanned failures may lead to cascading grid failures.	32	[56]	Contingency plan if lose long term power. [56]	Trautman [56]
Machine limitations are recorded	Limitations of systems configurations ability must be known (before installing preferred). What configuration you can or cannot do (e.g., hardening) because of design limitations is making the organization aware. Protocol limitations of machines are known. Machines that cannot be configured in networks or are misconfigured leave critical infrastructure vulnerable.	26, 30	[62, 174]	Open source and/or propriety software security limitations documented. [62] The concern with cyber components is that interconnected assets information is shared across networks and systems [174]. Knowing what systems can or cannot do (through hardening or because of design limitations) leads to	Ariffin and Ahmad [62] Bajramovic, et al. [174]

				better awareness of security capabilities.	
Network modeling for IoT is done	A security model is done based on protocols and network connections. Cloud assets are modeled. Contracts without specifications around network responsibilities and/or without models are likely to cause dropping the ball with security.	11, 30	[62, 89]	IoT device limitations should be documented. [62] Access control for IoT has different considerations than legacy computers. [89]	Ariffin and Ahmad [62] Internet of Things & Cybersecurity Readiness in Smart-government and Organizations - AlEnezi [89]
Outages are not required for security updates	Spares enable continuous operation. Asset work stoppages can lead to access failures.	26	[174]	Interconnected assets should be identified. [174]	Bajramovic, et al. [174]
Planning for forensic evidence collection	A model for evidence collection enables attribution and/or remuneration by shoring up legal loopholes. There are separate legal considerations for cloud providers. Without forensic planning legal loopholes can leave criminals free.	14, 21, 30	[62, 148, 176]	Post-incident procedures documented. [62] Are industry guidelines used for digital evidence collection? [148] Evidence collection must be planned for separately for cloud providers as it may or may not be possible to gather evidence from a provider without cloud providers help [176]? Cloud forensic inability is a concern and needs to be planned for.	Ariffin and Ahmad [62] Towards a Systemic Framework for Digital Forensic Readiness - Elyas, et al. [148] Alenezi, et al. [176]

Note: Data Loss Prevention used to be called Data Leakage Protection [229].

7.9 Organizational Criteria

Organizational are competencies are mission and business focused [226]. The impact of an attack on mission [must be addressed]… to operate and fulfill the mission. Mission is a "collection of activities.. to perform a task" [230]. Mission is a commonly used term in National Security Systems (NSS) to describe agency goals.

> This competency describes understanding of key business issues including business continuity, contracts, data management plans, and reuse of data and information assets. Understanding how data is shared and with whom and legal and regulatory compliance, and helping others acquire knowledge or develop skills. Skills include training of personnel in telecommunication, training courses, tools that enable the organization and how programs, policies, procedures, rules, and regulations drive and impact the work and objectives of the organization. This perspective includes monitoring and inspecting costs, work, and contractor performance, including assessment of failures and their consequences to meet organizational cybersecurity and risk requirements. Achieving common goals is stressed in order to control risks presented to the company, data, operations and finances through the products or services purchased from parties other than one's own company [226].

Table 22 – Organizational Criteria

Criteria	Elements	Model Reference	Paper Reference	Gaps	
Computer users settings and permissions are known	What each staff person needs to know is understood. Overprivileged setting can lead to more chances	11 ,24, 25	[87, 89, 91]	User settings and permissions are at the crux of cybersecurity practices, and need to	Hasan, et al. [87] AlEnezi [89]

	for breaches of data. Users setting unknown is a gap in security.			be tested [87]. Having the correct permissions set ensures organizational performance. New security requirements must be developed for new types of devices. [89] Line managers should understand cybersecurity profiles for staff. [91]	Chapman [91]
Cybersecurity Readiness Assessments	Quantitative self-rating aids in identifying if the organization is missing controls. No assessments mean no cybersecurity integration is likely being done with the rest of the operations.	11, 16, 32, 36	[56, 89, 166, 228]	Comprehensive list of tailored security considerations. Review of audit process done. [56] Surveys and checklists for auditing must be a part of the organizational process. [89] Is a cyber assessment done annually? [166] Assessments must incorporate assets and data to be holistic. [228]	Trautman [56] AlEnezi [89] Pereira da Silva and Bobbert [166] Borgman, et al. [228]
Documents are marked and protected	Sensitive attachments should be stored separately on protected systems. Haphazard and inconsistent markings that are not standards based (merely organizationally specific) create confusing language for auditors.	20	[161]	Is terrorism considered? [161]	Datong [161]
Presence of Implementation Oversight	Test plans should be verifying baselines. “Need to know” should be incorporated into an oversight plan. User settings should be communicated between	5, 24, 28, 29	[25, 45, 87, 181]	When new technology complexities arise training [87] and requirements need to be updated in and from the baseline. Questions to ask are: Have	Muraguri, et al. [25] An Empirical Assessment of Cybersecurity Readiness and

	employee and manager. Standards implementation that is lacking puts the financials of the organization at risk			polices for firewalls been documented and vetted based on changes [25]? Consistent implementation of security measures is required to mitigate risk properly. [45] Proactive procedures should be in place. [181]	Resilience in Small Businesses - Eilts [45] Hasan, et al. [87] Information Security: Cybersecurity Standards Adoption Among Malaysian Public Listed Companies - Abdalla and Arshad [181]
Presence of legislative understanding	Lack of legal understanding can lead to non-compliance and additional forced oversight. Legal issues can have a costly monetary penalty.	8, 26	[144, 174]	The organization must review the latest privacy legislation. [174] What penalties are in place for non-compliance? [144]	Bajramovic, et al. [174] Zhang, et al. [144]
Social impact of breaches is talked about in the company	Social con artistry, which is one of the easiest ways to get information, is discussed including impacts. Breaches are a concern and when unplanned for information/reputation could be lost.	25	[91]	Social engineering awareness should be covered. [91]	Chapman [91]
There is an organizational common vocabulary for cybersecurity in the energy industry	A defined technical vocabulary should be defined. If users don't understand vocabulary around detection and prevention they cannot discuss or deal with cyberattacks.	25	[91]	Users should have some ability to detect and prevent cyberattacks. [91]	Chapman [91]

7.10 Professional Criteria

Professional competencies may not be job-specific, but rather allow a worker to work well with others, improve performance, and provide value in a workplace more generally. Sometimes called soft or employability skills [226].

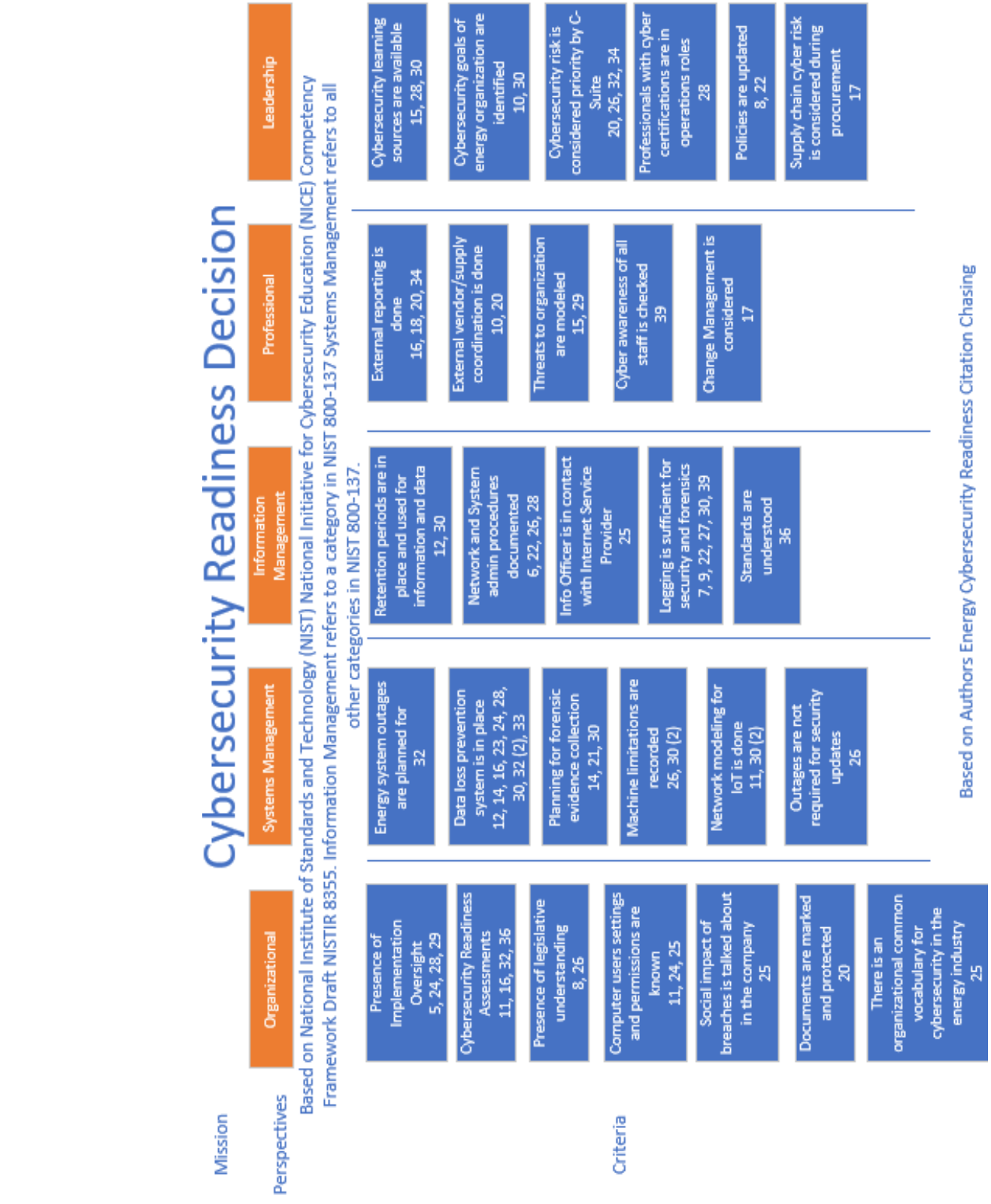
This competency describes capabilities related to effectively expressing information or ideas and understanding when and how to adapt messages for different audiences as well as listening. Managing and resolving conflicts, and collaborating with others to encourage cooperation and teaming. This perspective allows the user to make inferences or draw conclusions that enable sound decision-making in order to work effectively, responding appropriately to the needs, feelings, and capabilities and determining the accuracy and relevance of information and risks while perceiving the impact and implications of the decisions [226].

Table 23 – Professional Criteria

Criteria	Elements	Model Reference	Paper Reference	Gaps	Article
Cyber awareness of all staff is checked	Rogue access points awareness by Wi-Fi users. Malicious links create a man in the middle attack possibility. Vulnerable employees will likely lead to vulnerable organizational assets.	39	[100]	Are staff aware of good and bad cyber behavior. [100]	Mills [100]
External reporting is done	Electricity Information Sharing and Analysis Centers and Computer Security Incident Response Teams help keep industry a step	16, 18, 20, 34	[30, 161, 169, 228]	Do you share information on cybersecurity with your partners? [161] If the industry has an association for	Datong [161] Gott and Greenfield [30]

	ahead of criminals. If no security reports are being made the criminals have a knowledge advantage.			cybersecurity the organization must take part. [30] Reporting to a third-party entity on security must be done. [228] Report to an entity on security is key to effectiveness. [169]	Borgman, et al. [228] Cybersecurity incident response capabilities in the Ecuadorian financial sector - Catota, et al. [169]
External vendor/supply coordination is done	Coordination of security information with other organizations in the supply chain. If no updates then information sharing (thus security) is immature.	10, 20	[145, 161]	Coordination must be done with other organizations for cyber security sharing to be mature. [145] Does your organization get cybersecurity information updates? [161]	Miron [145] Datong [161]
Threats to organization are modeled	A corpus to prioritize and deal with threats. If don't have a threat model then awareness of security and attack vectors is not present.	15, 29	[162, 181]	Do you have a verified and validated threat model? [162] News of threats and breaches should be shared often. [181]	Cardenas, et al. [162] Abdalla and Arshad [181]
Change Management is considered	A repeatable and sustainable framework. Naming conventions, version control system, and document and storage retrieval system. Scope assessment against: quality, risk, schedule, cost, resources, and customer satisfaction are realized. When change is not logged there is an out-of-control situation, that is no one is aware of the current state of vulnerability.	17	[159]	Monitoring changes to network must be done. [159]	Johnson [159]

Figure 24 – The HDM Model with Criteria and Reference Numbers



Note: See Appendix D for article references in the HDM model.

7.11 Model Generalization

HDM serves as a template that can be tailored for repeatability and reproducibility [28]. The open nature of the assessment tool posted makes this is generalizable, tailorable, logical, repeatable, and verifiable. [Generalization means] re-expressing the idea for other applications, sub-criteria, and model building [43]. Generalization implies broad usefulness and removes references to specific goals [231].

Tailoring (aka a unique implementation) would involve choosing a narrower, broader, or a special interest focus [43]. Overlays to the HDM controls model (Note: Overlay is terminology used by CNSSI 1253 for implementing NIST 800-53 controls for certain organizational types tailoring) can be created. “Overlays… are agreed to by subject matter experts… to address divergence… from [a models] baseline” [232]. An overlay is the first step to tailoring [232]. Each overlay use case represents an “organizational indicator” of what is likely to be required [26]. Tailoring is also called Tuning Variables by Microsoft in technical implementations [233].

In conclusion, this HDM model adds a cultural approach (which is reflected in the hierarchical structure) rather than a purely technical or practical approach. Using the HDM quantitative decision-making model creates outputs to make better informed decisions based on organizational needs for impact and mission.

CHAPTER 8: CASE ANALYSIS

8.1 Research Application

This chapter presents the results of conducting the research steps. The initial model was developed based on literature review findings. A multimethod approach of literature review, expert interviews, and data questionnaires was used to collect data for this PhD. The data questionnaire invitation was responded to by 54 experts who showed their willingness to contribute and serve as an expert in Readiness of Cybersecurity for the USA Energy Industry research subject. All experts work or have recently worked (within the last three years), in the USA Energy Industry.

Each expert received an invitation letter of consent to determine their abilities to participate. Experts were identified through recommendations of committee members, through personal contacts, and via LinkedIn. Qualtrics data questionaries were used to collect experts' judgment and responses for both the validation and quantification steps of the research model.

Validation testing with subject matter experts (SMEs) was undertaken to verify that HDM model conforms to the core concepts and intent of Cybersecurity Readiness. After the consent form was submitted, the data questionnaire was sent to the expert. The pairwise comparison was then calculated in the ETM-HDM online software, developed by Portland State University. For the HDM portion the expert focused on two elements at a time, in order to provide a more precise evaluation [49] overall.

A hierarchy is noted as a composition of inductive generalization… to get a composite result [49]. HDM assumes preferential independence of decision elements at each level [209] so that panels can be formed.

Some of the HDM judgements were inconsistent. Two participants were removed from the analysis as none of their data could be used. Several other participants contributed to more than one data questionnaire but because of inconsistency not all their pairwise comparisons could be included in the final results.

> The "level of inconsistency must be measured and controlled to ensure soundness of the decision. Inconsistency is a slight or gross, deliberate or unintentional error in the elicited pairwise judgment related to the rank order and mutual preference proportionality of alternatives" [209].

Pairwise comparisons made by the experts during the analysis are shown in the following equation.

Table 24 – Pairwise Comparison Formula and Count

$N = n(n\text{-}1)/2$ where $n > 0$

Thus, for the pairwise comparisons in this study:

- Perspectives number of comparisons, $N = 5(4)/2 = 10$
- Organizational Criterion number of comparisons, $N = (7(6))/2 = 21$
- Systems Management Criterion number of comparisons, $N = 6(5)/2 = 15$
- Information Management Criterion number of comparisons, $N = 5(4)/2 = 10$
- Professional Criterion number of comparisons, $N = 5(4)/2 = 10$
- Leadership Criterion number of comparisons, $N = 6(5)/2 = 15$

The experts count represent a balanced group with all the experience types related to Readiness of Cybersecurity in the USA Energy Industry being included. A balanced group increase minimize the bias and increase the reliability of the results [234].

Experts were assigned to the 12 panels based on the type of their experience. 19 experts have or recently had an affiliation with an Agency of Government. 35 had commercial Private Entity experience with no significant (over one year) recent Agency of Government experience within the last 3 years.

Table 25 – Experts Roles and Questionnaire Participation

Experts Information			**Questionnair**	**HDM Quantification Questionnaire**						**Desirability Quantification Questionnaire**				
ID	**Company**	**Role**	**Validation**	**Perspectives**	**Organizatio**	**Info Mgmt**	**Sys Mgmt**	**Professional**	**Leadership**	**D Sys Mgmt**	**D Prof**	**D Org**	**D Leader**	**D Info Mgmt**
1	INL	Training Opportunities and Strategy Lead	X											
2	PNNL	Cybersecurity Director	X	X										
3	Avangrid	Senior Cybersecurity Protection Analyst	X		X			X	X					
4	PGE	Program Manager, Security Awareness	X											
5	CISA	Cybersecurity Advisor	X											
6	SCL	CISO/Director Information Security	X						X					
7	Gannett Fleming	Information Security Consultant	X	X	X	X	X	X	X					
8	Siemens	Director Industrial Cyber Security GTM North America	X											

9	CISA / Edison Electric Institute	Managing Director, Cyber & Infrastructure Security	X											
10	INL	Homeland Security Division Director	X		X				X	X	X	X	X	X
11	INL	Program Manager	X											
12	SCL	Cyber Security Sr Manager, CISO	X					X						
13	Northwestern Energy	Security Consultant	X					X						
14	PLM / PNNL	SCADA Engineer	X		X									
15	Hawaii Electric / PG&E	System Engineer	X			X								
16	National Grid	Enterprise Architect	X											
17	WECC / Archer	Risk Manager	X		X									
18	Piedmont Natural Gas	SCADA Administrator	X											
19	INL	Energy Strategist	X											
20	Dragos	Technical Engineer		X										
22	CAISO	Compliance Analyst			X									
23	Duke	Cyber Engineer				X	X							
24	Evergy	OT Manager		X										
25	PGE	IT Security Analyst			X									
26	Gannett Fleming	Cybersecurity Compliance						X						
27	NAES	Security Director		X	X									
28	Entergy	IT Compliance			X									
29	KPMG/BPA	Cybersecurity ISSO						X						
30	SEMCO/DTE	IT Enterprise Architect				X	X							

31	SERC	Cybersecurity Specialist							X						
32	Accenture/ Westinghouse	Cybersecurity Consultant		X											
33	Vermont Power	Cybersecurity Analyst			X										
35	1898	Director		X					X						
36	DOE	Cybersecurity Director							X						
37	Schneider Electric	Cybersecurity Consultant		X	X	X	X								
38	ISO New England	Engineer and Architect						X	X						
39	NREL	Cybersecurity Researcher		X	X	X	X	X	X						
40	LADWP	Cybersecurity Specialist		X	X										
41	Boyett Petroleum	IT Admin		X	X	X	X	X	X						
42	PSE	Infrastructure Security		X		X		X							
43	Williams	IT Analyst				X	X								
44	ExxonMobil/ DOE	IT Specialist		X				X	X						
45	Nozomi/GE	Technical Leader					X	X	X	X	X	X	X	X	X
46	DCP Midstream	OT Specialist				X	X								
47	Sandia	Engineering Staff				X	X								
48	Johnson Controls	OT Engineer								X	X	X		X	
49	Orsted/MAN Energy	Product Engineer									X	X	X		
50	Liberty Utilities	IT Helpdesk											X		
51	Duke	Cybersecurity Analyst										X			
52	NextEra	Compliance Specialist										X	X	X	
53	WAPA	IT Director											X		
54	Eversource Energy	Identity and Access Mgmt. Specialist									X				
55	DER Security Corp	Software Engineer								X			X	X	
56	CI-Discern/ WAPA	Chief Cyber Advisor												X	
54			**19**	**13**	**14**	**11**	**10**	**12**	**12**	**4**	**5**	**6**	**7**	**6**	

8.1.1 Data Collection

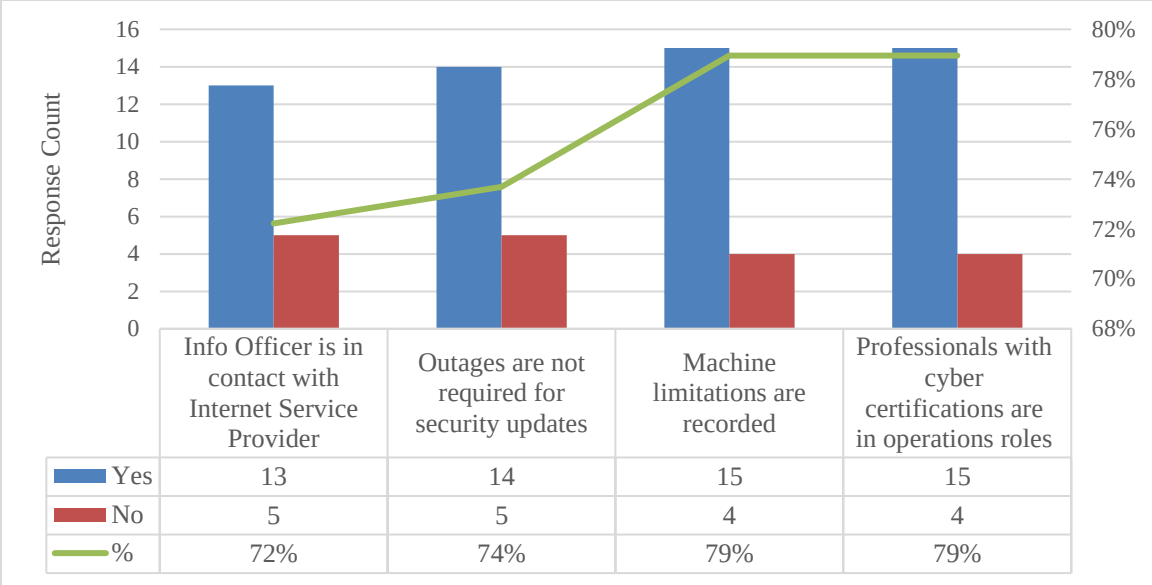
Appendix G includes a sample of the invitation and samples of additional communications with experts. Experts evaluated the data points identified by the research as the most critical factors affecting Readiness of Cybersecurity in the energy industry. Experts were given a chance to suggest other criteria based on their experience.

Additional explanation and communication with experts were undertaken if requested by the expert using one-on-one meetings. Experts never met each other or had the chance to discuss the data questionnaires between themselves. This approach eliminates the "loud voice" and "bystander" problems associated with eliciting experts' judgment using workshops [234]. Experts were invited from all over the country to minimize the bias that might result from experts representing a single region, corporation or background.

8.1.2 Panels

Panels were created for perspectives validation, cybersecurity readiness pairwise comparison and desirability metrics quantification. Panel (1) consisted of nineteen experts who responded to validate the model. All criteria passed (there was no redesign of the model) being that 2/3rd's (66.6%) accepted the criteria for inclusion [203, 219] into the final model. This validates that the decision model and the goal of the research is properly formed, and that the results add value to Readiness of Cybersecurity in the USA Energy Industry.

Figure 25 - Most Contentious Validation Criteria



	Info Officer is in contact with Internet Service Provider	Outages are not required for security updates	Machine limitations are recorded	Professionals with cyber certifications are in operations roles
Yes	13	14	15	15
No	5	5	4	4
%	72%	74%	79%	79%

8.1.2.1 Validation Questionnaire Results

Perspectives (Panel 1)

Perspectives are variables at the strategic level. Perspectives (in addition to criteria) were validated. The professional perspective was the least scoring validated perspective at 84%. Based on comments from the validation responses the greatest challenge going forward is to include Operational Technology as related to Readiness of Cybersecurity in the energy industry.

Three experts recommended that Operational Technology be added as a perspective. After further evaluation there are only two criteria (currently under Systems Management) in this model that would fit into an Operational Technology perspective (Network modeling for IoT is done, and Outages are not required for security updates). Future work on Operational Technology related to Readiness of Cybersecurity in the USA Energy Industry needs to be conducted as the academic literature expands over time.

Table 26 - Expert Panel 1, Perspectives Level Validation

Perspectives	Yes	No	%
Organizational	19	0	100%
Information Management	17	2	89%
Systems Management	19	0	100%
Professional	16	3	84%
Leadership	19	0	100%

Comments Summary:

- consider risk to business
- compliance conflicts with security
- add operational technology as a perspective
- add operational technology as a perspective
- add operational technology as a perspective
- use NIST ICS instead of NIST Continuous Monitoring to segregate Technical perspective

Organizational (Panel 2)

For the Organization panel one criteria Presence of legislative understanding was found by many to have a lack of importance. Although not one of the lowest scoring or highest scoring criterion the Presence of legislative understanding final score ranked low in both cases (average 1.05). This means that the desirability in practical application for this criterion is low. In literature this is important gap to address, but the experts who filled out the desirability curves disagreed.

> The Federal to State to Local jurisdiction communication pipeline for topics of: regulations need, information sharing capability, and funding support is lacking. If state legislatures can't fund the programs, then State cybersecurity will be deficient. USA States and local jurisdictions don't have money for Cybersecurity programs. The Centers of Excellence (COE) in academic universities are being

used as SOC and CSIRTs currently. The COE's initiatives are operational based on student engagement/volunteerism [235].

Local authorities [e.g. utilities]… are of modest means and cybersecurity professionals are scarce [236]. Lack of resources is a problem for implementation.

Legal policies, regulation, and enforcement is complex in the USA because of the Federal, State, and Local decentralized jurisdictional structure. Publishing mandatory polices is necessary so that agencies and entities can be held accountable. Voluntary standards such as the early NERC CIP standards [237] are ineffective. Legal policies, whether voluntary or mandatory, should be reassessed periodically because technical capabilities, people's concerns, ability to trust, and cultures change.

Table 27 - Expert Panel 2, Organizational Level Validation

Organizational	Yes	No	%
Presence of Implementation Oversight	19	0	100%
Cybersecurity Readiness Assessments	18	1	95%
Presence of legislative understanding	16	3	84%
Computer users settings and permissions are known	18	1	95%
Social impact of breaches is talked about in the company	18	1	95%
Documents are marked and protected	18	1	95%
There is an organizational common vocabulary for cybersecurity in the energy industry	18	1	95%

Comments Summary:

- system of record must be considered a high value asset
- agencies of government will remove sensitive information for us
- add operational technology factors
- teach cyber maturity
- each organization should use a standard lexicon
- sensitive information definition is not clear

Information Management (Panel 3)

One criteria Info Officer is in contact with Internet Service Provider was found by many to have a lack of importance. One commentor stated that this is not something an Information Officer would normally do. This was the lowest scoring criteria in the case models (.4). Based on the low score either this criterion is a severely lacking communication channel or there is an alternative method to mitigating provider backbone communication in terms of security. This should be investigated in future research.

Table 28 - Expert Panel 3, Information Management Level Validation

Information Management	Yes	No	%
Retention periods are in place and used for information and data	17	1	94%
Network and System admin procedures documented	18	0	100%
Info Officer is in contact with Internet Service Provider	13	5	72%
Logging is sufficient for security and forensics	18	0	100%
Standards are understood	18	0	100%
	*Only 18 respondents		

Comments Summary:

- add Info Protection Plan
- Operational technology uses isolated encrypted networks
- these criteria are applicable to most industries
- ISP is rarely communicated with

Systems Management (Panel 4)

Systems management criteria were the most contended of any of the perspectives. Validation experts were slightly unsure on whether these criteria were applicable to Readiness of Cybersecurity in the USA Energy Industry.

Outages are not required for security updates was found to be one of the most important criteria through the HDM models pairwise comparisons. Outages are not required scored second at highest (21%) in the Systems Management perspective. Only

one of the literature articles mentioned Outages are not required for security updates is important for readiness. An entity needs a plan to operate without the system. Availability generally relies on engineering design, configuration management, redundancy, functional analysis, communication network analysis, and engineering practices [238].

Machine limitations are recorded was found to be one of the most unimportant criteria through the HDM models pairwise comparisons. This was one of the lowest scoring final scores (average 1.05). More research should be done to find out why. It is important to note that this criterion has impact on configuration management. One commenter mentioned that the machine limitations definition is not clear.

Table 29 - Expert Panel 4, Systems Management Level Validation

Systems Management	Yes	No	%
Energy system outages are planned for	16	3	84%
Data loss prevention system is in place	18	1	95%
Planning for forensic evidence collection	17	2	89%
Machine limitations are recorded	15	4	79%
Network modeling for IoT is done	16	3	84%
Outages are not required for security updates	14	5	74%

Comments Summary:

- add asset classification
- Operators should be qualified to address business issues
- work must be done when full staff is available so no outage
- add operational technology factors
- DLP is very complex and may need to be broken out
- machine limitations definition is not clear

Professional (Panel 5)

The experts overwhelmingly agreed with the professional criteria. Experts agreed that Cyber awareness of all staff is checked is the most important criterion for the Professional perspective (HDM pairwise score of 29%).

Table 30 - Expert Panel 5, Professional Level Validation

Professional	Yes	No	%
External reporting is done	19	0	100%
External vendor/supply coordination is done	19	0	100%
Threats to organization are modeled	19	0	100%
Cyber awareness of all staff is checked	18	1	95%
Change Management is considered	19	0	100%

Comments Summary:

- change management is key
- add patch management as a criterion
- know your attack surface
- continuous testing when changes happen
- criteria are not well defined

Leadership (Panel 6)

Table 31 - Expert Panel 6, Leadership Level Validation

Professionals with cyber certifications are in operations roles was the most contended criterion at the validation point. Through HDM this criterion was neither important nor unimportant. Cybersecurity risk is considered priority by C-Suite was the highest scoring criterion in the HMD model (30%).

Leadership	Yes	No	%
Cybersecurity learning sources are available	19	0	100%
Cybersecurity goals of energy organization are identified	19	0	100%
Cybersecurity risk is considered priority by C-Suite	19	0	100%
Professionals with cyber certifications are in operations roles	15	4	79%
Policies are updated	19	0	100%
Supply chain cyber risk is considered during procurement	19	0	100%

Comments Summary:

- CISO should be a VP
- add continuing education
- add access to threat intelligence
- VP or Officer should sign off for detailed access to Critical Infrastructure Info
- Certifications are not needed for operational technology. Experience and training are.

8.1.2.2 HDM Results

The results show that all the experts reflect an acceptable level of HDM inconsistency in their judgments (<0.1). There is no significant level of disagreement among the experts (<0.1), which is the average of the standard deviations. Thus, the results are valid. If the expert score inconsistency was less than 10% the expert was contacted to retake the data questionnaire. No data that was resubmitted resulted in a then consistent score.

Figure 26 - Cronbach's Alpha Rule of Thumb

Cronbach's alpha	Internal consistency
$\alpha \geq 0.9$	Excellent
$0.8 \leq \alpha < 0.9$	Good
$0.7 \leq \alpha < 0.8$	Acceptable
$0.6 \leq \alpha < 0.7$	Questionable
$0.5 \leq \alpha < 0.6$	Poor
$\alpha < 0.5$	Unacceptable

Note: Taken from A. Terminato, A. N. Hidayanto, and W. Nugroho, "Measurement of Readiness Levels for Adoption of Enterprise Resource Planning Clouds in Small Medium Enterprise with Net Ready Model," Journal of computational and theoretical nanoscience, vol. 16, pp. 5396-5407, 2019.

HDM validity testing for inconsistency and disagreement align with Cronbach's alpha rule of thumb where any responses with consistency of 90% are considered

excellent data. If an expert judgment is inconsistent beyond 10%, this means he or she might not be experts after all [234].

Perspectives (Panel 7)

Perspectives are grouping categories to which importance weights are given by expert subjective judgment pairwise comparison. This is the same pairwise comparison as criteria weighting mechanism. Each perspective has a number of items calculated with a minimum, maximum, mean, and std. deviation [28] shown below. From the results, Leadership (26%) ranked as the most important perspective with respect to the mission (aka Readiness of Cybersecurity in the USA Energy Industry). The Perspectives panel consisted of 13 experts, 4 of which were from Agencies of Government and the rest from Private Entities.

Table 32 - Analysis of Expert Panel Results, Assessment Perspectives with Respect to the Mission

ID	Organizational	Information Management	Systems Management	Professional	Leadership	Inconsistency
41	0.25	0.19	0.21	0.08	0.27	0.01
27	0.14	0.16	0.13	0.17	0.4	0.01
44	0.2	0.2	0.2	0.2	0.2	0
32	0.15	0.14	0.17	0.13	0.4	0.03
37	0.19	0.22	0.21	0.18	0.2	0.04
2	0.11	0.15	0.19	0.08	0.47	0.03
7	0.16	0.29	0.23	0.18	0.14	0.01
40	0.2	0.21	0.18	0.16	0.24	0.01
42	0.34	0.11	0.11	0.19	0.25	0.04
20	0.16	0.13	0.24	0.38	0.08	0.03
35	0.16	0.15	0.2	0.25	0.24	0.01
24	0.27	0.16	0.17	0.13	0.28	0.03
39	0.21	0.23	0.2	0.17	0.19	0.03
Mean	**0.2**	**0.18**	**0.19**	**0.18**	**0.26**	

Minimum	0.11	0.11	0.11	0.08	0.08	
Maximum	0.34	0.29	0.24	0.38	0.47	
Std. Deviation	0.06	0.05	0.04	0.07	0.11	
Disagreement						0.061

Note: Leadership was the highest scoring Perspective and is highlighted in green.

Figure 27 - Perspectives of Readiness Importance Government vs Industry

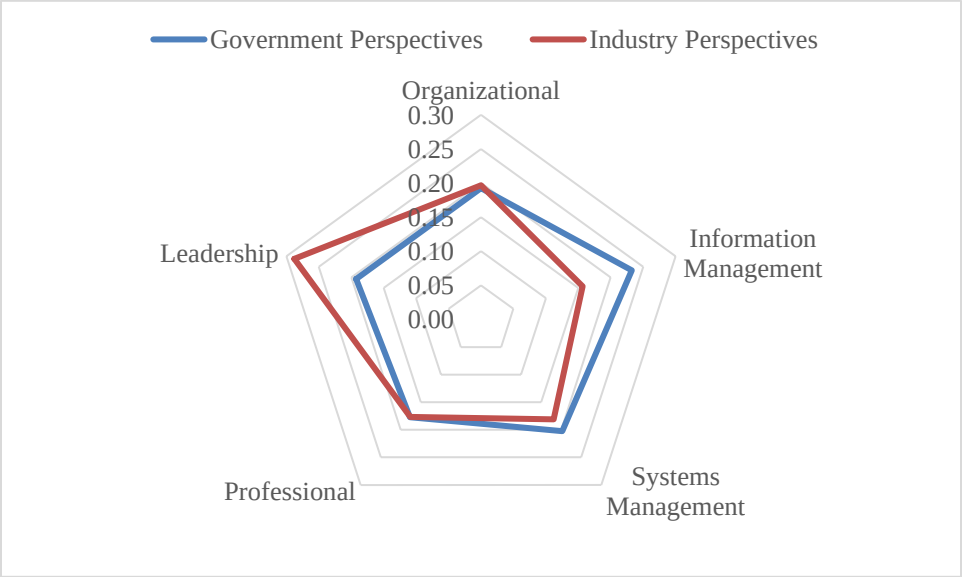


Table 33 - Data Table for Perspectives Radar Chart Figure

ID	Organizational	Information Management	Systems Management	Professional	Leadership
Agencies of Government Perspectives	0.19	0.23	0.20	0.18	0.19
Private Entity Perspectives	0.20	0.16	0.18	0.18	0.29

Note: Agencies of Government Perspective Experts N = 4, Private Entity Perspective Experts N=9. Total experts equal 13.

Agencies of Government experts agree that Information Management is the most important perspective for readiness. In Agencies of Government information management is often mandated by multiple oversight bodies which helps explains why

information management is most important in Agencies of Government. In Private Entities the most important perspective is Leadership. Leadership in Private Entities supports cybersecurity spending.

Analysis of Panel 7

The results show that all the experts had an acceptable level of consistency in their judgments (<0.1). There is no significant level of disagreement among the experts (0.061).

Leadership includes, but is not limited to:

- "Experienced executives understand a strong culture always trumps strategy" [239].
- Policy Development, Strategic Planning and Workforce Management.
    - Policies in company need to be updated so that new risks/new technology/new configurations are captured into the organizational culture management.
        - Culture management helps "disparate business units unite by a common set of goals and values" [240].

Organizational (Panel 8)

This panel consisted of 14 experts, 6 of which were from Agencies of Government.

Table 34 - Analysis of Expert Results, Organizational Readiness Perspective

ID	Computer users settings and permissions are known	Cybersecurity Readiness Assessments	Documents are marked and protected	Presence of Implementation Oversight	Presence of legislative understanding	Social impact of breaches is talked about in the company	There is an organizational common vocabulary for cybersecurity in the energy industry	Inconsistency
14	0.32	0.18	0.28	0.09	0.03	0.04	0.04	0.06
41	0.16	0.15	0.14	0.14	0.19	0.09	0.13	0.03
27	0.33	0.21	0.09	0.12	0.08	0.07	0.09	0.02
3	0.25	0.07	0.15	0.24	0.15	0.05	0.09	0.03
33	0.23	0.13	0.2	0.14	0.19	0.04	0.06	0.09
37	0.07	0.3	0.17	0.17	0.05	0.17	0.06	0.04
7	0.12	0.2	0.1	0.17	0.06	0.16	0.19	0.01
40	0.15	0.15	0.13	0.11	0.15	0.12	0.19	0.01
28	0.21	0.06	0.11	0.15	0.17	0.12	0.18	0.09
22	0.17	0.15	0.16	0.21	0.1	0.11	0.1	0.03
17	0.21	0.16	0.1	0.25	0.04	0.08	0.17	0.04
10	0.19	0.28	0.12	0.09	0.11	0.11	0.09	0.05
39	0.12	0.12	0.22	0.13	0.14	0.12	0.14	0.04
25	0.33	0.17	0.05	0.18	0.07	0.07	0.13	0.04
Mean	**0.2**	**0.17**	**0.14**	**0.16**	**0.11**	**0.1**	**0.12**	
Minimum	0.07	0.06	0.05	0.09	0.03	0.04	0.04	
Maximum	0.33	0.3	0.28	0.25	0.19	0.17	0.19	
Std. Deviation	0.08	0.06	0.06	0.05	0.05	0.04	0.05	
Disagreement								0.055

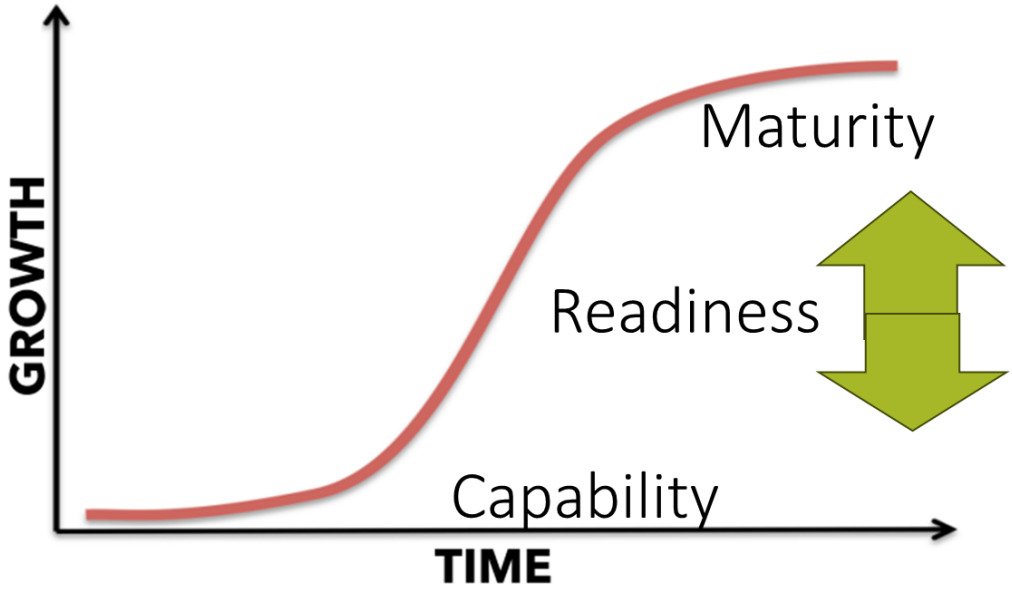
Analysis of Panel 8

The results show that all the experts reflect an acceptable level of consistency in their judgments (<0.1). There is no significant level of disagreement among the experts (0.055). Experts agreed that computer user's settings and permissions are known is the most important criterion (20%) for the organizational perspective.

The readiness of cybersecurity in the USA energy industry strategy should include identifying and tracking what each staff person needs to know especially regarding privileges and user's settings.

The second highest scoring criteria was Cybersecurity Readiness Assessments (17%) should be done. Strategies must be developed to address designs, remediations, (preemptive), mitigations (reactive), emergent issues and subsequent actions. Readiness should be early and continuous. If no assessments are regularly done, then the company has no information to build a better program.

Figure 28 - Where Readiness Assessments Fit into the Process of an Organizational Lifecycle



Information Management (Panel 9)

This panel consisted of 11 experts, 2 of which were from Agencies of Government.

Table 35 - Analysis of Expert Results, Information Management Readiness Perspective

ID	Info Officer is in contact with Internet Service Provider	Logging is sufficient for security and forensics	Network and System admin procedures documented	Retention periods are in place and used for information and data	Standards are understood	Inconsistency
46	0.04	0.29	0.39	0.13	0.16	0.06
41	0.07	0.19	0.25	0.15	0.32	0.06
23	0.03	0.22	0.21	0.25	0.3	0.04
37	0.1	0.24	0.29	0.17	0.2	0.04
7	0.14	0.1	0.54	0.08	0.15	0.01
30	0.02	0.32	0.2	0.38	0.08	0.07
42	0	0.24	0.31	0.16	0.29	0.01
15	0.08	0.06	0.25	0.28	0.33	0.03
47	0.02	0.23	0.19	0.1	0.46	0.01
43	0.04	0.08	0.27	0.2	0.42	0.06
39	0.08	0.2	0.27	0.21	0.25	0.05
Mean	**0.06**	**0.2**	**0.29**	**0.19**	**0.27**	
Minimum	0.02	0.06	0.19	0.08	0.08	
Maximum	0.14	0.32	0.54	0.38	0.46	
Std. Deviation	0.04	0.08	0.1	0.08	0.11	
Disagreement						0.075

Analysis of Panel 9

The results show that all of the experts reflect an acceptable level of consistency in their judgments (<0.1). There is no significant level of disagreement among the experts (0.075).

Responses to Network and System admin procedures documented and Standards are understood had almost equal relative importance and ranked (29%) and (27%) respectively.

Procedures provide clarity that things are covered in an organization. Discussions with team members, assessments to compare actual vs expected, and checklists for a one-to-one comparison will be follow up activities.

Standards enable planning for emergency, safety and security, and reliable energy power. Reliability is important because less failure means more sustainability which equal higher gross margins, and higher operating margins. This criterion can be achieved by creating a policy of standards to be followed within the company. The implementation of standards policy list mitigates the model problem of when standards are misunderstood there will be audit violations. The company needs staff that can interpret the standards.

Systems Management (Panel 10)

This panel consisted of 10 experts, 2 of which were from Agencies of Government. System is not simply a host or machine; it also means studying the behavior of complex environmental problems of those hosts and machines. The Soft Systems Methodology (SSM) developed originally in the 1970s by Peter Checkland [241] is a way to take a systems thinking approach of thinking through all system applications, perceptions, practices, and interpretations to engage and solve actions. In this case software applications and databases are included in systems management thinking.

Table 36 - Analysis of Expert Results, Systems Management Readiness Perspective

ID	Data loss prevention system is in place	Energy system outages are planned for	Machine limitations are recorded	Network modeling for IoT is done	Outages are not required for security updates	Planning for forensic evidence collection	Inconsistency
46	0.22	0.23	0.09	0.02	0.24	0.22	0.07

41	0.11	0.18	0.11	0.17	0.24	0.17	0.01
23	0.14	0.12	0.11	0.13	0.14	0.34	0.01
37	0.12	0.27	0.06	0.09	0.32	0.13	0.02
7	0.28	0.16	0.17	0.18	0.08	0.13	0.03
30	0.26	0.15	0.28	0.11	0.05	0.16	0.01
47	0.21	0.11	0.12	0.12	0.27	0.18	0.07
43	0.25	0.11	0.07	0.11	0.32	0.15	0.03
39	0.14	0.4	0.06	0.03	0.31	0.06	0.04
45	0.14	0.44	0.11	0.11	0.08	0.12	0.03
Mean	**0.19**	**0.22**	**0.12**	**0.11**	**0.21**	**0.17**	
Minimum	0.11	0.11	0.06	0.02	0.05	0.06	
Maximum	0.28	0.44	0.28	0.18	0.32	0.34	
Std. Deviation	0.06	0.11	0.06	0.05	0.1	0.07	
Disagreement							0.076

Analysis of Panel 10

The results show that all the experts reflect an acceptable level of consistency in their judgments (<0.1). There is no significant level of disagreement among the experts (0.076).

Responses to Energy system outages are planned for and Outages are not required for security updates have almost equal relative importance and ranked (22%) and (21%). An entity needs a plan to operate without the system. An unscheduled outage in the power system is an unacceptable mission impact in the Energy Industry. One data questionnaire expert stated that “Continuity of Operations (COOP) is important because people lives are in line and affected.”

Professional (Panel 11)

This panel consisted of 12 experts, 4 of which were from Agencies of Government.

Table 37 - Analysis of Expert Results, Professional Readiness Perspective

ID	Change Management is considered	Cyber awareness of all staff is checked	External reporting is done	External vendor/supply coordination is done	Threats to organization are modeled	Inconsistency
41	0.16	0.24	0.14	0.15	0.31	0.02
26	0.23	0.42	0.02	0.3	0.03	0.06
3	0.3	0.16	0.22	0.08	0.24	0.01
44	0.07	0.21	0.11	0.26	0.34	0.08
7	0.31	0.3	0.13	0.15	0.1	0.03
12	0.13	0.39	0.03	0.21	0.23	0.02
42	0.13	0.39	0.03	0.21	0.23	0.02
29	0.27	0.26	0.21	0.16	0.1	0.01
38	0.14	0.18	0.15	0.19	0.34	0.05
39	0.21	0.44	0.1	0.15	0.1	0.05
13	0.28	0.15	0.07	0.18	0.32	0.06
45	0.14	0.3	0.08	0.16	0.32	0.03
Mean	**0.2**	**0.29**	**0.11**	**0.18**	**0.22**	
Minimum	0.07	0.15	0.02	0.08	0.03	
Maximum	0.31	0.44	0.22	0.3	0.34	
Std. Deviation	0.08	0.1	0.06	0.05	0.11	
Disagreement						0.08

Analysis of Panel 11

The results show that all the experts reflect an acceptable level of consistency in their judgments (<0.1). There is no significant level of disagreement among the experts (0.08).

Experts agree that Cyber awareness of all staff is checked is the most important criterion for the Professional perspective. The Readiness for Cybersecurity in the USA Energy industry strategy should have awareness of access points and malicious links. This encompasses most of the cross-site scripting (XXS) attacks, phishing etc. in which

one receives a link to click that enables an adversary to open a shell (local access control). Being able to remediate against this vector is a high priority.

Leadership (Panel 12)

This panel consisted of 12 experts, 5 of which were from Agencies of Government.

Table 38 - Analysis of Expert Results, Leadership Readiness Perspective

ID	Cybersecurity goals of energy organization are identified	Cybersecurity learning sources are available	Cybersecurity risk is considered priority by C-Suite	Policies are updated	Professionals with cyber certifications are in operations roles	Supply chain cyber risk is considered during procurement	Inconsistency
41	0.15	0.09	0.42	0.13	0.12	0.1	0.03
6	0.16	0.1	0.2	0.21	0.15	0.18	0.05
3	0.08	0.13	0.28	0.04	0.05	0.43	0.02
44	0.1	0.12	0.15	0.09	0.18	0.36	0.07
7	0.15	0.12	0.27	0.08	0.24	0.14	0.03
31	0.02	0.01	0.9	0.01	0.01	0.04	0.02
35	0.13	0.09	0.26	0.13	0.21	0.19	0.01
38	0.35	0.08	0.23	0.11	0.02	0.22	0.06
10	0.18	0.12	0.19	0.04	0.36	0.11	0.06
39	0.22	0.08	0.17	0.27	0.12	0.15	0.02
36	0.15	0.19	0.25	0.09	0.09	0.23	0.02%
45	0.19	0.1	0.24	0.17	0.13	0.16	0.02
Mean	**0.16**	**0.1**	**0.3**	**0.11**	**0.14**	**0.19**	
Minimum	**0.02**	**0.01**	**0.15**	**0.01**	**0.01**	**0.04**	
Maximum	**0.35**	**0.19**	**0.9**	**0.27**	**0.36**	**0.43**	
Std. Deviation	**0.08**	**0.04**	**0.19**	**0.07**	**0.09**	**0.1**	
Disagreement							**0.089**

Analysis of Panel 12

The results show that all of the experts reflect an acceptable level of consistency in their judgments (<0.1). There is no significant level of disagreement among the experts (0.089).

Experts agreed that Cybersecurity risk is considered priority by C-Suite is the most important criterion for the Leadership perspective. The board of directors and the C-Suite professionals should be involved in cybersecurity risk engagement. The Chief Information Officer (CIO) should be an equal on the board as noted by one expert during validation.

> Organizations with successful cybersecurity cultures tend to have C-suite executives who reinforce behavioral norms when they lead by example. They appoint—or become—a senior level champion, participate in town hall discussions, allocate budgetary support, hire consultants, and do the research to assess the enterprise's risk and capabilities [242].

If Executives don't understand risk, then they will not act. If companies don't think they are targets they will not invest or act. Private Entity standards and best practice adherence is needed to maintain a quality network of services. The products and services must be robust enough to enable all the other more technical and administrative, and cultural aspects to be performed.

One executive expert PhD interviewee commented that a good readiness process requires sticking your neck out for the business case.

> CEOs from the best companies… hold everyone accountable for cybersecurity and therefore demand education, training, and constant testing of their workforce at every level. They establish clear and enforceable standards and set the priorities for what information must be protected. They have strong, empowered CIOs that are accountable and report directly to them. They establish organizational structures and processes that optimize alignment of responsibility, authority, and accountability. They maintain good situational awareness of their organizations' cyber-health and require and use dashboards and scorecards to predict and monitor performance. They mandate the use of simulations and threat modeling to train their personnel and prepare of "0" day events [239].

The second highest criteria was Supply chain cyber risk is considered during procurement (at 19%). One data questionnaire expert commented that outsourcing cyber security specialists to 3rd party companies (is a risk because they) are not could possibly overreach with stop work orders which would shut down operations. This expert thought that supply chain risk needs to be handled in-house.

8.1.2.3 Final Model

Leadership is the most important perspective for increasing the readiness of Cybersecurity in the USA Energy Industry according to the experts. Local weights are based on the criteria within a single perspective whereas global weights are the weights when summing all perspectives to equal 1. The second level Perspectives define categorizations for decision makers to use to support decisions related to the outcome.

Each criteria have a global weight and local weight within its parent perspective. “Quantifying perspective and factors and valuing both global and local weights is necessary for any degree of clarity in decision-making” [243]. The result thereby bring clarity to the diverse options available and displaying the importance and utility of each option [35]. The HDM model results are helpful because they “help the participants in their decision making in the sense that they supported them in revising their decisions by providing recommendations that do not completely override their initial preferences” [244]. This section shows the global contribution of the factors to the overall objective of assessing Readiness of Cybersecurity in the USA Energy Industry. The final HDM model with local and global weights is shown below.

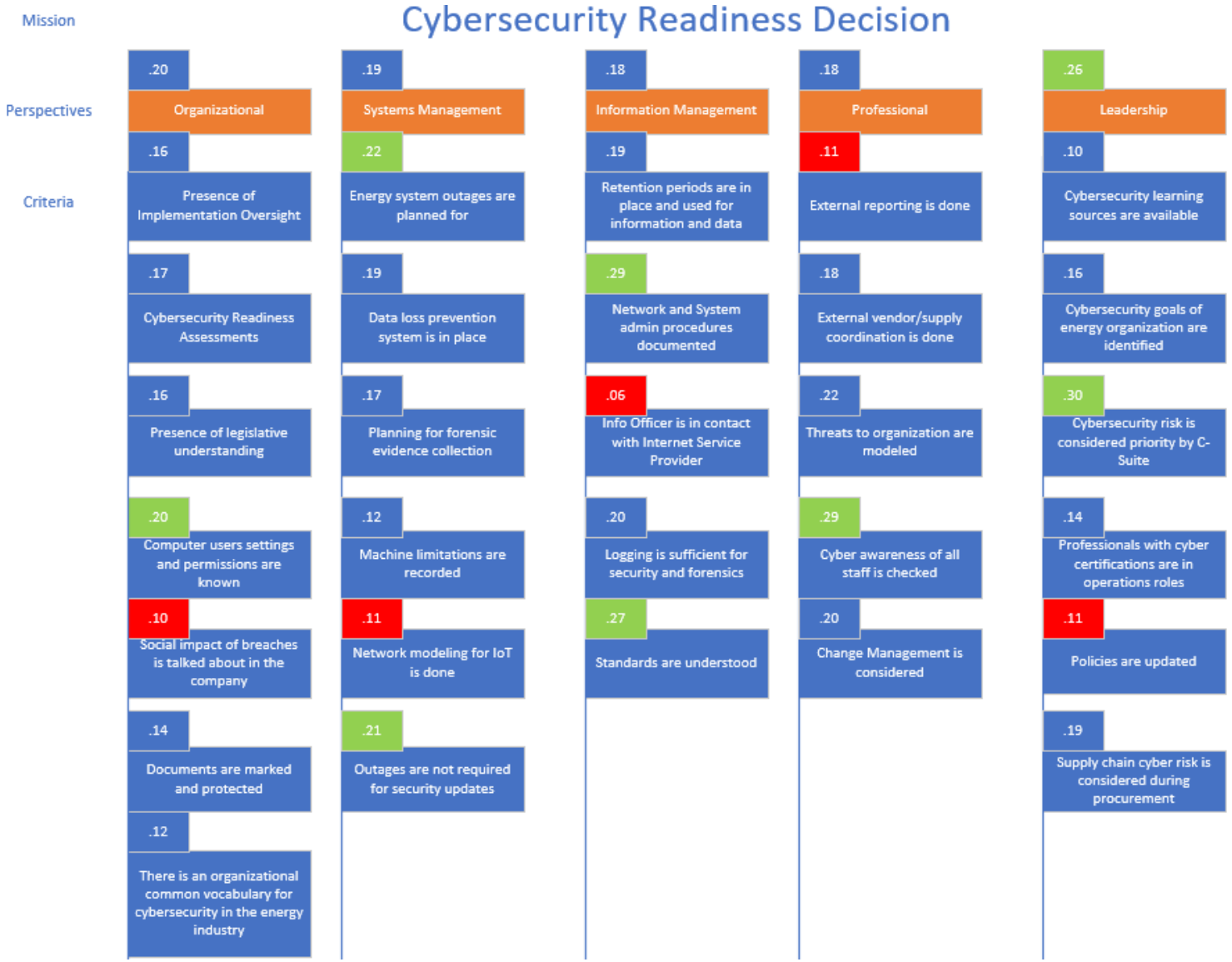
Table 39 - Result of Experts Judgment Quantification

Perspectives	Value	Readiness Criterion	Local Weights	Global Weights
Organizational	0.2	Computer users settings and permissions are known	0.2	0.04
		Cybersecurity Readiness Assessments	0.17	0.03
		Documents are marked and protected	0.14	0.03
		Presence of Implementation Oversight	0.16	0.03
		Presence of legislative understanding	0.11	0.02
		Social impact of breaches is talked about in the company	0.1	0.02
		There is an organizational common vocabulary for cybersecurity in the energy industry	0.12	0.02
Information Management	0.18	Info Officer is in contact with Internet Service Provider	0.06	0.01
		Logging is sufficient for security and forensics	0.2	0.04
		Network and System admin procedures documented	0.29	0.05
		Retention periods are in place and used for information and data	0.19	0.03
		Standards are understood	0.27	0.05
Systems Management	0.19	Data loss prevention system is in place	0.19	0.04
		Energy system outages are planned for	0.22	0.04

		Machine limitations are recorded	0.12	0.02
		Network modeling for IoT is done	0.11	0.02
		Outages are not required for security updates	0.21	0.04
		Planning for forensic evidence collection	0.17	0.03
Professional	0.18	Change Management is considered	0.2	0.03
		Cyber awareness of all staff is checked	0.29	0.05
		External reporting is done	0.11	0.02
		External vendor/supply coordination is done	0.18	0.03
		Threats to organization are modeled	0.22	0.04
Leadership	0.26	Cybersecurity goals of energy organization are identified	0.16	0.04
		Cybersecurity learning sources are available	0.1	0.03
		Cybersecurity risk is considered priority by C-Suite	0.3	0.08
		Policies are updated	0.11	0.03
		Professionals with cyber certifications are in operations roles	0.14	0.04
		Supply chain cyber risk is considered during procurement	0.19	0.05
Total	1		5.0	1

Higher weight represents a more important issue in satisfying the decision. Comparing Levels 3 “Criterion” is arguably where the most value is being gained from [the HDM] MCDM [216]. The visualization below show which data points (perspectives and criteria) can affect the mission. The figure is a depiction of the model with the criterion weights. At a minimum, one representation from each perspective is recommended as a starting point for implementation of a readiness solution.

Figure 29 - Final Model Weights


Cybersecurity Readiness Decision
Mission
Perspectives
Criteria
.20
Organizational
.16
Presence of Implementation Oversight
.17
Cybersecurity Readiness Assessments
.16
Presence of legislative understanding
.20
Computer users settings and permissions are known
.10
Social impact of breaches is talked about in the company
.14
Documents are marked and protected
.12
There is an organizational common vocabulary for cybersecurity in the energy industry
.19
Systems Management
.22
Energy system outages are planned for
.19
Data loss prevention system is in place
.17
Planning for forensic evidence collection
.12
Machine limitations are recorded
.11
Network modeling for IoT is done
.21
Outages are not required for security updates
.18
Information Management
.19
Retention periods are in place and used for information and data
.29
Network and System admin procedures documented
.06
Info Officer is in contact with Internet Service Provider
.20
Logging is sufficient for security and forensics
.27
Standards are understood
.18
Professional
.11
External reporting is done
.18
External vendor/supply coordination is done
.22
Threats to organization are modeled
.29
Cyber awareness of all staff is checked
.20
Change Management is considered
.26
Leadership
.10
Cybersecurity learning sources are available
.16
Cybersecurity goals of energy organization are identified
.30
Cybersecurity risk is considered priority by C-Suite
.14
Professionals with cyber certifications are in operations roles
.11
Policies are updated
.19
Supply chain cyber risk is considered during procurement

8.1.2.4 Desirability Results

The desirability results identify how desirable or valuable a metric is for a decision-maker. It's an applied risk analysis that places itself pairwise comparisons set by the experts, for use in cases. In statistics desirability is an objective function that ranges from 0 to 1 [245]. It represents how close a response is to its ideal value.

The experts have been asked through the Qualtrics data questionnaire tool to quantify the levels of desirability for each readiness criterion, enabling the establishment of desirability curves. Desirability curves are a "graded approach" which means there are levels in the process. Those levels depend on the level of analysis, documentation, and any actions necessary to complete the readiness criterion requirements. For this study the optimal design for each desirability metric is to utilize a maximize function. Thus, the highest score is always on the right side of the curve. The outcomes of the desirability metrics quantifications are shown below.

Organizational

The outcomes of the desirability metrics quantifications of organizational readiness are shown below. The curves below show what is the optimal level for each factor.

Table 40 - Desirability Experts and Questions for Organizational Perspective

ID	Company	Title	D Org
10	INL	Homeland Security Division Director	1
45	Nozomi/GE	Technical Leader	1
48	Johnson Controls	OT Engineer	1
49	Orsted/MAN Energy	Product Engineer	1
51	Duke	Cybersecurity Analyst	1
52	NextEra	Compliance Specialist	1

Total	**6**

Q1	To what degree are computer user's settings and permissions known by management?
Q2	What is the expected level of Cybersecurity Readiness Assessments in the organization?
Q3	What is the level that documents are marked and protected?
Q4	What is the degree of implementation oversight?
Q5	What is the degree of legal understanding?
Q6	What is the extent to which social impact of breaches are talked about?
Q7	What is the expected level of Cybersecurity vocabulary awareness?

Figure 30 - Desirability Metrics Quantification Outcomes for To what degree are computer user's settings and permissions known by management?

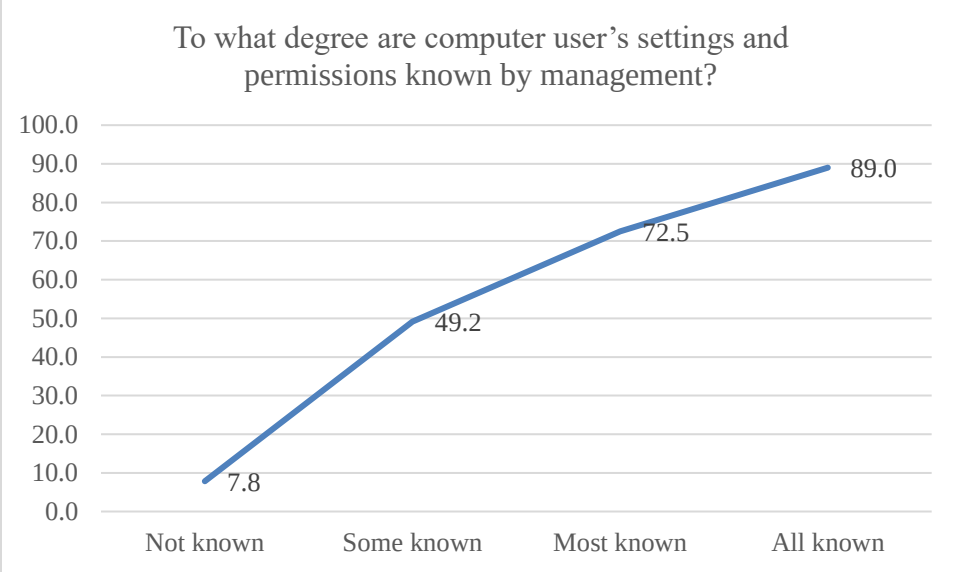


Table 41 - Desirability Metrics for To what degree are computer user's settings and permissions known by management?

Q1	Not known	Some known	Most known	All known
10	0	31	65	100
45	30	50	73	100
48	0	90	95	100
49	7	54	67	83
51	10	20	35	51
52	0	50	100	100
Total	**7.8**	**49.2**	**72.5**	**89.0**

Figure 31 - Desirability Metrics Quantification Outcomes for What is the expected level of Cybersecurity Readiness Assessments in the organization?

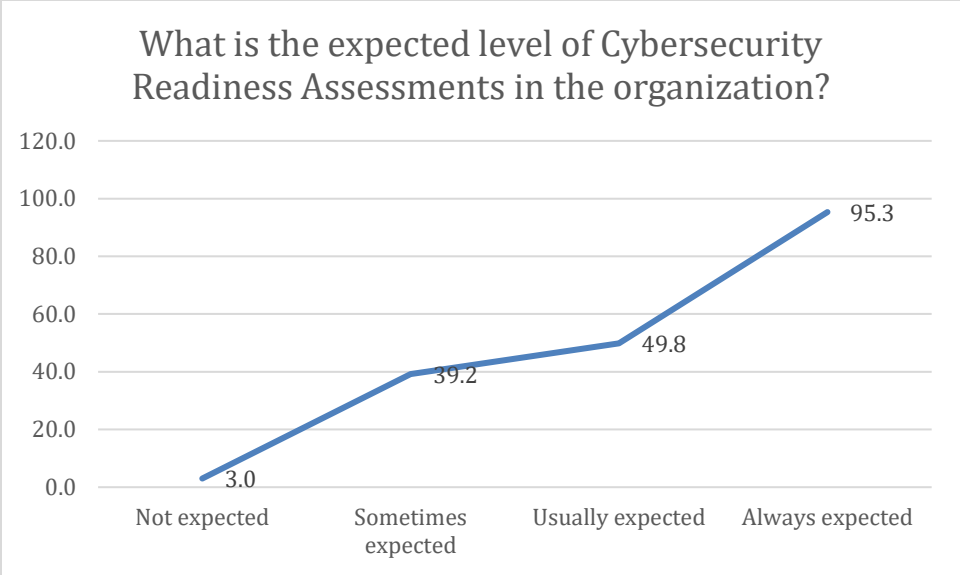


Table 42 - Desirability Metrics for What is the expected level of Cybersecurity Readiness Assessments in the organization?

Q2	Not expected	Sometimes expected	Usually expected	Always expected
10	0	35	70	93
45	18	39	57	81
48	0	90	95	100
49	0	71	77	98
51	0	0	0	100
52	0	0	0	100
Total	**3.0**	**39.2**	**49.8**	**95.3**

Figure 32 - Desirability Metrics Quantification Outcomes for What is the level that documents are marked and protected?

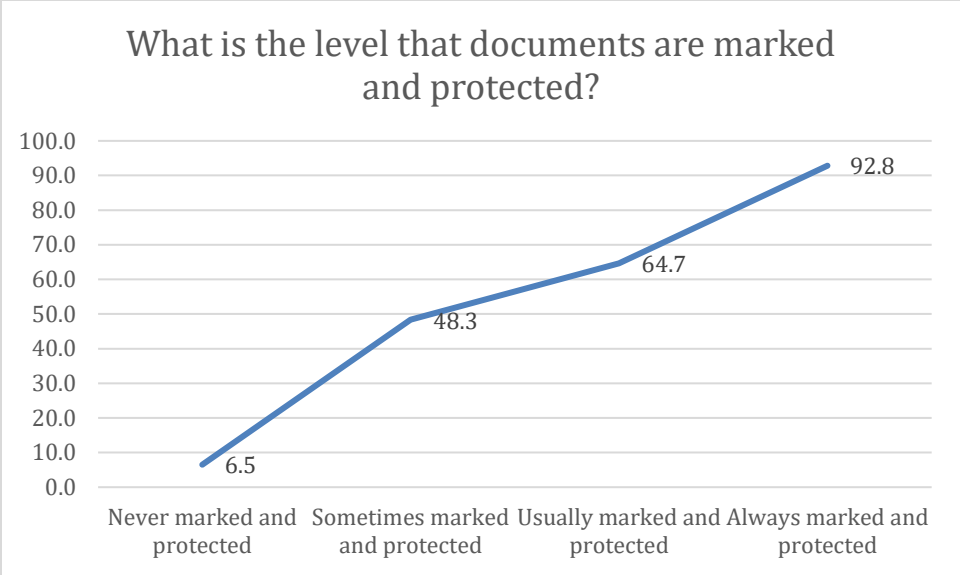


Table 43 - Desirability Metrics for What is the level that documents are marked and protected?

Q3	Never marked and protected	Sometimes marked and protected	Usually marked and protected	Always marked and protected
10	0	40	71	94
45	19	43	81	100
48	0	90	95	100
49	0	67	76	93
51	20	50	65	70
52	0	0	0	100
Total	**6.5**	**48.3**	**64.7**	**92.8**

Figure 33 - Desirability Metrics Quantification Outcomes for What is the degree of implementation oversight?

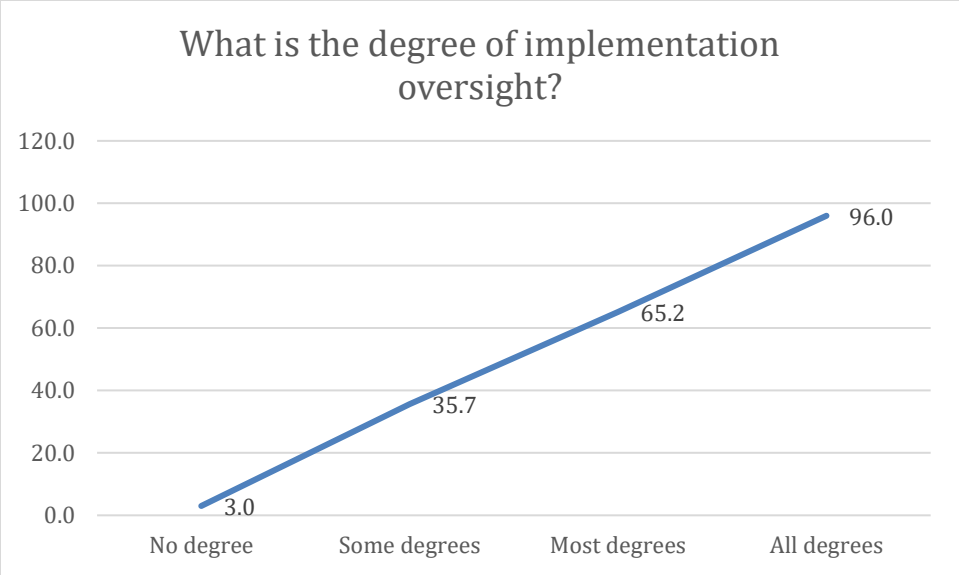


Table 44 - Desirability Metrics for What is the degree of implementation oversight?

Q4	No degree	Some degrees	Most degrees	All degrees
10	0	36	66	94
45	18	40	64	85
48	0	80	90	100
49	0	58	71	97
51	0	0	0	100
52	0	0	100	100
Total	**3.0**	**35.7**	**65.2**	**96.0**

Figure 34 - Desirability Metrics Quantification Outcomes for What is the degree of legal understanding?

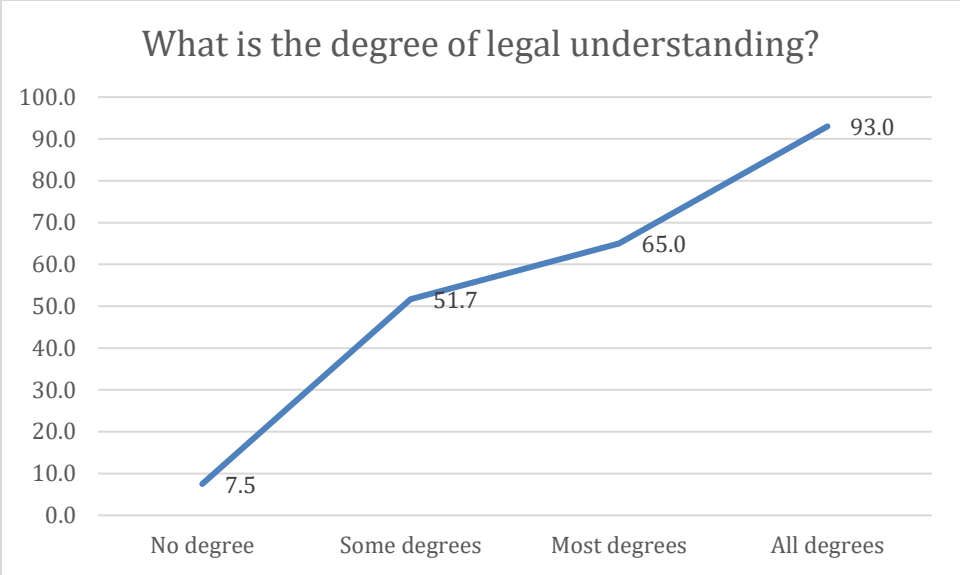


Table 45 - Desirability Metrics for What is the degree of legal understanding?

Q5	No degree	Some degrees	Most degrees	All degrees
10	0	32	69	92
45	28	44	58	74
48	0	98	99	100
49	7	61	79	97
51	10	75	85	95
52	0	0	0	100
Total	**7.5**	**51.7**	**65.0**	**93.0**

Figure 35 - Desirability Metrics Quantification Outcomes for What is the extent to which social impact of breaches are talked about?

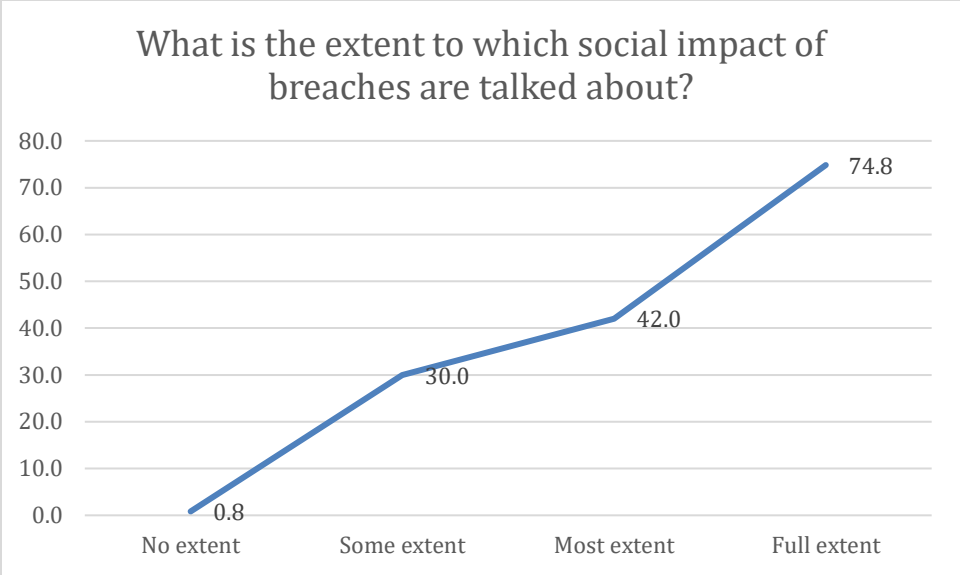


Table 46 - Desirability Metrics for What is the extent to which social impact of breaches are talked about?

Q6	No extent	Some extent	Most extent	Full extent
10	0	35	63	85
45	0	51	71	100
48	0	10	20	30
49	0	69	73	94
51	5	15	25	40
52	0	0	0	100
Total	**0.8**	**30.0**	**42.0**	**74.8**

Figure 36 - Desirability Metrics Quantification Outcomes for What is the expected level of Cybersecurity vocabulary awareness?

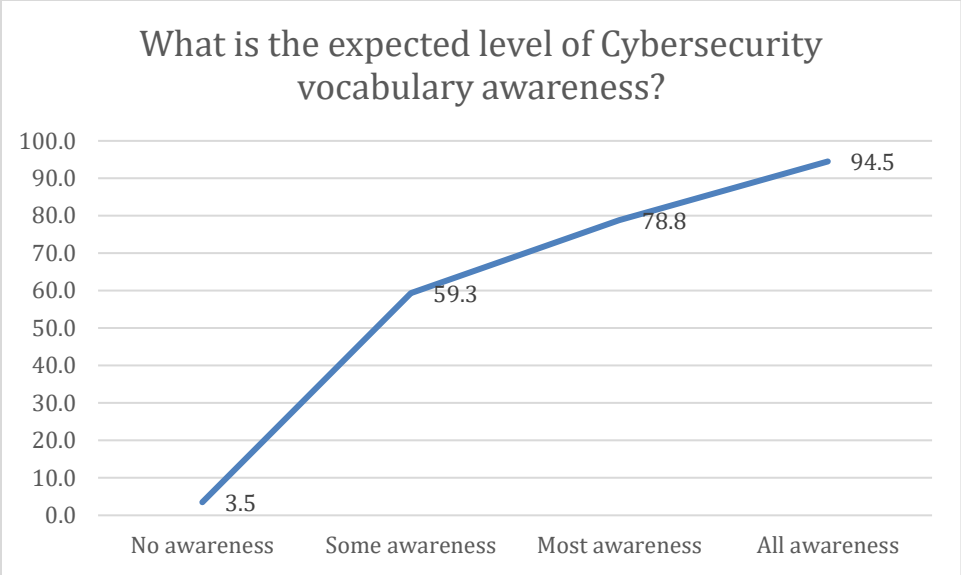


Table 47 - Desirability Metrics for What is the expected level of Cybersecurity vocabulary awareness?

Q7	No awareness	Some awareness	Most awareness	All awareness
10	0	35	71	90
45	0	50	75	100
48	0	98	99	100
49	21	53	68	87
51	0	70	85	90
52	0	50	75	100
Total	**3.50**	**59.33**	**78.83**	**94.50**

Information Management

The outcomes of the desirability metrics quantifications of information management readiness are shown below.

Table 48 - Desirability Experts and Questions for Information Management Perspective

ID	Company	Title	D Info Mgmt
10	INL	Homeland Security Division Director	1
45	Nozomi/GE	Technical Leader	1
48	Johnson Controls	OT Engineer	1
52	NextEra	Compliance Specialist	1
55	DER Security Corp	Software Engineer	1

56	CI-Discern/WAPA	Chief Cyber Advisor	1
Total			**6**

Q1 What is amount of communication sharing with Internet Service Provider?
Q2 Logging required is sufficient for Security and Forensics?
Q3 What is the extent that Network and System Administration procedures are documented?
Q4 What is the degree of retention periods in place for data and information?
Q5 What is the expected level that standards are understood?

Figure 37 - Desirability Metrics Quantification Outcomes for What is amount of communication sharing with Internet Service Provider?

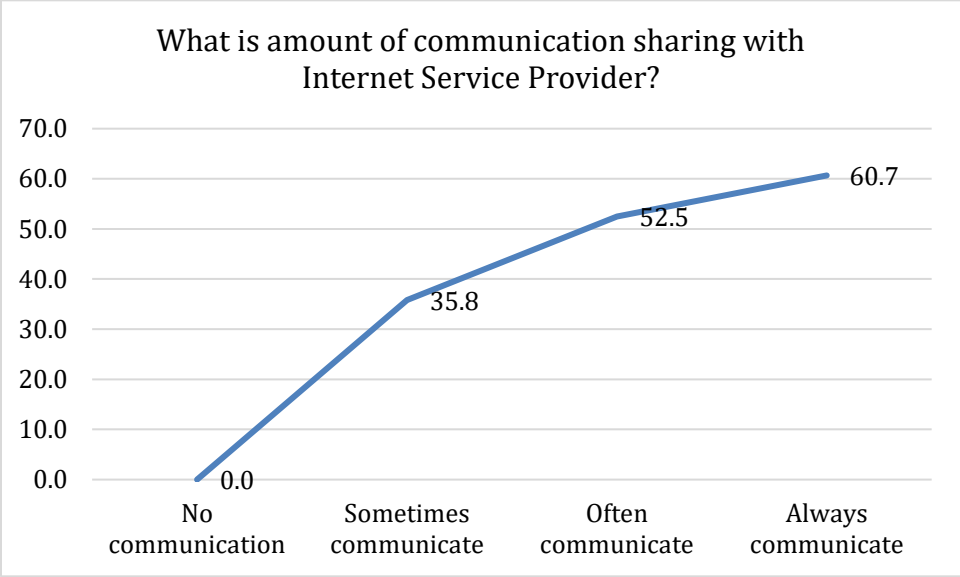


Table 49 - Desirability Metrics for What is amount of communication sharing with Internet Service Provider?

Q1	No communication	Sometimes communicate	Often communicate	Always communicate
10	0	42	69	90
45	0	18	36	61
48	0	12	70	90
52	0	3	0	0
55	0	90	80	70
56	0	50	60	53
Total	**0.0**	**35.8**	**52.5**	**60.7**

Figure 38 - Desirability Metrics Quantification Outcomes for Logging required is sufficient for Security and Forensics?

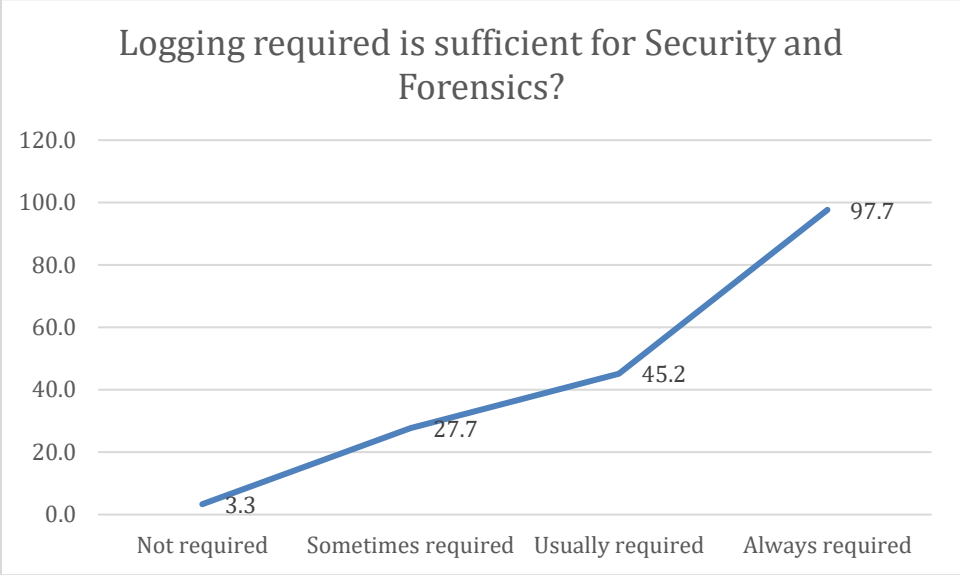


Table 50 - Desirability Metrics for Logging required is sufficient for Security and Forensics?

Q2	Not required	Sometimes required	Usually required	Always required
10	0	41	71	95
45	20	43	65	91
48	0	12	30	100
52	0	50	75	100
55	0	20	30	100
56	0	0	0	100
Total	**3.3**	**27.7**	**45.2**	**97.7**

Figure 39 - Desirability Metrics Quantification Outcomes for What is the extent that Network and System Administration procedures are documented?

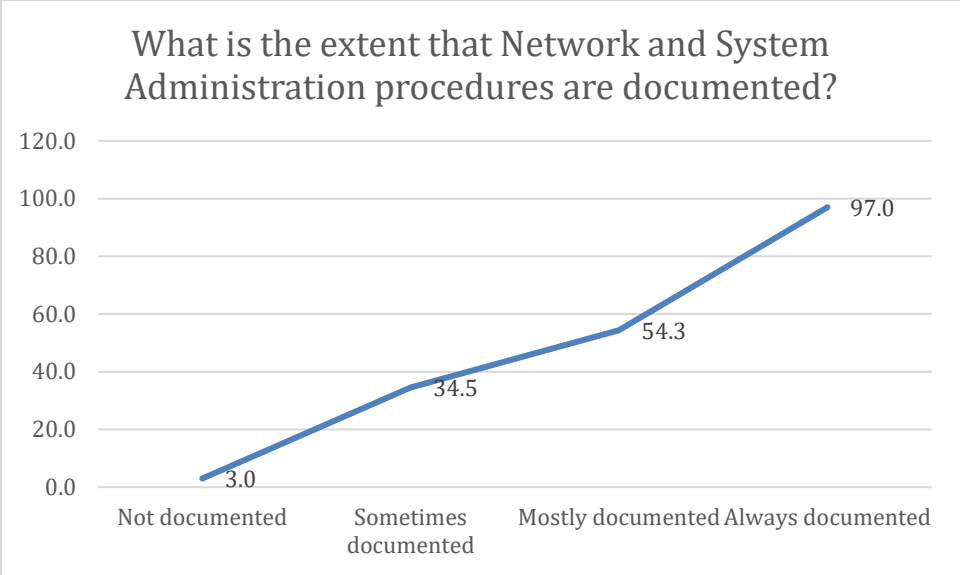


Table 51 - Desirability Metrics for What is the extent that Network and System Administration procedures are documented?

Q3	Not documented	Sometimes documented	Mostly documented	Always documented
10	0	56	78	100
45	8	30	56	82
48	0	71	91	100
52	0	0	0	100
55	10	30	70	100
56	0	20	31	100
Total	**3.0**	**34.5**	**54.3**	**97.0**

Figure 40 - Desirability Metrics Quantification Outcomes for What is the degree of retention periods in place for data and information?

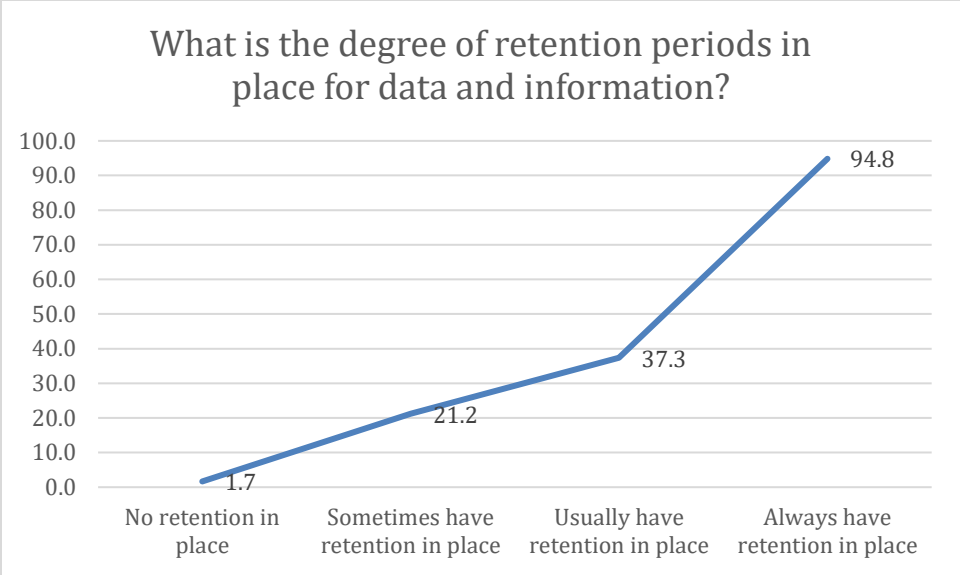


Table 52 - Desirability Metrics for What is the degree of retention periods in place for data and information?

Q4	No retention in place	Sometimes have retention in place	Usually have retention in place	Always have retention in place
10	0	45	70	90
45	10	32	58	79
48	0	9	20	100
52	0	0	5	100
55	0	30	60	100
56	0	11	11	100
Total	**1.7**	**21.2**	**37.3**	**94.8**

Figure 41 - Desirability Metrics Quantification Outcomes for What is the expected level that standards are understood?

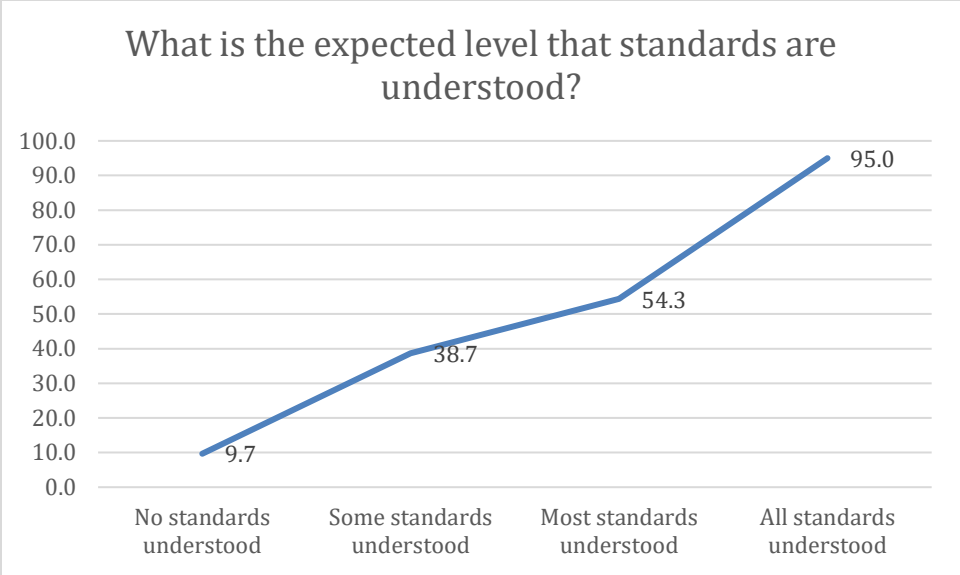


Table 53 - Desirability Metrics for What is the expected level that standards are understood?

Q5	No standards understood	Some standards understood	Most standards understood	All standards understood
10	0	45	70	90
45	8	37	70	100
48	0	20	31	100
52	0	50	75	100
55	50	80	80	80
56	0	0	0	100
Total	**9.7**	**38.7**	**54.3**	**95.0**

Systems Management

The outcomes of the desirability metrics quantifications of systems management readiness are shown below.

Table 54 - Desirability Experts and Questions for Systems Management Perspective

ID	Company	Title	D Sys Mgmt
10	INL	Homeland Security Division Director	1
45	Nozomi/GE	Technical Leader	1
48	Johnson Controls	OT Engineer	1
55	DER Security Corp	Software Engineer	1
Total			**4**

Q1	What is the complexity of Data Loss Prevention (DLP) systems that are in place?
Q2	To what degree are Energy System outages planned to?
Q3	What is the degree that machine limitations are recorded?
Q4	What is the degree of network modeling for ICS/IoT/Nuclear done?
Q5	What is the expected level of outages required for applying security updates?
Q6	What is the degree of planning done for forensic evidence collection?

Figure 42 - Desirability Metrics Quantification Outcomes for What is the complexity of Data Loss Prevention (DLP) systems that are in place?

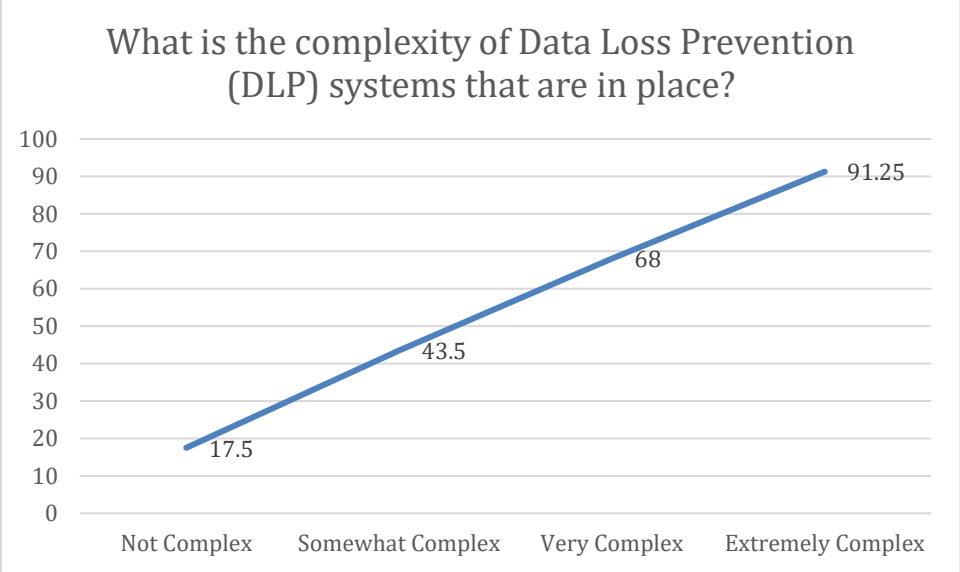


Table 55 - Desirability Metrics for What is the complexity of Data Loss Prevention (DLP) systems that are in place?

Q1	Not Complex	Somewhat Complex	Very Complex	Extremely Complex
10	20	34	60	90
45	30	50	61	75
48	0	60	81	100
55	20	30	70	100
Total	**17.5**	**43.5**	**68**	**91.25**

Figure 43 - Desirability Metrics Quantification Outcomes for To what degree are Energy System outages planned to?

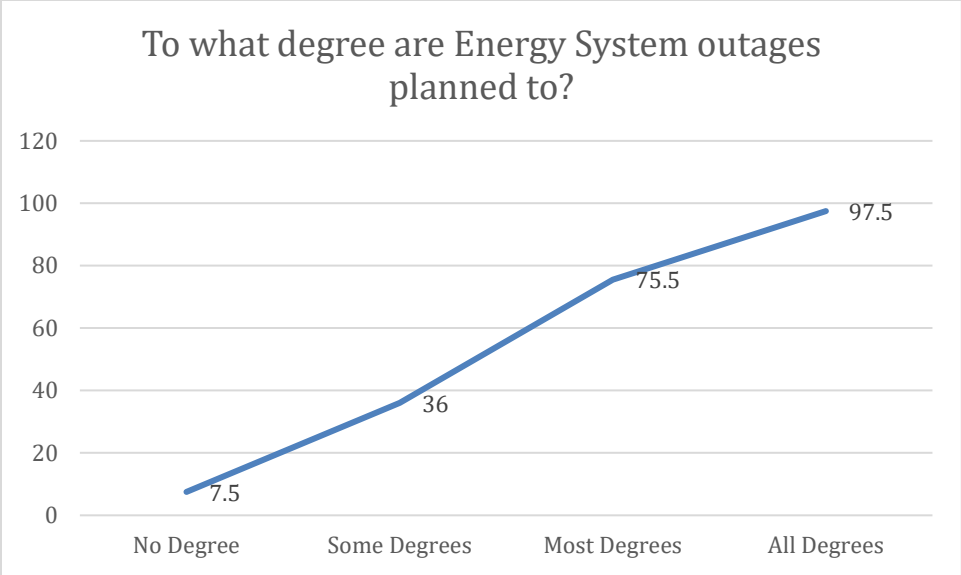


Table 56 - Desirability Metrics for To what degree are Energy System outages planned to?

Q2	No Degree	Some Degrees	Most Degrees	All Degrees
10	20	35	68	90
45	10	49	74	100
48	0	10	90	100
55	0	50	70	100
Total	**7.5**	**36**	**75.5**	**97.5**

Figure 44 - Desirability Metrics Quantification Outcomes for What is the degree that machine limitations are recorded?

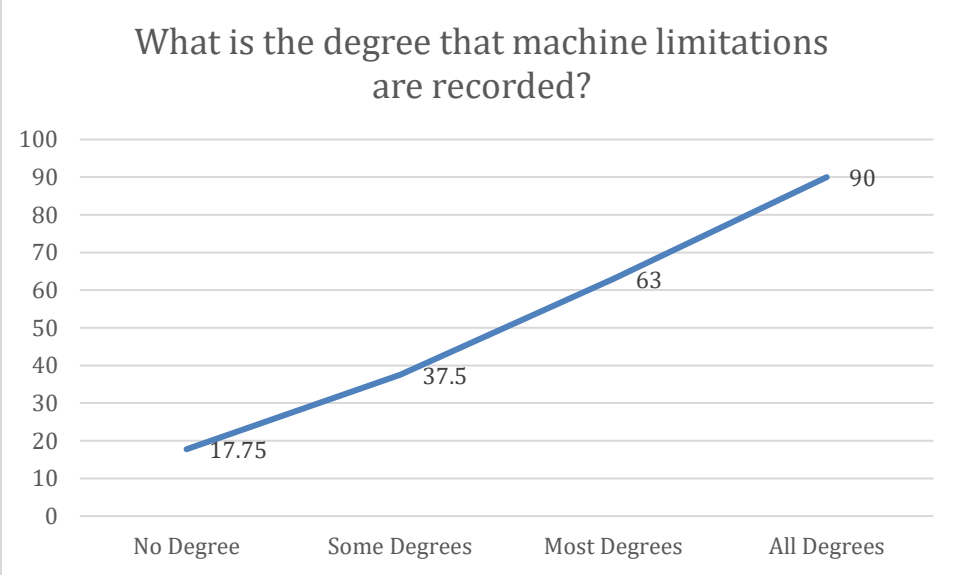


Table 57 - Desirability Metrics for What is the degree that machine limitations are recorded?

Q3	No Degree	Some Degrees	Most Degrees	All Degrees
10	20	50	66	90
45	31	50	76	100
48	0	10	50	100
55	20	40	60	70
Total	**17.75**	**37.5**	**63**	**90**

Figure 45 - Desirability Metrics Quantification Outcomes for What is the degree of network modeling for ICS/IoT/Nuclear done?

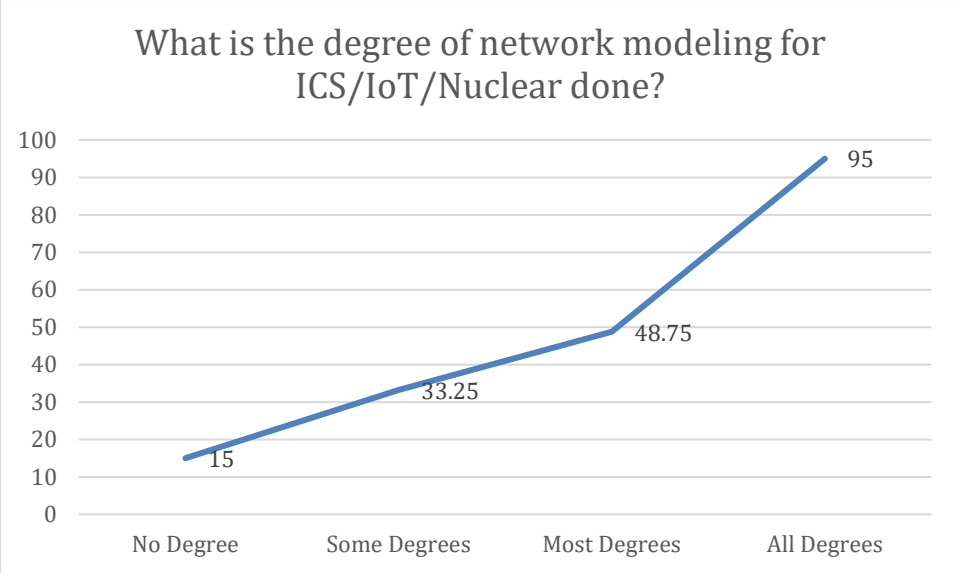


Table 58 - Desirability Metrics for What is the degree of network modeling for ICS/IoT/Nuclear done?

Q4	No Degree	Some Degrees	Most Degrees	All Degrees
10	20	53	77	100
45	30	50	68	80
48	0	0	0	100
55	10	30	50	100
Total	**15**	**33.25**	**48.75**	**95**

Figure 46 - Desirability Metrics Quantification Outcomes for What is the expected level of outages required for applying security updates?

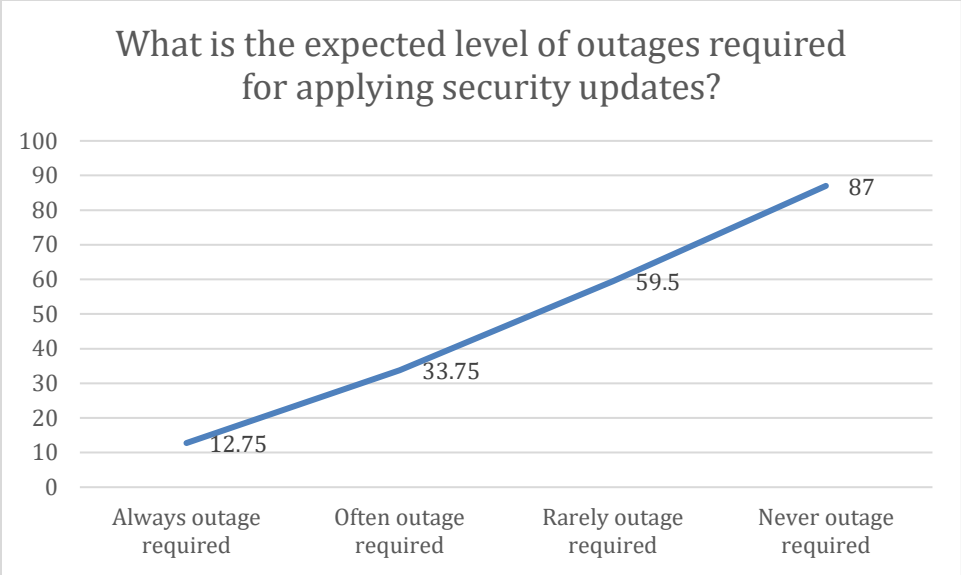


Table 59 - Desirability Metrics for What is the expected level of outages required for applying security updates?

Q5	Always outage required	Often outage required	Rarely outage required	Never outage required
10	0	50	75	100
45	31	49	64	78
48	0	6	49	100
55	20	30	50	70
Total	**12.75**	**33.75**	**59.5**	**87**

Figure 47 - Desirability Metrics Quantification Outcomes for What is the degree of planning done for forensic evidence collection?

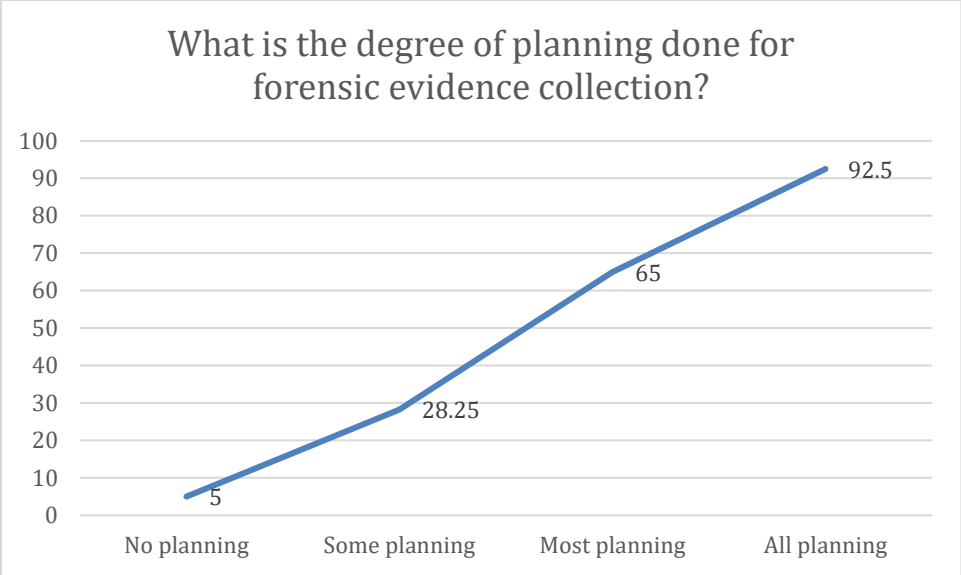


Table 60 - Desirability Metrics for What is the degree of planning done for forensic evidence collection?

Q6	No planning	Some planning	Most planning	All planning
10	0	50	75	90
45	20	40	60	80
48	0	3	75	100
55	0	20	50	100
Total	**5**	**28.25**	**65**	**92.5**

Professional

The outcomes of the desirability metrics quantifications of professional readiness are shown below.

Table 61 - Desirability Experts and Questions for Professional Perspective

ID	Company	Title	D Prof
10	INL	Homeland Security Division Director	1
45	Nozomi/GE	Technical Leader	1
48	Johnson Controls	OT Engineer	1
49	Orsted/MAN Energy	Product Engineer	1
54	Eversource Energy	Identity and Access Mgmt Specialist	1
Total			**5**

Q1	To what extent is cybersecurity awareness of behavior of staff checked?
Q2	What is the required amount of external reporting?
Q3	What is the degree of vendor and supply alignment on security?
Q4	What is the expected level that threats to the organization are modeled?
Q5	What is the expected level that change management will be considered?

Figure 48 - Desirability Metrics Quantification Outcomes for To what extent is cybersecurity awareness of behavior of staff checked?

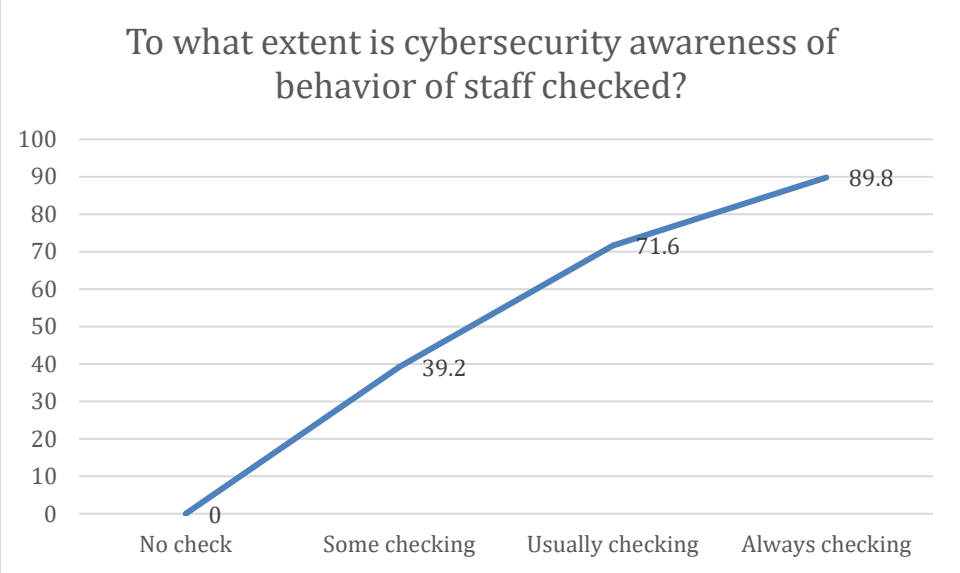


Table 62 - Desirability Metrics for To what extent is cybersecurity awareness of behavior of staff checked?

Q1	No check	Some checking	Usually checking	Always checking
10	0	50	75	100
45	0	40	60	82
48	0	10	75	100
49	0	46	58	67
54	0	50	90	100
Total	**0**	**39.2**	**71.6**	**89.8**

Figure 49 - Desirability Metrics Quantification Outcomes for What is the required amount of external reporting?

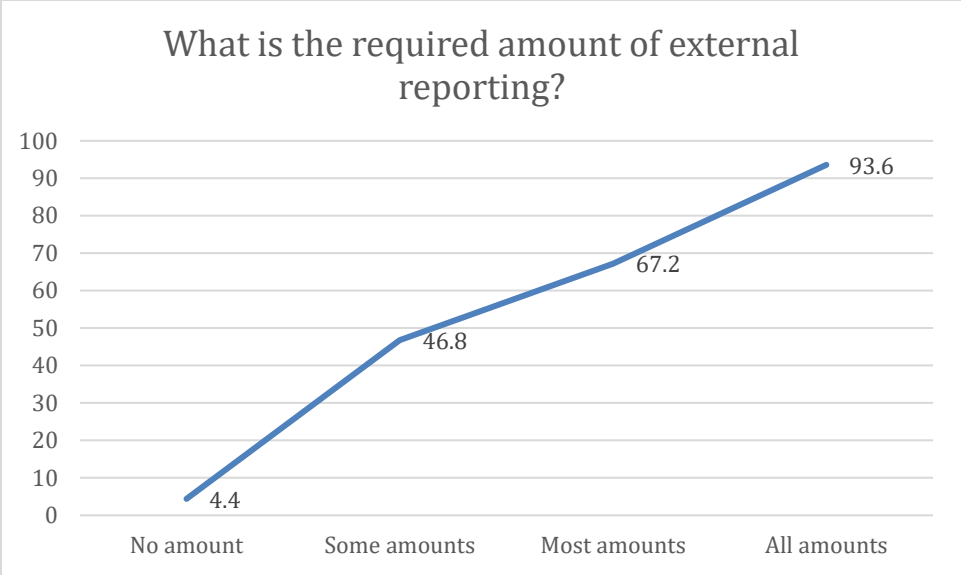


Table 63 - Desirability Metrics for What is the required amount of external reporting?

Q2	No amount	Some amounts	Most amounts	All amounts
10	0	42	72	90
45	22	43	59	81
48	0	10	50	100
49	0	59	70	97
54	0	80	85	100
Total	**4.4**	**46.8**	**67.2**	**93.6**

Figure 50 - Desirability Metrics Quantification Outcomes for What is the degree of vendor and supply alignment on security?

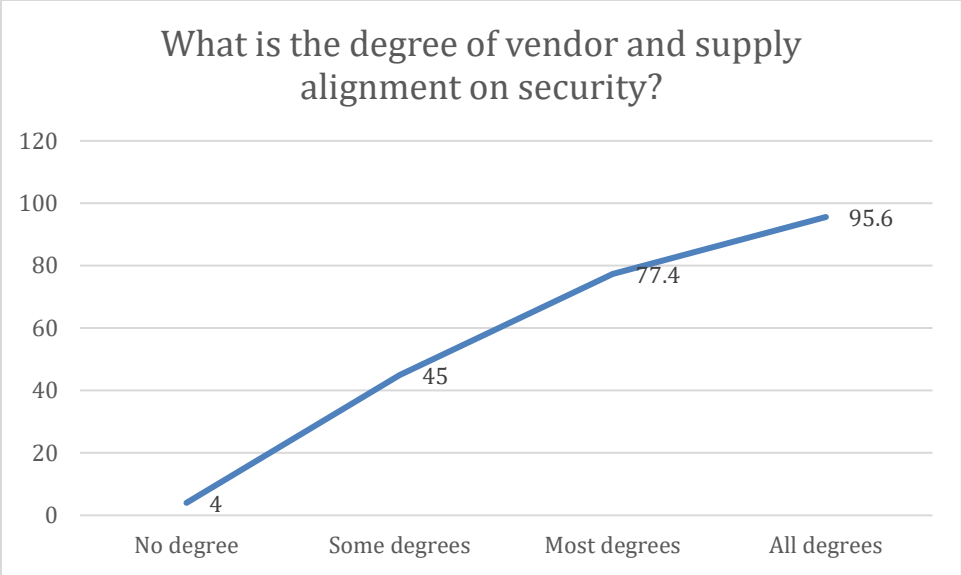


Table 64 - Desirability Metrics for What is the degree of vendor and supply alignment on security?

Q3	No degree	Some degrees	Most degrees	All degrees
10	0	50	75	100
45	20	42	52	80
48	0	0	90	100
49	0	73	95	98
54	0	60	75	100
Total	**4**	**45**	**77.4**	**95.6**

Figure 51 - Desirability Metrics Quantification Outcomes for What is the expected level that threats to the organization are modeled?

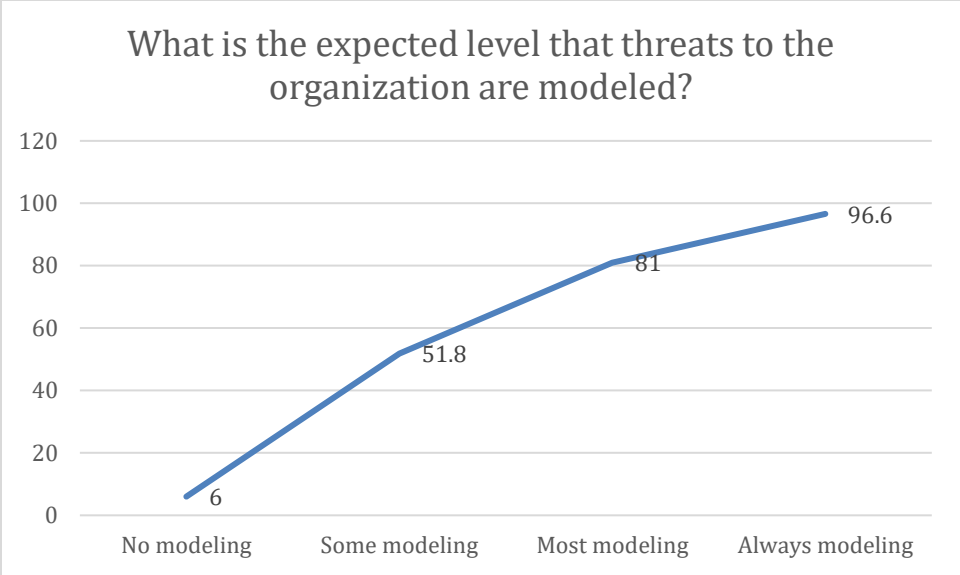


Table 65 - Desirability Metrics for What is the expected level that threats to the organization are modeled?

Q4	No modeling	Some modeling	Most modeling	Always modeling
10	0	50	75	100
45	30	50	70	85
48	0	0	91	100
49	0	89	94	98
54	0	70	75	100
Total	**6**	**51.8**	**81**	**96.6**

Figure 52 - Desirability Metrics Quantification Outcomes for What is the expected level that change management will be considered?

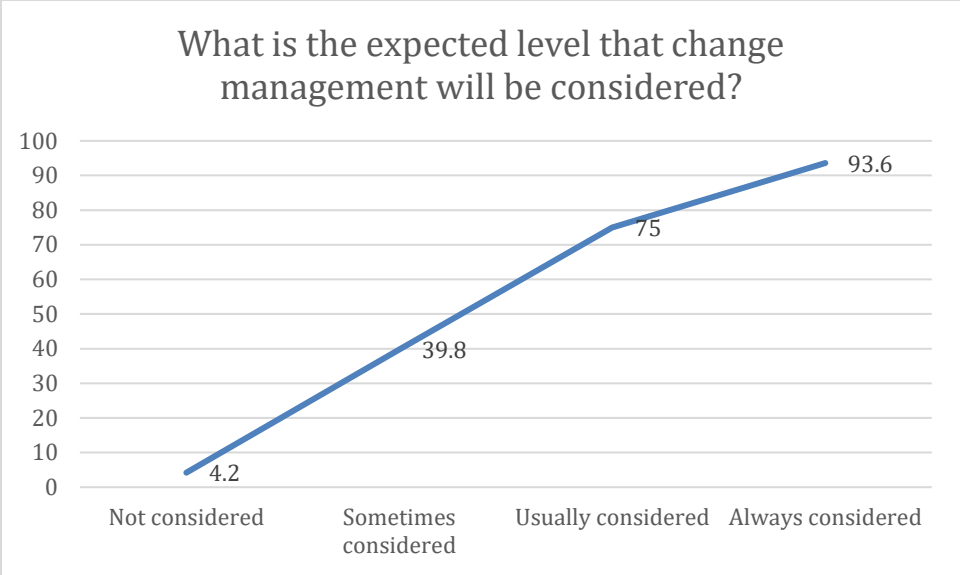


Table 66 - Desirability Metrics for What is the expected level that change management will be considered?

Q5	Not considered	Sometimes considered	Usually considered	Always considered
10	0	50	75	100
45	21	42	61	92
48	0	0	98	100
49	0	57	66	76
54	0	50	75	100
Total	**4.2**	**39.8**	**75**	**93.6**

Leadership

The outcomes of the desirability metrics quantifications of leadership readiness are shown below.

Table 67 – Desirability Experts and Questions for Leadership Perspective

ID	Company	Title	D Leader
10	INL	Homeland Security Division Director	1
45	Nozomi/GE	Technical Leader	1
49	Orsted/MAN Energy	Product Engineer	1
50	Liberty Utilities	IT Helpdesk	1
52	NextEra	Compliance Specialist	1
53	WAPA	IT Director	1

55	DER Security Corp	Software Engineer	1
Total			**7**

Q1	Are Cybersecurity goals identified in the organization?
Q2	What is the amount of Cybersecurity learning sources available?
Q3	Cybersecurity Risk is a required topic by C-Suite?
Q4	What is the expected level of policy updating?
Q5	What is the required level of certification in operations roles?
Q6	Are complex Cyber supply chain risks considered in procurement?

Figure 53 - Desirability Metrics Quantification Outcomes for Are Cybersecurity goals identified in the organization?



Table 68 - Desirability Metrics for Are Cybersecurity goals identified in the organization?

Q1	No goals	Some goals	Many goals	All goals
10	0	37	70	90
45	25	49	75	91
49	18	47	68	79
50	0	50	75	100
52	0	0	0	100
53	0	48	53	100
55	10	50	80	80
Total	**7.6**	**40.1**	**60.1**	**91.4**

Figure 54 - Desirability Metrics Quantification Outcomes for What is the amount of Cybersecurity learning sources available?

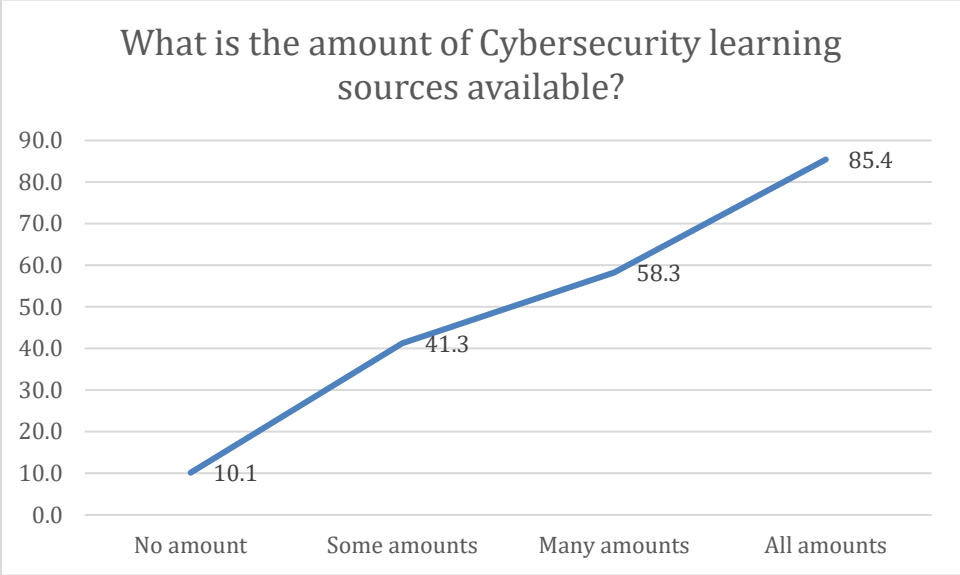


Table 69 - Desirability Metrics for What is the amount of Cybersecurity learning sources available?

Q2	No amount	Some amounts	Many amounts	All amounts
10	0	44	72	91
45	11	37	57	81
49	10	58	72	76
50	0	50	82	100
52	0	0	0	100
53	0	50	75	100
55	50	50	50	50
Total	**10.1**	**41.3**	**58.3**	**85.4**

Figure 55 - Desirability Metrics Quantification Outcomes for Cybersecurity Risk is a required topic by C-Suite?

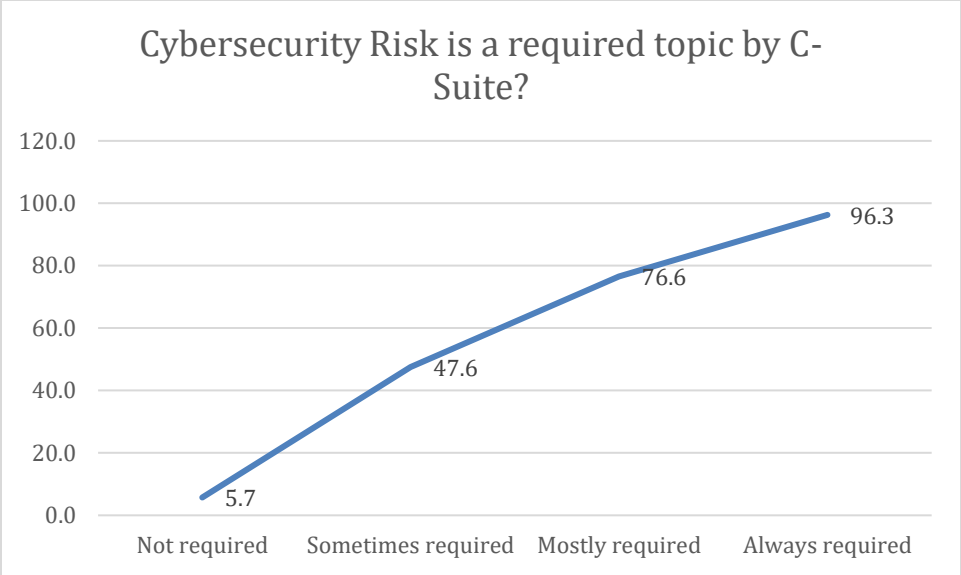


Table 70 - Desirability Metrics for Cybersecurity Risk is a required topic by C-Suite?

Q3	Not required	Sometimes required	Mostly required	Always required
10	0	55	78	100
45	0	51	76	99
49	0	55	72	95
50	0	60	75	100
52	0	2	80	100
53	0	50	75	100
55	40	60	80	80
Total	**5.7**	**47.6**	**76.6**	**96.3**

Figure 56 - Desirability Metrics Quantification Outcomes for What is the expected level of policy updating?

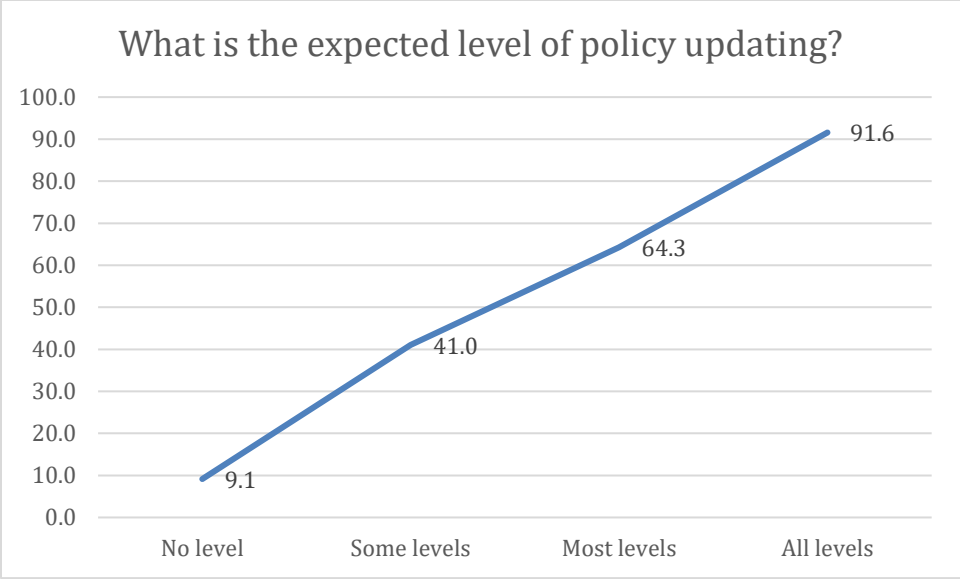


Table 71 - Desirability Metrics for What is the expected level of policy updating?

Q4	No level	Some levels	Most levels	All levels
10	0	45	72	90
45	14	36	59	81
49	0	56	75	100
50	0	50	84	100
52	0	0	0	100
53	0	50	100	100
55	50	50	60	70
Total	**9.1**	**41.0**	**64.3**	**91.6**

Figure 57 - Desirability Metrics Quantification Outcomes for What is the required level of certification in operations roles?

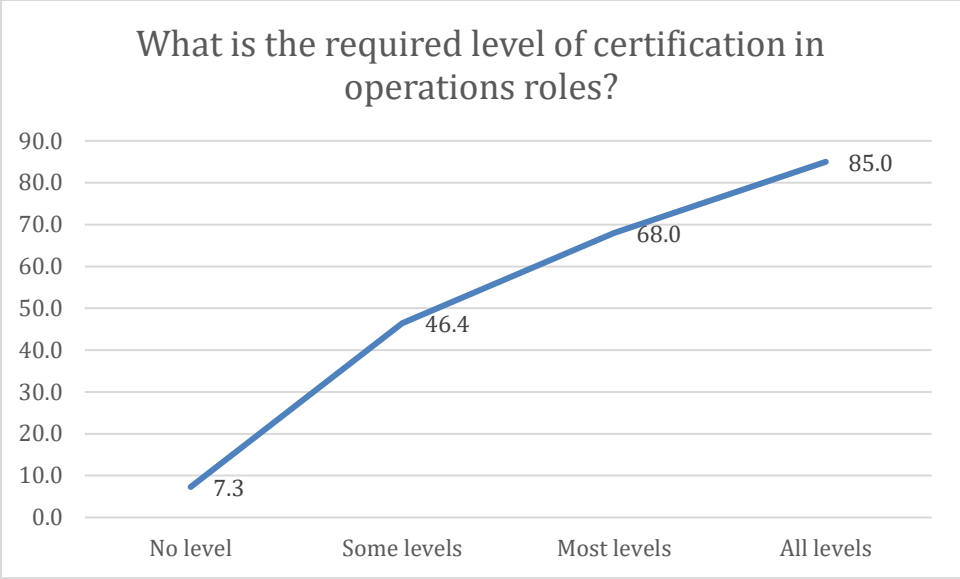


Table 72 - Desirability Metrics for What is the required level of certification in operations roles?

Q5	No level	Some levels	Most levels	All levels
10	0	41	69	90
45	0	22	40	68
49	1	60	72	87
50	0	52	75	100
52	0	50	75	100
53	0	50	95	100
55	50	50	50	50
Total	**7.3**	**46.4**	**68.0**	**85.0**

Figure 58 - Desirability Metrics Quantification Outcomes for Are complex Cyber supply chain risks considered in procurement?

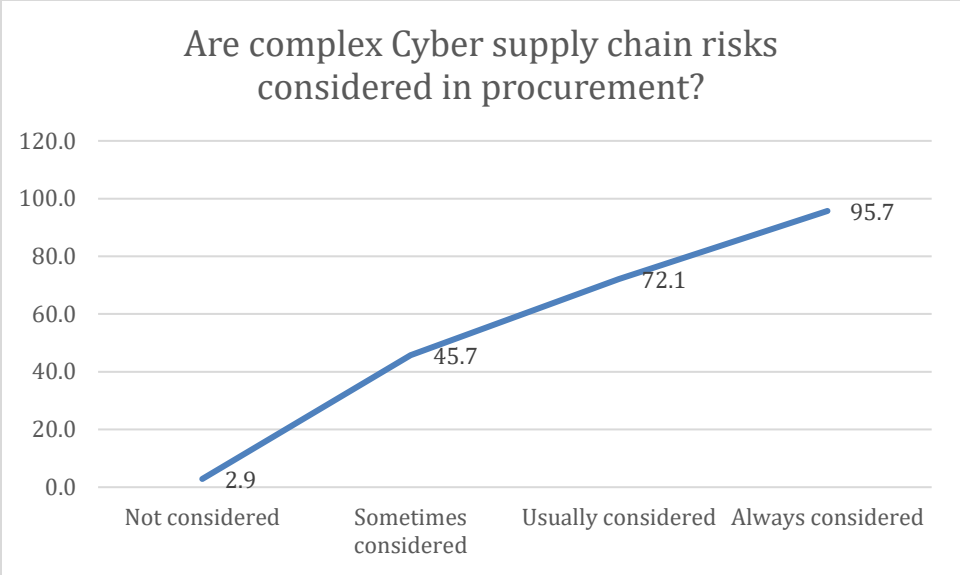


Table 73 - Desirability Metrics for Are complex Cyber supply chain risks considered in procurement?

Q6	Not considered	Sometimes considered	Usually considered	Always considered
10	0	50	75	95
45	20	39	63	83
49	0	58	70	92
50	0	33	75	100
52	0	50	77	100
53	0	50	75	100
55	0	40	70	100
Total	**2.9**	**45.7**	**72.1**	**95.7**

8.1.3 Analysis of Cases

Cases include a selection of experts identified as meeting the grouping to be included into a case. Thus, the scores are different for one case to another as only sample of the population is included.

The goal of the Cases is to sufficiently decompose, detail, and test criteria (aka controls or interactions) so that a model can be discussed in an applied setting and to assess the broader impact. The average mean of the desirability scores were used to

assign a value curve score for each case below. This application of value curves helps to identify what is the next target level for each criterion. Thus, the scores are reallocated and then mapped back to the HDM data in a case study to form a new interpretation of the data. This analysis ensures the use of a robust research design to study real-world applications which is important in ensuring the research's accuracy [217].

8.1.3.1 Agencies of Government and Private Entities Readiness

The HDM pairwise model is applied to desirability scores to identify the overall evaluation of two cases: Agencies of Government and Private Entities. These are two types of organizations in the Energy industry sector. Both help implement cyber security for the energy industry and specifically for the national grid (aka Bulk Energy/Power System). Guidelines come from a mix of Agencies of Government and Private Entities including private non-profit, and for-profit organizations.

Case: Agencies of Government

The Department of Energy (DOE) has several offices and 17 National Laboratories including but not limited to: Office of Electricity Delivery and Energy Reliability (OE or DOE-OE), The Office of Energy Efficiency and Renewable Energy (DOE-EERE), labs like Pacific Northwest National Laboratory (PNNL), Electric Power Research Institute (EPRI), the National Renewable Energy Laboratory (NREL) in Golden Colorado. The laboratories study projects such as Wind and Solar Integration. DOE also gives out grants to fund research. The Modern Grid Initiative is sponsored by the US Department of Energy.

There are numerous legal, regulatory, requirements, set by Agencies of Government for cybersecurity authorizations, including Agencies of Government information security and privacy legislation (including NERC CIP and FISMA legislation) and NIST Special Publications and Federal Information Processing Standards (FIPS) [53]. NIST is one the most prolific standards entities and is well known for Special Publications SP's 500, 800, 1800, and Interagency Reports (IR's) [53].NERC (which is a quasi-governmental organization) operates the Electricity Sector ISAC (ES-ISAC or EISAC), which works with the Department of Homeland Security (DHS), the Department of Energy (DOE), and other Agencies of Government to help protect the North American Bulk Electric System (BES) [53]. OMB issue guidance to Agencies of Government on implementing privacy provisions of the E-Government Act [246]. GAO uses Technical Readiness Assessments (TRA) for procurement.

Agencies of Government funded projects and programs conduct research and implementation with funding provided from the Department of Energy (DOE) to identify and understand the competencies necessary to perform cybersecurity functions and to assess needs in the energy industry [247]. The National Information Technology and Research and Development (NITRD) program historically is the United States primary source of federally funded work on advanced [cybersecurity readiness and] information technologies [138]. The U.S. Department of Energy operates the Control System Security and the National SCADA Testbed programs [53]. Department of Energy engages in, but is not limited to: White Papers, System Reports, Risk Management, Roadmaps, Maturity Models, Templates, Agreements Tools, Demonstration Projects, Forums, Advisory

Groups and Councils, and membership organizations [53]. The US Department of Energy has adopted the National Aeronautics and Space Administration (NASA) (and used by Department of Defense (DoD)) Technology Readiness Assessment, and thus already has a perception of what readiness means. In addition, Agencies of Government also receive mandated reports from high consequence power grid operators.

Experts with substantial recent experience (past three years) in agencies of Government (over one year) who also have Private Entity experience were grouped into the Agencies of Government case study (and not into the Private Entity case study). 15 experts (30 data questionnaires) in Agencies of Government are shown below.

Table 74 – Experts for Agencies of Government Case

ID	Company	Role	Perspectives	Organization	Info Mgmt	Sys Mgmt	Professional	Leadership	D Sys Mgmt	D Prof	D Org	D Leader	D Info Mgmt
2	PNNL	Cybersecurity Director	X										
6	SCL	CISO/Director Information Security						X					
10	INL	Homeland Security Division Director		X				X	X	X	X	X	X
12	SCL	Cyber Security Sr Manager, CISO					X						
14	PLM / PNNL	SCADA Engineer		X									
17	WECC / Archer	Risk Manager		X									
29	KPMG/BPA	Cybersecurity ISSO					X						
33	Vermont Power	Cybersecurity Analyst		X									
36	DOE	Cybersecurity Director						X					
39	NREL	Cybersecurity Researcher	X	X	X	X	X	X					
40	LADWP	Cybersecurity Specialist	X	X									
44	ExxonMobil/ DOE	IT Specialist	X				X	X					
47	Sandia	Engineering Staff			X	X							

53	WAPA	IT Director										X		
56	CI-Discern/WAPA	Chief Cyber Advisor												X
15			**4**	**6**	**2**	**2**	**4**	**5**	**1**	**1**	**1**	**2**	**2**	

Table 75 - Agencies of Government Assessment Score

Perspectives	Value	Readiness Criterion	Global Weights	Value Curve Score (D Score Average)	Final Score (Global * Value Curve)	Perspectives Sum
Organizational	0.2	Computer users settings and permissions are known	0.04	49.0	2.0	
		Cybersecurity Readiness Assessments	0.03	49.5	1.5	
		Documents are marked and protected	0.03	51.3	1.5	
		Presence of Implementation Oversight	0.03	49.0	1.5	
		Presence of legislative understanding	0.02	48.3	1.0	
		Social impact of breaches is talked about in the company	0.02	45.8	0.9	
		There is an organizational common vocabulary for cybersecurity in the energy industry	0.02	49.0	1.0	9.3
Information Management	0.18	Info Officer is in contact with Internet Service Provider	0.01	45.5	0.5	
		Logging is sufficient for security and forensics	0.04	38.4	1.5	
		Network and System admin procedures documented	0.05	48.1	2.4	
		Retention periods are in place and used for information and data	0.03	40.9	1.2	
		Standards are understood	0.05	38.1	1.9	7.5
Systems Management	0.19	Data loss prevention system is in place	0.04	51.0	2.0	
		Energy system outages are planned for	0.04	53.3	2.1	
		Machine limitations are recorded	0.02	56.5	1.1	
		Network modeling for IoT is done	0.02	62.5	1.3	

		Outages are not required for security updates	0.04	56.3	2.3	
		Planning for forensic evidence collection	0.03	53.8	1.6	10.4
Professional	0.18	Change Management is considered	0.03	56.3	1.7	
		Cyber awareness of all staff is checked	0.05	56.3	2.8	
		External reporting is done	0.02	51.0	1.0	
		External vendor/supply coordination is done	0.03	56.3	1.7	
		Threats to organization are modeled	0.04	56.3	2.3	9.5
Leadership	0.26	Cybersecurity goals of energy organization are identified	0.04	49.3	2.0	
		Cybersecurity learning sources are available	0.03	51.8	1.6	
		Cybersecurity risk is considered priority by C-Suite	0.08	58.3	4.7	
		Policies are updated	0.03	51.8	1.6	
		Professionals with cyber certifications are in operations roles	0.04	50.0	2.0	
		Supply chain cyber risk is considered during procurement	0.05	55.0	2.8	14.5
Total					**51.2**	

Agencies of Government Strengths and Weaknesses

Those items with the highest criteria score have been assigned the action for priority. Experts prioritized Cybersecurity Risk is a required topic by C-Suite as being the top concern for Readiness of Cybersecurity for the USA Energy Industry. According to the experts the next top 3 priorities to focus on for Agencies of Government Entities should be: Cyber Awareness Checked, Network and System Administration Procedures Documented, and making sure that Standards are Understood.

Table 76 - The Strengths and Weaknesses of Agencies or Government

Agencies of Government Case	Readiness Criteria	Criteria Information	Desirability Value
Strength	Outages are not required for security updates	Spares enable continuous operation. Asset work	56.3

	stoppages can lead to access failures.	
There is an organizational common vocabulary for cybersecurity in the energy industry	A defined technical vocabulary should be defined. If users don't understand vocabulary around detection and prevention they cannot discuss or deal with cyberattacks.	49

Weakness

Note: Those criteria that scored high or low for both cases are discussed in detail after the cases are presented.

Case: Private Entities

Private Entities must implement mandatory compliance standards that Agencies of Government create and Government enforces, if applicable by law. Organizations need to consider leveraging external guidance obtained from Agencies of Government departments and Information Sharing and Analysis Centers (ISACs), Information Sharing and Analysis Organizations (ISAOs), existing maturity models, or other sources to assist in determining their desired tier of compliance and responsibility [120]. Private Entities do have the ability to comment on some of the proposed standards such as through NERC CIP Reliability Standard Audit Worksheets (RSAWs) [53]. North American Energy Reliability Corporation (NERC) Critical Infrastructure Protection (CIP) is an audit and assessment scheme designed to protect high consequence assets of the national grid. The System Owner or Information Owner categorizes the information system and records the results of security categorization into a system security plan [108] if meeting the threshold of NERC CIP.

Organizations have additionally participated in the founding of Center for Internet Security (CIS) controls in October 2000 included ISACA, the American Institute of

Certified Public Accountants (AICPA), the Institute of Internal Auditors (IIA), the International Information Systems Security Certification Consortium (ISC2) and the SANS Institute (System Administration, Networking and Security). The ISA/IEC which is made up of private participants also develops Private Entity standards which are voluntary. IEEE, ISO, and IETC publish various engineering standards and have many committees that do the technical "bits and bytes."

The drivers for security are different affect how much money is wanted to be allocated. Private Entities are concerned with profit and loss (whereas Agencies of Government are concerned about spending allocated budget) in order to meet owner and/or shareholder concerns. Private Entities primarily obtain funding from owning and operating facilities for production and energy delivery to consumers. The cost of [Cybersecurity] incidents varies, according to the size of the organization… An organization of more than 75,000 employees [large organizations], spent an average of $7.8 million to resolve a major incident. Organizations with 1,000 to 5,000 employees [small businesses], spent an average of $2 million [100].

Table 77 - Experts for the Private Entity Case

ID	Company	Role	Perspectives	Organizatio	Info Mgmt	Sys Mgmt	Professional	Leadership	D Sys Mgmt	D Prof	D Org	D Leader	D Info
3	Avangrid	Senior Cybersecurity Protection Analyst		X			X	X					
7	Gannett Fleming	Information Security Consultant	X	X	X	X	X	X					
13	Northwestern Energy	Security Consultant					X						
15	Hawaii Electric / PG&E	System Engineer			X								
20	Dragos	Technical Engineer	X										

22	CAISO	Compliance Analyst		X										
23	Duke	Cyber Engineer			X	X								
24	Evergy	OT Manager	X											
25	PGE	IT Security Analyst		X										
26	Gannett Fleming	Cybersecurity Compliance					X							
27	NAES	Security Director	X	X										
28	Entergy	IT Compliance		X										
30	SEMCO/DTE	IT Enterprise Architect			X	X								
31	SERC	Cybersecurity Specialist						X						
32	Accenture/Westinghouse	Cybersecurity Consultant	X											
35	1898	Director	X					X						
37	Schneider Electric	Cybersecurity Consultant	X	X	X	X								
38	ISO New England	Engineer and Architect					X	X						
41	Boyett Petroleum	IT Admin	X	X	X	X	X	X						
42	PSE	Infrastructure Security	X		X		X							
43	Williams	IT Analyst			X	X								
45	Nozomi/GE	Technical Leader				X	X	X	X	X	X	X	X	
46	DCP Midstream	OT Specialist			X	X								
48	Johnson Controls	OT Engineer							X	X	X	X	X	
49	Orsted/MAN Energy	Product Engineer								X	X	X		
50	Liberty Utilities	IT Helpdesk										X		
51	Duke	Cybersecurity Analyst									X			
52	NextEra	Compliance Specialist							X		X	X	X	
54	Eversource Energy	Identity and Access Mgmt Specialist								X				
55	DER Security Corp	Software Engineer							X			X	X	
30			**9**	**8**	**9**	**8**	**8**	**7**	**4**	**4**	**5**	**6**	**4**	

In the below example those items with the highest criteria score have highlighted in green.

Table 78 – Private Entity Assessment Score

Perspectives	Value	Readiness Criterion	Global Weights	Value Curve Score (D Score Average)	Final Score (Global * Value Curve)	Perspectives sum
Organizational	0.2	Computer users settings and permissions are known	0.04	55.8	2.2	
		Cybersecurity Readiness Assessments	0.03	46.3	1.4	
		Documents are marked and protected	0.03	53.5	1.6	
		Presence of Implementation Oversight	0.03	50.2	1.5	
		Presence of legislative understanding	0.02	55.5	1.1	
		Social impact of breaches is talked about in the company	0.02	35.2	0.7	
		There is an organizational common vocabulary for cybersecurity in the energy industry	0.02	61.1	1.2	9.8
Information Management	0.18	Info Officer is in contact with Internet Service Provider	0.01	33.1	0.3	
		Logging is sufficient for security and forensics	0.04	46.0	1.8	
		Network and System admin procedures documented	0.05	46.8	2.3	
		Retention periods are in place and used for information and data	0.03	37.7	1.1	
		Standards are understood	0.05	55.1	2.8	8.4
Systems Management	0.19	Data loss prevention system is in place	0.04	56.4	2.3	
		Energy system outages are planned for	0.04	54.4	2.2	
		Machine limitations are recorded	0.02	50.6	1.0	
		Network modeling for IoT is done	0.02	43.2	0.9	
		Outages are not required for security updates	0.04	45.6	1.8	
		Planning for forensic evidence collection	0.03	45.7	1.4	9.5
Professional	0.18	Change Management is considered	0.03	52.4	1.6	
		Cyber awareness of all staff is checked	0.05	48.6	2.4	

		External reporting is done	0.02	53.5	1.1	
		External vendor/supply coordination is done	0.03	55.3	1.7	
		Threats to organization are modeled	0.04	59.5	2.4	9.1
Leadership	0.26	Cybersecurity goals of energy organization are identified	0.04	49.9	2.0	
		Cybersecurity learning sources are available	0.03	46.7	1.4	
		Cybersecurity risk is considered priority by C-Suite	0.08	56.3	4.5	
		Policies are updated	0.03	49.3	1.5	
		Professionals with cyber certifications are in operations roles	0.04	50.1	2.0	
		Supply chain cyber risk is considered during procurement	0.05	53.5	2.7	14.1
Total					**50.8**	

Private Entities Strengths and Weaknesses

According to the experts the top 3 priorities to focus on for Private Entities should be: Cybersecurity Risk is a required topic by C-Suite, the expected level that standards are understood, and Cyber supply chain risks considered in procurement.

Table 79 – The Strengths and Weaknesses of Private Entities

Private Entity Case	Readiness Criteria	Criteria Information	Desirability Value
Strength	Standards are understood	Create a model to follow tailored to your organization. When standards are misunderstood there may be violations. "Private Entity standards may be helpful for energy system Operators of Cybersecurity in Energy and closely related industries" [39].	55.1
	Data loss prevention system is in place	Data Loss Prevention system is essential for critical information and assets. DLP systems provide: logging, malfunction information, forensics, threat information, retention, reporting, and cloud information. A forensic model is in place for when an event occurs is one aspect of DLP. No DLP means there is no large integrated system for threat management.	56.4

Weakness	Network modeling for IoT is done	A security model is done based on protocols and network connections. Cloud assets are modeled. Contracts without specifications around network responsibilities and/or without models are likely to cause dropping the ball with security.	43.2
	Retention periods are in place and used for information and data	Attribution, solving data issues, restoration of data are some reasons why retention is a concern. If no offline backups, based on retention goals, then data could be lost in an attack or too much data could be exposed in an attack.	37.7

Note: Those criteria that scored high or low for both cases are discussed in detail after the cases are presented.

Overall, Strengths and Weaknesses Conclusions

Many priorities are shared in both cases. Below is a weighted score focus on readiness for each cases Perspective. Strong areas (high scores) this means that desirability multiplied by the expert's opinion shows a high importance for the case. For the weak areas this means that desirability multiplied by the expert's opinion shows a low importance (low score) for the case.

Table 80 - Case Analysis and Readiness Score

Perspective	Agencies of Government	Private Entities
Organizational	9.3	9.8
Information Management	7.5	8.4
Systems Management	10.4	9.5
Professional	9.5	9.1
Leadership	14.5	14.1
Overall Readiness Score	51.2	50.9

Table 81 - The Strengths and Weaknesses of Both Cases

Both Cases	Readiness Criteria	Criteria Information	Final Score Average of

			both cases
Strength	Supply chain cyber risk is considered during procurement	Communications and controls (such as contracts) are setup with vendors and suppliers. Third parties may have vulnerabilities.	2.75
	Cybersecurity risk is considered priority by C-Suite	The board, and or C-Suite, is not considering cyber a risk. If your assets are important the organization should be paying the same or more attention on security than on ease of use and time to market. The Chief Information Officer (CIO) should be making strategic decisions as an equal on the board if exists for Information Technology (IT) security awareness at the organizational level. There is no comprehensive plan and recognition of experts for cybersecurity at the strategic level.	4.6
	Cyber awareness of all staff is checked	Rogue access points awareness by Wi-Fi users. Malicious links create a man in the middle attack possibility. Vulnerable employees will likely lead to vulnerable organizational assets.	2.6
	Network and System admin procedures documented	Setup policies and procedure settings are known. Administrators are identified. Without the policies and procedures thoroughness and	2.35

		clarity are not complete.	
	Threats to organization are modeled	A corpus to prioritize and deal with threats. If don't have a threat model then awareness of security and attack vectors is not present.	2.35
Weakness	Info Officer is in contact with Internet Service Provider	There is communication between Chief Information Office (or delegate) and the Internet Service Provider or other sites. The Internet Service Provider is part of the internet network interfaces and can add to complete cyber awareness.	.4
	Social impact of breaches is talked about in the company	Social con artistry, which is one of the easiest ways to get information, is discussed including impacts. Breaches are a concern and when unplanned for information/reputation could be lost.	.8
	Presence of legislative understanding	Lack of legal understanding can lead to non-compliance and additional forced oversight. Legal issues can have a costly monetary penalty.	1.05
	Machine limitations are recorded	Limitations of systems configurations ability must be known (before installing preferred). What configuration you can or cannot do (e.g.,	1.05

	hardening) because of design limitations is making the organization aware. Protocol limitations of machines are known. Machines that cannot be configured in networks or are misconfigured leave critical infrastructure vulnerable.	
External reporting is done	Electricity Information Sharing and Analysis Centers and Computer Security Incident Response Teams help keep Private Entities a step ahead of criminals. If no security reports are being made the criminals have a knowledge advantage.	1.05

The experts prioritize the criterion highlighted in green below as being at the top of remediation readiness. These five priorities come across as most important for experts to address in both industries. Firstly, in the Leadership perspective cybersecurity risk is considered priority by C-Suite was the highest scoring HDM criteria (averaged 4.6) in the model and both cases, Agencies of Government and Private Entities. This concern is also related in the Cyber-Risk Oversight Handbook [248]. Secondly, in the Leadership perspective Supply chain cyber risk is considered during procurement averaged 2.75. The supply chain is how adversary's got into the Target Corporation credit card system [58]. Thirdly, in the Professional perspective Cyber awareness of all staff is checked averaged 2.6. Being aware of malware threats is important [58]. Tied for fourth currently most

important for experts for cybersecurity readiness in the USA energy industry were: Network and System admin procedures documented (in the Information Management perspective) and Threats to organization are modeled (in the Professional perspective). Both had an average score of 2.35. Requiring admin accounts for IT installations is part of the procedures is referenced by Carbon Black [249]. While Operational Technology threat models are currently being developed [250].

The following were low scoring findings:

Machine limitations are recorded was one of the lowest scoring final scores (average 1.05). Machine limitations are recorded was found to be one of the most unimportant criteria through the HDM model. More research should be done to find out why as this impacts configuration management. One commenter mentioned that "machine limitations definition is not clear."

External reporting is done was a low scoring criterion in practical application (average 1.05). It's not clear why external reporting is seen as unimportant. There is a compliance aspect to reporting that is not always appreciated by security experts. The MITRE ICS matrix [251] was created from external reports over time so it's clearly an important cybersecurity philosophy.

Presence of legislative understanding although not one of the lowest scoring or highest scoring criterion the HDM final score, it did rank low in both cases (average 1.05). This means that desirability in practical application is low. In literature this is important gap but the experts who created the desirability curves disagreed. More

research should be done on this important topic. The corporate handbook for oversight states that knowing legal impact is important [248].

Social impact of breaches is talked about in the company was the second lowest scoring criteria in the final case models (.8). Even at the highest level of full extant the scorer only gave desirability at 75%. This should be investigated in future research as most desirability curves are near 100% for the high score. The NIST Artificial Intelligence (AI) Risk Management Framework (RMF) discusses social responsibility and negative impacts [252]. Again, the corporate handbook for oversight states that understanding and discussing threats is important [248].

Info Officer is in contact with Internet Service Provider was the lowest scoring criteria in the case models (.4). It is necessary to be in contact with ISP for their support in a distributed denial of service (DDOS) attack because the organization will not be able to stop a DDOS attack without help. It was found by many to have a lack of importance for Cybersecurity Readiness in the USA Energy Industry. Based on the low score either this area is a severely lacking communication channel or there is an alternative method to mitigating provider backbones in terms of security. This should be investigated in future research.

Both organizations think no readiness action is needed for change management because they either have good systems in place or don't consider it a priority. The criteria standards are understood was addressed once in the literature but was found to be of high importance in Private Entities decision making. Data Loss Prevention was mentioned the most numerous times of any criteria in the literature and is also seen as most highly

important to Private Entities. In these Cases, both organizations experts agree that standards are understood is an important shared concern. Network modeling for IoT is done and Retention periods are in place neither criterion is being flagged as important by Private Entities.

Although the literature quoted some concerns multiple times (machine limitations are recorded, and external reporting is done) the experts keyed in on other elements that were rarely mentioned in literature (Supply chain cyber risk is considered during procurement, and cyber awareness of all staff is checked). The elements that are widely known in practice do not always align with the literature.

This comparison shows how the model was able to capture different attributes that contribute to each case. There are plenty of chances to enhance readiness, as there are no factors scored above 60. Target of the improvements would most likely be factors where the score is low. Other targets are where the alternate case scores high. This shows that the readiness score is achievable.

Figure 59 - HDM model with Strengths (Green) and Weaknesses (Red) for both Entity Types Highlighted

Cybersecurity Readiness Decision

Mission

Perspectives

Organizational | Systems Management | Information Management | Professional | Leadership

Based on National Institute of Standards and Technology (NIST) National Initiative for Cybersecurity Education (NICE) Competency Framework Draft NISTIR 8355. Information Management refers to a category in NIST 800-137 Systems Management refers to all other categories in NIST 800-137.

Criteria

Organizational	Systems Management	Information Management	Professional	Leadership
Presence of Implementation Oversight 5, 24, 28, 29	Energy system outages are planned for 32	Retention periods are in place and used for information and data 12, 30	External reporting is done 16, 18, 20, 34	Cybersecurity learning sources are available 15, 28, 30
Cybersecurity Readiness Assessments 11, 16, 32, 36	Data loss prevention system is in place 12, 14, 16, 23, 24, 28, 30, 32 (2), 33	Network and System admin procedures documented 6, 22, 26, 28	External vendor/supply coordination is done 10, 20	Cybersecurity goals of energy organization are identified 10, 30
Presence of legislative understanding 8, 26	Planning for forensic evidence collection 14, 21, 30	Info Officer is in contact with Internet Service Provider 25	Threats to organization are modeled 15, 29	Cybersecurity risk is considered priority by C-Suite 20, 26, 32, 34
Computer users settings and permissions are known 11, 24, 25	Machine limitations are recorded 26, 30 (2)	Logging is sufficient for security and forensics 7, 9, 22, 27, 30, 39	Cyber awareness of all staff is checked 39	Professionals with cyber certifications are in operations roles 28
Social impact of breaches is talked about in the company 25	Network modeling for IoT is done 11, 30 (2)	Standards are understood 36	Change Management is considered 17	Policies are updated 8, 22
Documents are marked and protected 20	Outages are not required for security updates 26			Supply chain cyber risk is considered during procurement 17
There is an organizational common vocabulary for cybersecurity in the energy industry 25				

Based on Authors Energy Cybersecurity Readiness Citation Chasing

Note: Green = High Value, Blue = Medium Value, Red = Low Value

8.1.4 Improvement Simulations

Based on the new assessment, new corrective actions should be introduced, and then the readiness score can be reevaluated. Desirability (aka value) curves play a crucial role in this process. The highest priorities, from the research findings, have assigned actions in the action column. The actions help to identify where the case could be improved to a more optimal level. Those data points that scored reasonably well and those with shared weaknesses are not targeted for immediate improvement and thus do not have any action assigned. The tables below show actions suggested for each case and how those actions result in a higher score.

Table 82 - Improvement Simulation – Case of Agencies of Government

Perspectives	Value	Readiness Criterion	Global Weights	Value Curve Score (D Score Average)	Final Score (Global * Value Curve)	New VC Score	New Score	Actions
Organizational	0.2	Computer users settings and permissions are known	0.04	49.0	2.0	49.0	2.0	No Action
		Cybersecurity Readiness Assessments	0.03	49.5	1.5	49.5	1.5	No Action
		Documents are marked and protected	0.03	51.3	1.5	51.3	1.5	No Action
		Presence of Implementation Oversight	0.03	49.0	1.5	49.0	1.5	No Action

		Presence of legislative understanding	0.02	48.3	1.0	48.3	1.0	No Action
		Social impact of breaches is talked about in the company	0.02	45.8	0.9	45.8	0.9	No Action
		There is an organizational common vocabulary for cybersecurity in the energy industry	0.02	49.0	1.0	61.1	1.2	Define your vocabulary. A defined technical vocabulary should be defined. If users don't understand vocabulary around detection and prevention they cannot discuss or deal with cyberattacks.
Information Management	0.18	Info Officer is in contact with Internet Service Provider	0.01	45.5	0.5	45.5	0.5	No Action
		Logging is sufficient for security and forensics	0.04	38.4	1.5	38.4	1.5	No Action
		Network and System admin procedures documented	0.05	48.1	2.4	48.1	2.4	No Action
		Retention periods are in place and used for information and data	0.03	40.9	1.2	40.9	1.2	No Action
		Standards are understood	0.05	38.1	1.9	55.1	2.8	Create a model to follow tailored to your organization. When standards are misunderstood there may be violations. Private Entity standards may be helpful for energy system Operators of Cybersecurity in Energy and closely related industries.

Systems Management	0.19	Data loss prevention system is in place	0.04	51.0	2.0	56.4	2.3	Implement a Data Loss Prevention system. DLP is essential for critical information and assets. DLP systems provide: logging, malfunction information, forensics, threat information, retention, reporting, and cloud information. A forensic model is in place for when an event occurs is one aspect of DLP. No DLP means there is no large integrated system for threat management.
		Energy system outages are planned for	0.04	53.3	2.1	53.3	2.1	No Action
		Machine limitations are recorded	0.02	56.5	1.1	56.5	1.1	No Action
		Network modeling for IoT is done	0.02	62.5	1.3	62.5	1.3	No Action
		Outages are not required for security updates	0.04	56.3	2.3	56.3	2.3	No Action
		Planning for forensic evidence collection	0.03	53.8	1.6	53.8	1.6	No Action
Professional	0.18	Change Management is considered	0.03	56.3	1.7	56.3	1.7	No Action
		Cyber awareness of all staff is checked	0.05	56.3	2.8	56.3	2.8	No Action
		External reporting is done	0.02	51.0	1.0	51.0	1.0	No Action
		External vendor/supply coordination is done	0.03	56.3	1.7	56.3	1.7	No Action

		Threats to organization are modeled	0.04	56.3	2.3	56.3	2.3	No Action
Leadership	0.26	Cybersecurity goals of energy organization are identified	0.04	49.3	2.0	49.3	2.0	No Action
		Cybersecurity learning sources are available	0.03	51.8	1.6	51.8	1.6	No Action
		Cybersecurity risk is considered priority by C-Suite	0.08	58.3	4.7	58.3	4.7	No Action
		Policies are updated	0.03	51.8	1.6	51.8	1.6	No Action
		Professionals with cyber certifications are in operations roles	0.04	50.0	2.0	50.0	2.0	No Action
		Supply chain cyber risk is considered during procurement	0.05	55.0	2.8	55.0	2.8	No Action
Total					**51.2**		**52.5**	

8.1.4.1 Implications of Agencies of Government Improvement Simulation Scenario

The finding is that Agencies of Government need to clearly define vocabulary. A defined technical vocabulary should be defined to avoid miscommunication. Issues may arise because employees in one department don't understand the technical vocabulary being used by IT or security. If users don't understand vocabulary around terms like detection and prevention they cannot discuss or deal with cyberattacks effectively.

Figure 60– Agencies of Government My Proposal 1

Weakness low score 49

Agencies of Government	Private Entities
49	61.1

Perspective: Organizational
Criteria: There is an organizational common vocabulary for cybersecurity in the energy private

Define your vocabulary. A defined technical vocabulary should be defined. If users don't understand vocabulary around detection and prevention they cannot discuss or deal with cyberattacks effectively. Issues may arise because employees in one department don't understand the technical vocabulary being used by IT or security. If users don't understand the cyberattack detection and prevention language, and concerns and detection and protection are not defined, then users will likely not be able to detect and prevent cyberattacks

A technical cyber lexicon allows for collaboration for the whole cyber community.
National Security Agency (NSA) Cyber Security Operations, "NSA/CSS Technical Cyber Threat Framework v1," March 6 2018.

When standards are misunderstood there may be violations. Non-government standards may be helpful for reference in completing full scope audit and assessment preparation. Creating a model to follow that is tailored to an organization is important. When standards are misunderstood an auditor will likely find violations when an assessment is done. Standards a good place to start when going through a checklist or trying to create a model tailored for your organization.

Figure 61 – Agencies of Government My Proposal 2

A Private entity readiness focus area. Private score: 55.1

Agencies of Government	Private Entities
38.1	55.1

Perspective: Information Management
Criteria: Standards are understood.

Create a model to follow tailored to your organization. When standards are misunderstood there may be violations. Non-government standards may be helpful for reference in completing full scope audit and assessment preparation.
When standards are misunderstood an auditor will likely find violations when an assessment is done. Standards a good place to start when going through a checklist or trying to create a model tailored for your organization.

"Ernst & Young says most oil and gas don't have high enough network standards."
OWL Cyber Defense, "Cybersecurity Solutions For the Digital Oil Field," Columbia, MD2023.

Implement a Data Loss Prevention system. DLP is essential for critical information and assets. DLP systems provide: logging, malfunction information,

forensics, threat information, retention, reporting, and cloud information. A forensic model is in place for when an event occurs is one aspect of DLP. No DLP means there is no large integrated system for threat management. Information Security Management System (ISMS) can take the place of a DLP system. Detection, if included in a DLP means that the organization also has a system for threat management. Make sure the logging is setup correctly. Check that the log time is protected, to correctly attribute and sync of egregious actions, and make sure that the logging storage is functioning correctly. Post-incident procedures (aka response and recovery) add to a comprehensive list of security considerations for DLP.

Figure 62 – Agencies of Government My Proposal 3

A Private entity readiness focus area. Private score: 56.4

Agencies of Government	Private Entities
51	56.4

Perspective: Systems Management
Criteria: Data loss prevention system is in place

Implement a Data Loss Prevention system. DLP is essential for critical information and assets. DLP systems provide: logging, malfunction information, forensics, threat information, retention, reporting, and cloud information. A forensic model is in place for when an event occurs is one aspect of DLP. No DLP means there is no large integrated system for threat management.
Make sure the logging is setup correctly. Check that the log time is protected, to correctly attribute and sync of egregious actions, and make sure that the logging storage is functioning correctly.
Post-incident procedures (aka response and recovery) add to a comprehensive list of security considerations for DLP.

Information Security Management System (ISMS) can take the place of a DLP system. Detection, if included in a DLP means that the organization also has a system for threat management.

E. Conrad and S. Misner, "SEC511: Continuous Monitoring and Security Operations - Course," SANS [PowerPoint].

Table 83 - Improvement Simulation – Case of Private Entities

Perspectives	Value	Readiness Criterion	Global Weights	Value Curve Score (D Score Average)	Final Score (Global * Value Curve)	New VC Score	New Score	Actions

Organizational	0.2	Computer users settings and permissions are known	0.04	55.8	2.2	55.8	2.2	No Action
		Cybersecurity Readiness Assessments	0.03	46.3	1.4	46.3	1.4	No Action
		Documents are marked and protected	0.03	53.5	1.6	53.5	1.6	No Action
		Presence of Implementation Oversight	0.03	50.2	1.5	50.2	1.5	No Action
		Presence of legislative understanding	0.02	55.5	1.1	55.5	1.1	No Action
		Social impact of breaches is talked about in the company	0.02	35.2	0.7	35.2	0.7	No Action
		There is an organizational common vocabulary for cybersecurity in the energy industry	0.02	61.1	1.2	61.1	1.2	No Action
Information Management	0.18	Info Officer is in contact with Internet Service Provider	0.01	33.1	0.3	33.1	0.3	No Action
		Logging is sufficient for security and forensics	0.04	46.0	1.8	46.0	1.8	No Action
		Network and System admin procedures documented	0.05	46.8	2.3	46.8	2.3	No Action
		Retention periods are in place and used for information and data	0.03	37.7	1.1	40.9	1.2	Create offline backups and retention standards Attribution, solving data issues, restoration of data are some reasons why retention is a concern. If no offline backups, based on retention goals, then data could be lost in an attack or too much data could be exposed in an attack..

		Standards are understood	0.05	55.1	2.8	55.1	2.8	No Action
Systems Management	0.19	Data loss prevention system is in place	0.04	56.4	2.3	56.4	2.3	No Action
		Energy system outages are planned for	0.04	54.4	2.2	54.4	2.2	No Action
		Machine limitations are recorded	0.02	50.6	1.0	50.6	1.0	No Action
		Network modeling for IoT is done	0.02	43.2	0.9	62.5	1.3	Create a security model is done based on protocols, network connections, and endpoints. Cloud assets also need to be modeled. Contracts without specifications around network responsibilities and/or without models are likely to cause gaps in security.
		Outages are not required for security updates	0.04	45.6	1.8	56.3	2.3	Spares enable continuous operation. Asset work stoppages can lead to access failures. Create a backup operations plan.
		Planning for forensic evidence collection	0.03	45.7	1.4	45.7	1.4	No Action
Professional	0.18	Change Management is considered	0.03	52.4	1.6	52.4	1.6	No Action
		Cyber awareness of all staff is checked	0.05	48.6	2.4	48.6	2.4	No Action
		External reporting is done	0.02	53.5	1.1	53.5	1.1	No Action
		External vendor/supply coordination is done	0.03	55.3	1.7	55.3	1.7	No Action
		Threats to organization are modeled	0.04	59.5	2.4	59.5	2.4	No Action

Leadership	0.26	Cybersecurity goals of energy organization are identified	0.04	49.9	2.0	49.9	2.0	No Action
		Cybersecurity learning sources are available	0.03	46.7	1.4	46.7	1.4	No Action
		Cybersecurity risk is considered priority by C-Suite	0.08	56.3	4.5	56.3	4.5	No Action
		Policies are updated	0.03	49.3	1.5	49.3	1.5	No Action
		Professionals with cyber certifications are in operations roles	0.04	50.1	2.0	50.1	2.0	No Action
		Supply chain cyber risk is considered during procurement	0.05	53.5	2.7	53.5	2.7	No Action
Total					**50.8**		**51.7**	

8.1.4.2 Implications of Private Entity Improvement Simulation Scenario

Private Entities need to create offline backups and retention standards. Attribution, solving data issues, restoration of data are some reasons why retention is a concern. If no offline backups, based on retention goals, then data could be lost in an attack or too much data could be exposed in an attack. Retention must be considered and planned for; including, but not limited to a model for cloud assets. Create a security model is done based on protocols, network connections, and endpoints. Cloud assets also need to be modeled. Contracts without specifications around network responsibilities and/or without models are likely to cause gaps in security.

Figure 63 – Private Entities My Proposal 1

Agencies of Government	Private Entities
40.9	37.7

Weakness low score. Score: 37.7

Perspective: Information Management
Criteria: Retention periods are in place and used for information and data

Create offline backups and retention standards. Attribution, solving data issues, restoration of data are some reasons why retention is a concern. If no offline backups, based on retention goals, then data could be lost in an attack or too much data could be exposed in an attack.
Retention must be considered and planned for; including, but not limited to a model for cloud assets

Retention periods are accounted for by Agencies of Government.
U.S. Department of Energy, "DOE Records Disposition Manual: Transmittal 07," May ed: DOE, 2024.

IoT networks are often remote, physical systems that may operate on different vulnerable protocols like ZigBee. IoT logs should be backed up. Visibility and control of cloud assets comes down to contracting and that concern should be modeled in the IoT network.

Figure 64 – Private Entities My Proposal 2

Agencies of Government	Private Entities
62.5	43.2

Weakness low score. Score: 43.2

Perspective: Systems Management
Criteria: Network modeling for IoT is done.

Create a security model is done based on protocols, network connections, and endpoints. Cloud assets also need to be modeled. Contracts without specifications around network responsibilities and/or without models are likely to cause gaps in security.
IoT networks are often remote, physical systems that may operate on different vulnerable protocols like ZigBee. IoT logs should be backed up. Visibility and control of cloud assets comes down to contracting and that concern should be modeled in the IoT network.

IoT Asset Inventories are now required for Federal Agencies.
Office of Management and Budget (OMB), "M-24-04 Fiscal Year 2024 Guidance on Federal Information Security and Privacy Management Requirements," Executive Office of the President, Ed., Dec 4 ed. Washington, DC, 2023.

Spares enable continuous operation. Asset work stoppages can lead to access failures. Create a backup operations plan. Machine stoppages can lead to access failures. Enabling continuous operation of the grid interconnection is essential to modern life functions.

Figure 65 – Private Entities My Proposal 3

An Agency of Government readiness focus area. Agency of Government score: 56.3

Perspective: Systems Management
Criteria: Outages are not required for security updates

Agencies of Government	Private Entities
56.3	45.6

Spares enable continuous operation. Asset work stoppages can lead to access failures. Create a backup operations plan.
Machine stoppages can lead to access failures.
Enabling continuous operation of the grid interconnection is essential to modern life functions.

Scanning a duplicated machine would enable avoiding traffic on production ICS systems which could lead to ICS failure.

R. M. Zain, "Hybrid Approach for Assessing Security Vulnerability and Increasing the Resiliency of Industrial Control System (ICS)," International Journal of Computer and Information Technology, vol. 4, July 2015.

8.2 Scenarios

To build a decision support system covering all aspects the scenarios simulation test was conducted. “The model needs to be tested for different types of problems in different contexts so that the results can be generalized” [244]. Analysis of scenarios improves the applicability and reliability of the HDM model. This is conducted through testing by changing the numbers of analysis. Scenarios show change and clarify importance of factors. The scenarios are as-if based on weights being changed. When the median is high or there are many criteria in a perspective then the perspective itself will be more likely to affect the overall scenario score.

8.2.1 Sensitivity Analysis

Sensitivity analysis approach is used to test the robustness of the model.

The model's sensitivity may be evaluated by measuring how much the ranking would be altered in various settings. [Sensitivity analysis] can be used to investigate how much impact a change to the model's priorities would have on its

outcomes by calculating the amount of perturbation it would endure. This is performed when the decision-maker believes that a particular perspective's importance has changed. [217].

To better understand the dynamics of the model and the influence of each perspective five sensitivity scenarios are suggested. In each scenario, one of the perspectives is boosted with the assumption that it might turn out in reality (i.e. materially) as the most critical perspective.

This analysis aims to measure how the model's final output will react to changes in the relevance of criteria. Multiple scenarios were created to capture the result of the analyses. Five scenarios are suggested, in each scenario, one of the perspectives is boosted with the assumption that it might turn out that this is the most critical perspective. That is to see if any of those scenarios materialized to affect the perspective results.

Each scenario alters the relevance of perspectives by boosting one of the perspectives and the same process is repeated for the five perspectives. For example, the economical perspective boosted to be 0.96, while the remaining perspective's values are 0.01 for each. The result of the five scenarios is summarized below.

Table 84 - Future Scenarios

	0.2	0.18	0.19	0.18	0.26
Organizational	0.96	0.01	0.01	0.01	0.01
Information Management	0.01	0.96	0.01	0.01	0.01
Systems Management	0.01	0.01	0.96	0.01	0.01
Professional	0.01	0.01	0.01	0.96	0.01
Leadership	0.01	0.01	0.01	0.01	0.96

8.2.1.1 Organizational Emphasis

For the Organizational perspective Agencies of Government Case Sum adds to 47.0328 and the Private Entity Case Sum 49.4150. The higher number shows that Private Entities have more Organizational readiness opportunities for improvement than do Agencies of Government. If organizational aspects are deemed more important the Private Entity case is positively affected.

Table 85 - Organizational Emphasis

Perspectives	Value	Readiness Criterion	Local Weights	Global Weights	Agencies of Government D	Agencies of Government Case	Private Entity D Score	Private Entity Case
Organizational	0.96	Computer users settings and permissions are known	0.2	0.1920	49.0	9.4080	55.8	10.7040
		Cybersecurity Readiness Assessments	0.17	0.1632	49.5	8.0784	46.3	7.5562
		Documents are marked and protected	0.14	0.1344	51.3	6.8880	53.5	7.1837
		Presence of Implementation Oversight	0.16	0.1536	49.0	7.5264	50.2	7.7030
		Presence of legislative understanding	0.11	0.1056	48.3	5.0952	55.5	5.8608
		Social impact of breaches is talked about in the company	0.1	0.0960	45.8	4.3920	35.2	3.3744
		There is an organizational common vocabulary for cybersecurity in the energy industry	0.12	0.1152	49.0	5.6448	61.1	7.0330

Information Management	0.01	Info Officer is in contact with Internet Service Provider	0.06	0.0006	45.5	0.0273	33.1	0.0199
		Logging is sufficient for security and forensics	0.2	0.0020	38.4	0.0768	46.0	0.0920
		Network and System admin procedures documented	0.29	0.0029	48.1	0.1396	46.8	0.1356
		Retention periods are in place and used for information and data	0.19	0.0019	40.9	0.0777	37.7	0.0716
		Standards are understood	0.27	0.0027	38.1	0.1029	55.1	0.1487
Systems Management	0.01	Data loss prevention system is in place	0.19	0.0019	51.0	0.0969	56.4	0.1072
		Energy system outages are planned for	0.22	0.0022	53.3	0.1172	54.4	0.1197
		Machine limitations are recorded	0.12	0.0012	56.5	0.0678	50.6	0.0607
		Network modeling for IoT is done	0.11	0.0011	62.5	0.0688	43.2	0.0475
		Outages are not required for security updates	0.21	0.0021	56.3	0.1181	45.6	0.0957
		Planning for forensic evidence collection	0.17	0.0017	53.8	0.0914	45.7	0.0776
Professional	0.01	Change Management is considered	0.2	0.0020	56.3	0.1125	52.4	0.1048
		Cyber awareness of all staff is checked	0.29	0.0029	56.3	0.1631	48.6	0.1410
		External reporting is done	0.11	0.0011	51.0	0.0561	53.5	0.0589
		External vendor/supply coordination is done	0.18	0.0018	56.3	0.1013	55.3	0.0996

		Threats to organization are modeled	0.22	0.0022	56.3	0.1238	59.5	0.1309
Leadership	0.01	Cybersecurity goals of energy organization are identified	0.16	0.0016	49.3	0.0788	49.9	0.0798
		Cybersecurity learning sources are available	0.1	0.0010	51.8	0.0518	46.7	0.0467
		Cybersecurity risk is considered priority by C-Suite	0.3	0.0030	58.3	0.1748	56.3	0.1688
		Policies are updated	0.11	0.0011	51.8	0.0569	49.3	0.0542
		Professionals with cyber certifications are in operations roles	0.14	0.0014	50.0	0.0700	50.1	0.0701
		Supply chain cyber risk is considered during procurement	0.19	0.0019	55.0	0.1045	53.5	0.1017
Total						49.1106		51.4475

The resulting summary table below shows that the overall score for the Private Entity case increased from 50.8185 to 51.4475 while the Agencies of Government case was negatively impacted. The ranking has changed. The favorable change for the Private Entity case suggests that organization readiness has had a positive impact. Too much focus on Organizational in Agencies of Government will lead to declining readiness. If the perspective is addressed in Private Entities then there will be more confidence (a positive score) to readiness as a whole.

Table 86 - Organization Score and Rank Change

	Agencies of Government	Private Entities
Organizational Original	51.1963	50.8185

Scenario	49.1106	51.4475
Score Change	-2.08569	0.62892
Rank	1	2
Scenario Ranking	2	1

8.2.1.2 Information Management Emphasis

The Information Management perspective finds that the Agencies of Government Case Sum adds to 40.7244 and the Private Entities Case Sum 44.9016. The higher number shows that Private Entities have more Information Management readiness opportunities for improvement than Agencies of Government.

Table 87 - Information Management Emphasis

Perspectives	Value	Readiness Criterion	Local Weights	Global Weights	Agencies of Government D	Agencies of Government Case	Private Entity D Score	Private Entity Case
Organizational	0.01	Computer users settings and permissions are known	0.2	0.0020	49.0	0.0980	55.8	0.1115
		Cybersecurity Readiness Assessments	0.17	0.0017	49.5	0.0842	46.3	0.0787
		Documents are marked and protected	0.14	0.0014	51.3	0.0718	53.5	0.0748
		Presence of Implementation Oversight	0.16	0.0016	49.0	0.0784	50.2	0.0802
		Presence of legislative understanding	0.11	0.0011	48.3	0.0531	55.5	0.0611
		Social impact of breaches is talked about in the company	0.1	0.0010	45.8	0.0458	35.2	0.0352
		There is an organizational common vocabulary for cybersecurity in	0.12	0.0012	49.0	0.0588	61.1	0.0733

		the energy industry						
Information Management	0.96	Info Officer is in contact with Internet Service Provider	0.06	0.0576	45.5	2.6208	33.1	1.9080
		Logging is sufficient for security and forensics	0.2	0.1920	38.4	7.3680	46.0	8.8320
		Network and System admin procedures documented	0.29	0.2784	48.1	13.3980	46.8	13.0152
		Retention periods are in place and used for information and data	0.19	0.1824	40.9	7.4556	37.7	6.8742
		Standards are understood	0.27	0.2592	38.1	9.8820	55.1	14.2722
Systems Management	0.01	Data loss prevention system is in place	0.19	0.0019	51.0	0.0969	56.4	0.1072
		Energy system outages are planned for	0.22	0.0022	53.3	0.1172	54.4	0.1197
		Machine limitations are recorded	0.12	0.0012	56.5	0.0678	50.6	0.0607
		Network modeling for IoT is done	0.11	0.0011	62.5	0.0688	43.2	0.0475
		Outages are not required for security updates	0.21	0.0021	56.3	0.1181	45.6	0.0957
		Planning for forensic evidence collection	0.17	0.0017	53.8	0.0914	45.7	0.0776
Professional	0.01	Change Management is considered	0.2	0.0020	56.3	0.1125	52.4	0.1048
		Cyber awareness of all staff is checked	0.29	0.0029	56.3	0.1631	48.6	0.1410
		External reporting is done	0.11	0.0011	51.0	0.0561	53.5	0.0589
		External vendor/supply	0.18	0.0018	56.3	0.1013	55.3	0.0996

		coordination is done						
		Threats to organization are modeled	0.22	0.0022	56.3	0.1238	59.5	0.1309
Leadership	0.01	Cybersecurity goals of energy organization are identified	0.16	0.0016	49.3	0.0788	49.9	0.0798
		Cybersecurity learning sources are available	0.1	0.0010	51.8	0.0518	46.7	0.0467
		Cybersecurity risk is considered priority by C-Suite	0.3	0.0030	58.3	0.1748	56.3	0.1688
		Policies are updated	0.11	0.0011	51.8	0.0569	49.3	0.0542
		Professionals with cyber certifications are in operations roles	0.14	0.0014	50.0	0.0700	50.1	0.0701
		Supply chain cyber risk is considered during procurement	0.19	0.0019	55.0	0.1045	53.5	0.1017
Total						42.8679		46.9810

For Information Management both cases were negatively affected. These negative changes suggest that if this perspective is focused on to a critical degree, at the behest of other perspectives, then overall readiness decreases. This scenario is generally bad and suggests that if Information Management criteria are the most critical factors by management, more caution and preparation must be considered when implementing. The ranking has changed.

Table 88 - Information Management Score and Rank Change

Information Management	Agencies of Government	Private Entities
Original	51.1963	50.8185
Scenario	42.8679	46.9810

Score Change	-8.32837	-3.83750
Rank	1	2
Scenario Ranking	2	1

8.2.1.3 Systems Management Emphasis

The Systems Management perspective finds that the Agencies of Government Case Sum adds to 53.7696 and the Private Entity Case Sum 48.8112. The higher number shows that Agencies of Government have more Systems Management readiness opportunities for improvement than Private Entities.

Table 89 - Systems Management Emphasis

Perspectives	Value	Readiness Criterion	Local Weights	Global Weights	Agencies of Government D	Agencies of Government Case	Private Entity D Score	Private Entity Case
Organizational	0.01	Computer users settings and permissions are known	0.2	0.0020	49.0	0.0980	55.8	0.1115
		Cybersecurity Readiness Assessments	0.17	0.0017	49.5	0.0842	46.3	0.0787
		Documents are marked and protected	0.14	0.0014	51.3	0.0718	53.5	0.0748
		Presence of Implementation Oversight	0.16	0.0016	49.0	0.0784	50.2	0.0802
		Presence of legislative understanding	0.11	0.0011	48.3	0.0531	55.5	0.0611
		Social impact of breaches is talked about in the company	0.1	0.0010	45.8	0.0458	35.2	0.0352
		There is an organizational common vocabulary for cybersecurity in	0.12	0.0012	49.0	0.0588	61.1	0.0733

		the energy industry						
Information Management	0.01	Info Officer is in contact with Internet Service Provider	0.06	0.0006	45.5	0.0273	33.1	0.0199
		Logging is sufficient for security and forensics	0.2	0.0020	38.4	0.0768	46.0	0.0920
		Network and System admin procedures documented	0.29	0.0029	48.1	0.1396	46.8	0.1356
		Retention periods are in place and used for information and data	0.19	0.0019	40.9	0.0777	37.7	0.0716
		Standards are understood	0.27	0.0027	38.1	0.1029	55.1	0.1487
Systems Management	0.96	Data loss prevention system is in place	0.19	0.1824	51.0	9.3024	56.4	10.2904
		Energy system outages are planned for	0.22	0.2112	53.3	11.2464	54.4	11.4928
		Machine limitations are recorded	0.12	0.1152	56.5	6.5088	50.6	5.8272
		Network modeling for IoT is done	0.11	0.1056	62.5	6.6000	43.2	4.5584
		Outages are not required for security updates	0.21	0.2016	56.3	11.3400	45.6	9.1896
		Planning for forensic evidence collection	0.17	0.1632	53.8	8.7720	45.7	7.4528
Professional	0.01	Change Management is considered	0.2	0.0020	56.3	0.1125	52.4	0.1048
		Cyber awareness of all staff is checked	0.29	0.0029	56.3	0.1631	48.6	0.1410
		External reporting is done	0.11	0.0011	51.0	0.0561	53.5	0.0589
		External vendor/supply	0.18	0.0018	56.3	0.1013	55.3	0.0996

		coordination is done						
		Threats to organization are modeled	0.22	0.0022	56.3	0.1238	59.5	0.1309
Leadership	0.01	Cybersecurity goals of energy organization are identified	0.16	0.0016	49.3	0.0788	49.9	0.0798
		Cybersecurity learning sources are available	0.1	0.0010	51.8	0.0518	46.7	0.0467
		Cybersecurity risk is considered priority by C-Suite	0.3	0.0030	58.3	0.1748	56.3	0.1688
		Policies are updated	0.11	0.0011	51.8	0.0569	49.3	0.0542
		Professionals with cyber certifications are in operations roles	0.14	0.0014	50.0	0.0700	50.1	0.0701
		Supply chain cyber risk is considered during procurement	0.19	0.0019	55.0	0.1045	53.5	0.1017
Total						55.7772		50.8499

Both cases have scored well (positive change) for the Systems Management perspective. The cases overall are positively affected. The highly favorable changes for Agencies of Government Case show that Systems Management readiness is critical perspective that should be addressed to increase readiness. The ranking has not changed.

Table 90 - Systems Management Score and Rank Change

Systems Management	Agencies of Government	Private Entities
Original	51.1963	50.8185
Scenario	55.7772	50.8499
Score Change	4.58094	0.03137
Rank	1	2
Scenario Ranking	1	2

8.2.1.4 Professional Emphasis

The Professional perspective finds that the Agencies of Government Case Sum adds to 53.4456 and the Private Entity Case Sum 51.3672. The higher number shows that Agencies of Government entities have more Professional readiness capabilities than Private Entities.

Table 91 - Professional Emphasis

Perspectives	Value	Readiness Criterion	Local Weights	Global Weights	Agencies of Government D	Agencies of Government Case	Private Entity D Score	Private Entity Case
Organizational	0.01	Computer users settings and permissions are known	0.2	0.0020	49.0	0.0980	55.8	0.1115
		Cybersecurity Readiness Assessments	0.17	0.0017	49.5	0.0842	46.3	0.0787
		Documents are marked and protected	0.14	0.0014	51.3	0.0718	53.5	0.0748
		Presence of Implementation Oversight	0.16	0.0016	49.0	0.0784	50.2	0.0802
		Presence of legislative understanding	0.11	0.0011	48.3	0.0531	55.5	0.0611
		Social impact of breaches is talked about in the company	0.1	0.0010	45.8	0.0458	35.2	0.0352
		There is an organizational common vocabulary for cybersecurity in the energy industry	0.12	0.0012	49.0	0.0588	61.1	0.0733
Information Management	0.01	Info Officer is in contact with	0.06	0.0006	45.5	0.0273	33.1	0.0199

		Internet Service Provider						
		Logging is sufficient for security and forensics	0.2	0.0020	38.4	0.0768	46.0	0.0920
		Network and System admin procedures documented	0.29	0.0029	48.1	0.1396	46.8	0.1356
		Retention periods are in place and used for information and data	0.19	0.0019	40.9	0.0777	37.7	0.0716
		Standards are understood	0.27	0.0027	38.1	0.1029	55.1	0.1487
Systems Management	0.01	Data loss prevention system is in place	0.19	0.0019	51.0	0.0969	56.4	0.1072
		Energy system outages are planned for	0.22	0.0022	53.3	0.1172	54.4	0.1197
		Machine limitations are recorded	0.12	0.0012	56.5	0.0678	50.6	0.0607
		Network modeling for IoT is done	0.11	0.0011	62.5	0.0688	43.2	0.0475
		Outages are not required for security updates	0.21	0.0021	56.3	0.1181	45.6	0.0957
		Planning for forensic evidence collection	0.17	0.0017	53.8	0.0914	45.7	0.0776
Professional	0.96	Change Management is considered	0.2	0.1920	56.3	10.8000	52.4	10.0560
		Cyber awareness of all staff is checked	0.29	0.2784	56.3	15.6600	48.6	13.5372
		External reporting is done	0.11	0.1056	51.0	5.3856	53.5	5.6496
		External vendor/supply coordination is done	0.18	0.1728	56.3	9.7200	55.3	9.5580
		Threats to organization are modeled	0.22	0.2112	56.3	11.8800	59.5	12.5664

Leadership	0.01	Cybersecurity goals of energy organization are identified	0.16	0.0016	49.3	0.0788	49.9	0.0798
		Cybersecurity learning sources are available	0.1	0.0010	51.8	0.0518	46.7	0.0467
		Cybersecurity risk is considered priority by C-Suite	0.3	0.0030	58.3	0.1748	56.3	0.1688
		Policies are updated	0.11	0.0011	51.8	0.0569	49.3	0.0542
		Professionals with cyber certifications are in operations roles	0.14	0.0014	50.0	0.0700	50.1	0.0701
		Supply chain cyber risk is considered during procurement	0.19	0.0019	55.0	0.1045	53.5	0.1017
Total						55.4566		53.3793

For the Professional perspective both cases were positively affected. Both entity types show that Professional readiness is a perspective that if addressed increases readiness. The ranking has not changed.

Table 92 - Professional Score and Rank Change

Professional	Agencies of Government	Private Entities
Original	51.1963	50.8185
Scenario	55.4566	53.3793
Score Change	4.26031	2.56075
Rank	1	2
Scenario Ranking	1	2

8.2.1.5 Leadership Emphasis

The Leadership perspective finds that the Agencies of Government Case Sum adds to 47.0328 and the Private Entity Case Sum 49.4150. The higher number shows that

Private Entities have more Leadership readiness opportunities for improvement than Agencies of Government.

Table 93 - Leadership Emphasis

Perspectives	Value	Readiness Criterion	Local Weights	Global Weights	Agencies of Government D	Agencies of Government Case	Private Entity D Score	Private Entity Case
Organizational	0.01	Computer users settings and permissions are known	0.2	0.0020	49.0	0.0980	55.8	0.1115
		Cybersecurity Readiness Assessments	0.17	0.0017	49.5	0.0842	46.3	0.0787
		Documents are marked and protected	0.14	0.0014	51.3	0.0718	53.5	0.0748
		Presence of Implementation Oversight	0.16	0.0016	49.0	0.0784	50.2	0.0802
		Presence of legislative understanding	0.11	0.0011	48.3	0.0531	55.5	0.0611
		Social impact of breaches is talked about in the company	0.1	0.0010	45.8	0.0458	35.2	0.0352
		There is an organizational common vocabulary for cybersecurity in the energy industry	0.12	0.0012	49.0	0.0588	61.1	0.0733
Information Management	0.01	Info Officer is in contact with Internet Service Provider	0.06	0.0006	45.5	0.0273	33.1	0.0199
		Logging is sufficient for security and forensics	0.2	0.0020	38.4	0.0768	46.0	0.0920
		Network and System admin procedures documented	0.29	0.0029	48.1	0.1396	46.8	0.1356

		Retention periods are in place and used for information and data	0.19	0.0019	40.9	0.0777	37.7	0.0716
		Standards are understood	0.27	0.0027	38.1	0.1029	55.1	0.1487
Systems Management	0.01	Data loss prevention system is in place	0.19	0.0019	51.0	0.0969	56.4	0.1072
		Energy system outages are planned for	0.22	0.0022	53.3	0.1172	54.4	0.1197
		Machine limitations are recorded	0.12	0.0012	56.5	0.0678	50.6	0.0607
		Network modeling for IoT is done	0.11	0.0011	62.5	0.0688	43.2	0.0475
		Outages are not required for security updates	0.21	0.0021	56.3	0.1181	45.6	0.0957
		Planning for forensic evidence collection	0.17	0.0017	53.8	0.0914	45.7	0.0776
Professional	0.01	Change Management is considered	0.2	0.0020	56.3	0.1125	52.4	0.1048
		Cyber awareness of all staff is checked	0.29	0.0029	56.3	0.1631	48.6	0.1410
		External reporting is done	0.11	0.0011	51.0	0.0561	53.5	0.0589
		External vendor/supply coordination is done	0.18	0.0018	56.3	0.1013	55.3	0.0996
		Threats to organization are modeled	0.22	0.0022	56.3	0.1238	59.5	0.1309
Leadership	0.96	Cybersecurity goals of energy organization are identified	0.16	0.1536	49.3	7.5648	49.9	7.6570
		Cybersecurity learning sources are available	0.1	0.0960	51.8	4.9680	46.7	4.4832
		Cybersecurity risk is considered	0.3	0.2880	58.3	16.7760	56.3	16.2000

		priority by C-Suite						
		Policies are updated	0.11	0.1056	51.8	5.4648	49.3	5.2008
		Professionals with cyber certifications are in operations roles	0.14	0.1344	50.0	6.7200	50.1	6.7334
		Supply chain cyber risk is considered during procurement	0.19	0.1824	55.0	10.0320	53.5	9.7584
Total						53.5566		52.0588

For the Leadership perspective both cases were positively affected. Both entity types shows that Leadership readiness is a perspective that if addressed increases readiness. The ranking has not changed.

Table 94 - Leadership Score and Rank Change

Leadership	Agencies of Government	Private Entities
Original	51.1963	50.8185
Scenario	53.5566	52.0588
Score Change	2.36031	1.24025
Rank	1	2
Scenario Ranking	1	2

8.2.1.6 Emphasis Summary

Overall, the Original Application Case created by the experts HDM data questionnaires and desirability curves are in the first row. For the perspectives that can be positively affected in each case the number is green. For the perspectives where the case would be negatively affected because of increased focus the number is in red. For those perspectives where little change was found those numbers remain in a yellow color.

Table 95 - Summary of Scenario Score and Rank Changes

Scenario		Boosted Perspective	Agencies of Government Case	Private Entities Case
Original Application		None	51.2	50.8
	1	Organizational	49.1	51.4
	2	Information Management	42.9	47.0
	3	Systems Management	55.8	50.8
	4	Professional	55.5	53.4
	5	Leadership	53.6	52.1

CHAPTER 9: CONCLUSIONS AND CONTRIBUTIONS

9.1 Conclusion

The model develops and supports literature findings. The criteria are in accord with the stated goals. A well-defined model increases confidence in the models topic area.

Readiness of Cybersecurity in the USA Energy Industry includes engagement from several stakeholders within Private Entities and Agencies of Government. The current status shows that Agencies of Government and Private Entities have similar readiness composite scores overall, but there are some key criterion differences.

Participation and critical thinking are at the core of readiness planning. The research model helps [entities] make sure they are assessing their readiness for a project in a way that is comprehensive and structured, and not limited to technology factors only. The model helps assess organizational readiness status against each of the criteria and what can be done to enhance the chances of a successful [implementation]. [234].

This PhD readiness work is concentrated on gaps where data cannot or has previously not been quantified [28] in the literature. The cyber criteria/controls enable energy companies to look at the cybersecurity problem comprehensively (criterion based, goal based, and composite based). This is a strategic approach for decision making [43]. In understanding the cause, a truly resilient entity needs to learn and adapt with a feedback loop.

Readiness is a facilitated process which aims to remove severe consequences proactively. Historically a readiness assessment only goes up to the point of identifying plausible scenarios. Now we can add the HDM quantitative decision-making model outputs to better inform decisions based on organizational needs for impact and mission. That we now have a tool to engage cultural posture as a significant input towards the security protection and response process.

From the HDM model Leadership (26%) ranked as the most important perspective with respect to the mission. Cybersecurity risk is considered priority by C-Suite scored the highest of any criterion at 30% and was also in the highest scoring perspective of Leadership at 26%. Network and System admin procedures documented and Cyber awareness of all staff is checked were tied at second at 29% for criterion high scores within their perspectives. However, those two grouped perspectives Information Management and Professional respectively were the two lowest score perspectives overall at 18% each.

When desirability was calculated into the HDM model for the Private Entities case DLP became the highest scoring case criterion at 56.4%. The highest scoring desirability criterion for the Agencies of Government case was Outages are not required for security updates at 56.3%. Cybersecurity Risk is a required topic by C-Suite was the highest desired, most commonly shared criterion, for both Agencies of Government and Private Entities at 58.3% and 56.3% respectively.

The pool of experts used in this study was composed of a very heterogeneous and diverse set of individuals, representing different types of educational backgrounds, as

well as different roles in the entities. The HDM Model has made recommendations based on empirical knowledge by grouping data and information. HDM is good for new study topic area dataset building where regression calculations are not yet able to be scoped, and where experts can first identify the gaps [28]. HDM's most notable characteristics are visualization, information extraction, feature importance, interpretability, and decision making [28].

The policy implications of the dissertation are that trust is further established between stakeholders. One PhD data questionnaire respondent stated that "Organizational trust is the linchpin to critical infrastructure security." This same expert stated that "trust is important not only at the C-Suite level but at the Individual Contributor level in order to get things done." By ensuring that external communications and vendor/supply communication are considered in SME analysis the governance stakeholders can be assured of the decisions that need to be prioritized. Additionally, internal policies themselves are a criterion in the model and is rank weighted against other criteria for priority within the organization.

Other decision models should be used to verify and validate the results found in this model. Additionally, another HDM or AHP study could be conducted using another software such as Smart Decisions or Expert Choice.

9.2 Contribution

In this dissertation I have identified list of categories, defined the categories, and have given a list of categories scored using Multi-Criteria Decision Making. HDM fulfills the research gap by providing a structured and comprehensive investigation into the

Cybersecurity Readiness for Energy Industry. This research contributes to the emerging field of cyber readiness and specifically to the energy related industries body of knowledge [43]. HDM allows researchers to minimize false positives through a smoothing technique and through multiple iterations of analysis. HDM serves as a template that can be tailored for repeatability and reproducibility [28].

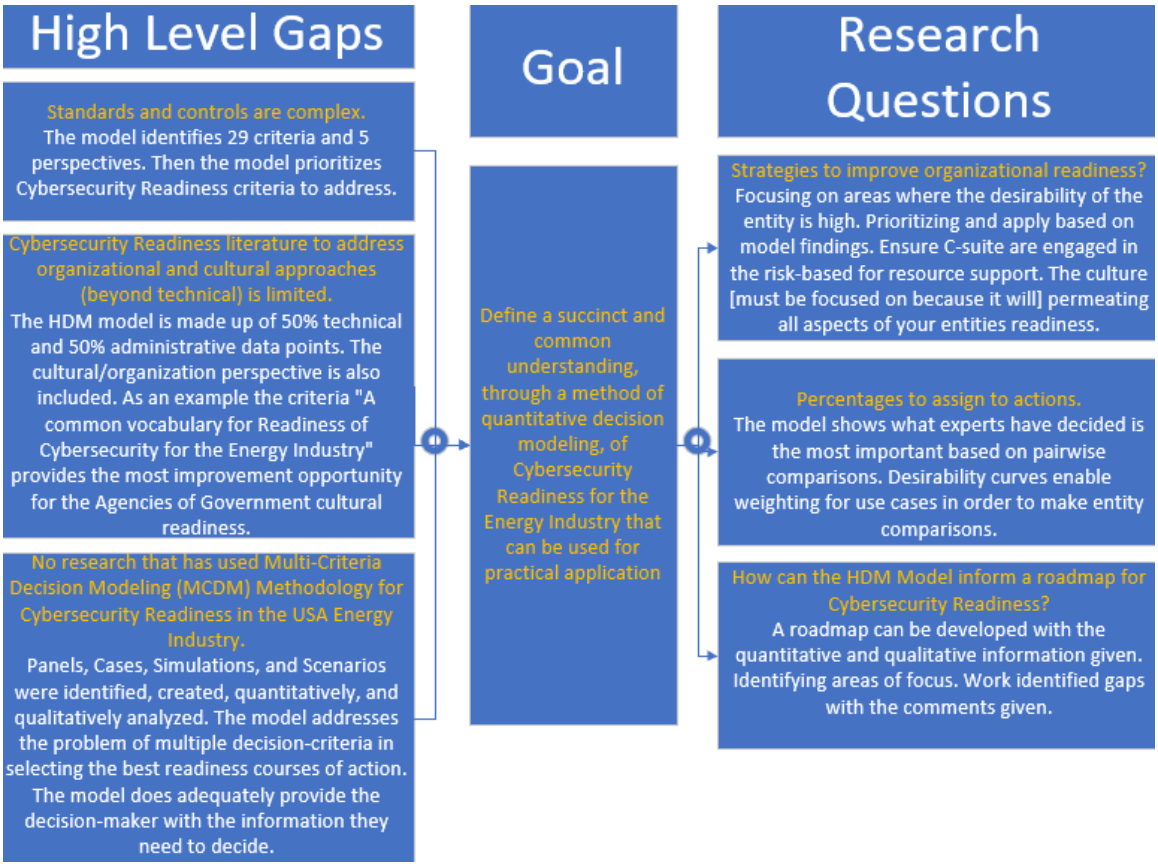
The model fulfills the research gap by providing applying the HDM tool, with a full MCDMA quantitative controls application framework for decision making to the area of Readiness of Cybersecurity in the USA Energy Industry. In short, the model also fills the research gap by providing a structured and comprehensive investigation into the Readiness of Cybersecurity in the USA Energy Industry [43]. This research focused on Readiness of Cybersecurity in the USA Energy Industry and the differences across sectors. The decision model assists decision makers to comprehensively assess organizational Readiness of Cybersecurity in the USA Energy Industry. The model provided deeper insights regarding the NIST NICE 8355 Draft workforce skills: organizational, professional, leadership, and technical aspects in Readiness of Cybersecurity.

HDM helps the cybersecurity strategy to be aligned and integrated with the overall goals and responsibilities of the organization. The HDM model (decision support tool) criterion prioritizes Cybersecurity Readiness criteria for implementation. The prioritization of criteria helps detect, mitigate, and prevent abuse techniques [84]. The dissertation research (and the use of the HDM model) ensures that the posture within the organization is focused on Readiness of Cybersecurity in the USA Energy Industry and is

aligned with business or mission strategy. This alignment objective is a concept espoused by the USA Navy [239].

HDM is a valuable tool that experts can use to effectively understand the internal and external dynamics surrounding a readiness implementation. The theoretical (scholarly) implications of the dissertation are a full (as opposed to partial) MCDA on readiness for cybersecurity in the energy industry. The thorough literature review and model. combined with the analysis provide this outcome. This HDM model adds a cultural approach (which is reflected in the hierarchical structure) rather than a purely technical or practical approach. This study HDM scores can be used as a benchmark for the industry.

Table 96 - How the Research Addressed the Gaps, Goal, and Questions



The quantified model is able to serve as an input to regression methods [28]. The HDM is a tool to evaluate strategy for the functional areas related to Readiness of Cybersecurity in the USA Energy Industry criteria and creates quantitatively justifiable prioritizations.

CHAPTER 10: LIMITATIONS AND FUTURE WORK

10.1 Limitations

Limitations could be potential opportunities for future research. Although HDM is a good tool for MCDA, HDM has some limitations. HDM can't cope with flow of information which Analytic Network Process (ANP) can. Constraints are not deeply analyzed they are just approximated [43] through desirability, and sensitivity. HDM is limited to the responses from those questioned which may not represent a larger population [28].

The Readiness Assessment process is executed through sampling, and some important elements of readiness may not be evaluated because of this. The model may perform differently in other settings where, for instance, cyber defense and/or resilience takes on different priorities and meanings than readiness [43]. Each organization should look at the test they want to run, based on the environment, and select the best tool.

Bias may affect decision making. HDM results are subjective because the modeling depends on the experts. Downside can be minimized by selecting panel members with high levels of expertise and balancing the biases in panel [253] formation. Different types of bias are shown in the table below.

Table 97 – Types of Questionnaire Research Bias

Non-response bias – A Questionnaire is based on a sample number of returns and it's possible that individuals who do not participate are substantially different in their responses.
Sampling frame bias – Accuracy is based on contact information and the degree to which that is representative of the population.

Self-reported results – Responses are confidential, but may lack integrity, that is there is the possibility that the experts do not provide accurate responses.

Note: Taken from Ponemon Institute LLC, "Hidden Threats in Encrypted Traffic: A Study of North America & EMEA," Ponemon Institute, May 2016.

HDM lacks the ability to do more quantitative analysis, such as Structural Equation Modeling (SEM) [28]. Structural Equation Modeling (SEM) and Factor Analysis (FA) are statistical models that need quantified input data which HDM can provide. FA though, requires 200 or more samples for a statistically strong result [43].

Limitations of classification schemes are:

- Errors
- Limited knowledge
- Inconsistent methods of application
- Inconsistency in determinations
- Confusing/unclear labeling

HDM's scalability is limited because of the number of calculations experts need to do for inconsistency scoring. A drawback to HDM is that the mathematical calculations are complex when there are many variables which is also a problem with other MCDM such as Technique for Order Preference by Similarity to Ideal Solutions (TOPSIS) [254].The factorials starting with 4 are calculated below with the number of spreadsheet rows needed to do an HDM calculation.

Table 98 – Factorials 4 to 10

• 4! - 4 × 3 × 2 × 1 – 24 rows of data • 5! - 5 × 4 × 3 × 2 × 1 - 120 • 6! - 6 × 5 × 4 × 3 × 2 × 1 - 720

- 7! - 7 × 6 × 5 × 4 × 3 × 2 × 1 - 5,040
- 8! - 8 × 7 × 6 × 5 × 4 × 3 × 2 × 1 - 40,320
- 9! - 9 × 8 × 7 × 6 × 5 × 4 × 3 × 2 × 1 - 362,880
- 10! - 10 × 9 ×8 × 7 × 6 × 5 ×4 × 3 × 2 × 1 - 3,628,800

Challenges are: interpreting the results in a complex organization, overfitting or underfitting results without including strategic input, and selection bias of picking the wrong questions and or experts [255]. It may be hard for judgment quantification by expert panels to distinguish between criteria if the experts don't see clear differentiations from one criteria to another, thus, successive rounds [of Questionnaires might need to be] conducted to get valid data [215].

10.2 Future Work

This readiness assessment modeled 29 articles gaps (of 36 core bibliometric articles, some papers had called out multiple gaps). The original gaps totaled 74 total data points with 52 unique gaps which were later combined to the final 29 gaps in the HDM model. The additional unique could be used as sub-criteria in a future pairwise analysis.

The author developed a dataset of 421 articles that could further be reviewed for sub criteria. One researcher noted that "there was a consensus around the idea that the model application could be easily and readily replicated" [203]. One data questionnaire responded that most of the criteria are "probably true for most any business with a technology dependency."

Ongoing cost estimations and execution are beyond the scope of the paper. "Security criterion used to determine gas system remedial actions impacts the cost of the electric grid. [20]" Additionally, procurement and cost principles (aka acquisition) were

not included in the model. Procurement and cost principles are covered in NIST 800-35 [115] and NIST 800-65 [116] respectively. Incident costs can be estimated by regulators or in the financial reports. Several academic and technical works address return on investment [256], return on security investment [257], and metrics [258] for measuring cybersecurity. If one criterion is the most expensive and one would have to increase readiness for a scenario, one may not want to invest. What one considered a business value for quality operations at an organization determines where one is going to invest resources. One could choose to invest or drop/outsource that opportunity.

HDM does not cover specific scanning and monitoring schemas or technology. Alternatives to human decision making is protocols for threat intelligence sharing [259], and tagging such as: SCAP, Snort, YARA, STIX, TACS, TAXII, CyBOX, Veris, MISP, nor their corollary manual template checklist predecessors OVAL or XCCDFF are discussed. These schemas are high-level (an abstraction that can be interpreted for various structures and sizes) which can be used for decision making for machine-to-machine categorizations and action taking [26]. Attack terms as shown in could be the subject of a future literature review research HDM project. More technical factors could be added if backed by future literature.

The model itself does not cover specific technologies (like mobile, switches), architectures (enterprise, Bring Your Own Device [BYOD], etc.), companies' tools or specific configurations (Cisco, NIST 1800 series example configurations), or specific gaps in cyber education programs. During PhD research there were several "buzz words" in Cybersecurity that showed up some examples were: Trust, Threats, Failure, Event,

Virtual Machines, Defense, Protection, Encryption, Proof of Work, Blockchain, Interoperability, Electromagnetism, Data Exfiltration, Reliability, and Industrial Control [96].

As the language in the industry changes further research should be done to reflect Agencies of Government and Private Entity language changes. A Body of Knowledge is a living framework thus terms change over time. Some terms likely show more hits in future literature searches while some diminish. An attacker wants to make your strongest points your weakest links. That is to say that the attackers are also doing literature reviews to find information [96].

Additional research can be done on Nuclear Energy and Grid Modernization/Smart Grid respectively. Weights might be different by sectors, can be verified by further research where experts from other sectors are asked to quantify the model for their sectors.

The history and trends of multiple sequential readiness scores assessed throughout time could serve as evidence and measure of progress. Benefits could be expected from the application of this model by striving to achieve excellence in every perspective and criteria [203]. The organization inevitably increases its readiness-sharing communication abilities.

Many organizations also need an auditing/readiness mechanism (aka follow on checklists) to implement readiness analysis into the operational workplace which is

beyond the scope of the model. Auditing would be an additional follow-on activity to assure that the organization is meeting goals implement readiness priorities.

This model does not address physical security which is another perspective that could be further added to the model. Chatterjee [240], on page 92 of his book, provides a defense in depth chart that could be used as a starting point to develop the physical security perspective. During the literature review the focus was on Cybersecurity.

The future goals should aim to replicate the assessment capabilities of this model, and to expand it beyond Readiness of Cybersecurity in the USA Energy Industry or readiness of the national grid. The model is valuable to businesses through its quantitative results regarding the conditions that are favorable in addressing readiness.

REFERENCES

[1] A. Georgiadou, S. Mouzakitis, K. Bounas, and D. Askounis, "A Cyber-Security Culture Framework for Assessing Organization Readiness," *Journal of Computer Information Systems,* vol. 62, pp. 452-462, 2020.

[2] H. Barham, "Doctoral Dissertation Proposal: Project Readiness Assessment - A Hierarchical Decision Model to Evaluate Readiness for a Smart-City-Related Big Data Project," Doctor of Philosophy, Engineering and Technology Management, Portland State University, Portland, OR, USA, 2018.

[3] A. de Beaupré and M. Toussain, "SEC460: Enterprise & Cloud | Threat and Vulnerability Assessment," ed: SANS Institute, 2020.

[4] S. N. G. Gourisetti, M. Mylrea, and H. Patangia, "Cybersecurity vulnerability mitigation framework through empirical paradigm (CyFEr):: Enhanced prioritized gap analysis," *Future Generation Computer Systems,* vol. 105, pp. 410-431, Dec. 17 2019.

[5] W. H. Ware, "Security Controls for Computer Systems: Report of Defense Science Board Task Force on Computer Security," RAND Corporation, https://www.rand.org/pubs/reports/R609-1.html1969.

[6] Department of Defense (DoD). (1985, Mar 22). *DoD Rainbow Series*. Available: https://csrc.nist.gov/publications/detail/white-paper/1985/12/26/dod-rainbow-series/final

[7] National Computer Security Center (NCSC), "A Guide to Understanding Configuration Management in Trusted Systems," ed. Fort George G. Meade, MD: National Computer Security Center (NCSC), 1988.

[8] National Computer Security Center (NCSC), "A Guide to Understanding Trusted Distribution in Trusted Systems," ed. Fort George G. Meade, MD: National Computer Security Center (NCSC), 1988.

[9] National Computer Security Center (NCSC), "Computer Security Subsystem Interpretation of Trusted Computer System Evaluation Criteria," ed. Fort George G. Meade, MD: National Computer Security Center (NCSC), 1988.

[10] National Computer Security Center (NCSC), "Guidelines for Formal Verification Systems," ed: National Computer Security Center (NCSC), 1989.

[11] National Computer Security Center (NCSC), "Guide to Understanding Trusted Facility Management," ed: National Computer Security Center (NCSC), 1989.

[12] National Computer Security Center (NCSC), "Rationale for Selecting Access Control List Features for the Unix System," ed. Fort George G. Meade, MD: National Computer Security Center (NCSC), 1989.

[13] National Computer Security Center (NCSC), "Trusted Network Interpretation Environments Guideline," ed: National Computer Security Center (NCSC), 1990.

[14] National Computer Security Center (NCSC), "Trusted Database Management System Interpretation," ed: National Computer Security Center (NCSC), 1991.

[15] National Computer Security Center (NCSC), "A Guide to Writing the Security Features User's Guide for Trusted Systems," ed. Fort George G. Meade, MD: National Computer Security Center (NCSC), 1991.

[16] National Computer Security Center (NCSC), "Guidelines for Writing Trusted Facility Manuals," ed. Fort George G. Meade, MD: National Computer Security Center (NCSC), 1992.
[17] National Computer Security Center (NCSC), "Introduction to Certification and Accreditation," ed. Fort George G. Meade, MD: National Computer Security Center (NCSC), 1994.
[18] National Computer Security Center (NCSC), "Rating Maintenane Phase Program Document Version 2," ed: National Computer Security Center (NCSC), 1995.
[19] Oxford English Dictionary. (2024, July 6). *security - Quick search results | Oxford English Dictionary*. Available: https://www.oed.com/search/dictionary/?scope=Entries&q=security
[20] C. O'Malley, L. Roald, D. Kourounis, O. Schenk, and G. Hug, "Security Assessment in Gas-Electric Networks," presented at the 2018 Power Systems Computation Conference (PSCC), 2018.
[21] Cloudian. (2024, Sept 2). *Data Security: Risks, Policies, Best Practices & Compliance*. Available: https://cloudian.com/guides/data-security/data-security-risks-policies-best-practices/
[22] *E-Government Act of 2002,* Public Law 107–347, 2002.
[23] R. D. McDowall, "Computer (In)Security 1: Logical Security," *The Quality Assurance Journal,* vol. 4, pp. 197-205, 2000.
[24] Institute of Internal Auditors (IIA), "Auditing Cybersecurity Operations: Prevention and Detection," in *Supplemental Guidance: Practice Guide*, ed. Lake Mary, FL: Institute of Internal Auditors (IIA), 2022.
[25] N. Muraguri, T. Mwalili, and T. Mose, "Factors influencing cybersecurity readiness in deposit taking savings and credit cooperatives: A case study of Nairobi County," *International Academic Journal of Information Systems and Technology,* vol. 2, pp. 157-182, 2019.
[26] A. Cavanaugh, "Hierarchical Decision Modeling (HDM) Mapping for a Cybersecurity Readiness Use Case," Portland State University, Portland, Oregon2022.
[27] D. Gupta, E. Bajramovic, H. Hoppe, and A. Ciriello, "The Need for Integrated Cybersecurity and Safety Training," *Journal of Nuclear Engineering and Radiation Science,* vol. 4, October 2018.
[28] A. Cavanaugh, "Comprehensive Proposal: Hierarchical Decision Model to Evaluate Readiness of Cybersecurity in the USA Energy Industry," Portland State University, Portland, ORSep 8 2021.
[29] United States Government Accountability Office (GAO), "Space Command and Control: Comprehensive Planning and Oversight Could Help DOD Acquire Critical Capabilities and Address Challenges," United States Government Accountability Office (GAO), Ed., ed. Washington DC, 2019.
[30] E. Gott and K. Greenfield, "New tool assesses banks' cybersecurity readiness," *The Risk Managment Association Journal,* vol. 98, 2015.
[31] Federal Information Processing Standards (FIPS), "Standards for Security Categorization of Federal Information and Information Systems," C. S. Division, Ed., ed. Gaithersburg, MD: U.S. Department of Commerce, 2004.

[32] J. Tyson. (2019, Jan 11). *What is IAAA?* Available: https://blog.jamestyson.co.uk/what-is-iaaa#:~:text=Well%2C%20security%20generally%20works%20on,%2C%20Authentication%2C%20Authorisation%2C%20Accountability.

[33] Amerian Institute of Certified Public Accountants (AICPA), *SOC 2 Reporting on an Examination of Controls at a Service Organization Relevant to Security, Availability, Processing Integrity, Confidentiality, or Privacy*. Leigh Farm Road, NC, 2018.

[34] R. C. Reid and A. H. Gilbert, "Using the Parkerian Hexad to Introduce Security in an Information Literacy Class," in *Information Security Curriculum Development Conference*, 2010, pp. 45-47.

[35] S. Alzahrani and T. Daim, "Evaluation of the Cryptocurrency Adoption Decision Using Hierarchical Decision Modeling (HDM) " in *2019 Portland International Conference on Management of Engineering and Technology (PICMET)*, Portland, OR, 2019, pp. 1-7.

[36] L. Jamali. (2021, Aug 4). *The Legacy of Enron in California's Power Challenges Today*. Available: https://www.marketplace.org/2021/08/04/the-legacy-of-enron-in-californias-power-challenges-today/

[37] Practical Engineering. (2022, Feb 15). *What Really Happened During the 2003 Blackout?* Available: https://practical.engineering/blog/2022/2/9/what-really-happened-during-the-2003-blackout

[38] National Energy Research Scientific Computing Center (NERSC), "Annual Report 2000," vol. January, Ernest Orlando Lawrence Berkeley National Laboratory (LBNL), Ed., ed, 2001.

[39] Berlilana, T. Noparumpa, A. Ruangkanjanases, T. Hariguna, and Sarmini, "Organization Benefit as an Outcome of Organizational Security Adoption: The Role of Cyber Security Readiness and Technology Readiness," *Sustainability,* Dec 13 2021.

[40] N. N. Muraguri, T. Mwalili, and T. Mose, "Factors Influencing Cybersecurity Readiness in Deposit Taking Savings and Credit Cooperatives: A Case Study of Nairobi County," *International Academic Journal of Information Systems and Technology,* vol. 2, pp. 157-182, Oct. 18 2019.

[41] RAND Corporation, "Measuring Cybersecurity and Cyber Resiliency," RAND Corporation, Santa Monica, CA2020.

[42] National Information Assurance Partnership (NIAP), "Assurance Continuity: Guidance for Maintenance and Re-evaluation," Fort George G. Meade, MDSept. 12 2016.

[43] A. Cavanaugh, "PhD Comprehensive Exam: Assessment of the Cybersecurity Controls Posturing for the Management of the Energy Sector Critical Infrastructure and Key Resources (ES-CIKR): Using Hierarchical Decision Model (HDM) to Evaluate Readiness of Cybersecurity in the USA Energy Industry," ed. Portland, OR: Portland State University, 2022.

[44] M. d. C. Moura, H. H. L. Diniz, E. L. Droguett, and V. R. Simoni, "Embedding Resilience in the Design of the Electrical Supply for Industrial Clients," *PLOS ONE,* p. 33, Nov. 30 2017.

[45] D. Eilts, "An Empirical Assessment of Cybersecurity Readiness and Resilience in Small Businesses," Doctor of Philosophy in Information Systems, College of Computing and Engineering, Nova Southeastern University, Florida, 2020.

[46] Cybersecurity & Infrastructure Security Agency (CISA). (2022, Jan. 28). *Case Studies*. Available: https://www.cisa.gov/case-studies

[47] Comments of the Bonneville Power Administration, "Grid Resilience in Regional Transmission Organizations and Independent System Operators," ed: Federal Energy Regulatory Commission (FERC), 2018.
[48] North American Electric Reliability Corporation (NERC), "Grid Resilience in Regional Transmission Organizations and Independent System Operators," ed: Federal Energy Regulatory Commission (FERC), 2018.
[49] T. L. Saaty, *The Analytic Hierarchy Process: Planning, Priority Setting, Resource Allocation*. New York, NY: McGraw-Hill, 1980.
[50] North American Electric Reliability Corporation (NERC). (2023, July 19). *Reliability Indicators*. Available: https://www.nerc.com/pa/RAPA/ri/Pages/default.aspx
[51] Government Accountability Office (GAO), "Technology Assessment: Cybersecurity for Critical Infrastructure Protection," U. S. G. A. Office, Ed., ed: GAO, 2004.
[52] eisac.com. (2021, Nov 12). *E-ISAC Home*.
[53] A. Cavanaugh, "Literature Review of Cyber Security Standards in Energy Related Sectors," Portland State University, Portland, ORAug. 8 2020.
[54] Idaho National Laboratory (INL), "Cyber Threat and Vulnerability Analysis of the U.S. Electric Sector," Idaho National LaboratoryAugust 2016.
[55] Y. Xiang, L. Wang, and Y. Zhang, "Adequacy Evaluation of Electric Power Grids Considering Substation Cyber Vulnerabilities," *INTERNATIONAL JOURNAL OF ELECTRICAL POWER & ENERGY SYSTEMS,* 2017.
[56] L. J. Trautman, "Managing Cyberthreat," *Santa Clara High Technology Law Journal,* vol. 33, pp. 230-287, Jan. 2 2017.
[57] P. Sabharwall, J. Gibb, C. Ritter, K. Araujo, A. Gupta, I. Ferguson*, et al.*, "Cyber security for microreactors in advanced energy systems," *Cyber Security: A Peer-Reviewed Journal,* vol. 4, pp. 345-367, Nov 18 2020.
[58] United States Senate, "A “Kill Chain” Analysis of the 2013 Target Data Breach," United States Senate, Ed., ed: COMMITTEE ON COMMERCE, SCIENCE, AND TRANSPORTATION, 2014.
[59] S. Gong and C. Lee, "Cyber Threat Intelligence Framework for Incident Response in an Energy Cloud Platform," *Electronics,* vol. 10, p. 239, Jan 21 2021.
[60] Smart Grid Interoperability Panel Cyber Security Working Group (SGIP), "Introduction to NISTIR 7628 Guidelines for Smart Grid Cyber Security," September 2010.
[61] Carnegie Mellon University and The John Hopkins University Applied Physics Laboratory LLC, "Cybersecurity Maturity Model Certification (CMMC)," Acquistion and Sustainment, Office of the Under Secretary of Defense2020.
[62] K. A. Z. Ariffin and F. H. Ahmad, "Indicators for maturity and readiness for digital forensic invesitgation in era of industrial revolution 4.0," *Computer & Security,* vol. 105, Feb. 15 2021.
[63] M. Giles. (2019, March 5). *Triton is the World’s Most Murderous Malware, and it’s Spreading*. Available: https://www.technologyreview.com/2019/03/05/103328/cybersecurity-critical-infrastructure-triton-malware/
[64] M. D. Firoozjaei, N. Mahmoudyar, Y. Baseri, and A. A. Ghorbani, "An Evaluation Framework for Industrial Control Systems Cyber Incidents," *International Journal of Critical Infrastructure Protection,* vol. 36, p. 100487, Oct 4 2021.

[65] washingtonpost.com. (2022, Sept. 14). *U.S. indicts, sanctions Iranians for allegedly hacking systems*. Available: https://www.washingtonpost.com/national-security/2022/09/14/iranian-ransomware-indictment/

[66] S. Gatlan. (2023, Mar 15). *FBI: Ransomware Hit 860 Critical Infrastructure Orgs in 2022*. Available: https://www.bleepingcomputer.com/news/security/fbi-ransomware-hit-860-critical-infrastructure-orgs-in-2022/

[67] Department of Homeland (DHS) Security Cybersecurity & Infrastructure Agency (CISA), "Ways to Create a Campaign: Key messaging, articles, social media, and more to promote Cybersecurity Awareness Month 2022," cisa.gov2022.

[68] E. Yagdereli, C. Gemci, and A. Z. Aktas, "A study on cyber-security of authonomous and unmanned vehicles," *Journal of Defense Modeling and Simulation: Applications, Methodology, Technology,* vol. 12, pp. 369-381, 2015.

[69] R. G. Waweru, "Cyber Security Readiness Assessment Model in Kenyas' Higher Learning Institutions: A Case of University of Nairobi," Master of Science Information Technology Management, School of Computing and Informatics, University of Nairobi, 2019.

[70] B. Green, R. Derbyshire, W. Knowles, J. Boorman, P. Ciholas, D. Prince*, et al.*, "ICS Testbed Tetris: Practical Building Blocks Towards a Cyber Security Resource," School of Computing and Communications, Lancaster University, United Kingdom, 2020.

[71] J. Wynn, J. Whitmore, G. Upton, L. Spriggs, D. McKinnon, R. McInnes*, et al.*, "Threat Assessment and Remediation Analysis (TARA)," Mitre Corporation, Bedford, MA2011.

[72] cubro.com. (2022, Aug 12). *The Difference Between Network and Security Monitoring*. Available: https://www.cubro.com/en/blog/the-difference-between-network-and-security-monitoring/

[73] Department of Homeland Security (DHS), "Risk-Based Performance Standards Guidance," https://www.cisa.gov/sites/default/files/publications/cfats-rbps-guidance_508.pdf CISA-CFATS-002, May 2009.

[74] C.-W. Ten, A. Ginter, and R. Bulbul, "Cyber-Based Contingency Analysis," *IEEE Transactions on Power Systems,* vol. 31, July 2015.

[75] Department of Energy (DOE). (2023, July 19). *Types of Hydropower Plants: Water Power Technologies Office*. Available: https://www.energy.gov/eere/water/types-hydropower-plants

[76] U.S. Energy Information Administration (EIA). (2023, July 19). *Nuclear Explained: Nuclear Power Plants*. Available: https://www.eia.gov/energyexplained/nuclear/nuclear-power-plants.php

[77] National Electrical Manufacturers Association (NEMA). (2023, July 19). *Baseload Generation*. Available: https://energytransition.nema.org/baseload-generation/#:~:text=The

[78] W. Knox and E. Laderman, "MITRE Sixth Annual Secure and Resilient Cyber Architectures Invitational 2016," MITRE Corporation, mitre.org2016.

[79] Department of Energy, "DOE Standard 3006: Planning and Conducting Readiness Reviews," DOE, Ed., ed. Washington, DC, 2010.

[80] S. Pugh and D. McMorrow, "Impacts of Severe Space Weather on the Electric Grid," vol. November, J. P. Office, Ed., ed. https://irp.fas.org/agency/dod/jason/: The MITRE Corporation, 2011.

[81] A. Vafadarnikjoo, M. Tavana, K. Chalvatzis, and T. Botelho, "A Soci-Economic and Environmental Vulnerability Assessment Model with Causal Relationships in Electric Power Supply Chains," *Socio-Economic Planning Sciences,* vol. 80, p. 101156, 2022.
[82] Crowdstrike, "Mergers & Acquisitions Cyber Risk Assessment," crowdstrike.com2016.
[83] J. O'Brien, M. Cassiadoro, T. Becejac, G. B. Shebie, J. Follum, U. Agrawal*, et al.*, "Electric Grid Blackstart: Trends, Challenges, and Opportunities," Department of Energy (DOE), Pacific Northwest National Laboratory (PNNL)April 2022.
[84] FIRST DNS Abuse Special Interest Group, "DNS Abuse Techniques Matrix," First.orgFeb 9 2023.
[85] A. Cavanaugh, "Towards a Cybersecurity Readiness Gap Analysis in the Energy Industry using Citation Chasing and Web of Science Bibliometric Analysis," Portland State Univeristy, Portland, ORJune 11 2021.
[86] U.S. Nuclear Regulatory Commission (NRC), "Regulatory Guide 5.71: Cyber Security Programs for Nuclear Facilities," Office of Nuclear Regulatory Research, Ed., ed, 2010.
[87] S. Hasan, M. Ali, S. Kurnia, and R. Thurasamy, "Evaluating the cyber security readiness of organizations and its influence on performance," *Journal of Information Security and Applications,* vol. 58, p. 102726, Feb. 4 2021.
[88] S. Sridhar, A. Hahn, and M. Govindarasu, "Cyber-Physical System Security for the Electric Power Grid," *Proceedings of the IEEE,* vol. 100, January 2012.
[89] A. AlEnezi, "Internet of Things & Cybersecurity Readiness in Smart-government and Organizations," Master's Degree in Information Technology, Information Technology, Kuwait University, 2020.
[90] P. Cunningham and S. Head, "Cybersecurity Readiness as a Business Value," *The Risk Management Association Journal,* vol. 101, February 2019.
[91] T. A. Chapman, "Factors Affecting Perceptions of Cybersecurity Readiness Among Workgroup IT Managers," Doctor of Philosophy in Business Administration, Management Information Systems, University of Mississippi, 2018.
[92] D. J. Bodeau, C. D. McCollum, and D. B. Fox, "Cyber Threat Modeling: Survey, Assessment, and Representative Framework " Department of Homeland Security2018.
[93] Codex Alimentarius Commission, "Hazard Analysis And Critical Control Point (HACCP) System And Guidelines For Its Application," 2003.
[94] Department of Homeland Security (DHS), "Common Cybersecurity Vulnerabilities in Industrial Control Systems," Control Systems Security Program - National Cyber Security Division, Ed., ed, 2011.
[95] D. J. Bodeau, R. D. Graubart, R. M. McQuaid, and J. Woodill, "Cyber Resiliency Metrics, Measures of Effectiveness, and Scoring: Enabling Systems Engineers and Program Managers to Select the Most Useful Assessment Methods," MITRE Corporation, Bedford, MASeptember 2018.
[96] A. Cavanaugh, "Computer Science Security Terms related to the Energy Industry: A PRIMO Literature Review," Portland State University, Portland, ORMarch 19 2021.
[97] ISACA, "Design Guide: Designing an Informaton and Technology Governance Solution," Information Systems Audit and Control Association, Schaumburg, IL2019.
[98] D. Coston, "Certified Information Systems Security Professional (CISSP),," stormwindstudios.com, Ed., ed, 2023.
[99] COBIT, "Implementing and Optimizing an Information and Technology Governance Solution," ISACA, Schaumberg, IL2019.

[100] R. R. Mills, "The Current State of Insider Threat Awareness and Readiness in Corporate Cyber Security - An Analysis of Definitions, Preventions, Detection, and Mitigation," Master of Science in Cybersecurity, Utica College, 2018.
[101] Department of Homeland (DHS) Security Cybersecurity & Infrastructure Agency (CISA), "Risk and Vulnerability Assessment (RVA) Mapped to the MITRE ATT&CK Framework," https://www.cisa.gov/sites/default/files/publications/RVA_INFOGRAPHIC_508c.pdf2022.
[102] Department of Homeland (DHS) Security Cybersecurity & Infrastructure Agency (CISA), "CPG Cross-Sector Cybersecurity Performance Goals," https://www.cisa.gov/sites/default/files/publications/2022_00092_CISA_CPG_Report_508c.pdfOctober 2022.
[103] P. N. Stockton, "Securing the Grid from Supply-Chain Based Attacks," Sonecon LLC, Idaho National LaboratorySept 2 2020.
[104] Council on Foreign Relations. (2015, Sept. 14). *Compromise of a power grid in eastern Ukraine*. Available: https://www.cfr.org/cyber-operations/compromise-power-grid-eastern-ukraine
[105] A. Krigman. (2020, Oct 22). *Cyber Autopsy Series: Ukrainian Power Grid Attack Makes History*. Available: https://www.globalsign.com/en/blog/cyber-autopsy-series-ukranian-power-grid-attack-makes-history
[106] M. Assante. (2016, Jan 6). *Confirmation of a Coordinated Attack on the Ukrainian Power Grid*. Available: https://www.sans.org/blog/confirmation-of-a-coordinated-attack-on-the-ukrainian-power-grid/
[107] J. Styczynski and N. Beach-Westmoreland, "When The Lights Went Out: A Comprehensive Review Of The 2015 Attacks On Ukrainian Critical Infrastructure," Booz Allen Hamilton2019.
[108] P. D. Howard, *Official (ISC)2 Guide to the CAP CBK*, Second ed. Boca Raton, FL: CRC Press, 2013.
[109] A. Shehod, "Ukraine Power Grid Cyberattack and US Susceptibility: Cybersecurity Implications of Smart Grid Advancements in the US " Cybersecurity Interdisciplinary Systems Laboratory (CISL), Sloan School of ManagementDecember 2016.
[110] J. Slowik, "Anatomy of an Attack: Detecting and Defeating CRASHOVERRIDE " DragosOct. 12 2018.
[111] Dragos, "CRASHOVERRIDE: Threat to the Electric Grid Operations," Dragos2017.
[112] A. Cherepanov, "Win32/Industroyer: A new threat for industrial control systems," ESET, SlovakiaJuly 12 2017.
[113] L. H. Newman. (2018, Nov 18). *Russian Hackers Haven't Stopped Probing the US Power Grid*. Available: https://www.wired.com/story/russian-hackers-us-power-grid-attacks/
[114] Department of Homeland (DHS) Security Cybersecurity & Infrastructure Agency (CISA). (2022, Apr 20). *Alert (AA22-110A): Russian State-Sponsored and Criminal Cyber Threats to Critical Infrastructure*. Available: https://www.cisa.gov/uscert/ncas/alerts/aa22-110a
[115] T. Grance, J. Hash, M. Stevens, K. O'Neal, and N. Bartol, "NIST SP 800-35: Guide to Information Technology Security Services," C. S. Division, Ed., ed. Gaithersburg, MD: National Institute of Standards and Technology, 2003.
[116] J. Hash, N. Bartol, H. Rollins, W. Robinson, J. Abeles, and S. Batdorff, "NIST SP 800-65: Integrating IT Security into the Capital Planning and Investment Control Process," C. S. Division, Ed., ed. Gaithersburg, MD: National Institute of Technology Standards, 2005.

[117] S. Donovan, "Memorandum for Heads of Executive Departments and Agencies," Executive Office of the President, Ed., June 10 ed: Office of Management and Budget (OMB), 2015.
[118] FireEye, "The Business Case for Protecting Against Advanced Attacks: Demonstrating ROI to Non-Technical Executives," FireEye Inc., fireeye.com2014.
[119] Y. Levy and T. J. Ellis, "A Systems Approach to Conduct an Effective Literature Review in Support of Information Systems Research," *Informing Science Journal,* vol. 9, pp. 181-212, 2006.
[120] National Institute of Standards and Technology (NIST), "Framework for Improving Critical Infrastructure Cybersecurity," vol. April 16, 1.1 ed. https://doi.org/10.6028/NIST.CSWP.04162018, 2018.
[121] D. Trump, "Executive Order 13800: Executive Order on Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure," vol. May 11, Executive Office of the President, Ed., ed. https://www.cisa.gov/topics/cybersecurity-best-practices/executive-order-strengthening-cybersecurity-federal-networks-and-critical-infrastructure, 2017.
[122] Electric Power Research Institute (EPRI), "Analysis to Inform CA Grid Integration Rules for PV: Final Report on Inverter Settings for Transmission and Distribution System Performance," Electric Power Research Institute (EPRI), Palo Alto, California2016.
[123] E. S. Office of Cybersecurity, and Emergency Response,. (2024, July 12). *Energy Security: Office of Cybersecurity, Energy Security, and Emergency Response*. Available: https://www.energy.gov/ceser/energy-security
[124] ISC2, "Certified Information Systems Security Professional: Official ISC2 Student Guide," ISC22022.
[125] Congressional Research Service, "Electric Grid Cybersecurity," P. f. M. o. C. o. Congress, Ed., ed. Washington DC, 2018.
[126] N. S. Fernando, Z. Zheng, J. M. Acken, and R. B. Bass, "Trust Model System for the Energy Grid of Things Trust Model System for the Energy Grid of Things Network Communications Network Communications " presented at the 2023 IEEE Conference on Technologies for Sustainability (SusTech), 2023.
[127] *Homeland Security Act,* t. Congress, 2002.
[128] Washington State Energy Coordinating Council, "Biennial Report on Critical Energy Infrastructure and Key Resources, Washington State," wa.gov, www.commerce.wa.govMarch 2013.
[129] Department of Homeland (DHS) Security Cybersecurity & Infrastructure Agency (CISA), "Cross-Sector Cybersecurity Performance Goals (CPGs) Common Baseline: Controls List," Cybersecurity and Infrastructure Security Agency (CISA), https://www.cisa.gov/sites/default/files/publications/Common_Baseline_v2_Controls_List_508c.pdf2022.
[130] M. E. Luallen, "Critical Control System Vulneabilties Demonstrated - And What to Do About Them," sans.orgNovember 2011.
[131] "Critical Infrastructure Information Act of 2002," in *6 USC Chapter 1, SUBCHAPTER XVIII, Part B: Critical Infrastructure Information*, ed. United States of America, 2020.
[132] W. Knowles, D. Prince, D. Hutchinson, J. F. P. Disso, and K. Jones, "A Survey of Cyber Security Management in Industrial Control Systems," *International Journal of Critical Infrastructure Protection,* vol. 9, pp. 52-80, Mar 3 2015.

[133] Mandiant, "APT1: Exposing One of China's Cyber Espionage Units," mandiant.comFebruary 2013.
[134] Interagency Security Committee. (2023, Mar 22). *Interagency Security Committee*. Available: https://www.cisa.gov/resources-tools/groups/interagency-security-committee-isc
[135] National Institute of Standards and Technology (NIST). (2020, Apr 17). *Computer Security Resource Center (CSRC) Publications*.
[136] National Institute of Standards and Technology (NIST), "Security and Privacy Controls for Federal Information Systems and Organizations," vol. April, J. T. F. T. Initiative, Ed., Revision 4 ed: US Department of Commerce, 2013.
[137] The European Parliament And The Council Of The European Union, "Directive (EU) 2022/2555 Of The European Parliament And Of The Council," ed: Official Journal of the European Union, 2022.
[138] M. Hathaway, C. Demchak, J. Kerben, J. McArdle, and F. Spidalieri, "CYBER READINESS INDEX 2.0 - A PLAN FOR CYBER READINESS: A BASELINE AND AN INDEX," Potomac Institute for Policy StudiesNovember 2015.
[139] United States Senate Committee on Armed Services. (2023, Mar 22). *118th Congress Subcomittees*. Available: https://www.armed-services.senate.gov/subcommittees
[140] Oregon State Legislature. (2022, Mar 22). *2021-2022 Interim: Joint Committee On Information Management and Technology*. Available: https://olis.oregonlegislature.gov/liz/2021I1/Committees/JLCIMT/Overview
[141] R. J. Craven, J. Daly, and E. Gray, "A Cross-Sector Capacities, Resources, and Needs Assessment: Research to Support the Drafting of the Oregon Cybersecurity Center of Excellence Proposal," Portland State University, Center for Public Service Mark O. Hatfield School of GovernmentMarch 2018.
[142] E. Seager, "Phone Interview with Bonneville Power Administration Cybersecurity Specialist," in *Engineering and Technology Management*, A. Cavanaugh, Ed., ed. Portland State University, 2022.
[143] A. Pooe and L. Labuschagne, "A conceptual model for digital forensic readiness," 2012.
[144] H. Zhang, Z. Tang, and K. Jayakar, "A socio-technical analysis of China's cybersecurity policy: Towards delivering trusted e-Government services," in *TPRC*, 2017.
[145] W. Miron, "Adoption of Cybersecurity Capability Maturity Models in Municipal Governments," Master of Applied Science, Technology Innovation Management, Carleton University, Ottawa, Canada, 2015.
[146] P. Sharma, D. Arora, and T. Sakthivel, "Mobile Cloud Forensic Readiness Process Model for Cloud-Based Mobile Applications," *Internal Journal of Digital Crime and Forensics,* vol. 12, pp. 58-76, September 2020.
[147] L. Daubner, M. Macak, B. Buhnova, and T. Pitner, "Towards verifiable evidence generation in forensic-ready systems," in *2020 IEEE International Conference on Big Data (Big Data)*, 2020, pp. 2264-2269.
[148] M. Elyas, S. B. Maynard, A. Ahmad, and A. Lonie, "Towards a Systemic Framework for Digital Forensic Readiness," *Journal of Computer Information Systems,* vol. 54, pp. 97-105, January 2014.
[149] Government Accountability Office (GAO), "Technology Readiness Assessment Guide: Best Practices for Evaluating the Readiness of Technology for Use in Acquisition Programs and Projects," vol. January, G. A. O. (GAO), Ed., ed. Washington, DC, 2020.

[150] HukariAscendant, "Readiness Reviews," Government Nuclear Capabilities ed. Wheat Ridge, CO: HukariAscendant, 2017.
[151] National Nuclear Security Administration (NNSA), "Baseline Cybersecurity Program," vol. Supplemental Directive, July 6 ed, 2017.
[152] Department of Energy, "Technology Readiness Assessment Guide," Office of Management, Ed., ed. Washington, DC: US Department of Energy (DOE), 2011.
[153] E. Bajramovic, "Secure Logging in Operational Instrumentation and Control Systems," Friedrich-Alexander-Universität Erlangen-Nürnberg (FAU), 2019.
[154] Institute of Internal Auditors (IIA), "Assessing Cybersecurity Risk: The Three Lines Model," ed. Lake Mary, FL: Institute of Internal Auditors (IIA), 2020.
[155] Department of Defense (DoD), "Cybersecurity," D. o. Defense, Ed., ed: DoD CIO, 2014.
[156] H. Kirkham and C. Marinovici, "Technology Readiness and the Smart Grid," *IEEE,* 2013.
[157] U.S. Department of Energy (DOE), "Fiscal Year 2021: Stockpile Stewardship and Management Plan - Bieennial Plan Summary: ," National Nuclear Security Administration (NNSA), Washington, DC2021.
[158] Nanotechnology Signature Initiative, "Data Readiness Levels," nnco.nano.gov, Ed., Discussion document ed, 2013.
[159] A. L. Johnson, "Cybersecurity for Financial Institutions: The Integral Role of Information Sharing in Cyber Attack Mitigation," *UNC School of Law: North Carolina Banking Institute,* vol. 20, March 1 2016.
[160] A. Cavanaugh, "Change and Configuration Management Plan (Proposal)," MESA Oregon, Portland, ORDec. 11 2020.
[161] D. G. Datong, "Cyber-Terrorism: Nigeria's Payment System Infrastructural Readiness," Master of Conflict Security and Development (MCSD), Department of History and War Studies, Nigerian Defence Academy (NDA), 2018.
[162] A. A. Cardenas, T. Roosta, G. Taban, and S. Sastry, "Cyber Security Basic Defenses and Attack Trends," in *Homeland Security*, ed, 2008, pp. 73-102.
[163] Department of Homeland (DHS) Security Cybersecurity & Infrastructure Agency (CISA), "Cybersecurity Workforce Trainig Guide," cisa.govAug 5 2021.
[164] F. Bisel, "Naval Information Warfare Center Atlantic: Cybersecurity Trainig for the DoD Workforces with a Limited Budget," csrc.nist.gov2019.
[165] B. Borgman, S. Mubarak, and K.-K. R. Choo, "Cyber security readiness in the South Australian Government," vol. 37, pp. 1-8, 2015.
[166] A. D. Pereira da Silva and Y. Bobbert, "Cybersecurity Readiness: An Empirical Study of Effective Cybersecurity Practices for Industrial Control Systems," *Scientific Journal of Research and Reviews,* Dec. 18 2019.
[167] M. H. Shah, R. Muhammad, and N. Ameen, "Cybersecurity Readiness of E-tail Organisations: A Technical Perspective," presented at the I3E 2020 – 19th IFIP Conference on e-Business, e-Services and e-Society, Skukuza, Kruger National Park, South Africa, 2020.
[168] M. Segal, "Cloud Security Posture Management webinar ", ed: ISACA San Franscisco Chapter, 2023.
[169] F. E. Catota, G. M. Morgan, and D. C. Sicker, "Cybersecurity incident response capabilities in the Ecuadorian financial sector," *Journal of Cybersecurity,* vol. 0, pp. 1-20, 2018.

[170] National Cybersecurity and Communications Integration Center (NCCIC), "ICS-CERT Annual Asssessment Report: Industrial Control Systems Cyber Emergency Response Team ", ed. hq.dhs.gov: NCCIC, 2016.
[171] B. Prince. (2013, July 1). *Cyber Attacks Against Energy Sector Jump in 2013: ICS-CERT*. Available: https://www.securityweek.com/cyber-attacks-against-energy-sector-jump-2013-ics-cert/
[172] J. Li, E. Bajramovic, Y. Gao, and M. Parekh, "Graded security forensics readiness of SCADA systems," *Informatik 2016,* 2016.
[173] T. Cruz, L. Rosa, J. Proence, L. Magiaras, M. Aubigny, L. Lev*, et al.*, "A Cybersecurity Detection Framework for Supervisory Control and Data Acquisition Systems," *IEEE Transactions on Industrial Informatics,* vol. 12, December 2016.
[174] E. Bajramovic, K. Waedt, A. Ciriello, and D. Gupta, "Forensic Readiness of Smart Buildings: Preconditions for Cybersecurity Tests," *IEEE,* 2016.
[175] A. AlEnezi, "Internet of Things & Cybersecurity Readiness in Smart-government and Organizations," 2019.
[176] A. Alenezi, H. F. Atlam, and G. B. Wills, "Experts reviews of a could forensic readiness framework for organizations," *Journal of Cloud Computing: Advances, Systems and Applications,* vol. 8, 2019.
[177] Amazon Web Services (AWS), "Guidance for Trusted Internet Connection (TIC) Readiness on AWS ", aws.amazon.comFebruary 2016.
[178] V. R. Kebande, N. M. Karie, and H. S. Venter, "A Generic Digital Forensic Readiness Model for BYOD using Honeypot Technology," in *IST-Africa 2016*, 2016.
[179] L. Simonovich and R. Blakemore. (2023, May 5). *Unlocking a Sustainable Future by Making Cybersecurity more Accessible*. Available: https://www.atlanticcouncil.org/blogs/energysource/unlocking-a-sustainable-future-by-making-cybersecurity-more-accessible/
[180] Department of Energy (DOE), "Evaluation Report: DOE-OIG-19-01 The Department of Energy's Unclassified Cybersecurity Program," Office of Inspector General (OIG), Ed., ed, 2018.
[181] M. Abdalla and Y. Arshad, "Information Security: Cybersecurity Standards Adoption Among Malaysian Public Listed Companies," *International Journal of Engineering Research & Technology (IJERT),* vol. 9, pp. 929-933, August 2020.
[182] O. E. MacBride, "Petition Of The North American Electric Reliability Corporation For Approval Of Amendments To Its Rules Of Procedure To Reflect Elimination Of The Reliabiity Readiness Evaluation And Improvement Program," ed. nerc.com: SCHIFF HARDIN LLP,, 2009.
[183] International Standards Organization (ISO), "e-Competence Framework (e-CF) - A common European Framework for ICT Professionals in all Sectors - Part 3: Methodolgy," ed. Brussels: European Committee for Standardization, 2021.
[184] The Secretary of the Navy, "Cybersecurity Manual," Department of the Navy, Ed., ed: Chief Information Officer, 2022.
[185] Defense Acquisition University (DAU). (2023, Mar 22). *Risk Management Framework (RMF) for DoD Information Technology (IT)*. Available: https://www.dau.edu/acquipedia/pages/ArticleContent.aspx?itemid=245#:~:text=The%20RMF%20process%20consists%20of,System%2C%20and%20Monitor%20Security%20Controls.

[186] American Institute of Certified Public Accountants Inc (AICPA), *Guide: Reporting on an Entity's Cybersecurity Risk Management Program and Controls*. New York, NY: American Institute of Certified Public Accountants, Inc. (AICPA), 2017.
[187] COBIT, "Design Guide: Designing an Information and Technology Governance Solution," ISACA, Schaumburg, IL2019.
[188] R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, and R. McQuaid, "NIST Special Publication 800-160 Volume 2 Developing Cyber Resilience Systems: A Systems Security Engineering Approach," Department of CommerceNovember 2019.
[189] Cisco. (2022, Dec 1). *Cisco Identity Services Engine Data Sheet*. Available: https://www.cisco.com/c/en/us/products/collateral/security/identity-services-engine/data_sheet_c78-656174.html
[190] A. Georgiadou, S. Mouzakitis, and D. Askounis, "Assessing MITRE ATT&CK Risk Using a Cyber-Security Culture Framework," *Sensors,* May 9 2021.
[191] Gold Sky Security. (2021, Apr 17). *Estimated Costs Associated with NIST 800-53 and NIST 800-171 Security Risk Assessments*. Available: https://www.goldskysecurity.com/estimated-costs-associated-with-nist-800-53-and-nist-800-171-security-risk-assessments/
[192] scottmadden.com. (2023, Apr 18). *What is NERC CIP Compliance and Why is it Important?* Available: https://www.scottmadden.com/insight/what-is-nerc-cip-compliance/
[193] M. Mylrea, S. N. Gupta, and A. Nicholls, "An Introduction to Buildings Cybersecurity Framework," IEEE2017.
[194] Hiscox, "Hiscox Cyber Readiness Report," H. Ltd, Ed., ed. Bermuda, 2020.
[195] Crowdstrike, "Targeted Attacks Checklist," Crowdstrike, Ed., ed. Crowdstrike.com, 2015.
[196] F. Cleveland, "List of Cybersecurity for Smart Grid Standards and Guidelines," I. T. WG15, Ed., ed. http://iectc57.ucaiug.org/wg15public/Public%20Documents/Forms/AllItems.aspx: UCA International Users Group, 2013.
[197] M. Tang, M. g. Li, and T. Zhang, "The impacts of organizational culture on information security culture: a case study," vol. 17, pp. 179-186, 2015.
[198] A. Cavanaugh, "Criterion Clarification for Cybersecurity Readiness for the Energy Industry and Alternative Cybersecurity Readiness Models," Portland State University, Portland, ORMar 16 2022.
[199] National Security Agency (NSA), "A Framework for Assessing and Improving the Security Posture of Industrial Control Systems (ICS)," Aug. 20 2010.
[200] A. Ganin, A., P. Quach, M. Panwar, Z. A. Collier, J. M. Keisler, D. Marchese*, et al.*, "Multicriteria Decision Framework for Cybersecurity Risk Assessment and Management," *Risk Analysis,* vol. 40, 2020.
[201] J. Rossebo, E.Y., R. Wolthuis, F. Fransen, G. Bjorkman, and N. Medeiros. (2017) An Enhanced Risk Assessment Methodology for Smart Grids. *Computer*.
[202] T. L. Hughes, "Pre-Incident Planning for the Los Alamos National Laboratory," Master's Thesis, Naval Postgraduate School, Monterey, CA, 2017.
[203] J. Lavoie, "A Scoring Model to Assess Organizations' Technology Transfer Capabilities: The Case of a Power Utility in the Northwest USA," ed. Portland State University, 2020.

[204] K. Teknomo, "Analytic Hierarchy Process (AHP) Tutorial," Revoledu.com, https://mathsci2.appstate.edu/~wmcb/Class/5340/ClassNotes141/AHP/AHP%20Tutorial%20Teknomo.pdfMar. 23 2014
[205] S. Pant, A. Kumar, M. Ram, Y. Klochkov, and H. K. Sharma, "Consistency Indices in Analytic Hierarchy Process: A Review," *Mathematics,* vol. 10, 2022.
[206] W. E. Stein and P. J. Mizzi, "The Harmonic Consistency Index for the Analytic Hierarchy Process," *European Journal of Operational Research,* vol. 177, pp. 488-497, 2005.
[207] H. A. Barham, "Development of a Readiness Assessment Model for Evaluating Big Data Projects: Case Study of Smart City in Oregon, USA," Doctor of Philosophy in Technology Management, Engineering and Technology Management, Portland State University, Portland, OR, 2019.
[208] G. Shields, "The Shortcut Guide To: Network Management for the Mid-Market," Solarwinds, solarwinds.com.
[209] M. S. Abbas, "Consistency Analysis for Judgement Quantification in Hierarchical Decision Model," PDXScholar, Portland State University, 2016.
[210] N. Multari, "6th Annual Secure and Resilient Cyber Architectures Invitational " Pacific Northwest National Laboratory (PNNL), mitre.org2016.
[211] J. Estep, "Development of a Technology Transfer Score for Evaluating Research Proposals: Case Study of Demand Response Technologies in the Pacific Northwest " Ph.D. Dissertation Proposal, Engineering and Technology Management, Portland State University, 2015.
[212] D. S. Bakry, "An evaluation of the effectiveness of innovation ecosystems in facilitating the adoption of sustainable entrepreneurship ", Engineering and Technology Managment, Portland State University, 2022.
[213] A. Giadedi, "Ph.D. Dissertation Proposal: Oil and Gas Offshore Projects Evaluation: Case Study of Mellitah Oil & Gas B.V Libyan Branch," ed: Portland State University, 2019.
[214] S. Zhou, "The Development and Evaluation of Aggregation Methods for Group Pairwise Comparison Judgements," Doctor of Philosophy, Systems Science: Engineering Management, Portland State University, Portland, OR, 1996.
[215] R. Abotah, "Evaluation of Energy Policy Instruments for the Adoption of Renewable Energy: Case of wind energy in the Pacific Northwest U.S," Doctor of Philosophy, Engineering and Technology Management, Portland State University, Portland, OR, USA, 2014.
[216] A. Cavanaugh, "Hierarchical Decision Modeling (HDM) Mechanics," Portland State University, Portland, OR2021.
[217] S. ALGhamdi, "Organizational Readiness Assessment for Fraud Detection and Prevention: Case of Airlines Sector and Electronic Payment," Doctor of Philosophy, Technology Management, Portland State University, Portland, OR, 2022.
[218] D. F. Kocaoglu, "A Participative Approach to Program Evaluation," *IEEE Transactions on Engineering Management,* vol. EM-30, August 1983.
[219] J. Estep, "Development of a Technology Transfer Score for Evaluating Research Proposals: Case Study of Demand Response Technologies in the Pacific Northwest," Doctor of Philosophy, Technology Management, Portland State University, Portland, OR, 2017.
[220] H. A. Alanzi, T. U. Daim, and D. F. Kocaoglu, "Identify the Best Alternatives to Help the Diffusion of Teleconsultation by Using the Hierarchical Decision Model (HDM) " in *2015*

Portland International Conference, Management of Engineering and Technology (PICMET), 2015, pp. 422-432.
[221] G. Wen, W. Yu, X. Yu, and J. Lv, "Complex Cyber-Physical Networks: From Cybersecurity to Security Control," *Journal System Science Complex,* vol. 30, pp. 46-67, 2017.
[222] O. O. Illiashenko, M. A. Kolisnyk, A. E. Strielkina, I. V. Kotsiuba, and V. S. Kharchenko, "Conception and Application of Dependable Internet of Things Based Systems," *Radio Electronics, Computer Science, Control,* vol. 4, pp. 139-150, 2020.
[223] Y. Wan and C. Jinde, "A Brief Survey of Recent Advances and Methodologies for the Security Control of Complex Cyber-Physical Networks," *Sensors,* vol. 23, Apr 15 2023.
[224] M. S. Viveros, "Cybersecurity Education for the Next Generation - Emerging Best Practices," IBM Corporation, nist.gov2013.
[225] D. F. Kocaoglu, "Hierarchical Decision Modeling (HDM)," Portland State University1987.
[226] National Institute of Standards and Technology (NIST), "NICE Framework Competencies: Assessing Learners for Cybersecurity Work (2nd Draft): List of Competencies (draft) (xls)," ed. https://csrc.nist.gov/CSRC/media/Publications/nistir/8355/draft/documents/draft_nice_competencies_mar2021.xlsx: NIST, 2022.
[227] National Institute of Standards and Technology (NIST), "NIST 800-137: Information Security Continuous Monitoring (ISCM) for Federal InformationSystems and Organizations," September ed. Gaithersburg, MD: U.S. Department of Commerce,, 2011.
[228] B. Borgman, S. Mubarak, and K.-K. R. Choo, "Cyber security readiness in the South Australian Government," *Computer Standards & Interfaces,* vol. 37, pp. 1-8, Aug. 2 2014.
[229] Institute of Internal Auditors (IIA), "IT Essentials for Internal Auditors," in *Supplemental Guidance: Practice Guide*, ed. Lake Mary, FL: Institute of Internal Auditors (IIA), 2020.
[230] S. Musman, A. Temin, M. Tanner, D. Fox, and B. Pridemore, "Evaluating the Impact of Cyber Attacks on Missions," MITRE Corporation, McLean, VA2010.
[231] R. D. Ross, D. Bodeau, and R. Graubart, "MITRE Sixth Annual Secure and Resilient Cyber Architectures Invitational 2016," MITRE Corporation, mitre.org2016.
[232] Committee on National Security Systems (CNSS), "CNSSI No. 1253: Categorization And Control Selection For National Security Systems," ed. Ft. Meade, MD: National Security Agency (NSA), 2022.
[233] Microsoft. (2022, May 18). *Performance Tuning Network Adapters*. Available: https://learn.microsoft.com/en-us/windows-server/networking/technologies/network-subsystem/net-sub-performance-tuning-nics
[234] H. Barham, "Big Data Readiness in Smart Cities," ed. Portland State University, 2020.
[235] B. Yesilada, "PhD dissertation draft review: One on one with Birol," A. Cavanaugh, Ed., ed, 2024.
[236] Associated Press. (2024, Jan 5). *States and Congress Wrestle With Cybersecurity After Iran Attacks Small Town Water Utilities*. Available: https://www.securityweek.com/states-and-congress-wrestle-with-cybersecurity-after-iran-attacks-small-town-water-utilities/
[237] network-perception.com. (2023, July 25). *The Evolution of NERC CIP Compliance: Safeguarding the Power Grid*. Available: https://www.network-perception.com/blog/the-evolution-of-nerc-cip-compliance

[238] F. Cleveland, "What Security Topics Should Be Covered in Standards and Specifications," UCA International Users Group, IEC TC57 WG15 on Data and Communication Security for Power SystemsMay 29 2013.
[239] The Secretary of the Navy, "Cybersecurity Readiness Review," Navy, Ed., ed, 2019.
[240] D. Chatterjee, *Cybersecurity Readiness : A Holistic and High-Performance Approach*: SAGE Publications, 2021.
[241] M. Pidd, *Tools for Thinking: Modelling in Management Science*, Third ed. West Sussex, United Kingdom: John Wiley & Sons Ltd., 2009.
[242] ISACA, "Narrowing the Culture Gap for Better Business Results," Dec 4 2018.
[243] L. Hogaboam, B. Ragel, and T. Daim, "Development of a Hierarchical Decision Model (HDM) for health technology assessment (HTA) to design and implement a new patient care database for low back pain," presented at the PICMET '14, Portland International Center for Management of Engineering and Technology; Infrastructure and Service Integration, 2014.
[244] A. Ishizaka and S. Siraj, "Are multi-criteria decision-making tools useful? An experimental study of three methods," *European Journal of Operational Research,* vol. 204, pp. 452-471, May 26, 2017 2017.
[245] Stat-Ease. (2024, June 6). *Stat-Ease » v22.0 » Optimization Overview » Numerical Optimization » Desirability Function*. Available: https://www.statease.com/docs/v22.0/contents/optimization/desirability-function/
[246] Office of Management and Budget (OMB). (2003, Sept 26). *M-03-22 OMB Guidance for Implementing the Privacy Provisions of the E-Government Act of 2002*.
[247] L. R. O'Niell, M. Assante, D. Tobey, T. Conway, T. J. Vanderhosrt, J. Januszewski III*, et al.*, "Developing Secure Power Systems Professional Competence: Alignment and Gaps in Workforce Development Programs for Phase 2 of the Secure Power Systems Professional project," Pacific Northwest National Laboratory (PNNL)August 2013.
[248] Internet Security Alliance, "Cyber-Risk Oversight Handbook For Corporate Boards," Sept. 2019.
[249] Carbon Black, "An IT Auditor's Guide to Security Controls & Risk Compliance: Understanding Compliance Control Policies & 6 Controls for Managing Regulated Systems," Waltham, MA2016.
[250] Secura. (2024, Sept 2). *Threat Modeling for Industrial Control Systems: Mapping Potential Cybersecurity Risks in Your OT Systems - ICS and SCADA*. Available: https://www.secura.com/services/operational-technology/threat-modeling
[251] O. Alexander, M. Belisle, and J. Steele, "MITRE ATT&CK for Industrial Control Systems: Design and Philosophy," MITRE, McLean, VAMarch 2020.
[252] National Institute of Standards and Technology (NIST), "Artificial Intelligence Risk Management Framework (AI RMF 1.0)," vol. January, Department of Commerce, Ed., ed, 2023.
[253] Y. Suharto, "PhD Dissertation Proposal: Evaluation of Electrical Energy Storage (EES) Technologies for Renewable Energy," Doctor of Philosophy, Engineering and Technology Management, Portland State University, Portland, OR, 2016.
[254] E. Triantaphyllou, B. Shu, S. Nieto Sanchez, and R. T., "Multi-Criteria Decision Making: An Operations Research Approach," in *Encyclopedia of Electrical and Electronics Engineering* vol. 15, J. G. Webster, Ed., ed. New York, NY: John Wiley & Sons, 1998, pp. 175-186.

[255] A. Cavanaugh, "Graduate Programs for Cybersecurity Federal Compliance Employment using Hierarchy Decision Model (HDM)," Portland State University, Portland, ORWinter 2019.
[256] M. P. Warnecke, "Examining the return on investment of a security information and event management solution in a notional Department of Defense network environment," Naval Postgraduate School, Monterey, California, 2013.
[257] W. Sonnenreich, "Return on Security Investement (ROSI): A Practival Quantitative Model," *SageSecure LLC,* pp. 1-7.
[258] K. Waldron, "Resources for Measuring Cybersecurity: A Partial Annotated Bibliography," Washington D.C.October 2019.
[259] D. Schlette, M. Vielberth, and G. Pernul, "CTI-SOC2M2 - The Quest for Mature, Intelligence-Drive Security Operations and Incident Response Capabilities," *Computer & Security,* vol. 111, p. 102482, Sept 21 2021.
[260] Institute of Configuration Management, "Project Management Relative to CMII," USA2003.
[261] International Electrotechnical Commission (IEC), "IEC 62443-2-1: ED2 Draft for Public Comment," vol. Committee Draft for Vote (CDV) 65/756/CDV, ed: British Standards Institute (BSI), 2019.
[262] Federal Bureau of Investigation (FBI), "Internet Crime Report," Internet Crime Complaint Center (IC3), Ed., ed, 2019.
[263] "Occupational Safety and Health Standards (OSHA)," in *1910.120(c)(6)(iv)* vol. 29 CFR, ed. USA: U.S. Department of Labor, 2024.
[264] National Nuclear Security Administration (NNSA), "DOE O 425.1D Verification of Readiness to Start Up or Restart Nuclear Facilities," vol. Self-Study Program, D. o. Energy, Ed., ed, 2011.
[265] Department of Homeland (DHS) Security Cybersecurity & Infrastructure Agency (CISA), "Cybersecurity in the Nuclear Sector," in *Cybersecurity in the Nuclear Sector Infographic*, ed. cisa.gov: cisa.gov, 2021.
[266] A. Deane and A. Kraus, *CISSP Certified Information Systems Security Professional: An (ISC)2 Certification - The Official (ISC)2 CISSP CBK Reference*, 6th Edition ed. Hoboken, NJ: Sybex A Wiley Brand, 2021.
[267] R. Ross, P. Viscuso, G. Guissanie, K. Dempsey, and M. Riddle, "Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations," vol. December, National Institute of Standards and Technology (NIST), Ed., Revision 1 ed. US Department of Commerce, 2016.
[268] FedRAMP, "FedRAMP Security Assessment," PMO, Ed., 2.4 ed, 2017.
[269] T. Gann. (2020, Oct 13). *FedRAMP – What's the Big Deal?* Available: https://www.mcafee.com/blogs/other-blogs/executive-perspectives/fedramp-whats-the-big-deal/
[270] S. D. Young, "Memorandum For The Heads Of Executive Departments And Agencies," Executive Office of the President, Ed., Draft for Public Comment ed. Washington, DC, 2023.
[271] Center for Internet Security (CIS), "CIS Controls v8," May 2021.
[272] Open Web Application Security Project (OWASP), "OWASP Secure Coding Practices: Quick Reference Guide," November 2010.

[273] US Oxford dictionary. (2020). *Definition of standard* Available: https://www.lexico.com/en/definition/standard
[274] COBIT, "Governance and Management Objectives," ISACA, Schaumberg, IL2019.
[275] "Information Technology Management Reform Act," ed. United States, 1996.
[276] M. Swanson and B. Guttman, "NIST SP 800-14: Generally Accepted Principles and Practices for Securing Information Technology Systems," C. S. Laboratory, Ed., ed. Gaithersburg, MD: National Institute of Standards and Technology, 1996.

APPENDICES

Appendix A – Model Taxonomy

Model Information
Cybersecurity Readiness for Energy Industry
Number of Levels:
3
Level 1:
Mission
Level 2:
5
Perspectives
Level 3:
29
Criteria

Level 1 node name	Description of node in Level 1
Cybersecurity Readiness Decision	Aim of this research is identifying gaps in cybersecurity readiness in the energy industry

Level 2 node names	Description of node in Level 2
Organizational	Competencies that are mission and business focused.
Information Management	Technical competencies dealing with technology and systems that align with NIST 800-137 Information Management.
Systems Management	Technical competencies dealing with technology and systems that align with NIST 800-137 all categories (excluding Information Management).
Professional	Competencies that may not be job-specific, but allow a learner to work well with others, improve performance, and provide value in a workplace. Sometimes called soft or employability skills.
Leadership	Competencies that are especially important for learners in leadership positions.

Level 3 node names	Description of node in Level 3
Change Management is considered	Elements: A repeatable and sustainable framework. Naming conventions, version control system, and document and storage retrieval system. Scope assessment against: quality, risk, schedule, cost, resources, and customer satisfaction are realized. Problem: When change is not logged there is an out-of-control situation, that is no one is aware of the current state of vulnerability.
Computer users settings and permissions are known	Elements: What each staff person needs to know is understood. Problem: Overprivileged setting can lead to more chances for breaches of data. Users setting unknown is a gap in security.
Cyber awareness of all staff is checked	Elements: Rogue access points awareness by Wi-Fi users. Malicious links create a man in the middle attack possibility. Problem: Vulnerable employees will likely lead to vulnerable organizational assets.
Cybersecurity goals of energy organization are identified	Elements: Tools make controls and updating control viable. Dashboards keep goals top of mind. Problem: Executive priorities of the energy business not tied to cybersecurity realities can put other users (including consumers) at risk.
Cybersecurity learning sources are available	Elements: Resources on cybersecurity and the energy system specific topic threats. Online training on crime organizations and nations with malicious intent. Those with cybersecurity training and responsibilities should know all policies and practices. Problem: Smaller organizations don't think they are a target but they are breached in order to get credentials to larger organizations machines, by theft of more credentials or because of implicit trust.
Cybersecurity Readiness Assessments	Elements: Quantitative self-rating aids in identifying if the organization is missing controls. Problem: No assessments mean no cybersecurity integration is likely being done with the rest of the operations.
Cybersecurity risk is considered priority by C-Suite	Elements: The board, and or C-Suite, is not considering cyber a risk. The organization should be paying the same or more attention on security than on ease of use and time to market. The Chief Information Officer (CIO) should be making strategic decisions as an equal on the board if exists. Problem: There is no comprehensive plan and recognition of experts for cybersecurity at the strategic level.
Data loss prevention system is in place	Elements: Data Loss Prevention system is essential for critical information and assets. DLP systems provide: logging, malfunction information, forensics, threat information, retention, reporting, and cloud information. A forensic model is in place for when an event occurs is one aspect of DLP. Problem: No DLP means there is no large integrated system for threat management.
Documents are marked and protected	Elements: Sensitive attachments should be stored separately on protected systems. Problem: Haphazard and inconsistent markings that are not standards based (merely organizationally specific) create confusing language for auditors.

Energy system outages are planned for	Elements: There should be a plan for power loss. Problem: Unplanned failures may lead to cascading grid failures.
External reporting is done	Elements: Electricity Information Sharing and Analysis Centers and Computer Security Incident Response Teams help keep industry a step ahead of criminals. Problem: If no security reports are being made the criminals have a knowledge advantage.
External vendor/supply coordination is done	Elements: Coordination of security information with other organizations in the supply chain. Problem: If no updates then information sharing (thus security) is immature.
Info Officer is in contact with Internet Service Provider	Elements: There is communication between Chief Information Office (or delegate) and the Internet Service Provider. Problem: The Internet Service Provider is part of the internet network interfaces and can add to complete cyber awareness.
Logging is sufficient for security and forensics	Elements: Logs must be retrievable and understandable. Log time settings must be protected in order to correctly attribute violations. Problems: Bad logging is a limiting factor for forensic teams work so an attack may not be remediated correctly.
Machine limitations are recorded	Elements: Limitations of systems configurations ability must be known (before installing preferred). What configuration you can or cannot do (e.g., hardening) because of design limitations is making the organization aware. Protocol limitations of machines are known. Problem: Machines that cannot be configured in networks or are misconfigured leave critical infrastructure vulnerable.
Network and System admin procedures documented	Elements: Setup policies and procedure settings are known. Administrators are identified. Problems: Without the policies and procedures thoroughness and clarity are not complete.
Network modeling for IoT is done	Elements: A security model is done based on protocols and network connections. Cloud assets are modeled. Problems: Contracts without specifications around network responsibilities and/or without models are likely to cause dropping the ball with security.
Outages are not required for security updates	Elements: Spares enable continuous operation. Problems: Asset work stoppages can lead to access failures.
Planning for forensic evidence collection	Elements: A model for evidence collection enables attribution and/or remuneration by shoring up legal loopholes. There are separate legal considerations for cloud providers. Problems: Without forensic planning legal loopholes can leave criminals free.
Policies are updated	Elements: Organizational policies should match jurisdictional security and privacy requirements. Penalties should be listed. Technical authentication policies should be reviewed and updated regularly. Problems: Without policy updates disclosure of data is possible administratively.

Presence of Implementation Oversight	Elements: Test plans should be verifying baselines. “Need to know” should be incorporated into an oversight plan. User settings should be communicated between employee and manager. Problems: Standards implementation that is lacking puts the financials of the organization at risk
Presence of legislative understanding	Elements: Lack of legal understanding can lead to non-compliance and additional forced oversight. Problems: Legal issues can have a costly monetary penalty.
Professionals with cyber certifications are in operations roles	Elements: Those hired should feel aware of the entire landscape from governance to theory. Problems: Security could be not fully implemented. Costly incidents can happen if a problem spins out of control.
Retention periods are in place and used for information and data	Elements: Attribution, solving data issues, restoration of data are some reasons why retention is a concern. Problems: If no offline backups, based on retention goals, then data could be lost in an attack or too much data could be exposed in an attack.
Social impact of breaches is talked about in the company	Elements: Social con artistry, which is one of the easiest ways to get information, is discussed including impacts. Problems: Breaches are a concern and when unplanned for information/reputation could be lost.
Standards are understood	Elements: Create a model to follow tailored to your organization. Problems: When standards are misunderstood there may be violations.
Supply chain cyber risk is considered during procurement	Elements: Communications and controls (such as contracts) are setup with vendors and suppliers. Problems: Third parties may have vulnerabilities.
There is an organizational common vocabulary for cybersecurity in the energy industry	Elements: A defined technical vocabulary should be defined. Problems: If users don’t understand vocabulary around detection and prevention they cannot discuss or deal with cyberattacks.
Threats to organization are modeled	Elements: A corpus to prioritize and deal with threats. Problems: If don’t have a threat model then awareness of security and attack vectors is not present.

Appendix B – Selected Terms and Definitions

Advanced Persistent Threats (APT) (aka state sponsored hacking) (per Carnegie Mellon University and The John Hopkins University Applied Physics Laboratory) are when "an adversary that possesses sophisticated levels of expertise and significant resources which allow it to create opportunities to achieve its objectives by using multiple vectors (e.g. cyber, physical, and deception)" [53].

Audit readiness checklists, observe and interview SMEs to see if controls are implemented correctly.

Defense in depth (multiple hurdles for an adversary such as domains, zones, and conduits) [260].

A risk decision is an informed decision based on partial knowledge. That is a risk decision is an "administrative" (aka "process assessment") of best-defense rather than a scientific evaluation.

Security Information and Event Management (SIEM) or an Advanced Endpoint… kills some services or ports (blocks it), and adds information to a log file [43].

Security Operations Center (SOC) which repackages and distributes intelligence and recommendations (aka posturing). The posturing they are distributing is controls advice. Operations uses that advice to affect the risk status activities of the organization [43].

Systems Engineering documents [188] combine project management with protections needs (safety and security, including privacy "and privacy risk tolerances")… Systems Engineering principles are key to understanding integrated solutions (i.e., both system and environment based) [43]. Systems engineering [are] projects [that] have a start and end date attached to them so there is a gap [in applying] towards programs[43].

The International Electrotechnical Commission (IEC) Joint Technical Committee (JTC) International Standard ISO/IEC 27001 https://www.iso.org/isoiec-27001-information-security.html is focused on information security. Both the term cybersecurity and the term "cyber security" are used interchangeably. ISO 62443 parts (there are several documents that are called parts) uses the term "cyber security" [261].

Appendix C – Attack Mapping to HDM

Using the 10 categories/capabilities above we map to a scenario of attacker trying to get persistent access (and data from a machine) in an ICS environment.

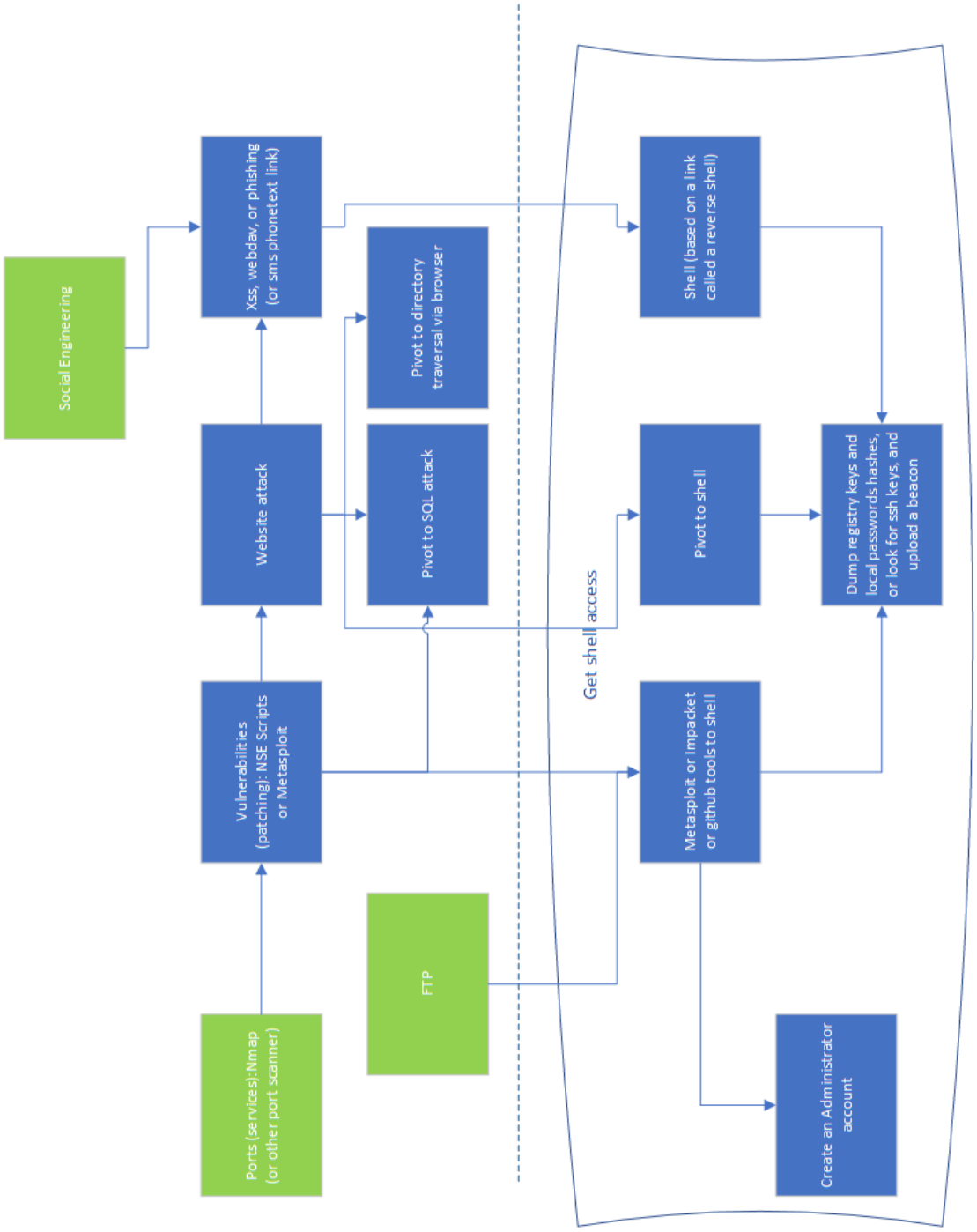
The first step is enumeration of environment which can be done with a tool like Nmap; or another port scanner tool like Nessus, OpenVAS, or Nuclei. Nmap is a powerful tool that has Nmap Scripting Engine (NSE) scripts which return a lot of information about the network assets. NSE scripts are code that can enumerate or run as code to attack a vulnerability (just like a Metasploit command). Once the attacker understands what ports and services are sending/receiving data they may use a vulnerability payload.

One of the first targets are likely the web servers (Internet Information Server (IIS), Python, PHP) because they are known to be communicating/routing traffic to the outside world through port 80 or 443. There are methods to attack these web servers using Metasploit or SQL attacks. If the attacker finds a vulnerable website (like a php website) then they can look for an upload option to upload a script (for the attacker there are many premade scripts in Kali Linux). If the file is uploaded the attacker will access that file with a web browser or a Command Line Interface (CLI) for directory traversal. One tool on Kali Linux is the qsd-php-backdoor.php script (which can also show SQL database on the machine). The next step is likely be to look for unpatched systems. Those systems usually have CVEs and can be exploited with scripts on GitHub, or in Kali “such as Impacket” or in Metasploit. These additional scripts can be used to get shell access to the machine. If shell access is gained the next step is to look for credentials (aka passwords, or certificates) either in plain text (using grep commands searching) or dumping memory using Mimikatz (if on a windows machine) or looking for Secure Shell (SSH) keys on a Linux box. Metasploit can also dump a lot of information such as the registry, local hashes, and some Windows Management Instrumentation Control (WMIC) asset info.

If it’s possible to create an administrator account on the machine (likely because of an unpatched system) then the attacker has many options. At this point a persistence file (or larger malware program) can be uploaded (through a shell, Remote Desktop Protocol (RDP), or Metasploit command line). Sometimes the tool for creating a beacon CLI tool (to send notifications to the attacker) is already on the machine (such as netcat).

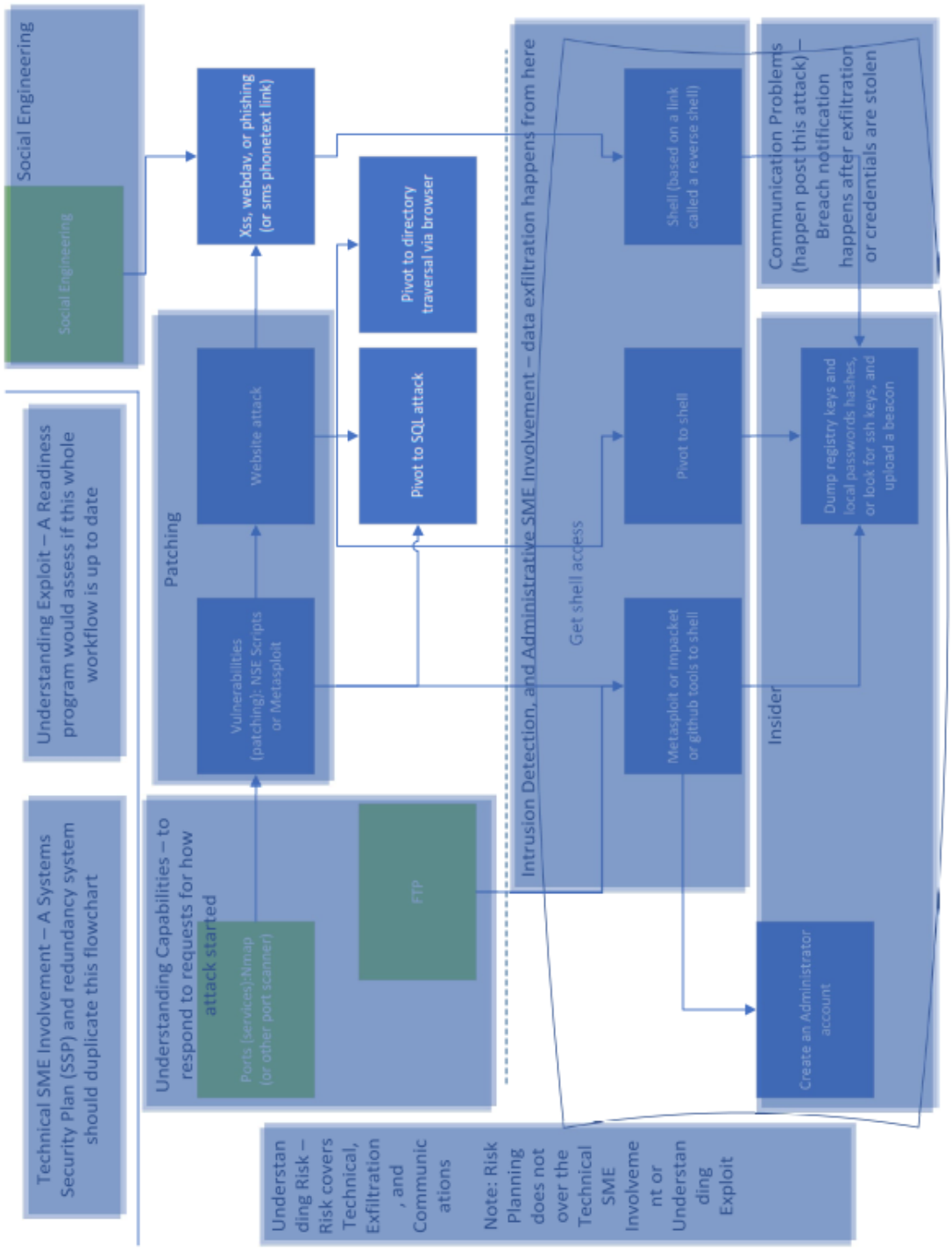
If an unpatched system cannot in the methods above then they can try a Cross Site Scripting (XXS) attack (a link in a webpage that opens a beacon), a WebDAV link such as google drive malicious link, or a phishing email that opens a beacon. If a user clicked on the link our server would be setup to be notified (an open a port to “listen”) waiting for the attacker to type in their commands. Another route is to look for ftp servers to upload a .sh or .exe file to create a beacon (which we connect to with a listener).

Figure 66 – Attacker Initial Foothold Paths Example



Once we apply HDM to the attack path we can see that from a Kill Chain/defense-in-depth aspect that the HDM model covers trigger points on an attack plane/flow disallowing access. Readiness gaps after the overlay is applied need to be solved with further tailoring (aka additional assurance controls for trustworthiness) beyond what the HDM model provides.

Figure 67 – Attack with Overlay



Note: The overlays implementations are the authors subjective determination.

In the above example the HDM model would cover the attack path and there are only a few gaps, such as: SQL, WebDAV, and web traversal as an exploit opportunity not covered by

HDM criteria. These exploits are the technical intrusion points from social engineering attacks. NIST has a number of technical documents that can be used to fill the gaps left by HDM. Additional technical gaps are covered in the NIST Rainbow Series.

Appendix D – References for HDM Model

Ref #	Article	Business or Functional Category	Method	Summary	NIST NICE Competencies	Criterion	Raw concerns of the article
5	An Empirical Assessment of Cybersecurity Readiness and Resilience in Small Businesses	Business	Survey, Statistics	Are small businesses prepared and do they perceive cyber risk	Organizational	**Presence of Implementation Oversight**	Consistent implementation of security measures
6	ICS Testbed Tetris: Practical Building Blocks Towards a Cyber Security Resource	Zones, Testing	Model	A model of smart grid zone testing to stimulate and support discussion	Technical	**Network and System admin procedures documented**	Subnetting over between zones is complex
7	Towards verifiable evidence generation in forensic-ready systems	Forensic	Model	Defining cyber structure for proper evidence handling	Technical	**Logging is sufficient for security and forensics**	Insufficient logging was most limiting factor in cyber investigations
8	A socio-technical analysis of China's cybersecurity policy: Towards delivering trusted e-Government services	Policy/Law	Model, Literature Review	Trust in technology = Trust in government	Leadership	**Policies are updated**	Is data from cyber experts anonymized to inhibit full disclosure
8					Organizational	**Presence of legislative understanding**	Are there penalties for non-compliance
9	A conceptual model for digital forensic readiness	Forensic	Model	Systematic evidence-based criteria are needed	Technical	**Logging is sufficient for security and forensics**	Are storage devices automation completely controlled
10	Adoption of Cybersecurity Capability Maturity Models in	Government	Survey, Model	Are organizations adopting cyber maturity models?	Leadership	**Cybersecurity goals of energy organization are identified**	Controls in place for progressive cyber goals

	Municipal Governments						
10					Professional	**External vendor/supply coordination is done**	Do you coordinate with other organizations on cyber security sharing
11	Internet of Things & Cybersecurity Readiness in Smart-government and Organizations	Government	Model, Survey	Governments are using more IoT devices	Organizational	**Computer user's settings and permissions are known**	Have you developed security requirements lately
11					Organizational	**Cybersecurity Readiness Assessments**	Have surveys and checklists for auditing
11					Technical	**Network modeling for IoT is done**	Need model for mitigating cyber iot access control
12	A Generic Digital Forensic Readiness Model for BYOD using Honeypot Technology	Forensic	Model	Creates a theoretical workflow, which includes a BYOD and honeypot, for forensics	Technical	**Data loss prevention system is in place**	A forensic model in place for when an event occurs
12					Technical	**Retention periods are in place and used for information and data**	A forensic model for cloud assets
13	CISTAR Cybersecurity Scorecard	Business	Survey, Statistics	A survey on Natural Gas (NG) cyber capabilities			None
14	Expert's reviews of a could forensic readiness framework for organizations	Cloud, Forensic	Survey	A perspective diagram of forensic readiness was created based on expert feedback	Technical	**Data loss prevention system is in place**	A forensic model for cloud assets

14					Technical	**Planning for forensic evidence collection**	Possible to gather evidence from cloud without cloud providers help?
15	Cyber Security Basic Defenses and Attack Trends	Threat/Victim	Instructive Material	Covers defense and attacks using the confidentiality, integrity, availability model	Leadership	**Cybersecurity learning sources are available**	Do you have security resources for people on your staff
15					Professional	**Threats to organization are modeled**	Do you have a verified and validated threat model?
16	Cyber security readiness in the South Australian Government	Government	Survey	Are information security management systems successfully deployed	Organizational	**Cybersecurity Readiness Assessments**	Does assessment incorporate both assets and data
16					Technical	**Data loss prevention system is in place**	Do you have an infosec mgmt. System in place
16					Professional	**External reporting is done**	Do you report to an entity on security?
17	Cybersecurity for Financial Institutions: The Integral Role of Information Sharing in Cyber Attack Mitigation	Financial	Instructive Material	A comprehensive overview of the financial services cybersecurity landscape	Technical	**Change Management is considered**	Do you monitor changes to your network
17					Leadership	**Supply chain cyber risk is considered during procurement**	Do you control activities of third parties in supply chain?
18	Cybersecurity incident response capabilities in the Ecuadorian	Financial	Semi-structured interviews	Motivation and effectiveness of their organizational	Professional	**External reporting is done**	Do you report to an entity on security?

	financial sector			cybersecurity responses			
19	Cybersecurity Readiness as a Business Value	Business	Survey	A Likert based maturity survey based on threats			None
20	Cyber-Terrorism: Nigeria's Payment System Infrastructural Readiness	Financial	Instructive Material	Defining cyber terrorism and how governments can respond	Leadership	**Cybersecurity risk is considered priority by C-Suite**	Is terrorism secured against?
20					Organizational	**Documents are marked and protected**	Are policies considered classified information?
20					Professional	**External reporting is done**	Do you share information on cybersecurity with your partners?
20					Professional	**External vendor/supply coordination is done**	Do you get cybersecurity information updates?
21	Towards a Systemic Framework for Digital Forensic Readiness	Forensic	Model	Forensic readiness factors are binned with links to sources	Technical	**Planning for forensic evidence collection**	Are industry guidelines used for digital evidence collection?
22	Secure Logging in Operational Instrumentation and Control Systems	Forensic	Prototype	How to log entries and correlate data from different sources	Technical	**Logging is sufficient for security and forensics**	Are timestamps of events able to be recorded with certainty that the timestamp as not been changed
22					Technical	**Network and System admin procedures documented**	Are your interfaces hardened for only serving on common ports and normal

							protocol setups?
22					Leadership	**Policies are updated**	Is authentication security address in policy?
23	Cybersecurity Readiness of E-tail Organisations : A Technical Perspective	Business	Semi-structured interviews	Some basic themes from experts are identified	Technical	**Data loss prevention system is in place**	Do you have a system for threat management?
24	Evaluating the cyber security readiness of organizations and its influence on performance	Hypothesis	Model, Structural Equation Modeling	Proposes hypothesis about cybersecurity and then tests through Structural Equation Modeling	Organizational	**Computer user's settings and permissions are known**	Have you tested cybersecurity practices against organizational performance?
24					Technical	**Data loss prevention system is in place**	Do you prevent, detect, and combat attacks?
24					Organizational	**Presence of Implementation Oversight**	Periodic training on new complexities
25	Factors Affecting Perceptions of Cybersecurity Readiness Among Workgroup IT Managers	Sociology	Model, Statistics	Talks about the human factor of cybersecurity	Organizational	**Computer user's settings and permissions are known**	Do line managers understand cybersecurity profiles for staff
25					Technical	**Info Officer is in contact with Internet Service Provider**	Does the internet service provider and IT manager talk?
25					Organizational	**Social impact of breaches is talked about in the company**	Is social engineering awareness covered (including

							effects on user)
25					Organizational	**There is an organizational common vocabulary for cybersecurity in the energy industry**	Are users able to detect and prevent cyberattacks?
26	Forensic Readiness of Smart Buildings: Preconditions for Cybersecurity Tests	Forensics	Instructive Material	Asks a lot of questions about forensic-ability of the organization	Leadership	**Cybersecurity risk is considered priority by C-Suite**	Are you paying same or more attention on security than on ease of use and time to market?
26					Technical	**Machine limitations are recorded**	Are interconnected assets information known?
26					Technical	**Network and System admin procedures documented**	Are interconnected devices considered above low risk?
26					Technical	**Outages are not required for security updates**	Can security assessments be done while systems are up or if not can some systems be brought down to test?
26					Organizational	**Presence of legislative understanding**	Is someone assigned to review the latest privacy legislation?
27	Graded security forensics readiness of SCADA systems	Industrial Control Systems	Instructive Material	A light overview of SCADA network security	Technical	**Logging is sufficient for security and forensics**	Is accurate time being logged in logs

28	Factors Influencing Cybersecurity Readiness in Deposit Taking Savings and Credit Cooperatives: A Case Study of Nairobi County	Policy/Law	Survey, Statistics	A survey of small financial institutions cybersecurity posture in Kenya	Leadership	**Cybersecurity learning sources are available**	For those with cybersecurity responsibility do they know all the organizations policies and practices?
28					Technical	**Data loss prevention system is in place**	Is there a cyber data loss prevention system?
28					Technical	**Network and System admin procedures documented**	Do you know if your cybersecurity controls are accurate, if so are they verified and validated?
28					Organizational	**Presence of Implementation Oversight**	Have polices for firewalls been documented and vetted?
28					Leadership	**Professionals with cyber certifications are in operations roles**	Do you feel aware of the cybersecurity technologies, if so are do you have people with certifications or recent academic degrees?
29	Information Security: Cybersecurity Standards Adoption Among Malaysian Public Listed Companies	Standards	Statistics	Do organizations in Malaysia intended to comply with standards	Organizational	**Presence of Implementation Oversight**	Are proactive practical procedures in place?
29					Professional	**Threats to organization are modeled**	Is news of threats and breaches shared often?

30	Indicators for maturity and readiness for digital forensic investigation in era of industrial revolution 4.0	Forensic	Literatur e Review	A thorough review of handling cloud forensic information	Leadership	**Cybersecurity goals of energy organization are identified**	Do you have a dashboard for security status (e.g., people, processes, and technology)?
30					Leadership	**Cybersecurity learning sources are available**	Are continuous security improvement processes documented?
30					Technical	**Data loss prevention system is in place**	Do you have post-incident procedures?
30					Technical	**Logging is sufficient for security and forensics**	Based on your network size have you scoped out what you will and will not be able to collect?
30					Technical	**Machine limitations are recorded**	Have you documented your iot device limitations for control?
30					Technical	**Machine limitations are recorded**	If you have open source and/or propriety software have you documented all the security limitations?
30					Technical	**Network modeling for IoT is done**	Do you have a backup logging for iot device logs
30					Technical	**Network modeling for IoT is done**	Do you have visibility and control of your cloud assets?

30					Technical	**Planning for forensic evidence collection**	Do you have forensic collection methods? Do you have a chain of custody written down for evidence if needed?
30					Technical	**Retention periods are in place and used for information and data**	Do you have offline backups of everything?
31	Information Security Standards	Standards	Instructive Material	A good summary of standards around the year 2010.			None
32	Managing Cyberthreat	Policy/Law	Instructive Material	An overview of breaches in critical infrastructure sectors	Organizational	**Cybersecurity Readiness Assessments**	Have you analyzed if audits done are effective?
32					Leadership	**Cybersecurity risk is considered priority by C-Suite**	Does the board have IT security minds?;
32					Technical	**Data loss prevention system is in place**	Do you have a comprehensive list of security considerations specific to your use case (e.g., info tech, industrial control system, etc.)?
32					Technical	**Data loss prevention system is in place**	Do you have a reporting and escalation written procedure for incidents?
32					Technical	**Energy system outages are planned for**	Do you have a contingency plan if your organization is without power for a

							prolonged period of time?
33	Mobile Cloud Forensic Readiness Process Model for Cloud-Based Mobile Applications	Cloud, Forensic	Model	Acceptable evidence documentation procedures concepts are highlighted.	Technical	**Data loss prevention system is in place**	Can cloud information be successfully isolated (without losing the data) if there is an incident?
34	New tool assesses banks' cybersecurity readiness	Financial	Interview	An interview with bank officials on a financial cybersecurity reporting tool available.	Leadership	**Cybersecurity risk is considered priority by C-Suite**	Is cybersecurity a key component of the risk management program?
34					Professional	**External reporting is done**	Does your industry have an association to supervise cybersecurity and are you a part of it?
35	Verification of Forensic Readiness in Software Development: A Roadmap	Model	Poster One-Pager	A timeline with definitions that could help lay people understand digital forensics			None
36	Cybersecurity Readiness: An Empirical Study of Effective Cybersecurity Practices for Industrial Control Systems	Industrial Control Systems, Business	Survey	A survey of businesses on current methods, reporting, and board involvement	Organizational	**Cybersecurity Readiness Assessments**	Do you rate your cyber assessment methods annually?
36					Technical	**Standards are understood**	Do you have someone on staff who can interpret cybersecurity standards?

37	Technology Readiness and the Smart Grid	Government, Business, Standards	Literature Review	A review of Technology Readiness Levels developed by NASA and how they could be applied to Smart Grid			None
38	The Need for Integrated Cybersecurity and Safety Training	Standards	Instructive Material	Cybersecurity training goals and risk rankings are discussed			None
39	The Current State of Insider Threat Awareness and Readiness in Corporate Cyber Security - An Analysis of Definitions, Preventions, Detection, and Mitigation	Literature Review	Instructive Material	Insider threat histories and motivations are discussed.	Professional	**Cyber awareness of all staff is checked**	Does your team understand the difference between good and bad cyber behavior?
39					Technical	**Logging is sufficient for security and forensics**	Is information sent to a log system that is retrievable and understandable?
40	Cyber Security Readiness Assessment Model in Kenyas' Higher Learning Institutions: A Case of University of Nairobi	Academia	Survey, Statistics	A survey of university departments IT practices under the scope of one university			None

Appendix E – Desirability Questions

What is the expected level that change management will be considered?

1. Awareness of need – 20%
2. Conventions and controls in place – 40%
3. A system in place – 60%
4. Quality, risk, cost, and satisfaction are done - 80%
5. A repeatable and sustainable framework is in place - 90%

To what degree are computer user's settings and permissions known by line management?

1. Unknown – 25
2. Tangentially understood – 50
3. Plans are in place and followed – 70
4. Audited by manager – 90

To what extent is cybersecurity awareness of working staff checked?

1. Little to none, (phishing emails only) – 20
2. Moderate, (training provided) – 40
3. High, Logs reviewed -75
4. Very High, an automated scanning solution is implemented – 95

Are Cybersecurity goals at one of these expected levels?

1. Very Low - 20
2. Updated periodically – 30
3. Scanning tools are used and then goals are created from that – 60
4. Dashboards are continuously monitoring cybersecurity controls – 90

What is the amount of Cybersecurity learning sources available?

1. Very Low - 20
2. Low, Threats to energy industry – 30
3. Medium, Internet crime – 50
4. High, Credentials penetration elaboration – 60
5. Very High, Cybersecurity specific policies and formal procedures – 90

What is the expected level of Cybersecurity Readiness Assessments in the organization?

1. Very Low - 20
2. Low, Self-assessments – 25
3. Medium, Internal auditing – 45
4. High, Assessment results are integrated into methodology – 65
5. Very High, Quantitative ratings – 90

Cybersecurity Risk is a required topic by C-Suite

1. Very Low - 20
2. Low, Security is considered important – 40

3. Moderate, CIO is making strategic decisions – 70
4. High, Cyber experts involved in strategy – 80
5. Very High, Specific terrorist acts are planned for – 95

What is the complexity of Data Loss Prevention (DLP) systems that are in place?

1. Very Low, Have Incident Response Plan - 10
2. Low, Logging, threats, retention, reporting, and cloud are considered -30
3. Moderate, Legal team periodic checks - 40
4. High, Contracting considers DLP - 80
5. Very High, A forensic model is used – 95

What is the level that documents are marked and protected?

1. Very Low - 20
2. Low, Language to use for sensitive communication is circulated - 30
3. Moderate, Sensitive information is stored separately - 60
4. High, Inconsistent markings are audited and assessed – 90

To what degree are Energy System outages planned to?

1. Very Low - 20
2. Low, There is a plan for power loss - 40
3. Medium, Maintenance outages are aligned with cyber concerns - 60
4. High, Long term outage contingency plan in place for cyber - 75
5. Very high, Cascading grid failures are aligned with cyber concerns – 90

What is the required amount of external reporting?

1. Very Low - 20
2. Low, Security reports done - 30
3. Medium, Escalation plan with external stakeholders in place - 55
4. High, Electricity Information Sharing and Analysis Centers (E-ISAC) and Computer Security Incident Response Teams (CSIRT) (or similar) are part of the external reporting and response process – 95

What is the degree of vendor and supply alignment on security?

1. Very Low - 20
2. Low, Supply chain is monitored - 40
3. Medium, Sharing with vendors is done - 80
4. High, Periodic updates on cyber security are pushed to vendors and pulled from supply chain – 90

What is amount of communication sharing with Internet Service Provider?

1. Very Low - 20
2. Low, Chief Information Office (CIO's) office has a line of communication – 50%
3. High, Cyber activities are often exchanged – 75%

Logging required is sufficient for Security and Forensics

1. Very Low - 20
2. Low, Timestamps/log time of assets is maintained - 30
3. Moderate, Logs are retrievable and accessible to specialists/owners – 50
4. High, Backup storage restoration capability is periodically tested - 75
5. Very High, Timestamps/log time is specifically protected through cyber controls – 90

What is the degree that machine limitations are recorded?

1. Very Low - 20
2. Low, Subnetting is done – 30
3. Moderate, Hardening limitations are known - 50
4. High, Only required protocols are allowed and deny all is default - 70
5. Very High, Intrusion detections systems are best can buy with budget – 90

What is the extent that Network and System Administration procedures are documented?

1. Very Low - 20
2. Low, Procedures are vetted - 40
3. Medium, Procedures are proactively shared and include roles - 70
4. High, Routable assets are at minimum a medium risk in every procedure - 80
5. Very high, Third parties have validated the organizations procedures – 95

What is the degree of network modeling for ICS/IoT/Nuclear done?

1. Very Low - 20
2. Low, A network model of protocols and cloud connections exists - 50
3. Medium, Non-TCP/IP networking is modeled - 75
4. High, Network diagrams are requirements in all contracts - 90

What is the expected level of outages required for applying security updates?

1. Very Low - 20
2. Low, Have a work stoppage plan – 50
3. Medium, Spare assets enable continuous operation – 80
4. High, Assessments of machines are done periodically, and machines are kept in an operable state at all times – 95

What is the degree of planning done for forensic evidence collection?

1. Very Low - 20
2. Low, Evidence collection requirements exist (e.g., chain of custody) – 50
3. Medium, A legal attribution model exists - 80
4. High, Cloud services have a forensic plan – 95

What is the expected level of policy updating?

1. Very Low - 20
2. Low, Updated regularly - 30

3. Medium, Data disclosure policy exists and is updated with legal changes -50
4. High, Jurisdictional (Federal, State, Local) requirements are included in company policies - 80
5. Very High, Monetary penalties for violations/non-conformance are in policies and/or references – 95

What is the degree of implementation oversight?

1. Very Low - 20
2. Low, Implementation baselines are created and tested - 50
3. Medium, Need to know is defined and audited - 75
4. High, Industry standards for firewalling and cyber operations are implemented and assessed – 90

What is the degree of legal understanding?

1. Very Low - 20
2. Low, Forced oversight (as result of non-compliances) is mitigated - 60
3. High, Monetary penalties have been reduced because legal is reacting to new legislation – 95

What is the required level of certification in operations roles?

1. Very Low - 20
2. Low, Individual development plans for operations roles - 50
3. High, Staff is aware of certification landscape and seeking certifications – 75

What is the degree of retention periods for data and information?

1. Very Low - 20
2. Low, Have a retention plan - 40
3. Medium, As a result of retention, attribution is able to be done within a short time frame - 50
4. High, Offline backups are kept for long term (e.g., 3 to 5 years) - 60
5. Very high, A cloud assets retention plan exists – 90

What is the extent to which social impact of breaches are talked about?

1. Very Low - 20
2. Low, Awareness campaigns - 50
3. Medium, Breach plans are in Incident Response Plan - 75
4. High, Social manipulation and its effect (beyond phishing) is discussed (e.g., con artistry tactics, slander) - 90

What is the expected level that standards are understood?

1. Very Low - 20
2. Low, Models are used that reference standards - 45
3. Moderate, Discussion about standards is captured in meeting notes - 65

4. High, Assessments compare requirements with standards – 75
5. Very High, Checklists are formed directly (one to one) from standards – 95

Are complex Cyber supply chain risks considered in procurement?

1. Slow Adopter - 20
2. Follower, Third party information sharing happens - 50
3. First Mover, Controls are in place with suppliers and vendors – 80

What is the expected level of Cybersecurity vocabulary awareness?

1. Very Low - 20
2. Low, Vocabulary in the company is created - 60
3. High, A vocabulary dictionary exists as an authoritative reference – 90

What is the expected level that threats to the organization are modeled?

1. Very Low - 20
2. Low, Threat models are created - 50
3. Medium, Lessons learned are included in threat modeling - 60
4. High, Threat models go through a validation process before being accepted – 65
5. Very high, Threat models are shared with trusted partners - 95

Appendix F – Closely Related Definitions of Readiness

A similar and closely related Readiness defined usage is Materials Readiness Assessment [157] for developing and improving multi-system components. There are nine Materials Readiness Levels (MRL) for a product to get to a steady state of manufacturing. MRLs provide decision makers (at all levels) with a common understanding of the relative maturity (and attendant risks) associated with manufacturing technologies, products, and processes being considered to meet DoD requirement [149].

GAO states system readiness assessment (SRA) methodology is a best practice which provides a systemic understanding of the development life-cycle of the entire system and its interfaces with external entities. SRA's are part of TRA's [149]. Technology development (aka the lifecycles) may involve new invention, technology maturation, or the adaptation of existing technologies or heritage technologies for new applications or environments [149].

Forensics Cybersecurity Readiness

Another type of readiness is forensic readiness. The FBI's IC3 [262] is the cybersecurity complaint center for citizens of the USA. Forensic readiness has three capability types: regulatory compliance, internal investigations, and legal evidence management [148]. Forensic cybersecurity readiness is currently concerned with cloud implementations: how, who protects that information, and who is responsible for following government standards and reporting out court ready information. An organization will "need an acceptable digital forensic approach that prepares for security incidents" [178]. Forensics is a sub-category of cybersecurity and has its own ISO 17025, 27037 and NIST 800-86 standards.

Nuclear Energy Readiness

Readiness in the Nuclear industry means starting up new facilities or restarting existing facilities after a shutdown. The health and safety impacts of this are called site characterization [263]. Nuclear industry startups have many phases. All nuclear power plants will have a readiness exercise performed [27]. Specific to nuclear plants achieving a state of readiness to safely conduct nuclear operations DOE conducts readiness assessments to review the history to make sure that a nuclear plant startup or restart is ready for operation [79]. The National Nuclear Security Administration (NNSA) has published a workbook [264] for those wishing to study more about DOE Order 425.1D "Verification of Readiness to Start Up or Restart Nuclear Facilities" with a well-developed questions and answers section.

The elements of a defense-in-depth approach included Cybersecurity Readiness.

Critical Assets that perform safety, security, and emergency preparedness functions at nuclear power plants, as week as critical components needed to safely operation and shutdown the reactor, are protected from cyberattacks. The nuclear industry adapts to threats by learning about the latest tactics and tools of cyber attackers through

participation in information-sharing activities with the U.S. government, including classified threat briefing [265].

In the USA the Nuclear Regulatory Commission (NRC) approves Cyber Security Plans and internationally nuclear facilities have their own ISO standards. ISO 62645 is implementation guidance depending on plant security level. This international standard creates a baseline requirement for nuclear power plants with degree ratings from 1 to 3. NRC (such as 5.71, 5.83, and 1.152) and International the IAEA guidance such as 17, 42-G, 33-T, SSG-39, NG-T-3.8, 37-G and other reports are IAEA technical and implementation guidance that cover Computer Security, Control Systems, and the Electric Grid.

Table 99 - Selected ISO Nuclear Standards

#	Title/Topic	Category
60880	Software	Nuclear
60987	Hardware	Nuclear
61226	Categorization of functions and classification of systems	Nuclear
61513	Reqs	Nuclear
62138	Software	Nuclear
62566	Integrated Circuits	Nuclear
62645	Reqs for Sec Programs	Nuclear
63096	Cybersec for Nuclear Plants	Nuclear

Government Accountability Office (GAO) states System Readiness Assessment (SRA) methodology is a best practice which provides a systemic understanding of the development life-cycle of the entire system and its interfaces with external entities. SRA's are part of Technical Readiness Assessment (TRA) [149] of an operational program.

Appendix G – Letters to Participants

Introductory Consent Letter

Re: Invitation for Expert Participation in Aaron Cavanaugh's Ph.D. research

Attachment: PDF consent form

Hi [Cybersecurity Experts Name],

I am currently conducting my dissertation research entitled "Readiness of Cybersecurity in the USA Energy Industry".

As part of my research, I am forming expert panels to help me validate and quantify my research model. I have identified you as an expert in the field. Your knowledge, background, experience, and expertise will be very valuable for my research.

If you agree to participate in this research, a consent form is attached for signature. After I receive the signed form, I will send you web-based data collection instruments for you to provide your response. The research instruments will take about 15-50 minutes each to be completed.

I will be honored and grateful if you could kindly accept my invitation and join the expert panel. I would also greatly appreciate it if you could please suggest other potential experts who have expertise or experiences in Cybersecurity and Energy industry field.

I look forward to receiving your reply!

Best Regards,

Aaron Cavanaugh

Consent Form as Attachment

Consent to Participate in Research

Project Title: [Readiness of Cybersecurity in the USA Energy Industry]

Researcher: [Aaron Cavanaugh], [Department of Engineering and Technology Management ETM]

[Portland State University]

Researcher Contact: [acavan2@pdx.edu] / [Phone Number]

You are being asked to take part in a research study. The box below highlights key information about this research for you to consider when deciding whether to participate. Carefully review the information provided on this form. Please ask questions about any of the information you do not understand before you decide to participate.

Key Information for You to Consider
• **Voluntary Consent**. You are being asked to volunteer for a research study. It is up to you whether you choose to participate or not. There is no penalty if you choose not to participate or discontinue participation. • **Purpose**. The purpose of this research is to provide a comprehensive framework that can be used for assessing and evaluating the Readiness of Cybersecurity in the USA Energy Industry. • **Duration.** It is expected that your participation will last 15 ~50 minutes for responding the research questionnaire. The questionnaires will be sent out to you once or two times during October 2023 - January 2024. • **Procedures and Activities.** You will be asked to validate or quantify the perspective, criteria, or desirability metrics listed in research model. • **Risks.** There is no foreseeable risks or discomforts of your participation. • **Benefits**. Some of the benefits that may be expected include facilitating a follow-on research or application of research model on your organization. • **Alternatives.** Participation is voluntary and the only alternative is to not participate.

Why is this research being done?

The purpose of this research is to evaluate the Readiness of Cybersecurity in the USA Energy Industry by developing a comprehensive decision model. You are being asked to participate because of your knowledge, skill, and experience in topics related to this research. About [30-50] people will take part in this research.

How long will I be in this research?

We expect that your participation will take around 15-50 minutes each time for responding to the questionnaires. We plan to ask for your participation one or two times during October - January.

What happens if I agree to participate?

If you agree to take part in this research, your participation will include serving as one of the experts within one or two expert panels, which will help validate and quantify the research model. Also, you may be invited as an expert to provide insights for a case study. We will tell you about any new information that may affect your willingness to continue participation in this research.

What happens to the information collected?
Information collected for this research will be used to validate and quantify the research model or will be used for case analysis. The information and analytical results will be documented in a Ph.D. dissertation, which can be accessible from university or academic database. Your identifiable information such as your name will be kept confidential.

How will my privacy and data confidentiality be protected?
We will take measures to protect your privacy including keeping your name and identifiable information hidden in the research documents. Despite taking steps to protect your privacy, we can never fully guarantee that your privacy will be protected.

To protect the security of all your personal information, we will store your personal information and responses to the questionnaires in the researcher's computer with a secured password. Despite these precautions, we can never fully guarantee the confidentiality of all study information.

Individuals and organizations that conduct or monitor this research may be permitted access to inspect research records. This may include private information. These individuals and organizations include the Institutional Review Board (IRB) that reviewed this research.

What are the risks if I participate?
There is no foreseeable risks or discomforts for participating in this research.

What are the benefits if I participate?
You may benefit from participating in this research. Potential benefits of participating in this research include receiving the research outcome, which may facilitate a follow-on research or implementation of the research model in your organization.

What are my responsibilities if I choose to participate?
If you choose to participate in this research, you will be responsible for validating & quantifying the research model or providing your insights for case studies.

What other choices do I have besides participation in this research?
It is your choice to decide if you want to participate or not to participate in research. If you do not want to take part, it is totally fine.

What if I want to stop participating in this research?
Your participation in this research is voluntary. You do not have to take part in this study, but if you do, you may stop at any time. You have the right to choose not to participate in any study activity or completely withdraw from participation at any point without penalty or loss of benefits to which you are otherwise entitled. Your decision whether to participate will not affect your relationship with the researchers or Portland State University.

Will it cost me money to take part in this research?
Taking part in this research will not cost you.

Will I be paid for participating in this research?
You will not be compensated for participation.

Who can answer my questions about this research?
If you have questions, or concerns contact the research team at:

[Name: Aaron Cavanaugh]
[Phone number]
[Email: acavan2@pdx.edu]

Who can I speak to about my rights as a research participant?
The Portland State University Institutional Review Board ("IRB") is overseeing this research. The IRB is a group of people who independently review research studies to ensure the rights and welfare of participants are protected. The Office of Research Integrity is the office at Portland State University that supports the IRB. If you have questions about your rights, or wish to speak with someone other than the research team, you may contact:

Office of Research Integrity
PO Box 751
Portland, OR 97207-0751
Phone: (503) 725-5484
Toll Free: 1 (877) 480-4400
Email: hsrrc@pdx.edu

Consent Statement
I have had the opportunity to read and consider the information in this form. I have asked any questions necessary to decide about my participation. I understand that I can ask additional questions throughout my participation.

By signing below, I understand that I am volunteering to participate in this research. I understand that I am not waiving any legal rights. I have been provided with a copy of this consent form. I understand that if my ability to consent for myself changes, either I or my legal representative may be asked to provide consent prior to me continuing in the study.

I consent to participate in this study.

Name of Adult Participant	**Signature of Adult Participant**	**Date**

Researcher Signature (to be completed at time of informed consent)

I have explained the research to the participant and answered all of his/her questions. I believe that he/she understands the information described in this consent form and freely consents to participate.

Name of Research Team Member	**Signature of Research Team Member**	**Date**

Model Validation Letter

Thanks for accepting my invitation to participate in my research.

You are asked to evaluate the factors affecting “Readiness of Cybersecurity in the USA Energy Industry”.

Please use the links below:
Perspectives - https://portlandstate.qualtrics.com/jfe/form/SV_8ANKflNtHDi6png
Organizational Competencies - https://portlandstate.qualtrics.com/jfe/form/SV_bfGuE8MNBTRCggS
Information Management - https://portlandstate.qualtrics.com/jfe/form/SV_8HYS6KdnIrBEUKy
Systems Management - https://portlandstate.qualtrics.com/jfe/form/SV_b9LfYDUSGgvckRw
Professional Competencies - https://portlandstate.qualtrics.com/jfe/form/SV_b1kmlTZtM0PIV0y
Leadership Competencies - https://portlandstate.qualtrics.com/jfe/form/SV_0jRPqBUkFDXC2qy

Duration: The Questionnaire should not take you more than 20 minutes to complete.

Deadline: I'll appreciate it if you can do the Questionnaire at your earliest convenience.

If you have any questions, please don’t hesitate to contact me acavan2@pdx.edu

Validation Questionnaire

Perspectives	Description
Organizational	Competencies that are mission and business focused.
Information Management	Technical competencies dealing with technology and systems that align with NIST 800-137 Information Management.
Systems Management	Technical competencies dealing with technology and systems that align with NIST 800-137 all categories (excluding Information Management).
Professional	Competencies that may not be job-specific, but allow a learner to work well with others, improve performance, and provide value in a workplace. Sometimes called soft or employability skills.
Leadership	Competencies that are especially important for learners in leadership positions.

Please click "Yes" if you think that the specific perspective has an impact on the Readiness of Cybersecurity in the USA Energy Industry.
Please click "No" if you think that the specific perspective does not have an impact on the Readiness of Cybersecurity in the USA Energy Industry.

	Yes	No
Organizational	○	○
Systems Management	○	○
Information Management	○	○
Professional	○	○
Leadership	○	○

If there are any other perspectives that you think should be considered in this model, please list them below:

Criteria	Elements
Computer users settings and permissions are known	What each staff person needs to know is understood. Overprivileged setting can lead to more chances for breaches of data. Users setting unknown is a gap in security.
Cybersecurity Readiness Assessments	Quantitative self-rating aids in identifying if the organization is missing controls. No assessments mean no cybersecurity integration is likely being done with the rest of the operations.
Documents are marked and protected	Sensitive attachments should be stored separately on protected systems. Haphazard and inconsistent markings that are not standards based (merely organizationally specific) create confusing language for auditors.
Presence of Implementation Oversight	Test plans should be verifying baselines. "Need to know" should be incorporated into an oversight plan. User settings should be communicated between employee and manager. Standards implementation that is lacking puts the financials of the organization at risk
Presence of legislative understanding	Lack of legal understanding can lead to non-compliance and additional forced oversight. Legal issues can have a costly monetary penalty.
Social impact of breaches is talked about in the company	Social con artistry, which is one of the easiest ways to get information, is discussed including impacts. Breaches are a concern and when unplanned for information/reputation could be lost.
There is an organizational common vocabulary for cybersecurity in the energy industry	A defined technical vocabulary should be defined. If users don't understand vocabulary around detection and prevention they cannot discuss or deal with cyberattacks.

Please click "Yes" if you think that the specific organizational criteria has an impact on the Readiness of Cybersecurity in the USA Energy Industry.
Please click "No" if you think that the specific organizational criteria does not have an impact on the Readiness of Cybersecurity in the USA Energy Industry.

	Yes	No
Presence of Implementation Oversight	○	○
Cybersecurity Readiness Assessments	○	○
Presence of legislative understanding	○	○
Computer users settings and permissions are known	○	○
Social impact of breaches is talked about in the company	○	○
Documents are marked and protected	○	○
There is an organizational common vocabulary for cybersecurity in the energy industry	○	○

If there are other Organizational criteria you feel should be listed please write below

Criteria	Elements
Data loss prevention system is in place	Data Loss Prevention system is essential for critical information and assets. DLP systems provide: logging, malfunction information, forensics, threat information, retention, reporting, and cloud information. A forensic model is in place for when an event occurs is one aspect of DLP. No DLP means there is no large integrated system for threat management.
Energy system outages are planned for	There should be a plan for power loss. Unplanned failures may lead to cascading grid failures.
Machine limitations are recorded	Limitations of systems configurations ability must be known (before installing preferred). What configuration you can or cannot do (e.g., hardening) because of design limitations is making the organization aware. Protocol limitations of machines are known. Machines that cannot be configured in networks or are misconfigured leave critical infrastructure vulnerable.
Network modeling for IoT is done	A security model is done based on protocols and network connections. Cloud assets are modeled. Contracts without specifications around network responsibilities and/or without models are likely to cause dropping the ball with security.
Outages are not required for security updates	Spares enable continuous operation. Asset work stoppages can lead to access failures.
Planning for forensic evidence collection	A model for evidence collection enables attribution and/or remuneration by shoring up legal loopholes. There are separate legal considerations for cloud providers. Without forensic planning legal loopholes can leave criminals free.

Please click "Yes" if you think that the specific systems management criteria has an impact on the Readiness of Cybersecurity in the USA Energy Industry. Please click "No" if you think that the specific systems management criteria does not have an impact on the Readiness of Cybersecurity in the USA Energy Industry.

	Yes	No
Energy system outages are planned for	○	○
Data loss prevention system is in place	○	○
Planning for forensic evidence collection	○	○
Machine limitations are recorded	○	○
Network modeling for IoT is done	○	○
Outages are not required for security updates	○	○

If there are other Systems Management criteria you feel should be listed please write below

Criteria	Elements
Info Officer is in contact with Internet Service Provider	There is communication between Chief Information Office (or delegate) and the Internet Service Provider or other sites. The Internet Service Provider is part of the internet network interfaces and can add to complete cyber awareness.
Logging is sufficient for security and forensics	Logs must be retrievable and understandable. Log time settings must be protected in order to correctly attribute violations. Bad logging is a limiting factor for forensic teams work so an attack may not be remediated correctly.
Network and System admin procedures documented	Setup policies and procedure settings are known. Administrators are identified. Without the policies and procedures thoroughness and clarity are not complete.
Retention periods are in place and used for information and data	Attribution, solving data issues, restoration of data are some reasons why retention is a concern. If no offline backups, based on retention goals, then data could be lost in an attack or too much data could be exposed in an attack.
Standards are understood	Create a model to follow tailored to your organization. When standards are misunderstood there may be violations. "Industry standards may be helpful for energy system Operators of Cybersecurity in Energy and closely related industries" [39].

Please click "Yes" if you think that the specific information management criteria has an impact on the Readiness of Cybersecurity in the USA Energy Industry. Please click "No" if you think that the specific information management criteria does not have an impact on the Readiness of Cybersecurity in the USA Energy Industry.

	Yes	No
Retention periods are in place and used for information and data	○	○
Network and System admin procedures documented	○	○
Info Officer is in contact with Internet Service Provider	○	○
Logging is sufficient for security and forensics	○	○
Standards are understood	○	○

If there are other Information Management criteria you feel should be listed please write below

Criteria	Elements
Cyber awareness of all staff is checked	Rogue access points awareness by Wi-Fi users. Malicious links create a man in the middle attack possibility. Vulnerable employees will likely lead to vulnerable organizational assets.
External reporting is done	Electricity Information Sharing and Analysis Centers and Computer Security Incident Response Teams help keep industry a step ahead of criminals. If no security reports are being made the criminals have a knowledge advantage.
External vendor/supply coordination is done	Coordination of security information with other organizations in the supply chain. If no updates then information sharing (thus security) is immature.
Threats to organization are modeled	A corpus to prioritize and deal with threats. If don't have a threat model then awareness of security and attack vectors is not present.
Change Management is considered	A repeatable and sustainable framework. Naming conventions, version control system, and document and storage retrieval system. Scope assessment against: quality, risk, schedule, cost, resources, and customer satisfaction are realized. When change is not logged there is an out-of-control situation, that is no one is aware of the current state of vulnerability.

Please click "Yes" if you think that the specific professional criteria has an impact on the Readiness of Cybersecurity in the USA Energy Industry.
Please click "No" if you think that the specific professional criteria does not have an impact on the Readiness of Cybersecurity in the USA Energy Industry.

	Yes	No
External reporting is done	○	○
External vendor/supply coordination is done	○	○
Threats to organization are modeled	○	○
Cyber awareness of all staff is checked	○	○
Change Management is considered	○	○

If there are other Professional criteria you feel should be listed please write below

Criteria	Elements
Cybersecurity goals of energy organization are identified	Tools make controls and updating control viable. Dashboards keep goals top of mind. Executive priorities of the energy business not tied to cybersecurity realities can put other users (including consumers) at risk.
Cybersecurity learning sources are available	Resources on cybersecurity and the energy system specific topic threats. Online training on crime organizations and nations with malicious intent. Those with cybersecurity training and responsibilities should know all policies and practices. Smaller organizations don't think they are a target but they are breached in order to get credentials to larger organizations machines, by theft of more credentials or because of implicit trust.
Cybersecurity risk is considered priority by C-Suite	The board, and or C-Suite, is not considering cyber a risk. If your assets are important the organization should be paying the same or more attention on security than on ease of use and time to market. The Chief Information Officer (CIO) should be making strategic decisions as an equal on the board if exists for Information Technology (IT) security awareness [52] at the organizational level. There is no comprehensive plan and recognition of experts for cybersecurity at the strategic level.
Policies are updated	Organizational policies should match jurisdictional security and privacy requirements. Penalties should be listed. Technical authentication policies should be reviewed and updated regularly. Without policy updates disclosure of data is possible administratively.
Professionals with cyber certifications are in operations roles	Those hired should feel aware of the entire landscape from governance to theory. Security could be not fully implemented. Costly incidents can happen if a problem spins out of control.
Supply chain cyber risk is considered during procurement	Communications and controls (such as contracts) are setup with vendors and suppliers. Third parties may have vulnerabilities.

Please click "Yes" if you think that the specific leadership criteria has an impact on the Readiness of Cybersecurity in the USA Energy Industry.
Please click "No" if you think that the specific leadership criteria does not have an impact on the Readiness of Cybersecurity in the USA Energy Industry.

	Yes	No
Cybersecurity learning sources are available	○	○
Cybersecurity goals of energy organization are identified	○	○
Cybersecurity risk is considered priority by C-Suite	○	○
Professionals with cyber certifications are in operations roles	○	○
Policies are updated	○	○
Supply chain cyber risk is considered during procurement	○	○

Yes No

If there are other Leadership criteria you feel should be listed please write below

If you have a comment or other additional suggested metrics/levels, please add them below

→

HDM Email

Subject: Hierarchical Decision Model (HDM) model for Cybersecurity PhD work
Thanks for accepting my invitation to participate in my research.

You are asked to evaluate the factors affecting “Readiness of Cybersecurity in the USA Energy Industry”.

Please use the links below:
Perspectives - https://portlandstate.qualtrics.com/jfe/form/SV_8ANKflNtHDi6png
Organizational Competencies -
https://portlandstate.qualtrics.com/jfe/form/SV_bfGuE8MNBTRCggS
Information Management - https://portlandstate.qualtrics.com/jfe/form/SV_8HYS6KdnIrBEUKy
Systems Management - https://portlandstate.qualtrics.com/jfe/form/SV_b9LfYDUSGgvckRw
Professional Competencies -
https://portlandstate.qualtrics.com/jfe/form/SV_b1kmlTZtM0PIV0y
Leadership Competencies - https://portlandstate.qualtrics.com/jfe/form/SV_0jRPqBUkFDXC2qy

Duration: The Questionnaire should not take you more than 20 minutes to complete.

Deadline: I'll appreciate it if you can do the Questionnaire at your earliest convenience.

If you have any questions, please don’t hesitate to contact me acavan2@pdx.edu

HDM Questionnaire Example

Q0.

Systems Management Technical competencies dealing with technology and systems that align with NIST 800-137 all categories (excluding Information Management).

Please enter your name

Q1.

Criteria	Elements
Data loss prevention system is in place	Data Loss Prevention system is essential for critical information and assets. DLP systems provide: logging, malfunction information, forensics, threat information, retention, reporting, and cloud information. A forensic model is in place for when an event occurs is one aspect of DLP. No DLP means there is no large integrated system for threat management.
Energy system outages are planned for	There should be a plan for power loss. Unplanned failures may lead to cascading grid failures.
Machine limitations are recorded	Limitations of systems configurations ability must be known (before installing preferred). What configuration you can or cannot do (e.g., hardening) because of design limitations is making the organization aware. Protocol limitations of machines are known. Machines that cannot be configured in networks or are misconfigured leave critical infrastructure vulnerable.
Network modeling for IoT is done	A security model is done based on protocols and network connections. Cloud assets are modeled. Contracts without specifications around network responsibilities and/or without models are likely to cause dropping the ball with security.
Outages are not required for security updates	Spares enable continuous operation. Asset work stoppages can lead to access failures.
Planning for forensic evidence collection	A model for evidence collection enables attribution and/or remuneration by shoring up legal loopholes. There are separate legal considerations for cloud providers. Without forensic planning legal loopholes can leave criminals free.

Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Energy system outages are planned for	
Data loss prevention system is in place	
#Conjoint, Total#	

Q2. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Machine limitations are recorded	
Data loss prevention system is in place	
#Conjoint, Total#	

Q3. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Network modeling for IoT is done	
Data loss prevention system is in place	
#Conjoint, Total#	

Q4. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Outages are not required for security updates	
Data loss prevention system is in place	
#Conjoint, Total#	

Q5. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Planning for forensic evidence collection	
Data loss prevention system is in place	
#Conjoint, Total#	

Q6. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Machine limitations are recorded	
Energy system outages are planned for	

#Conjoint, Total#	

Q7. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Network modeling for IoT is done	
Energy system outages are planned for	
#Conjoint, Total#	

Q8. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Outages are not required for security updates	
Energy system outages are planned for	
#Conjoint, Total#	

Q9. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Planning for forensic evidence collection	
Energy system outages are planned for	
#Conjoint, Total#	

Q10. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Network modeling for IoT is done	
Machine limitations are recorded	
#Conjoint, Total#	

Q11. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Outages are not required for security updates	
Machine limitations are recorded	
#Conjoint, Total#	

Q12. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Planning for forensic evidence collection	
Machine limitations are recorded	
#Conjoint, Total#	

Q13. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Outages are not required for security updates	
Network modeling for IoT is done	
#Conjoint, Total#	

Q14. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100
Planning for forensic evidence collection	
Network modeling for IoT is done	
#Conjoint, Total#	

Q15. Please weigh each pair of the perspectives and criteria with respect to their importance to model's main objective

	Enter a number from 1 to 99 (99 is the highest score) so that the total equals 100

Planning for forensic evidence collection	
Outages are not required for security updates	
#Conjoint, Total#	

Desirability Curves Email

Subject: Desirability Data Collection for Cybersecurity PhD work

Thanks for accepting my invitation to participate in my research.

A desirability curve represents the experts preference of the technological metrics for the criterion. The desirability scale curves enable the visualization of the metric values of a criterion towards the company's objective. The mean is used as a relative value against the quantified criterion in Hierarchical Decision Model (HDM).

For each question there are four options. Please provide a rating for each option. A metric value of 100 is the perfect technology for the criteria because a company's objective is fully satisfied.

Duration: The data collection tool should not take you more than 50 minutes to complete.

Deadline: I'll appreciate it if you can do the expert judgment at your earliest convenience.

If you have any questions, please don't hesitate to contact me acavan2@pdx.edu

Please use the Desirability data collection tool links below:
Information Management -
https://portlandstate.qualtrics.com/jfe/form/SV_2t563m2IQKSKwaW
Systems Management - https://portlandstate.qualtrics.com/jfe/form/SV_7ZYMUXw5IUJwFTg
Professional - https://portlandstate.qualtrics.com/jfe/form/SV_8BojitIa2PZ9N3M
Organizational - https://portlandstate.qualtrics.com/jfe/form/SV_5zQKEDq3O9AIXno
Leadership - https://portlandstate.qualtrics.com/jfe/form/SV_7Pq0QDbaHzpjtHw

Desirability Questionnaire Example

Q0. Please enter your name

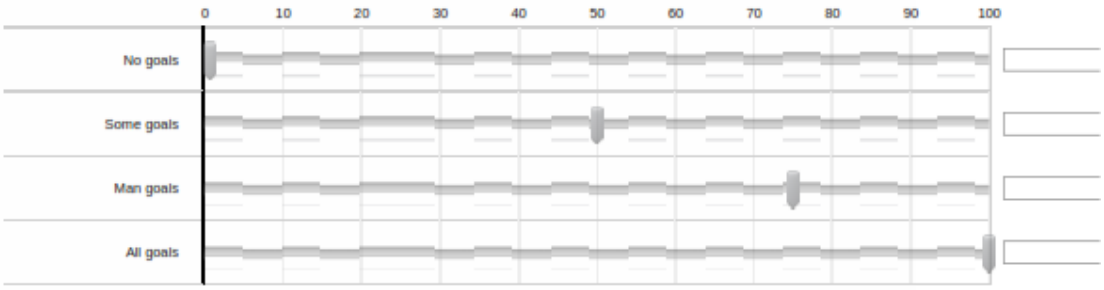
Q1.

Leadership

Criteria	Elements
Cybersecurity goals of energy organization are identified	Tools make controls and updating control viable. Dashboards keep goals top of mind. Executive priorities of the energy business not tied to cybersecurity realities can put other users (including consumers) at risk.
Cybersecurity learning sources are available	Resources on cybersecurity and the energy system specific topic threats. Online training on crime organizations and nations with malicious intent. Those with cybersecurity training and responsibilities should know all policies and practices. Smaller organizations don't think they are a target but they are breached in order to get credentials to larger organizations machines, by theft of more credentials or because of implicit trust.
Cybersecurity risk is considered priority by C-Suite	The board, and or C-Suite, is not considering cyber a risk. If your assets are important the organization should be paying the same or more attention on security than on ease of use and time to market. The Chief Information Officer (CIO) should be making strategic decisions as an equal on the board if exists for Information Technology (IT) security awareness [52] at the organizational level. There is no comprehensive plan and recognition of experts for cybersecurity at the strategic level.
Policies are updated	Organizational policies should match jurisdictional security and privacy requirements. Penalties should be listed. Technical authentication policies should be reviewed and updated regularly. Without policy updates disclosure of data is possible administratively.
Professionals with cyber certifications are in operations roles	Those hired should feel aware of the entire landscape from governance to theory. Security could be not fully implemented. Costly incidents can happen if a problem spins out of control.
Supply chain cyber risk is considered during procurement	Communications and controls (such as contracts) are setup with vendors and suppliers. Third parties may have vulnerabilities.

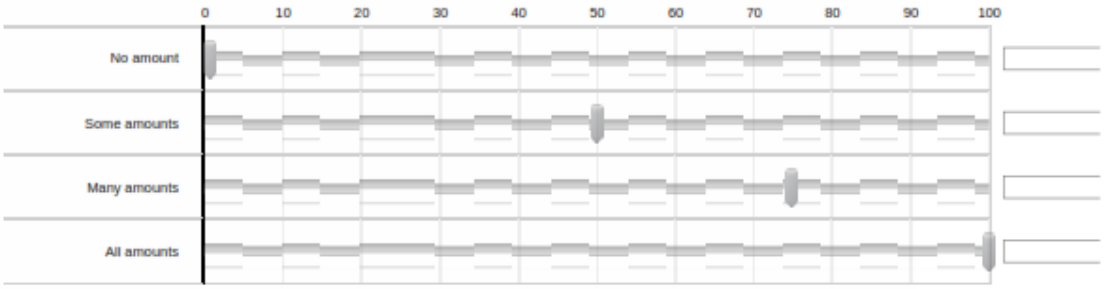
Are Cybersecurity goals identified in the organization?

Note: No goals is least favorable and all goals is the most favorable



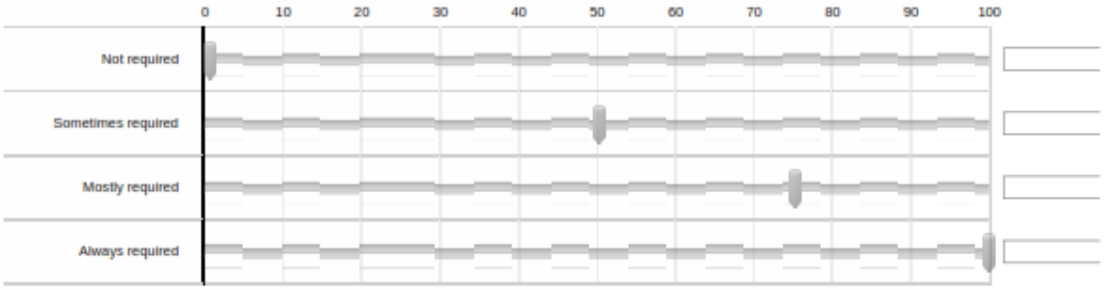
Q2. What is the amount of Cybersecurity learning sources available?

Note: No amount is least favorable and all amounts is the most favorable



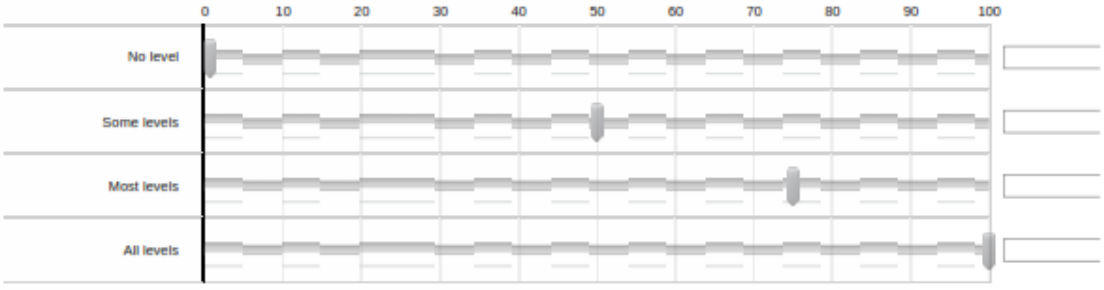
Q3. Cybersecurity Risk is a required topic by C-Suite?

Note: Not required is least favorable and always required is the most favorable



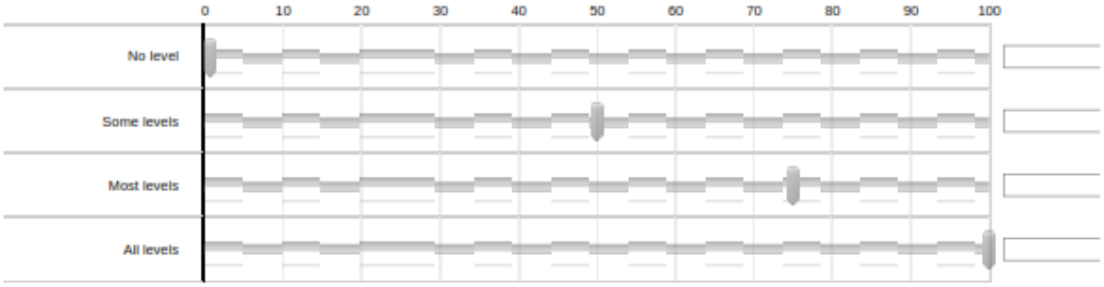
Q4. What is the expected level of policy updating?

Note: No level is least favorable and all levels required is the most favorable



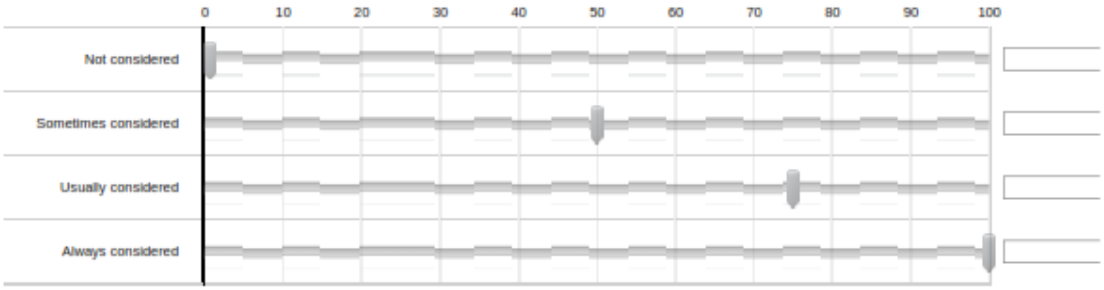
Q5. What is the required level of certification in operations roles?

Note: No level is least favorable and all levels required is the most favorable



Q6. Are complex Cyber supply chain risks considered in procurement?

Note: Not considered is least favorable and always considered is the most favorable



Q7. If you have any comment please add them below:

Appendix H – Original 52 literature gaps combined to 29 for the HDM model

Gap
No internal resources on cybersecurity in the organization
Cybersecurity goals not being updated
Cybersecurity is not considered as a key risk
Board of Directors has no security minds
Industry certifications or formal academic degrees are not req'd for security jobs
Cybersecurity responsible delegates on staff don't understand all org. policies and practices
Security is not as important as product ease of use and time to market
No authentication policies
No discussion or plan for terrorism
No supply chain communication and control
Data not anonymized so people will not report cyber problems
Security measures are not consistently implemented
No auditing (e.g., checklists or surveys)
No quantitative self-rating through assessments is done
Cybersecurity controls are not formally verified and validated
Current privacy legislation is not reviewed
Line management does not understand staff need to know settings
Social engineering is not discussed including impacts to self and others
No testing of cybersecurity plans
No periodic training of new cyber challenges
Policies aren't protected from those without the need to know
No combined asset and data assessment
Not updating security requirements
No penalties for non-compliance
No external or association security reports being made
Not aware of threats (i.e., a threat model) that pertain to the org.
Non-coordination of security information with other orgs
Staff doesn't thoroughly understand the difference between good and bad cyber behavior
Failures are not assumed to happen
Insufficient Logging
No data loss prevention system
No system (prevent, detect, combat) for threats or attacks
Log timestamps are not protected from changing or being incorrect
No model for evidence collection before an event
No Information Security Management System

No planned ability to gather cloud forensics
No model for evidence retention after an event
No cloud asset forensic model
No security model for IoT device remote control
Cybersecurity standards are not thoroughly understood by at least one person in the org.
No contingency plan for loss of power
Hardware and software limitations are not formally identified
Cybersecurity intrusion detection policies are not formally documented and vetted
Work stoppage outages are needed for security processes to be run
Devices with transport protocol abilities are only categorized as low risk
Interconnected assets are not identified
No communication about security between CIO and ISP
Users don't understand cyberattack detection and prevention
No hardening of services, ports, and protocols
No monitoring for changes to the network
Backup storage overwriting or malfunctioning
No subnetting between zones

Appendix I – Energy and Electricity Definitions

Energy industry (aka Energy Sector)

The energy industry, for the purposes of my dissertation proposal encompasses activities related to the production, distribution, and consumption of energy. The cyber scope includes facilities that do exploration, extraction, production, generation, transmission, distribution, and consumption of energy resources. "The reliance of virtually all industries on electric power and fuels means that all sectors have some dependence on the [DHS CISA defined] Energy Sector" https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors/energy-sector . Other sources of energy that are integral to growth and production across the nation were considered for criteria inclusion in the PhD decision model if there was a cybersecurity gap found in the literature. The DHS CISA defined: dams sector, and information technology sectors, are also primarily related to electrical energy, and cybersecurity. The transportation sector literature on cybersecurity, of which fuels from the energy industry is taken was specifically out of scope for the dissertation proposal.

Parts of the energy industry that were not in scope because of lack of relatedness to cybersecurity aspects in the literature are: Economics, oil and gas exploration, energy efficiency, energy storage (unless it relates to energy sector as defined by CISA minus transportation), and industry transformation thought. Nor, HVAC (sometimes considered in Energy control systems conversations). Nuclear specific concerns (outside of energy related topics of plants and microreactors) around data protection are outside the scope of this research.

Electricity Industry (aka the National Grid)

Bulk Energy Systems (BES), which uses Industrial Control Systems, is comprised of three components: generation, transmission, and distribution. Generation of power includes: Oil, natural gas, and coal for electricity generation, and industrial processes. Generation also includes renewables: Solar, wind, hydroelectric, geothermal, biomass, and other emergent sources of energy. Transmission and Distribution is responsible for transmitting electricity and distributing it to end-users through power grids which uses automated systems and computers that control networks. Primarily cybersecurity aspects related to industrial control systems, computer networks, regulations, and the human factors were found in the literature.

Regulation is a key component in modern cybersecurity, as found in the literature reviews. The BES is a highly regulated, having its own Agencies of Government mandated cybersecurity standards (NERC CIP). Thus, Agencies of Governments and regulatory bodies play a crucial role in shaping the electric power aspects of the energy industry.

Parts of the electricity industry that were not in scope included: Retail aspects, renewable integration, demand response, smart Grid, R&D, and technology transfer.

Appendix J - Control Schemes

A control is “any safeguard that is put in place to positively impact security” [266]. Readiness in practice is a control and an indicator where you need to be for the next step. Readiness control gaps found in literature were mapped to competencies of the National Institute of Standards and Technology (NIST) Workforce Framework for Cybersecurity National Initiative for Cybersecurity Education (NICE) which lists four competency types: Leadership, Organizational, Professional, and Technical. The NICE Framework: List of Competencies is currently in Draft format.

FISMA Law

Government operations require adherence to Federal Information Security Modernization Act (FISMA) which uses National Institute of Standards and Technology (NIST) 800-53 [26]. FISMA deals with privacy, risk, and security. FISMA is Section 208 of the E-Government Act of 2002 [22] which requires that OMB issue guidance to agencies on implementing privacy provisions of the E-Government Act [246]. FISMA has regulated that government agencies use NISTs risk-based controls. SMEs (such as Information System Security Officer (ISSO’s)) who work these standards should know technical dependencies internal to systems and sub-systems as well as administrative controls [26]. An ISSO is a person responsible for shepherding a piece of software through a secure lifecycle.

> The Federal Information Security Modernization Act (FISMA) of 2014 requires federal agencies to identify and provide information security protections commensurate with the risk resulting from the unauthorized access, use, disclosure, disruption, modification, or destruction of information collected or maintained by or on behalf of an agency; or information systems used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency [267].

The FISMA law specifies use of NIST 800-53, NIST 800-53A, and NIST 800-30 as baseline standards for agencies to make their own prescriptive (meaning specific targets) cybersecurity assessment tools. FISMA is not prescriptive, but relies on a deep understanding of over 1000 controls and a risk management.

NIST Cybersecurity Framework (CSF)

The NIST Cybersecurity Framework (CSF) is a phased/life-cycle view of 800-53 for use by private sector. The NIST CSF is not a guideline or standard. NIST CSF can be used along with NIST Risk Management standards/guidelines 800-30, 800-37 and 800-39. The CSF is broken down into 23 categories with 108 subcategories which includes a subset of NIST 800-53 controls. Overall NIST CSF is bigger than the HDM model and requires a lot of SME knowledge and time.

Committee on National Security Systems Instructions (CNSSI) 1253

Requirements are defined by the National Security Agency (NSA). Version 3 is the 2022 update to the version 2 2014 controls for National Security Systems. The mappings in Appendix

D (of CNSSI 1253) also add the privacy back into the matrix (as does NIST 800-53v5). CNSSI 1253 also includes a mapping to MITRE Att&ck concepts, and NIST 800-53 controls. Concepts of Committee on National Security Systems (CNSS) "operated by the Department of Defense (DoD)" CNSSI (Instruction) 1253 overlays which can be found at https://www.cnss.gov/CNSS/issuances/Instructions.cfm for National Security Systems (NSS).

NIST 800-137 Continuous Monitoring

The NIST 800-137 document has nine categories for the Continuous Monitoring (ISCM) controls for cyber systems. The categories are: Asset, Configuration, Digital Information, Event and Incident Management, Licensing, Malware, Network, Software, Vulnerability and Patch Management. NIST 800-137 is a fractional total of all the NIST controls so this choice as a readiness solution is an imperfect approach. NIST 800-137 can be thought of as a tailored version of NIST 800-53 controls.

Table 100 – Authors ISCM Matrix

Applied												
Technical Approach Example	**Functional Approach Example**	**Inventory Assets**	**Vuln. Assess**	**Patching**	**Events**	**Malware**	**Config Mgmt**	**Network**	**Soft. Licenses / Renewals**	**Info Mgmt**	**Software**	**Incident Mgmt**
Endpoints / PC's / Servers	**Business Line**											
Mobile	**IT Service Mgmt**											
Network Infrastructure	**Data Integration**											
Communications / Encryption	**Infrastructure**											
Embedded / IoT / Diodes	**Security**											
VM	**Collaboration**											
ICS	**Productivity**											
Cloud	**Development**											
Firewalls	**Programs**											
Directories / LDAP	**Governance**											
Apps												

Note: The ISCM controls are also called the security automation domains.

FedRamp Cloud (GovCloud)

FedRAMP Project Management Office (PMO) is a US government-wide program that provides a standardized approach to security assessment, authorization, and continuous monitoring for cloud products and services [268]. FedRAMP uses guidance from NIST and others in its program framework. FedRamp approval is complex [269]. In addition, FedRamp has a ready program [270] which is aimed at getting companies administration processes ready to do a FedRamp application. FedRamp is run by Chief Information Officers (CIOs) from Department of Homeland Security (DHS), General Services Administration (GSA), and DoD. The GSA Project

Management Office (PMO) manages the website. Entities that are using cloud are required to adhere to the FISMA law using a subset of NIST 800-53 controls. Three cloud category services are common: Infrastructure as a Service (IaaS), Software as a Service (SaaS), and/or Platform as a Service (PaaS).

A cloud implementation is a way to limit scope of Cyber compliance requirements; but visibility of all the infrastructure is limited because a cloud subscriber doesn't have direct observation of data thus threats are hard to monitor. Amazon Web Services (AWS) published a mapping of controls for FedRamp Trusted Internet Connections (TIC) in 2016 [177] which helps explain what a shared responsibility looks like between AWS and an Entity.

Center for Internet Security (CIS) Controls

The Center for Internet Security (CIS) Top 18 formerly known as the Sysadmin, Audit, Network and Security "SANS" Top 20 Security Controls) provide a mapping to NIST 800-53 controls. The CIS controls are an option for smaller energy utilities. Unfortunately, once mapped the CIS controls are still laborious to be implemented because of the extended scope [26]. The CIS Controls Version 8 [271] (and the OWASP Secure Coding Practices [272] are two high level documents (outside of NIST) for guidance on technical compliance and hardening. However, CIS Controls don't include: legislative, social, IoT, Other Standards, Outages, Asset Limitations, External Reporting, Scenarios, Organizational Goals, and People/Human Factors as are covered in HDM.

Table 101 – CIS Controls Version 8 (aka The Top 18) Gaps

- Legislative requirements which are a key component to getting fined. From a cost perspective this could take down your org.
- The social impact (to recover reputation) is not addressed.
- Beyond IT is IoT and there is not mention of this type of interaction (above and beyond cloud).
- Other standards are not addressed that have a real impact on how controls get implemented. So, we cannot say implementing this CIS will fix the problem.
- Outages (a time period when nothing is working "planned or unplanned") are not planned for. Need a plan to operate without the system. When doing updates will have downtime. Have we planned for that?
- Asset limitations should be addressed.
- Reporting to and coordination with external agencies helps everyone (really two separate things. This should be a requirement. This could be a legislative requirement.
- Scenario planning is not done for the org based on a graded/risk approach.
- What are the goals of the organization in regards to Cyber? Maybe they just use cloud, if then, then what's the plan? That is when is something considered a risk?
- Whether the people you have able to recognize subtleties in these controls that are not explicitly called out.

Note: Authors determination

Table 102 - CIS 18 Controls Summarized

Control	Risk	Policy
Inventory (Basic)	Unauthorized and unmanaged assets need to be removed or mediated	Inventory assets with DHCP logging
Inventory Software	Default software especially can be a risk and provide no benefit	Licensed software should be detailed
Data	Outflows of data not monitored	Log sensitive data
Secure Configuration	Patches and customizations need to be run	Approved software should be tracked through workflows, and port whitelists should be setup
Accounts	Service accounts are often not known about	Inventory with: owner, review data, and purpose
Access Control	Processes around: need to know, least privilege, and separation of duties are not followed	Inventory auth and auth systems to make sure people are still credentialed, validate privileges annually, and implement a directory service using groups.
Vulnerability	Org is not aware of what's in the news with ISAC and not using a scoring system	Use a SCAP tool to test monthly
Audit Log	System logs have no backup time for a failure, and user logs are not setup	Use two time keeping sources (for example if NIST goes down), review DNS logs and collect user info with shell scripts
Email and Web	Plugins and webmail are hard to monitor and harden	Use block lists for URL's and implement DMARC for mail
Malware	There are so many entry points	Try anti-exploitation software and behavior based anti-malware
Recovery	Changing registry entries, opening ports, turning off security services, and deleting logs hinder recovery efforts	Create a list of in-scope encryption and data separation needed
Network	Architecture out of control and admin not done securely	Segment enterprise from industrial network and use security protocols
Monitoring	False positives of TTP's	Review SIEM logs for normality

Awareness	People are enticed or unaware of their actions (they're tricked)	Ensure people know how to report and that they are aware of phishing, pre-texting, and tailgating
Service Provider	Third party and Fourth Party are not risk rated	Classify and assess service providers
Applications	DevOps and SaaS need to be considered for insight concerns	Have an external facing policy and a bill of materials list so you work with trusted sources
Response	Reactive response without considering forensics	Establish mechanisms for acting when incident happens
Penetration	Vulnerabilities are often known through some means either online or through AV, but penetration is active testing that is not always done	Have a test to see how a hacker can actually use the information they get

Note: Authors determination

Cloud Security Alliance (CSA)

Cloudalliance.org for IoT Security Controls Framework and/or CSAs Cloud Control Mapping to FedRamp v3.0.1 can be used by entities as a tool for implementation. However, CSA controls framework is similar in size and scope to NIST FedRamp.

Other Control Standards

"Security standards set the expectation of performance or compliance" [3]. The definition of a standard comes from the US Oxford dictionary "A level of quality or attainment or an idea or thing used as a measure, norm, or model in comparative evaluations. Additionally, Standards normally have requirements which are a thing that is needed or wanted or a thing that is compulsory; a necessary condition. Standards define requirements and are usually functional or administrative, but can also be technical" [273]. Standards for the purpose of readiness research are often required when to deploying IT controls in an Energy system environment [166]. Standards often have information on how, who, and what. Standards enable: planning for emergency, safety and security, and reliable energy power. Reliability is important because less failure means more sustainability which equal higher gross margins, and higher operating margins [28].

Table 103 - Standards mapped in the NIST CSF spreadsheet

• Center for Internet Security (CIS) Controls (originally known as SANS Top 20) – they also provide a free spreadsheet

- COBIT (Control Objectives for Information and Related Technologies) – which provides a more governance/project management approach (Objective's worksheet which is free)
- ISO 27001 Annex/Appendix A – Annex A has a high-level checklist for item controls related to: Policies, Organizational Security, Human Security, Assets, Access, Cryptography, Environment, Operations, Communications, Acquisition, Supplier, Incidents, Continuity, Compliance and more.
    - ISO 27002 expands on each topic area of 27001 Annex A in what they refer to as a hierarchy of: clauses (14 total, starting at 5 to 19), categories (35 total), and controls (114 total). Clause 14 has guidance on networking and services which is applicable to cloud systems.
- Industrial Control Systems (ICS) controls ISO 62443 (parts 2.1 and 3.3 – each separate documents). Unfortunately, these two parts use different WBS names so there is a mapping table in Annex A of Part 2-1.
    - ISO 62443-2-1 talks about owners and suppliers Industrial Automation Control Systems (IACS) "aka ICS" services. This document is essentially a maturity tool for organizations for Security Level (SL) controls.
        - Note: NIST 800-82 is the ISO 62443 answer for NIST.
    - ISO 62443-3-3 continues the talk about Operational Technology (aka ICS with IT) but focuses at the system level rather than policies and procedures like ISO 62443-2-1. This document and it's written similar to the North American Electric Reliability Corporation (NERC) Critical Infrastructure Protection (CIP) standards, but ISO guidance is included inline. Annex B has the SL maturity levels and cumulative task requirements to meet each level and move on to the next maturity level.
        - Note: In COBIT "capability" is noted that all activities of the level have to be performed for a level to "move on" [274].

As shown above the four major cybersecurity standards frameworks internationally are: COBIT (v5 currently), ISA 62443 Part 2-1 and Part 3-3 (ICS "Industrial Control systems, (also referred as Supervisory Control and Data Acquisition, SCADA which use a usually non-TCP/IP network and Programmable Logic Controllers, PLCs), ISO 27001 and 27002, and NIST 800-53.

Table 104 - Other Control Standards that Provide Limited Utility in Relation to Readiness

- ISO 27001 is used as an input to NIST 800-53 standards creation.
- COBIT 5 controls map to the NIST CSF for policy adherence.
- Federal Information Processing Standard (FIPS) 140-2 standardizes cryptography. This standard is applicable to all Federal agencies that use cryptographic based security systems to protect sensitive information in computer and telecommunication systems (including voice systems) as defined in Section 5131 of the Information Technology Management Reform Act of 1996, Public Law 104-106 [275].

- NIST 800-14 [276] was a seminal document for administrative SME's and it was replaced and incorporated into many other NIST documents over time.

Appendix K – HDM to NIST Crosswalk (Based on a FedRamp Low with 48 NIST 800-53 Controls)

This example shows how in a cloud responsibility model/matrix (CRM) a portion of 127 FedRamp Low controls (48) that small organization would have the shared responsibility to meet. HDM Criteria 4 and 7 are organizational/governance goals that are not covered with the NIST 800-53 controls for FedRamp low. Criteria number 15 looks at weaknesses of legacy systems which is not called out in the NIST cloud FedRamp criteria above. Criteria 22 is for legal understanding which is not covered. Criteria 26 is asking that awareness of standards (legal compliance) is a covered as a prerequisite for effective and efficient controls. Criteria 26 is not covered in the NIST controls. All of these HDM criteria were found in the literature review for Cybersecurity Readiness [26].

Table 105 – FedRamp Crosswalk

FedRamp Low Controls Customer Responsible	NIST 800-53 v4 Description	NIST 800-137 Principle	HDM Control Comparable Covered
AC-20	Use Of External Information Systems	Configuration Management	1, 5, 8, 9, 12, 17
AC-7	Unsuccessful Logon Attempts	Configuration Management	1, 8, 13, 14, 19
AT-1	Security Awareness And Training Policy And Procedures	Information	3, 5, 9, 25, 28
AC-2	Account Management	Configuration Management	1, 2, 14, 16
AC-8	System Use Notification	License / Information	6, 19, 20, 21
AU-6	Audit Review, Analysis, And Reporting	Event Management	3, 8, 11, 14
CM-6	Configuration Settings	Configuration Management / Network Management	1, 6, 16, 18
PL-4	Rules Of Behavior	Information	5, 11, 20, 21
SI-4	Information System Monitoring	Event Management / Malware Detection / Network Detection	6, 11, 12, 13, 16
SI-12	Information Handling And Retention	Information	5, 9, 21, 24
AC-1	Access Control Policy And Procedures	Information	9, 16, 20

AC-3	Access Enforcement	Configuration Management	1, 9, 20
AC-14	Permitted Actions Without Identification Or Authentication	Information / Software	2, 18, 20
AT-2	Security Awareness Training	Information	3, 5, 25
CA-3	System Interconnections	Asset Management / Vulnerability Management / Patch Management	10, 12, 17
CM-11	User-Installed Software	Licenses / Information	5, 16, 20
PS-7	Third-Party Personnel Security	Information	3, 21, 27
PS-8	Personnel Sanctions	Incident	13, 19, 20
AC-17	Remote Access	Network Management	8, 14
AC-19	Access Control For Mobile Devices	Configuration Management	1, 14
AT-3	Role-Based Security Training	Information	2, 3, 5
AU-1	Audit And Accountability Policy And Procedures	Information	9, 11
AU-2	Audit Events	Event Management	6, 14
AU-9	Protection Of Audit Information	Information	8, 29
IA-4	Identifier Management	Patch Management / Configuration Management	8, 9
IA-5	Authenticator Management	Patch Management / Configuration Management	1, 14
IR-4	Incident Handling	Vulnerability Management	9, 10
IR-8	Incident Response Plan	Incident	6, 10
PS-2	Position Risk Designation	Information	13, 25
PS-3	Personnel Screening	Information	8, 23
PS-6	Access Agreements	Licenses	9, 21
SA-4	Acquisition Process	Licenses	5, 27
SI-2	Flaw Remediation	Patch Management / Configuration Management	1, 10
AC-18	Wireless Access	Network Management	13
AT-4	Security Training Records	Information	3

AU-11	Audit Record Retention	Information	14
AU-12	Audit Generation	Event Management	14
CM-8	Information System Component Inventory	Asset Management / Network Management	6
IA-2	Identification And Authentication (Organizational Users)	Configuration Management	1
IA-7	Cryptographic Module Authentication	Licenses	8
IA-8	Identification And Authentication (Non- Organizational Users)	Patch Management / Configuration Management	1
PS-4	Personnel Termination	Incident	19
PS-5	Personnel Transfer	Incident	19
RA-2	Security Categorization	Information	6
SC-7	Boundary Protection	Network Management	17
SC-12	Cryptographic Key Establishment And Management	Malware Detection	8
SC-13	Cryptographic Protection	Malware Detection	8
SI-3	Malicious Code Protection	Malware Detection	8

Appendix L – HDM RSV Table for Inconsistency

Percentile	3	4	5	6	7	8	9	10	11	12
0.01	0.0001	0.0188	0.1495	0.3012	0.4249	0.51	0.5723	0.617	0.6521	0.68
0.02	0.0002	0.0418	0.1934	0.3462	0.462	0.54	0.5961	0.6371	0.669	0.6945
0.03	0.0005	0.0596	0.223	0.3745	0.4847	0.5581	0.6105	0.6493	0.6793	0.7034
0.04	0.0009	0.0748	0.246	0.3955	0.5012	0.5713	0.6211	0.6582	0.6868	0.71
0.05	0.0014	0.0884	0.2651	0.4124	0.5143	0.5818	0.6295	0.6653	0.6928	0.7152
0.06	0.0021	0.1008	0.2816	0.4266	0.5253	0.5904	0.6365	0.6712	0.6978	0.7196
0.07	0.0028	0.1124	0.2963	0.439	0.5347	0.5979	0.6425	0.6763	0.7022	0.7234
0.08	0.0037	0.1233	0.3095	0.4499	0.543	0.6045	0.6478	0.6807	0.706	0.7267
0.09	0.0046	0.1337	0.3215	0.4597	0.5505	0.6104	0.6526	0.6848	0.7095	0.7298
0.1	0.0057	0.1437	0.3327	0.4686	0.5572	0.6157	0.6569	0.6884	0.7126	0.7325
0.11	0.0069	0.1532	0.343	0.4769	0.5634	0.6206	0.6609	0.6918	0.7155	0.735
0.12	0.0083	0.1625	0.3528	0.4845	0.5691	0.6252	0.6646	0.6949	0.7182	0.7374
0.13	0.0097	0.1714	0.362	0.4916	0.5745	0.6294	0.6681	0.6978	0.7207	0.7396
0.14	0.0113	0.1801	0.3706	0.4983	0.5795	0.6334	0.6713	0.7005	0.7231	0.7417
0.15	0.0129	0.1886	0.3789	0.5047	0.5842	0.6371	0.6743	0.7031	0.7253	0.7436
0.16	0.0147	0.1969	0.3868	0.5106	0.5887	0.6406	0.6772	0.7056	0.7274	0.7455
0.17	0.0166	0.205	0.3944	0.5163	0.5929	0.644	0.68	0.7079	0.7294	0.7473
0.18	0.0187	0.2129	0.4016	0.5218	0.597	0.6472	0.6826	0.7101	0.7313	0.749
0.19	0.0207	0.2207	0.4086	0.527	0.6009	0.6502	0.6851	0.7122	0.7332	0.7506
0.2	0.023	0.2283	0.4154	0.532	0.6046	0.6532	0.6875	0.7143	0.735	0.7521
0.21	0.0254	0.2359	0.4219	0.5368	0.6081	0.656	0.6899	0.7163	0.7367	0.7537
0.22	0.0281	0.2433	0.4282	0.5414	0.6116	0.6587	0.6921	0.7182	0.7383	0.7551
0.23	0.0306	0.2506	0.4343	0.5459	0.6149	0.6614	0.6943	0.72	0.7399	0.7565
0.24	0.0334	0.2578	0.4403	0.5502	0.6181	0.6639	0.6964	0.7218	0.7415	0.7579
0.25	0.0363	0.2648	0.4461	0.5544	0.6212	0.6664	0.6984	0.7235	0.743	0.7592
0.26	0.0393	0.2719	0.4517	0.5585	0.6243	0.6688	0.7004	0.7252	0.7445	0.7605
0.27	0.0425	0.2788	0.4572	0.5625	0.6272	0.6711	0.7023	0.7268	0.7459	0.7618
0.28	0.0457	0.2856	0.4626	0.5664	0.6301	0.6734	0.7042	0.7284	0.7473	0.763
0.29	0.0491	0.2924	0.4679	0.5701	0.6329	0.6756	0.7061	0.73	0.7487	0.7643
0.3	0.0526	0.2991	0.473	0.5738	0.6356	0.6778	0.7079	0.7315	0.75	0.7654
0.31	0.0564	0.3057	0.478	0.5774	0.6383	0.6799	0.7096	0.733	0.7513	0.7666
0.32	0.0602	0.3123	0.483	0.5809	0.6409	0.682	0.7113	0.7345	0.7526	0.7677
0.33	0.0641	0.3188	0.4878	0.5843	0.6434	0.684	0.713	0.7359	0.7538	0.7689
0.34	0.0682	0.3253	0.4926	0.5877	0.646	0.686	0.7147	0.7374	0.7551	0.77
0.35	0.0725	0.3317	0.4972	0.591	0.6484	0.688	0.7163	0.7388	0.7563	0.771
0.36	0.0769	0.338	0.5018	0.5942	0.6508	0.6899	0.7179	0.7401	0.7575	0.7721
0.37	0.0815	0.3443	0.5063	0.5974	0.6532	0.6918	0.7195	0.7415	0.7587	0.7732
0.38	0.0862	0.3506	0.5108	0.6006	0.6555	0.6937	0.7211	0.7428	0.7599	0.7742
0.39	0.0911	0.3568	0.5152	0.6037	0.6579	0.6955	0.7226	0.7441	0.761	0.7752
0.4	0.096	0.363	0.5195	0.6067	0.6601	0.6973	0.7241	0.7454	0.7621	0.7762
0.41	0.1012	0.3691	0.5237	0.6097	0.6624	0.6991	0.7256	0.7467	0.7633	0.7772
0.42	0.1065	0.3752	0.5279	0.6126	0.6646	0.7009	0.7271	0.748	0.7644	0.7782
0.43	0.1119	0.3813	0.5321	0.6155	0.6668	0.7026	0.7286	0.7492	0.7655	0.7792
0.44	0.1174	0.3873	0.5362	0.6184	0.6689	0.7044	0.73	0.7505	0.7666	0.7802

0.45	0.1233	0.3933	0.5402	0.6213	0.671	0.7061	0.7314	0.7517	0.7677	0.7812
0.46	0.1292	0.3993	0.5443	0.6241	0.6732	0.7078	0.7329	0.7529	0.7687	0.7821
0.47	0.1351	0.4052	0.5482	0.6268	0.6752	0.7094	0.7343	0.7541	0.7698	0.7831
0.48	0.1411	0.4112	0.5521	0.6296	0.6773	0.7111	0.7357	0.7553	0.7709	0.784
0.49	0.1473	0.417	0.556	0.6323	0.6794	0.7128	0.7371	0.7565	0.7719	0.7849
0.5	0.1539	0.4229	0.5599	0.635	0.6814	0.7144	0.7384	0.7577	0.7729	0.7859

Note: Taken from Reference: M. S. Abbas, "Consistency Analysis for Judgement Quantification in Hierarchical Decision Model," PDXScholar, Portland State University, 2016.

Appendix M – Case Desirability Calculations

Agencies of Government

	ID	10
D Org		
	Not known	0.0
	Some known	31.0
	Most known	65.0
	All known	100.0
Q1		49.0
	Not expected	0.0
	Sometimes expected	35.0
	Usually expected	70.0
	Always expected	93.0
Q2		49.5
	Never marked and protected	0.0
	Sometimes marked and protected	40.0
	Usually marked and protected	71.0
	Always marked and protected	94.0
Q3		51.3
	No degree	0.0
	Some degrees	36.0
	Most degrees	66.0
	All degrees	94.0
Q4		49.0
	No degree	0.0
	Some degrees	32.0
	Most degrees	69.0
	All degrees	92.0
Q5		48.3
	No extent	0.0
	Some extent	35.0
	Most extent	63.0
	Full extent	85.0
Q6		45.8
	No awareness	0.0
	Some awareness	35.0

	Most awareness	71.0
	All awareness	90.0
Q7		49.0

	ID	10
D Sys Mgmt		
	Not Complex	20.0
	Somewhat Complex	34.0
	Very Complex	60.0
	Extremely Complex	90.0
Q1		51.0
	No Degree	20.0
	Some Degrees	35.0
	Most Degrees	68.0
	All Degrees	90.0
Q2		53.3
	No Degree	20.0
	Some Degrees	50.0
	Most Degrees	66.0
	All Degrees	90.0
Q3		56.5
	No Degree	20.0
	Some Degrees	53.0
	Most Degrees	77.0
	All Degrees	100.0
Q4		62.5
	Always outage required	0.0
	Often outage required	50.0
	Rarely outage required	75.0
	Never outage required	100.0
Q5		56.3
	No planning	0.0
	Some planning	50.0
	Most planning	75.0
	All planning	90.0

Q6	53.8

	ID	10	56	Total
D Info Mgmt				
	No communication	0.0	0.0	**0.0**
	Sometimes communicate	42.0	50.0	**46.0**
	Often communicate	69.0	60.0	**64.5**
	Always communicate	90.0	53.0	**71.5**
Q1		50.3	40.8	**45.5**
	Not required	0.0	0.0	**0.0**
	Sometimes required	41.0	0.0	**20.5**
	Usually required	71.0	0.0	**35.5**
	Always required	95.0	100.0	**97.5**
Q2		51.8	25.0	**38.4**
	Not documented	0.0	0.0	**0.0**
	Sometimes documented	56.0	20.0	**38.0**
	Mostly documented	78.0	31.0	**54.5**
	Always documented	100.0	100.0	**100.0**
Q3		58.5	37.8	**48.1**
	No retention in place	0.0	0.0	**0.0**
	Sometimes have retention in place	45.0	11.0	**28.0**
	Usually have retention in place	70.0	11.0	**40.5**
	Always have retention in place	90.0	100.0	**95.0**
Q4		51.3	30.5	**40.9**
	No standards understood	0.0	0.0	**0.0**
	Some standards understood	45.0	0.0	**22.5**
	Most standards understood	70.0	0.0	**35.0**
	All standards understood	90.0	100.0	**95.0**
Q5		51.3	25.0	**38.1**

ID	10

D Prof		
	No check	0.0
	Some checking	50.0
	Usually checking	75.0
	Always checking	100.0
Q1		56.3
	No amount	0.0
	Some amounts	42.0
	Most amounts	72.0
	All amounts	90.0
Q2		51.0
	No degree	0.0
	Some degrees	50.0
	Most degrees	75.0
	All degrees	100.0
Q3		56.3
	No modeling	0.0
	Some modeling	50.0
	Most modeling	75.0
	Always modeling	100.0
Q4		56.3
	Not considered	0.0
	Sometimes considered	50.0
	Usually considered	75.0
	Always considered	100.0
Q5		56.3

	ID	10	53	**Total**
D Leader				
	No goals	0.0	0.0	**0.0**
	Some goals	37.0	48.0	**42.5**
	Many goals	70.0	53.0	**61.5**
	All goals	90.0	100.0	**95.0**

Q1		49.3	50.3	**49.8**
	No amount	0.0	0.0	**0.0**
	Some amounts	44.0	50.0	**47.0**
	Many amounts	72.0	75.0	**73.5**
	All amounts	91.0	100.0	**95.5**
Q2		51.8	56.3	**54.0**
	Not required	0.0	0.0	**0.0**
	Sometimes required	55.0	50.0	**52.5**
	Mostly required	78.0	75.0	**76.5**
	Always required	100.0	100.0	**100.0**
Q3		58.3	56.3	**57.3**
	No level	0.0	0.0	**0.0**
	Some levels	45.0	50.0	**47.5**
	Most levels	72.0	100.0	**86.0**
	All levels	90.0	100.0	**95.0**
Q4		51.8	62.5	**57.1**
	No level	0.0	0.0	**0.0**
	Some levels	41.0	50.0	**45.5**
	Most levels	69.0	95.0	**82.0**
	All levels	90.0	100.0	**95.0**
Q5		50.0	61.3	**55.6**
	Not considered	0.0	0.0	**0.0**
	Sometimes considered	50.0	50.0	**50.0**
	Usually considered	75.0	75.0	**75.0**
	Always considered	95.0	100.0	**97.5**
Q6		55.0	56.3	**55.6**

Private Entities

	ID	45	48	49	51	52	**Total**
D Org							
	Not known	30.0	0.0	7.0	10.0	0.0	**9.4**

	Some known	50.0	90.0	54.0	20.0	50.0	**52.8**
	Most known	73.0	95.0	67.0	35.0	100.0	**74.0**
	All known	100.0	100.0	83.0	51.0	100.0	**86.8**
Q1		63.3	71.3	52.8	29.0	62.5	**55.8**
	Not expected	18.0	0.0	0.0	0.0	0.0	**3.6**
	Sometimes expected	39.0	90.0	71.0	0.0	0.0	**40.0**
	Usually expected	57.0	95.0	77.0	0.0	0.0	**45.8**
	Always expected	81.0	100.0	98.0	100.0	100.0	**95.8**
Q2		48.8	71.3	61.5	25.0	25.0	**46.3**
	Never marked and protected	19.0	0.0	0.0	20.0	0.0	**7.8**
	Sometimes marked and protected	43.0	90.0	67.0	50.0	0.0	**50.0**
	Usually marked and protected	81.0	95.0	76.0	65.0	0.0	**63.4**
	Always marked and protected	100.0	100.0	93.0	70.0	100.0	**92.6**
Q3		60.8	71.3	59.0	51.3	25.0	**53.5**
	No degree	18.0	0.0	0.0	0.0	0.0	**3.6**
	Some degrees	40.0	80.0	58.0	0.0	0.0	**35.6**
	Most degrees	64.0	90.0	71.0	0.0	100.0	**65.0**
	All degrees	85.0	100.0	97.0	100.0	100.0	**96.4**
Q4		51.8	67.5	56.5	25.0	50.0	**50.2**
	No Degree	28.0	0.0	7.0	10.0	0.0	**9.0**
	Some Degrees	44.0	98.0	61.0	75.0	0.0	**55.6**
	Most Degrees	58.0	99.0	79.0	85.0	0.0	**64.2**
	All Degrees	74.0	100.0	97.0	95.0	100.0	**93.2**
Q5		51.0	74.3	61.0	66.3	25.0	**55.5**
	No extent	0.0	0.0	0.0	5.0	0.0	**1.0**
	Some extent	51.0	10.0	69.0	15.0	0.0	**29.0**
	Most extent	71.0	20.0	73.0	25.0	0.0	**37.8**
	Full extent	100.0	30.0	94.0	40.0	100.0	**72.8**
Q6		55.5	15.0	59.0	21.3	25.0	**35.2**
	No awareness	0.0	0.0	21.0	0.0	0.0	**4.2**
	Some awareness	50.0	98.0	53.0	70.0	50.0	**64.2**
	Most awareness	75.0	99.0	68.0	85.0	75.0	**80.4**
	All awareness	100.0	100.0	87.0	90.0	100.0	**95.4**

Q7		56.3	74.3	57.3	61.3	56.3	**61.1**

	ID	45	48	49	51	52	Total
D Org							
	Not known	30.0	0.0	7.0	10.0	0.0	**9.4**
	Some known	50.0	90.0	54.0	20.0	50.0	**52.8**
	Most known	73.0	95.0	67.0	35.0	100.0	**74.0**
	All known	100.0	100.0	83.0	51.0	100.0	**86.8**
Q1		63.3	71.3	52.8	29.0	62.5	**55.8**
	Not expected	18.0	0.0	0.0	0.0	0.0	**3.6**
	Sometimes expected	39.0	90.0	71.0	0.0	0.0	**40.0**
	Usually expected	57.0	95.0	77.0	0.0	0.0	**45.8**
	Always expected	81.0	100.0	98.0	100.0	100.0	**95.8**
Q2		48.8	71.3	61.5	25.0	25.0	**46.3**
	Never marked and protected	19.0	0.0	0.0	20.0	0.0	**7.8**
	Sometimes marked and protected	43.0	90.0	67.0	50.0	0.0	**50.0**
	Usually marked and protected	81.0	95.0	76.0	65.0	0.0	**63.4**
	Always marked and protected	100.0	100.0	93.0	70.0	100.0	**92.6**
Q3		60.8	71.3	59.0	51.3	25.0	**53.5**
	No degree	18.0	0.0	0.0	0.0	0.0	**3.6**
	Some degrees	40.0	80.0	58.0	0.0	0.0	**35.6**
	Most degrees	64.0	90.0	71.0	0.0	100.0	**65.0**
	All degrees	85.0	100.0	97.0	100.0	100.0	**96.4**
Q4		51.8	67.5	56.5	25.0	50.0	**50.2**
	No Degree	28.0	0.0	7.0	10.0	0.0	**9.0**
	Some Degrees	44.0	98.0	61.0	75.0	0.0	**55.6**
	Most Degrees	58.0	99.0	79.0	85.0	0.0	**64.2**
	All Degrees	74.0	100.0	97.0	95.0	100.0	**93.2**
Q5		51.0	74.3	61.0	66.3	25.0	**55.5**
	No extent	0.0	0.0	0.0	5.0	0.0	**1.0**
	Some extent	51.0	10.0	69.0	15.0	0.0	**29.0**
	Most extent	71.0	20.0	73.0	25.0	0.0	**37.8**

	Full extent	100.0	30.0	94.0	40.0	100.0	**72.8**
Q6		55.5	15.0	59.0	21.3	25.0	**35.2**
	No awareness	0.0	0.0	21.0	0.0	0.0	**4.2**
	Some awareness	50.0	98.0	53.0	70.0	50.0	**64.2**
	Most awareness	75.0	99.0	68.0	85.0	75.0	**80.4**
	All awareness	100.0	100.0	87.0	90.0	100.0	**95.4**
Q7		56.3	74.3	57.3	61.3	56.3	**61.1**

	ID	45	48	52	55	Total
D Info Mgmt						
	No communication	0.0	0.0	0.0	0.0	**0.0**
	Sometimes communicate	18.0	12.0	3.0	90.0	**30.8**
	Often communicate	36.0	70.0	0.0	80.0	**46.5**
	Always communicate	61.0	90.0	0.0	70.0	**55.3**
Q1		28.8	43.0	0.8	60.0	**33.1**
	Not required	20.0	0.0	0.0	0.0	**5.0**
	Sometimes required	43.0	12.0	50.0	20.0	**31.3**
	Usually required	65.0	30.0	75.0	30.0	**50.0**
	Always required	91.0	100.0	100.0	100.0	**97.8**
Q2		54.8	35.5	56.3	37.5	**46.0**
	Not documented	8.0	0.0	0.0	10.0	**4.5**
	Sometimes documented	30.0	71.0	0.0	30.0	**32.8**
	Mostly documented	56.0	91.0	0.0	70.0	**54.3**
	Always documented	82.0	100.0	100.0	100.0	**95.5**
Q3		44.0	65.5	25.0	52.5	**46.8**
	No retention in place	10.0	0.0	0.0	0.0	**2.5**
	Sometimes have retention in place	32.0	9.0	0.0	30.0	**17.8**
	Usually have retention in place	58.0	20.0	5.0	60.0	**35.8**
	Always have retention in place	79.0	100.0	100.0	100.0	**94.8**
Q4		44.8	32.3	26.3	47.5	**37.7**
	No standards understood	8.0	0.0	0.0	50.0	**14.5**
	Some standards understood	37.0	20.0	50.0	80.0	**46.8**

	Most standards understood	70.0	31.0	75.0	80.0	**64.0**
	All standards understood	100.0	100.0	100.0	80.0	**95.0**
Q5		53.8	37.8	56.3	72.5	**55.1**

	ID	45	48	49	54	Total
D Prof						
	No check	0.0	0.0	0.0	0.0	**0.0**
	Some checking	40.0	10.0	46.0	50.0	**36.5**
	Usually checking	60.0	75.0	58.0	90.0	**70.8**
	Always checking	82.0	100.0	67.0	100.0	**87.3**
Q1		45.5	46.3	42.8	60.0	**48.6**
	No amount	22.0	0.0	0.0	0.0	**5.5**
	Some amounts	43.0	10.0	59.0	80.0	**48.0**
	Most amounts	59.0	50.0	70.0	85.0	**66.0**
	All amounts	81.0	100.0	97.0	100.0	**94.5**
Q2		51.3	40.0	56.5	66.3	**53.5**
	No degree	20.0	0.0	0.0	0.0	**5.0**
	Some degrees	42.0	0.0	73.0	60.0	**43.8**
	Most degrees	52.0	90.0	95.0	75.0	**78.0**
	All degrees	80.0	100.0	98.0	100.0	**94.5**
Q3		48.5	47.5	66.5	58.8	**55.3**
	No modeling	30.0	0.0	0.0	0.0	**7.5**
	Some modeling	50.0	0.0	89.0	70.0	**52.3**
	Most modeling	70.0	91.0	94.0	75.0	**82.5**
	Always modeling	85.0	100.0	98.0	100.0	**95.8**
Q4		58.8	47.8	70.3	61.3	**59.5**
	Not considered	21.0	0.0	0.0	0.0	**5.3**
	Sometimes considered	42.0	0.0	57.0	50.0	**37.3**
	Usually considered	61.0	98.0	66.0	75.0	**75.0**
	Always considered	92.0	100.0	76.0	100.0	**92.0**
Q5		54.0	49.5	49.8	56.3	**52.4**

	ID	45	49	50	52	55	Total
D Leader							
	No goals	25.0	18.0	0.0	0.0	10.0	**10.6**
	Some goals	49.0	47.0	50.0	0.0	50.0	**39.2**
	Many goals	75.0	68.0	75.0	0.0	80.0	**59.6**
	All goals	91.0	79.0	100.0	100.0	80.0	**90.0**
Q1		60.0	53.0	56.3	25.0	55.0	**49.9**
	No amount	11.0	10.0	0.0	0.0	50.0	**14.2**
	Some amounts	37.0	58.0	50.0	0.0	50.0	**39.0**
	Many amounts	57.0	72.0	82.0	0.0	50.0	**52.2**
	All amounts	81.0	76.0	100.0	100.0	50.0	**81.4**
Q2		46.5	54.0	58.0	25.0	50.0	**46.7**
	Not required	0.0	0.0	0.0	0.0	40.0	**8.0**
	Sometimes required	51.0	55.0	60.0	2.0	60.0	**45.6**
	Mostly required	76.0	72.0	75.0	80.0	80.0	**76.6**
	Always required	99.0	95.0	100.0	100.0	80.0	**94.8**
Q3		56.5	55.5	58.8	45.5	65.0	**56.3**
	No level	14.0	0.0	0.0	0.0	50.0	**12.8**
	Some levels	36.0	56.0	50.0	0.0	50.0	**38.4**
	Most levels	59.0	75.0	84.0	0.0	60.0	**55.6**
	All levels	81.0	100.0	100.0	100.0	70.0	**90.2**
Q4		47.5	57.8	58.5	25.0	57.5	**49.3**
	No level	0.0	1.0	0.0	0.0	50.0	**10.2**
	Some levels	22.0	60.0	52.0	50.0	50.0	**46.8**
	Most levels	40.0	72.0	75.0	75.0	50.0	**62.4**
	All levels	68.0	87.0	100.0	100.0	50.0	**81.0**
Q5		32.5	55.0	56.8	56.3	50.0	**50.1**
	Not considered	20.0	0.0	0.0	0.0	0.0	**4.0**
	Sometimes considered	39.0	58.0	33.0	50.0	40.0	**44.0**
	Usually considered	63.0	70.0	75.0	77.0	70.0	**71.0**
	Always considered	83.0	92.0	100.0	100.0	100.0	**95.0**

Q6	51.3	55.0	52.0	56.8	52.5	**53.5**